TREKLINK

TrekLink Developer Handbook

Conventions, Workflow & the AI-First Doctrine

Version 1.0 · 2026-11-13

MEMBER	CODE	ROLE
Đỗ Đăng Khoa	KhoaDD	Leader / Product Owner
Trần Khải Hoàng	HoangTK	Member: Frontend
Lâm Phi Long	LongLP	Member: Gateway & Data
Nguyễn Bá Tân	TanNB	Member: Reporting & Monitoring
Nguyễn Ngọc Long	LongNN	Member: Backend

Capstone FA26SE159 · TrekLink Team

Supervisor: Đặng Ngọc Minh Đức

> Generated from the markdown in `_docs/`. Do not edit this PDF — edit the source and rebuild.

Contents

Orientation

TrekLink: Project Charter

1. Problem
2. What we're building
3. Actors & role summary
4. Research questions (drive the experiment plan: see roadmap)
5. Non-functional targets (binding: used as PR/Definition-of-Done gates)
6. Tech stack (as registered: see D-001 in decisions log, resolved)
7. Deliverables (map to Jira epics and the five Main Flows: see roadmap §4)
8. Legal & compliance
9. Related work / gap statement (condensed)

TrekLink: The Five Main Flows

MF-01: Organization onboarding → Rental contract → Handover

MF-02: Field data → Field Station → Cloud synchronization

MF-03: SOS → Tiered alert → Escalation

MF-04: Live telemetry: web map and organization API

MF-05: Term end → Return → Inspection → Billing → Maintenance

Coverage tracking

TrekLink: Requirements Foundation

1. Context Diagram
2. Actors
3. Use Cases
4. Feature Tree
5. Business Rule Matrix
6. Exception Scenario Matrix
7. Honest status

TrekLink Engineering Conventions: Index

Read in this order

What changed in v2 (2026-09-13)

Adopting these conventions in a repo

Authority

How We Work

Core Engineering Philosophy: Session-Based Development & Living SSOT

1. The Core Philosophy
2. Pillar I: Living Documentation as SSOT
3. Pillar II: Session-Based Development (SBD)
4. Crash-Safe Memory Checkpoint Protocol
5. Context Window & Token Budget Management (AI Agents)
6. Tenets of Iterative Refinement

Spec-Driven Development Workflow (SDSDW)

1. Executive Overview
2. Directory Structure (specs/{module_name}/)
3. Phase-by-Phase Execution Protocol
4. Universal Phase Exit Gate Matrix

Engineering Lifecycle & Operational Workflows

1. Executive Workflow Matrix
2. Lifecycle 1: Normal Feature Development Flow (Spec-First)
3. Lifecycle 2: Diagnostic & Debugging Flow (Hypothesis-Driven)
4. Lifecycle 3: Pull Request & Code Review Flow
5. Lifecycle 4: Review Issue Resolution Flow

Delivery

GitHub Workflow, Branching, Commits & Pull Requests

1. Repositories
2. Branch Model
3. Commit Conventions
4. Rebase Discipline
5. Pull Requests
6. Language Rule (Hard Requirement)
7. Branch Protection Settings
8. Where Work Is Tracked
9. Quick Reference
10. GitLab → GitHub Concept Map

Jira Tracking, Board Workflow & the Development Loop

1. The Three Places Work Lives
2. Work Item Hierarchy
3. The Board Workflow
4. BUG vs NEEDS HELP: they are not the same thing
5. Where Bugs Actually Go
6. Jira ↔ GitHub Integration
7. Sprints

8. The Development Loop (End to End)

9. Backlog ↔ Jira Key Mapping

10. Quick Reference

Team Communication, Daily Reports & Schedule Awareness

1. Channels: What Goes Where

2. The Two Mandatory Announcements

3. Daily Reports

4. Raising Problems

5. Schedule Awareness: Automated Countdown

6. Weekly Rhythm

7. Quick Reference

AI-First Development

The AI-First Doctrine, Toolchain & Prompting Standard

1. The Doctrine in One Page

2. Model Policy (Hard Requirement)

3. Required Toolchain

4. Agent Auto-Steering

5. The Mandatory Session Workflow

6. Token & Context Discipline

7. How to Prompt Well

8. Starter Prompts

9. Common Failure Modes

10. Checklist: New Member Setup

AI Agent Steering, Governance & Thinking Discipline

1. Operating Principles & Decision Hierarchy

2. The Universal Pre-Action Protocol

3. Power Modes & Token Budget

4. Hallucination & Loop Circuit Breakers

5. Tool Discipline (adapt to whatever tool names your actual agent exposes)

5.1 The Mandatory Session Shape

6. Multi-Agent / Subagent Dispatch (if your tool supports it)

Doc-Driven Scaffold & SSOT Conventions

1. TrekLink Application Note (read this first)

2. Universal Documentation-Driven Scaffold & SSOT Architecture

Engineering Standards

Architectural Conventions: NestJS Backend / Node Gateway / React Frontend

0. Decision criteria

1. Module Topology

2. Entity & Audit Conventions

3. Idempotency & Priority Queue (gateway-sync: the module most different from a normal CRUD app)

4. Module Isolation & Parallel Team Scaling

5. Frontend Architecture: Feature-Sliced Design (FSD)

Business parameters are configuration, never constants (D-015)

Backend Code & REST API Conventions (NestJS)

1. The Standard Module Structure

2. Input Validation

3. The Canonical Response Envelope (binding: from API_Design_Template.md)

4. Status Code & Error Taxonomy

5. Controller Standards

6. Async, Transactional & Concurrency Standards

Frontend Code & UI/UX Conventions (React + TypeScript)

1. Architectural Layout (Feature-Sliced Design)

2. State Management: The Triad Standard

3. The Core UX Rule: 4 Steps, 6 Fields

4. Reusable Screen Patterns

5. Keyboard Navigation & Accessibility (WCAG 2.2 AA)

6. Client API & Validation Contract Mirroring

7. Screen Design Checklist (SD phase, D-053)

8. UI and UX Practices

9. CollectionView: One Module Renders Every List of Records (D-096)

10. Page Layout (D-096)

11. Leader UX rules (2026-11-05, binding for every screen)

13: Diagram & Figure Conventions

1. Mermaid only

1.1 The handbook gate: check, look, cross-check (D-067)

2. Process flows are swimlanes

3. Numbering and captions

4. Figure placement

5. Hard rules for every figure

6. The measurement harness

7. Practical guidance

Appendices

TrekLink: Roadmap & Milestone Calendar

1. The five things to know before reading anything else
2. Gate schedule
3. Week-by-week calendar
4. The five Main Flows
5. Deliverable ledger and ownership
6. ⚠️ The Week-6 scope lock
7. Gate readiness checklists
8. Known failure modes to design against

Appendix A: TP1–TP6 (historical, no longer the planning unit)

Appendix B: Superseded framings

TrekLink: Decisions Log & Risk Register

Decisions

Risk register (carried from FA26SE159, kept live)

Contributing to TrekLink

1. Orient yourself
2. Where work lives
3. Before writing code
4. Branch, commit, PR
5. Merging
6. Backend response contract (non-negotiable)
7. Language
8. Using an AI coding agent
9. Definition of Done, every PR

Orientation

TrekLink: Project Charter

> **Superseded in scope by D-033 (2026-10-03).** This charter describes the booking scope registered in September. TrekLink is now an enterprise device-rental platform built on asset management; read `03-decisions-and-risk-register.md` D-033 to D-035 first. The team, the research questions and the technical foundation below still hold.

Project code: FA26SE159 · **Group code**: GFA26SE55 · **Class/Specialty**: SE **Duration**: 09/2026 – 03/2027 *(as registered, includes the retake window; the working plan ends Week 15, Dec 20 2026)* · **Supervisor**: Đặng Ngọc Minh Đức (Assoc. Prof)

Team & skill matrix (used for backlog and Main Flow assignment, see `03-backlog/` and `02-roadmap-and-milestones.md` (`02-roadmap-and-milestones.md`) §5.1):

Name	Code	MSSV	Framework track	Tech stack	Lane	Main Flow
Đỗ Đăng Khoa	KhoaDD	SE192357	BIT_SE_IC_19A	Embedded C, **NestJS**, Spring Boot, Java, ReactJS, TypeScript, PostgreSQL	Leader, Prisma schema, `devices`, firmware, `gateway-sync`, UI layout, architecture	**MF-02**
Lâm Phi Long	LongLP	SE182769	**BIT_SE_NJS_18D**	Node.js, PostgreSQL, ReactJS, TypeScript	Delegate, `auth`, `rentals`, `billing`	**MF-05**
Trần Khải Hoàng	HoangTK	SE182767	**BIT_SE_NJS_18D**	Node.js, ReactJS	`incidents`, the `incident.alert` push	**MF-03**
Nguyễn Ngọc Long	LongNN	SE193490	BIT_SE_IC_19A	Java Spring Boot, ReactJS, TypeScript, PostgreSQL	`monitoring` backend, `frontend` (FSD), map and monitoring UI	**MF-04**
Nguyễn Bá Tân	TanNB	SE183860	BIT_SE_IC_18D	PostgreSQL, MySQL, ReactJS, TypeScript	Delegate, `trips`, booking, QA & test lead	**MF-01**

> **Skill-coverage note**, *corrected Session 6.* An earlier version of this matrix recorded NestJS as a skill held only by the leader, and that was wrong. **`BIT_SE_NJS_18D` is the Node.js enrolment track, and NestJS is a framework over Node**; LongLP and HoangTK are both on it, so backend capability is **3 of 5**, not 1 of 5. Core backend work is routed to them by lane. The residual exposure is the two IC-track members, LongNN and TanNB, picking up backend stories solo. Budgeted mitigation: ramp-up and pairing on `01-conventions/05-backend-conventions.md` (`05-backend-conventions.md`) across W2–W5, mentored by Khoa and LongLP. This is the substance of the Report 2 §2.3 Training Plan and is a downgraded risk in `03-decisions-and-risk-register.md` (`03-decisions-and-risk-register.md`).

> **Supervisor mandate** (2026-09-13): the team sets its own scope, flows and technology stack, and pitches and defends the result. The supervisor's outline is guidance, not a restriction. Decisions that depart from the registration form are logged in the decisions register and amended into the form before the Week-6 scope lock.

> This charter reconciles `Phieu_FA26SE159.docx` (primary, authoritative, has formal RQs/NFRs/experiments) with `Phieu_dang_ky_de_tai_TrekLink_FA26_FINAL.docx` (earlier draft, same project). Differences are called out inline and logged as Decision D-000 in `03-decisions-and-risk-register.md` (`03-decisions-and-risk-register.md`).

1. Problem

Market context. Trekking in Vietnam often takes place in remote mountainous areas (Tà Năng–Phan Dũng, Tả Liên Sơn, Bạch Mộc Lương Tử) where cellular connectivity is limited or unavailable for long stretches.

Identified gap. Integrated platforms combining off-grid IoT communication, monitoring, device management and structured incident coordination are not yet widely adopted in Vietnam's trekking service market.

Project opportunity. SU26 produced **TrekLink firmware**: a LoRa mesh (ESP32/ESP32-S3, based on the open-source Meshtastic v2.7.19, ~636 files / ~149k LOC, 4 hardware variants v1–v4) with mesh messaging, GPS tracking, IMU-based fall detection and device-level SOS, already working and **not being rebuilt**. This Capstone extends it into an integrated operational platform for the Vietnamese trekking environment (scope: D-033). Two technical requirements follow:

1. **Store-and-forward to the cloud.** Field events must survive long outages; the node's uplink queue holds 16 events in RAM, so a durable priority queue is added on the device and at the Field Station.
2. **Structured incident operations.** Each SOS becomes one incident with an owner, tiered alerts and an audit trail (D-034).

> Wording follows the Review 1 minutes (2026-10-01). The panel rejected the earlier framing that a device SOS reaches nobody and asked for comparison within Vietnam only.

2. What we're building

TrekLink Operations Platform, extends the inherited firmware with:

- **Gateway Bridge** (Node.js/TypeScript): LoRa-serial → SQLite priority queue (P0 SOS / P1 incident-location / P2 GPS / P3 telemetry) → MQTT → cloud, with store-and-forward and priority-ordered reconnection flush. Delivered in two stages, **both in permanent scope** (D-005): Stage A uses the node's own MQTT uplink; Stage B adds the basecamp bridge that holds the offline buffer. This is **MF-02**.
- **Idempotent event ingestion**: `GatewayEvent.eventId = sha256(nodeNum : packetId)` as the packet-level dedup key, plus open-Incident correlation for episode-level grouping, N deliveries of the same event ⇒ exactly 1 Incident + 1 notification. *The register's `DeviceID + SessionID + SequenceNumber` formula is not constructible from what the firmware transmits; see **D-006** and `04-firmware-ground-truth.md` (`04-firmware-ground-truth.md`) §3. The intent, a natural, device-derived idempotency key, is unchanged.*
- **Device Fleet & Rental Management**: 7-state device lifecycle `Available → Reserved → Rented → In-Field → Returned → Maintenance → Retired`.
- **SOS-to-Incident pipeline**: 5-state FSM `Detected → Acknowledged → In Progress → Resolved → Closed`, actor+timestamp+note on every transition, WebSocket push to Staff/Guide. This is **MF-03**.
- **Real-time monitoring**: live map of trip positions, device telemetry and gateway connectivity, rendered with **Leaflet over OpenStreetMap** and a Vietnamese sovereignty overlay (D-031). This is **MF-04**.
- **Trip/Booking/Billing**: packages, bookings, device reservation, check-out/check-in, deposits, damage/late fees, mock/sandbox payment. **MF-01** and **MF-05**.

Explicitly out of scope: rearchitecting the Meshtastic mesh stack, native mobile apps (responsive web only), production payment gateway, route/trail recommendation, localization, hardware certification (FCC/CE).

> **On firmware scope**, the register's "firmware redesign is out of scope" is read narrowly (**D-008**, supervisor-confirmed 2026-09-13). Firmware **enhancement and integration** is in scope and earns graded credit: a custom PortNum, an explicit SOS discriminator, a boot `sessionId` and per-packet `sequenceNumber`, and beacon priority are all legitimate work. What remains excluded is a rearchitecture of the mesh stack itself.

3. Actors & role summary

Role	Core capability
Admin	Orgs/users/roles, device types & firmware versions, pricing config, system health, audit logs
Staff	Bookings, device allocation, rental agreements, check-out/in, fees, incident acknowledgment/coordination
Guide	Assigned trips/devices, device handover confirmation, live group view, incident ack + response notes
Customer	Browse/book packages, reserve devices, view booking/rental/payment history

4. Research questions (drive the experiment plan: see roadmap)

- **RQ1**: Gateway reliability, delivery rate, data-loss rate, duplicate rate under intermittent connectivity.
- **RQ2**: Effect of connectivity-loss duration/reconnection pattern on delivery rate, sync latency, priority-ordering compliance.
- **RQ3**: SOS-to-Incident pipeline vs. uncoordinated baseline, MTTA, MTTR, traceability score, completion rate, via controlled drills.

5. Non-functional targets (binding: used as PR/Definition-of-Done gates)

Property	Target
API latency	≤300ms for 95% of requests @ 50 concurrent users
Gateway→cloud sync	≤5s when uplink available
Offline recovery delivery rate	≥99% after reconnection (30s–30min loss, ≥20 trials/condition)
Duplicate prevention	0 duplicate Incidents for repeated `eventId` delivery (10× replay test)
Priority-ordering compliance	≥99%, all P0 flushed before P2/P3 on reconnect
Concurrency	≥20 simultaneous gateway submissions, 0 loss/duplication
Fleet scale	≥50 devices, multiple concurrent trips, no architecture change
Security	JWT + RBAC + TLS + bcrypt; immutable/append-only incident & device audit logs

6. Tech stack (as registered: see D-001 in decisions log, resolved)

Layer	Technology
Embedded firmware	ESP32/ESP32-S3, C++/PlatformIO, RadioLib, Meshtastic base, **inherited, and editable this term**. Enhancement and integration are in scope and credited (D-008); mesh-stack rearchitecture is not
Gateway bridge	Node.js + TypeScript, SQLite (local queue), MQTT client
Backend	NestJS (TypeScript), REST + WebSocket (Socket.io)
Database	PostgreSQL. **ORM: Prisma** (resolved via D-001, FA26SE159 form originally specified TypeORM, team's FINAL draft specified Prisma; Prisma locked as team mandate)
Messaging	MQTT (Mosquitto, gateway↔backend) + Socket.io (backend↔browser)
Frontend	React + TypeScript, role-based views, **Leaflet** map over **OpenStreetMap** tiles with a Vietnamese sovereignty overlay (D-031, provider held in configuration, not hardcoded)
Auth/AuthZ	JWT + bcrypt; RBAC, CASL (`@casl/ability`) per the FINAL draft's more specific tech table
DevOps	Docker / Docker Compose, GitHub Actions CI/CD

7. Deliverables (map to Jira epics and the five Main Flows: see roadmap §4)

- TrekLink Operations Platform (web app, 4 role-based views)
- Gateway Bridge module (priority SQLite queue, idempotent MQTT sync, health reporting)
- Event Reliability Layer (eventId scheme, idempotency enforcement, sync audit log, dedup test suite)
- Device Fleet & Rental Management module
- SOS Incident Management module (FSM + WebSocket + audit trail)
- Real-Time Field Monitoring module
- Trip/Booking/Billing module
- Backend API (OpenAPI/Swagger) + WebSocket services
- Technical docs: SRS, 2 UML State Machine diagrams (Device 7-state, Incident 5-state), architecture, DB schema, API reference, test plan, deployment guide, user guide
- Evaluation report: RQ1/RQ2/RQ3 results
- Source + deployment package: gateway/backend/frontend repos, Docker Compose, CI/CD, demo environment

8. Legal & compliance

Short by design, but not optional, the faculty fault handbook §10 treats data, security and legal handling as a graded topic that groups routinely arrive unprepared for.

Area	Position
Map sovereignty	Vietnamese law penalises publishing a map of Vietnam that fails to fully or correctly depict national sovereignty, **Nghị định 174/2026/NĐ-CP Art. 93(3)(a)**, in force 1 Jul 2026, 30–40 M VND, with forced takedown or removal of the application. OpenStreetMap base layers label Hoàng Sa and Trường Sa with foreign toponyms. TrekLink uses OpenStreetMap under the supervisor's acceptance for the course, with an overlay that labels both archipelagos in Vietnamese, and keeps Goong Maps in configuration for any deployment beyond it (**D-031**). The overlay is checked over both archipelagos with filed screenshots (TC-24).
Personal data	Minimum-necessary collection. We store what operations require, name, contact, booking, rental and position history, and nothing else. No national ID, no document verification. Position data is operational telemetry tied to a rental, retained with the trip record.
Secrets	No API key or secret in source. The map key is unavoidably visible in the browser and is mitigated with an HTTP-referer allowlist and a per-IP rate limit; every other credential lives in environment configuration outside version control.
Third-party sources	Every third-party data source is cited: map tiles from OpenStreetMap (© OpenStreetMap contributors, ODbL); mesh firmware forked from Meshtastic (GPL-3.0) with attribution retained.
Payments	Sandbox/mock only. No real funds move, and no card data is collected, transmitted or stored.
Radio	LoRa operation on the Vietnamese licence-exempt band as configured in the inherited firmware. Hardware certification (FCC/CE) is out of scope and is not claimed.
Emergency-response disclaimer	TrekLink is an operations and coordination tool, not a certified safety-of-life system. It does not replace official search-and-rescue channels, and the user guide must say so plainly.

9. Related work / gap statement (condensed)

Meshtastic, which TrekLink builds on, is designed to work independently of infrastructure; TrekLink adds the organization-side layer. Generic IoT fleet platforms (AWS IoT Core, Azure IoT Hub, Balena) have no LoRa integration or store-and-forward for intermittent connectivity. DTN/store-and-forward research (RFC 4838, MQTT-SN) is protocol-level, not tied to a business workflow. IT incident tools (JIRA SM, PagerDuty, Opsgenie) have no IoT field-event ingestion. TrekLink combines the five dimensions in one domain-specific platform. Satellite messengers are deliberately not compared (Review 1: compare within Vietnam only).

TrekLink: The Five Main Flows

> **Source of the flow set**: `capstone/Documents/course-material/TrekLink-proposed-mainflow-ducndm.png`, supplied by the supervisor. These five are **binding**. The set was redrawn after Review 1 by **D-033**, which supersedes D-016; identifiers and owners are unchanged. They are the units the Mainflow Coverage Matrix tracks, the units demoed at each Iteration review, and the units the Faculty Council evaluates.
>
> **What this file is for.** It is the single source for the Main Flow material that appears in Report 2 §3, Report 3 (SRS), the Review 1 slide deck, and the Mainflow Coverage Matrix. Diagrams are Mermaid so they regenerate rather than rot, never paste a screenshot of one back into a doc.
>
> **Layout convention**: each diagram is a true Mermaid `swimlane-beta` diagram, one `subgraph` per actor lane, matching `Documents/templates/Main flows_ex02.jpg`, the actor-partitioned example the course supplies. `swimlane-beta` requires **Mermaid ≥ 11.16.0**; the handbook build is pinned to 12.0.0. Orientation is `TB` so lanes run as columns and the flow runs down the page, which is what fits A4 portrait. See `01-conventions/13-diagram-and-figure-conventions.md` (`13-diagram-and-figure-conventions.md`).
>
> **Every flow carries at least one exception scenario.** That is a W3 Definition-of-Done item and a named anti-fail check: *"Mỗi mainflow đều có ít nhất một exception scenario."* The scenarios below populate the Exception Scenario Matrix directly.

Actors across all flows: Guest · TrekLink Admin · TrekLink Staff · Organization Manager · Organization Operator · TrekLink Device · Field Station · Cloud Backend · SePay. Device holders carry devices and use the stock Meshtastic app; they are not system users.

MF	Name	Owner	Priority
MF-01	Organization onboarding → Rental contract → Handover	TanNB	High
MF-02	Field data → Field Station → Cloud synchronization	KhoaDD	**Highest**
MF-03	SOS → Tiered alert → Escalation	HoangTK	**Highest**
MF-04	Live telemetry: web map and organization API	LongNN	High
MF-05	Term end → Return → Inspection → Billing → Maintenance	LongLP	Medium

The device's life as a rented asset is the spine: MF-01 takes it out, MF-02 to MF-04 run while it is out, MF-05 brings it back and restocks it. Device intake and provisioning are supporting use cases that feed MF-01. **E7 (DevOps/CI-CD) and E8 (Research & Experimental Evaluation) are cross-cutting and deliberately are not Main Flows.** Say so whenever the Coverage Matrix is presented.

MF-01: Organization onboarding → Rental contract → Handover

Goal: take a trekking company from self-registration to holding provisioned, monitored devices under a signed rental contract. See **Figure 1**.

Actors: Organization Manager, Cloud Backend, TrekLink Staff, TrekLink Admin, SePay **Precondition**: devices of the requested variant in `AVAILABLE` **Postcondition**: organization `ACTIVE`; contract `ACTIVE`; devices `RENTED`, provisioned with the organization's channel key and monitored

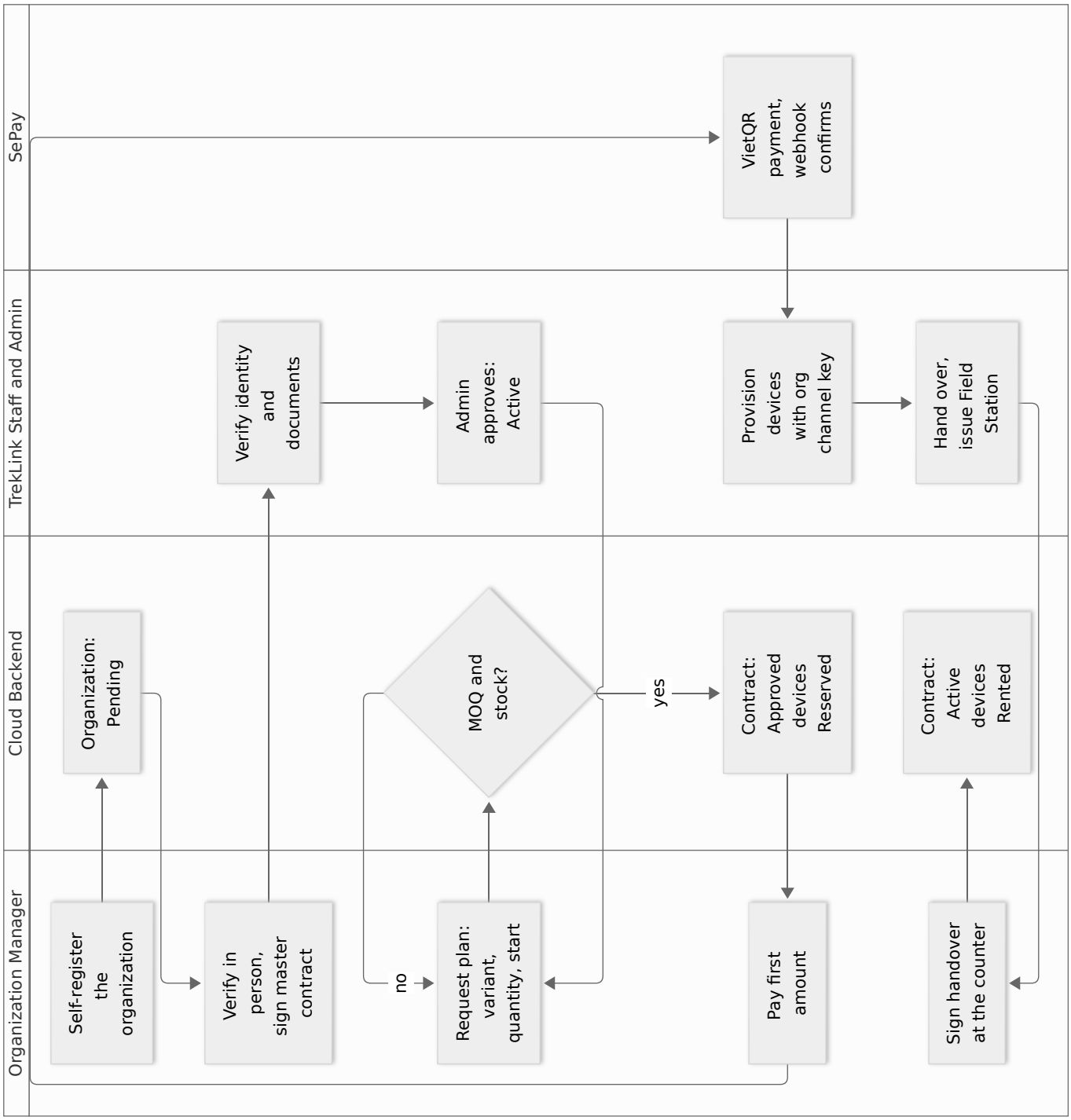


Figure 1: MF-01 Organization onboarding to Rental contract to Handover. Lanes are actors; the flow runs top to bottom. Placement: rotated plate, 182.0 x 194.6 mm, labels at 8.25 pt.

Main path

1. The Manager self-registers the organization (company name, tax code, Manager, contacts); the organization is `PENDING`.
2. The Manager comes to the TrekLink counter or calls; Staff verify identity and documents and the master contract is signed.
3. An Admin approves; the organization is `ACTIVE` and the Manager can invite members and set the on-duty roster.
4. The Manager requests a plan: monthly or day plan, hardware variant, quantity, start date.
5. The backend checks the minimum order quantity and stock; Staff approve and the devices become `RESERVED`.
6. The first amount is paid: the holding fee (half the term fee) for a monthly plan, the full amount for a day plan, through SePay or recorded at the counter.
7. Staff provision each device with the organization's channel key, hand them over with the Field Station package, and the Manager signs the handover note on the spot.
8. The contract becomes `ACTIVE`, the devices `RENTED`, and monitoring starts.

Exception scenarios

#	Scenario	Expected behaviour
E01-1	Two contracts claim the last devices of a variant at once	Allocation is transactional with row locks on the devices; the second approval sees the shortfall and is not approved. Never over-allocate.
E01-2	Requested quantity below the minimum order quantity	Rejected at request time with the current minimum shown.
E01-3	Organization still `PENDING`, `REJECTED` or `SUSPENDED` requests a plan	Rejected; only an `ACTIVE` organization can open a contract.
E01-4	Payment not confirmed by handover time	Handover cannot be signed; the contract stays `APPROVED` until the payment is confirmed or recorded, or Staff cancel it and the devices return to `AVAILABLE`.
E01-5	A reserved device fails the provisioning check at handover	Device to `MAINTENANCE`; Staff swap in another `AVAILABLE` unit of the same variant inside the same contract; if none exists the handover is held.
E01-6	SePay webhook arrives twice, or after a counter payment was recorded	The payment is matched by its reference and recorded once; a duplicate is a logged no-op.
E01-7	The organization cancels after approval, before handover	Contract `CANCELLED`; reserved devices return to `AVAILABLE`; a holding fee already paid is retained.

Business rules touched: organization approval, minimum order quantity, no over-allocation, first-payment rule per plan, on-the-spot handover with signature, channel-key provisioning.

Configurable parameters (D-015): minimum order quantity, monthly price per variant, day-plan lengths and premium, holding-fee ratio, reservation expiry before handover.

MF-02: Field data → Field Station → Cloud synchronization

Goal: deliver every field event from the mesh to the cloud exactly once, including events generated while the uplink is down. This is the flow that carries the project's research claim. See **Figure 2**.

Actors: TrekLink Device, Field Station (Gateway Bridge), Cloud Backend **Precondition**: device `RENTED` on a running contract; a node uplinks over its own Wi-Fi (Stage A) or the organization runs the Field Station (Stage C) **Postcondition**: every event persisted exactly once, in priority order, regardless of uplink state

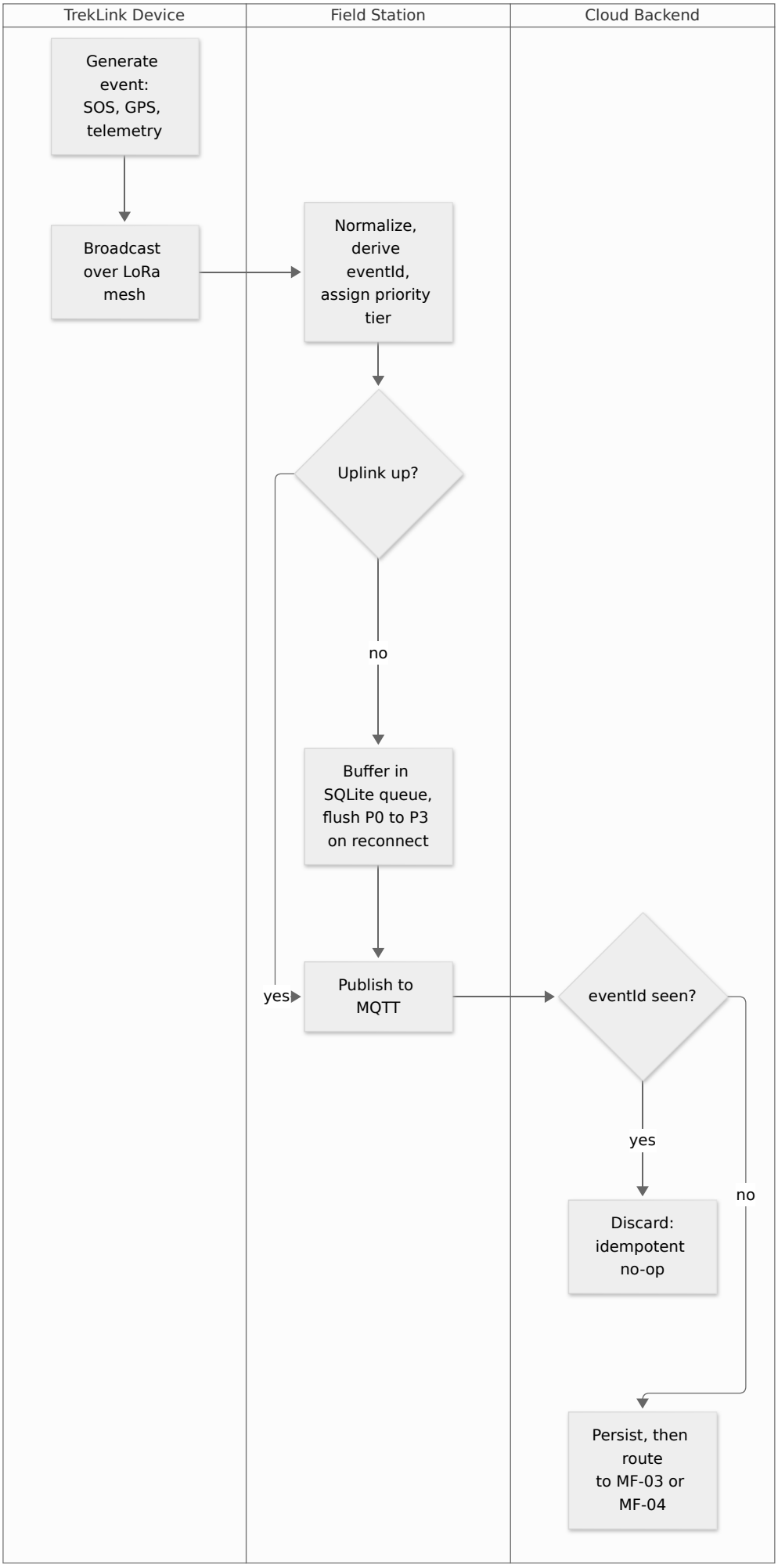

TrekLink Device
Field Station
Cloud Backend
Generate event: SOS, GPS, telemetry
Broadcast over LoRa mesh
Normalize, derive eventId, assign priority tier
Uplink up?
no
Buffer in SQLite queue, flush P0 to P3 on reconnect
yes
Publish to MQTT
eventId seen?
yes
Discard: idempotent no-op
no
Persist, then route to MF-03 or MF-04

Figure 2: MF-02 Field data to Field Station to Cloud synchronization. The SQLite buffer is on the no branch: events generated while the uplink is down are held and flushed in priority order. Placement: inline, 135.0 x 266.0 mm, labels at 7.50 pt.

Priority tiers: `P0` SOS · `P1` incident location · `P2` GPS · `P3` telemetry. All P0 events flush before any P2 or P3 event, the ordering-compliance NFR is measured on exactly this.

Three delivery stages, all in permanent scope (D-005, refined by **D-018**): **Stage A** uses the node's own MQTT uplink and has no durable buffer; **Stage B** is the on-device durable priority queue in the firmware, built first; **Stage C** is the **Field Station**, a bundled executable on the organization's own laptop with one of its rented nodes on a USB serial port; it holds the large SQLite queue for the whole local mesh and shows the field picture locally while offline (form per **D-033**, superseding D-020). Stage A is the first increment, never a substitute. Stage B buffers only its own node's events, so it does not replace Stage C. Documents written before 2026-09-17 call the basecamp bridge "Stage B"; that is Stage C.

Main path

1. Device generates an event and broadcasts it over the LoRa mesh.
2. Gateway receives the packet and normalizes it to the internal `TrekLinkEvent` shape.
3. Gateway derives `eventId = sha256(nodeNum : packetId)` and assigns a priority tier.
4. Uplink available → publish to MQTT. Uplink down → enqueue in SQLite by priority.
5. On reconnection, the queue flushes in strict priority order, oldest first within a tier.
6. Backend consumes, checks `eventId` against a unique index, discards duplicates as a no-op.
7. New events are persisted and routed by kind, SOS into MF-03, positions and telemetry into MF-04.

Exception scenarios

#	Scenario	Expected behaviour
E02-1	Uplink drops mid-flush	Partially flushed batch is not lost; only rows confirmed published are deleted. Flush resumes from the queue head on reconnect.
E02-2	The same packet arrives twice, mesh rebroadcast or replay	Unique index on `eventId` makes the second insert a no-op. **0 duplicate Incidents across a 10× replay is a binding NFR and a demo obligation.**
E02-3	Gateway process restarts with a non-empty queue	SQLite is on disk; the queue survives and flushes on next connect. Restart must not mint new `eventId`s.
E02-4	Malformed or undecodable packet	Logged with the raw payload, counted, and dropped, never crashes the ingest loop, never blocks the queue head.
E02-5	Queue grows beyond its configured bound during a long outage	P3 telemetry is shed first, P0 never. The shedding policy is configuration and the event is logged.
E02-6	Clock skew between gateway and backend	The gateway flush orders by queue sequence and priority, not wall-clock comparison across hosts. The backend orders display, trails and episode correlation by the event's own timestamp when it is valid, because stock firmware drains a queued backlog one entry per reconnect.

Business rules touched: priority-tier assignment, idempotency, flush ordering, queue retention and shedding, reconnect backoff.

Configurable parameters (D-015): MQTT broker URL and topic prefix, reconnect period, flush batch size, queue size bound, shedding policy, priority-tier mapping, sync-latency target.

Research questions: **RQ1** (delivery, loss and duplicate rates under intermittent connectivity) and **RQ2** (effect of outage duration on delivery rate, sync latency, ordering compliance) are both measured on this flow.

MF-03: SOS → Tiered alert → Escalation

Goal: turn a device SOS into one incident that a named organization member owns, and make sure that somebody is always responsible for it. See **Figure 3**. The state machine is **D-034**.

Actors: TrekLink Device, Field Station, Cloud Backend, Organization Operator (on duty and backup), Organization Manager, TrekLink Staff **Precondition**: device `RENTED`, or any device that raises an SOS **Postcondition**: exactly one incident per SOS episode, owned at every moment, `CLOSED` with a complete audit trail

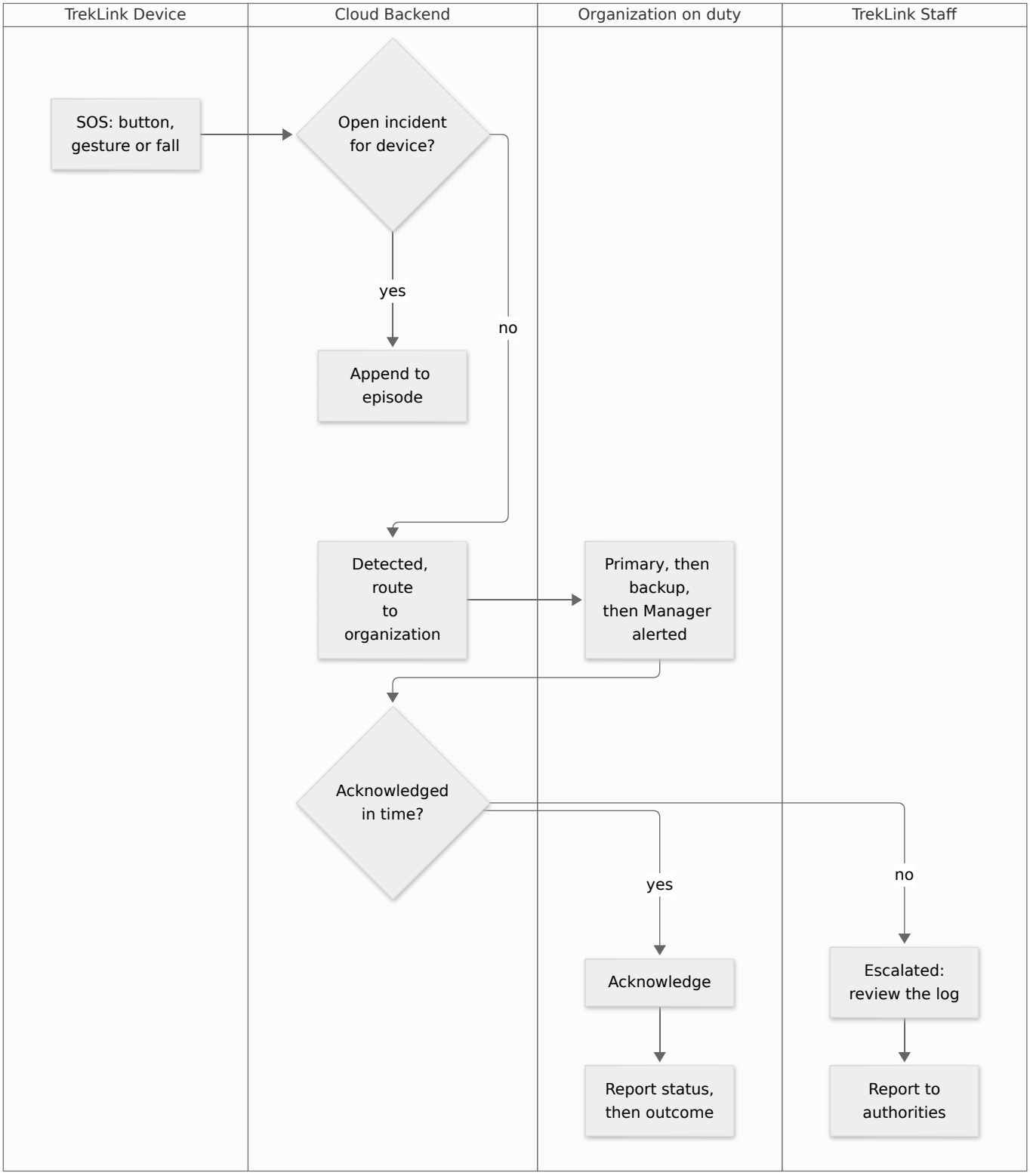


Figure 3: MF-03 SOS to Tiered alert to Escalation. Each tier has its own timeout; an unacknowledged alert always ends with TrekLink Staff. Placement: inline, 182.0 x 207.2 mm, labels at 7.71 pt.

Main path

1. The device raises an SOS; MF-02 delivers it first (P0).
2. The backend correlates it to an open episode or creates the incident and routes it, in one transaction, to the organization whose custody interval contains the event's occurrence time (D-040). With no custody at that time the incident is `UNROUTED` and goes to TrekLink Staff.
3. The on-duty member is alerted on the web, over WebSocket, by email and as an API event. Without acknowledgement within the timeout the backup is alerted, then the Manager.
4. A member acknowledges and owns the response; the organization coordinates the rescue itself, outside TrekLink.
5. The owner reports status on a cadence, then the outcome; the incident is `RESOLVED`, or `FALSE_ALARM` with a reason.
6. After the reopen window the incident is `CLOSED`.
7. If no tier acknowledges, or the response goes silent, the incident is `ESCALATED`; TrekLink Staff review the audit log and report to the authorities, recording the agency and reference.

Exception scenarios

#	Scenario	Expected behaviour
E03-1	The single SOS text frame is lost over RF	For a button or gesture SOS, cadence-anomaly detection raises a suspected episode from beacon density, flagged as lower confidence. A fall SOS sends no beacons (`04-firmware-ground-truth.md` §2), so its lost text frame cannot be recovered; this is the open Critical firmware risk.
E03-2	One episode produces dozens of beacons	Correlation appends to the open incident. One fall produces exactly one incident.
E03-3	Two members acknowledge at once	Compare-and-set on state and version; the first wins, the second sees who owns it.
E03-4	SOS from a device on no running contract, or the organization has no reachable member	`UNROUTED`; TrekLink Staff own it. Safety events are never dropped.
E03-5	The owner stops reporting during a response	After the stale limit, `ESCALATED` with the owner kept and the Manager notified.
E03-6	New SOS from the same device after `RESOLVED`, inside the reopen window	Reopens to `NOTIFY_PRIMARY`; the reopen is in the audit trail.
E03-7	Alert delivery fails (WebSocket down, email bounce)	The incident and its timers proceed; delivery is retried from the outbox and logged.
~~E03-8~~	Withdrawn by D-038: a cancel pressed on the device changes nothing, and the firmware sends none.	Only a person declares a false alarm.
E03-9	The contract is overdue or the organization suspended	The incident is still created and routed. Safety first.

Business rules touched: one episode one incident, tier order and timeouts, acknowledgement authority, stale-response escalation, authority reporting by TrekLink only on escalation, audit immutability.

Configurable parameters (D-015): episode window, cadence-anomaly threshold, tier timeouts, stale-response limit, reopen window, notification channels.

Research question: **RQ3** (time to acknowledge, time to resolve, traceability) is measured on this flow.

MF-04: Live telemetry: web map and organization API

Goal: give each organization a live picture of its own rented devices, on the TrekLink web platform or inside its own system through the API, and give TrekLink a fleet-wide view. See **Figure 4**.

Actors: TrekLink Device, Field Station, Cloud Backend, Organization Operator, Organization Manager, organization's own system (API client), TrekLink Staff **Precondition**: at least one device `RENTED` **Postcondition**: each viewer sees only what its organization rents, within the sync-latency target

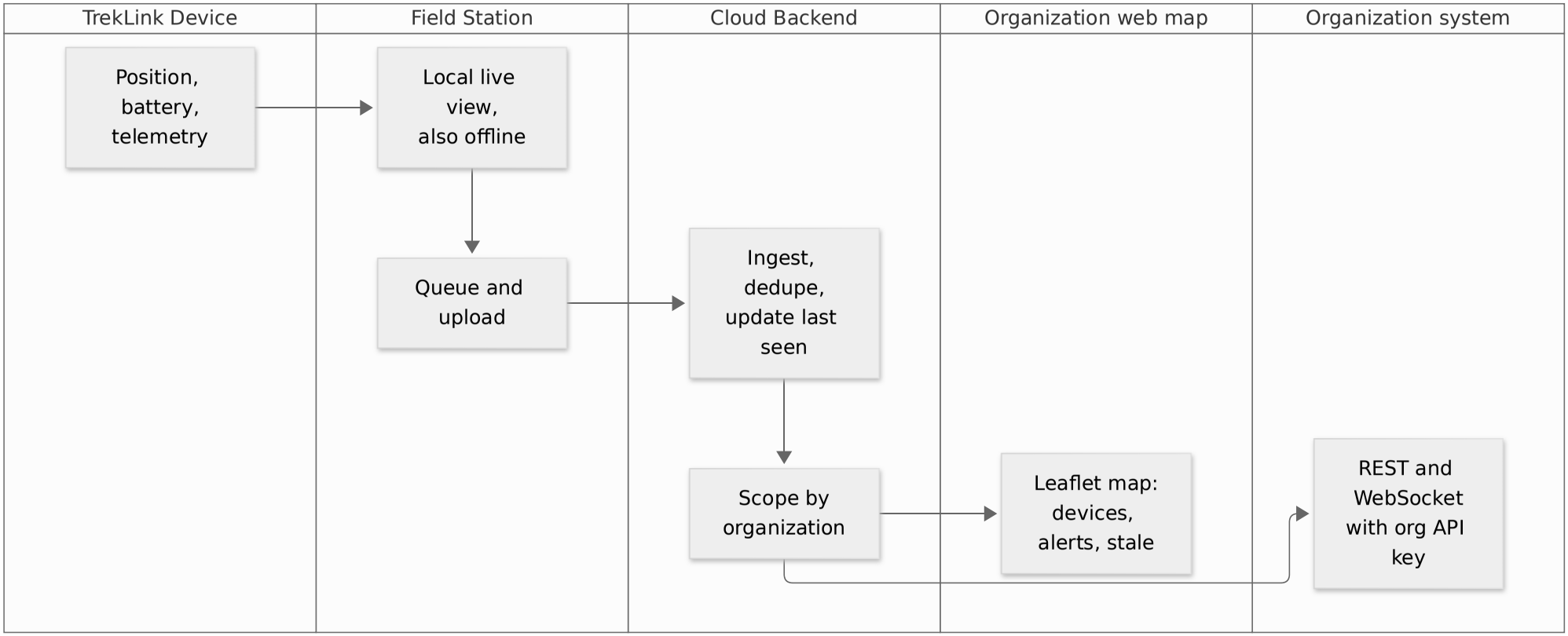

TrekLink Device
Field Station
Cloud Backend
Organization web map
Organization system
Position, battery, telemetry
Local live view, also offline
Queue and upload
Ingest, dedupe, update last seen
Scope by organization
Leaflet map: devices, alerts, stale
REST and WebSocket with org API key

Figure 4: MF-04 Live telemetry to the web map and the organization API. Scoping by organization is applied on the server, at the query and at the WebSocket emit. Placement: rotated plate, 104.2 x 266.0 mm, labels at 9.45 pt.

Main path

1. Devices report position, battery and telemetry; MF-02 delivers them.
2. The backend updates last seen and last position and scopes every read and push to the organization whose custody interval contains each event's occurrence time (D-040); an event that syncs late after a check-in still belongs to the organization that held the device when it occurred.
3. Organization operators see their devices and alerts on the Leaflet map; TrekLink Staff see the whole fleet.
4. An organization's own system reads the same data over REST and subscribes over WebSocket with its organization API key.
5. Offline, the Field Station shows the local mesh directly to the operators on site.

Exception scenarios

#	Scenario	Expected behaviour
E04-1	Device silent: out of range or flat battery	Marker ages to stale after the threshold, last seen shown. Never a frozen marker without indication.
E04-2	Field Station or uplink offline	Per-station connectivity indicator turns stale; the local view keeps working on site.
E04-3	Browser or API client loses the WebSocket	Reconnect with resync from the last event cursor; a visible reconnecting indicator on the web.
E04-4	An API key or user asks for another organization's device	Denied on the server; the data is never sent.
E04-5	API key revoked or rate limit exceeded	401 or 429 in the standard envelope; the key's last use is logged.
E04-6	Implausible position jump	Rejected at validation, logged, not plotted.
E04-7	Device checked in: no longer rented by the organization	Data that occurred after the check-in time never reaches that organization. An event that occurred inside its custody interval and syncs later still belongs to it (D-040): it is delivered as a late entry, kept off the live map, and stays in its history, which is clipped to its rental periods (FR-MON-08).

Business rules touched: organization scoping, API key per organization, staleness thresholds, position validation, map sovereignty overlay (D-031).

Configurable parameters (D-015): stale-device and stale-station thresholds, API rate limit, map provider and viewport, battery warning levels, position sanity bounds.

MF-05: Term end → Return → Inspection → Billing → Maintenance

Goal: end the contract, take every device back at the counter, assess it, settle the money and restock or service the device. See **Figure 5**.

Actors: Organization Manager, TrekLink Staff, TrekLink Admin, Cloud Backend, SePay **Precondition**: contract `RETURN_DUE` (day plan ended, or monthly notice given and the term ended) **Postcondition**: contract `CLOSED`; devices `AVAILABLE`, `MAINTENANCE`, `LOST` or `RETIRED`

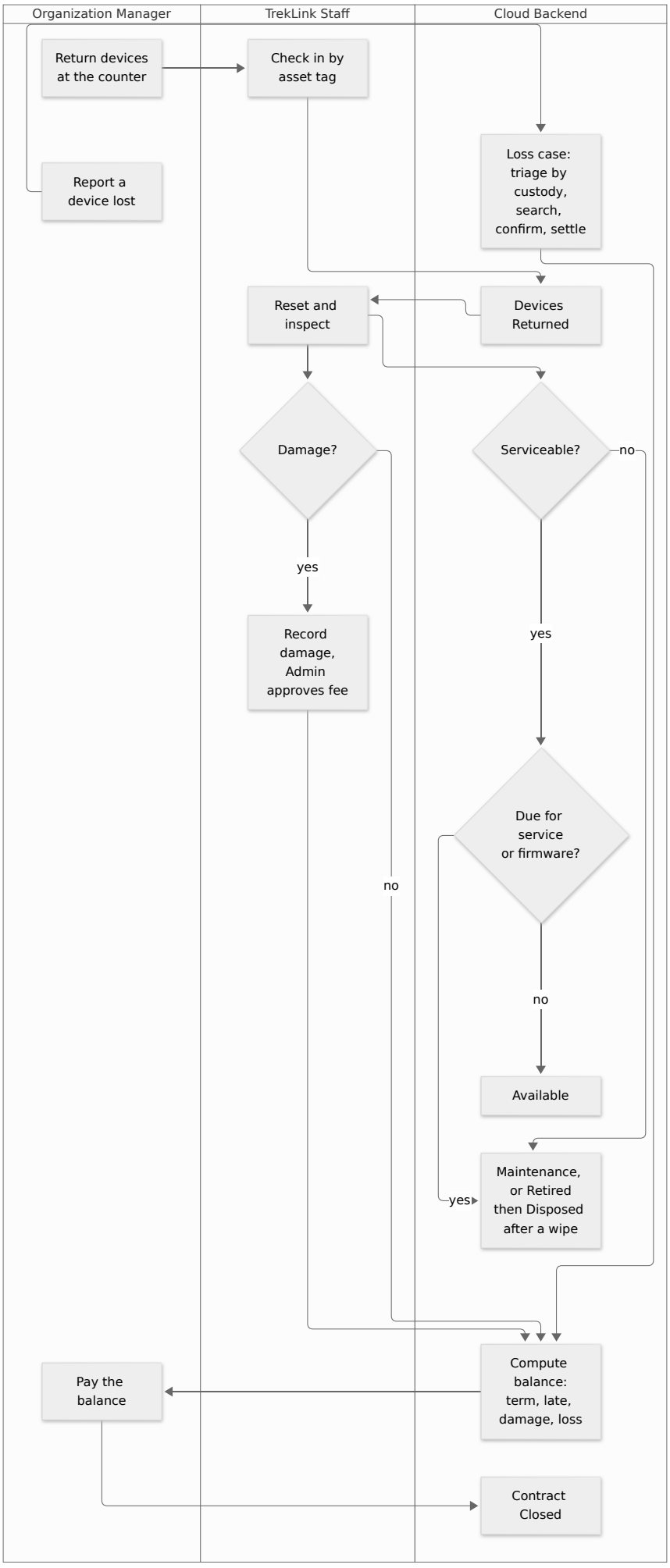

Organization Manager
TrekLink Staff
Cloud Backend
Return devices at the counter
Check in by asset tag
Report a device lost
Loss case: triage by custody, search, confirm, settle
Reset and inspect
Devices Returned
Damage?
Serviceable?
no
yes
Record damage, Admin approves fee
yes
Due for service or firmware?
no
Available
Maintenance, or Retired then Disposed after a wipe
yes
Compute balance: term, late, damage, loss
Pay the balance
Contract Closed

Figure 5: MF-05 Term end to Return to Inspection to Billing to Maintenance. Placement: inline, 162.0 x 266.0 mm, labels at 9.00 pt.

Main path

1. A day plan reaches its end date, or a monthly contract reaches the end of the term after notice; the contract is `RETURN_DUE`.
2. The Manager returns the devices at the counter; Staff check each in by asset tag; devices `RETURNED`.
3. Staff reset each device (channel key, node database, owner name) and inspect it.
4. The backend computes the balance: the second half of the term fee for a monthly plan, plus late, damage and loss charges; damage above the threshold waits for Admin approval.
5. The Manager pays through SePay or at the counter; the contract is `CLOSED` when every charge is paid and no incident is open.
6. Serviceable devices return to `AVAILABLE`, except a passed device due for service or with firmware off its variant's baseline, which goes to `MAINTENANCE` with a scheduled or firmware record (FR-DEV-19, E05-12). Failed devices go to `MAINTENANCE`, to `RETIRED` if beyond repair, and a retired device is `DISPOSED` only after a verified wipe (D-045).

Exception scenarios

#	Scenario	Expected behaviour
E05-1	Devices returned late	Contract `OVERDUE`; late fee per device per day after the grace period, itemized on the invoice.
E05-2	Devices not returned after the grace period, or the organization stops responding	Contract `DEFAULTED`; the organization is `SUSPENDED`; the devices' last positions are tracked; Staff report to the authorities with the audit log as evidence.
E05-3	Loss confirmed in renter custody	A loss case is triaged by the custody interval that contains the device's last seen time (D-040, D-045); confirmed in renter custody, the remaining value is charged to that contract and the organization's channel key is marked exposed; the case is `SETTLED` by an Admin other than the triager, and the device `RETIRED`. A device recovered before that goes back to `RETURNED`.
E05-4	Payment fails part-way	The contract does not close; the balance stays outstanding and visible to both sides.
E05-5	Monthly term ends without notice	No return: the term's balance and the next term's holding fee fall due together, and the contract runs on.
E05-6	The inspector also approves a damage waiver above the threshold	Refused: the approver must differ from the inspector.
E05-7	An incident on a returned device is still open	The contract cannot close until the incident is `CLOSED` (D-034).
E05-8	The Manager reports a device lost during a running contract	Device `LOST`, loss case opened; the contract keeps running; a replacement may be issued at the counter (FR-DEV-12, FR-CON-15).
E05-9	A unit in TrekLink custody is missing at stock-take	Loss case in TrekLink custody; written off, no charge to any organization (FR-DEV-10, FR-BILL-05).
E05-10	A lost device turns up after the loss was settled	Recovered to `RETURNED`, reset and inspected; the charge stands unless an Admin records an adjustment (FR-DEV-14, FR-BILL-06).
E05-11	Signs that an organization keeps devices by fraud or theft	Compliance case; a police report reference is required to close it; suspension and revocation are recorded on the case (D-046, FR-ORG-08, FR-ORG-09).
E05-12	A rented unit falls due for service during its contract	It stays on the contract; after check-in a passed inspection sends it to `MAINTENANCE` with a scheduled record (D-047, FR-DEV-18, FR-DEV-19).
E05-13	A repair estimate exceeds the approval threshold	Record `PENDING_APPROVAL`; it cannot be completed until another Admin approves or rejects it (D-047, FR-DEV-20).

Business rules touched: term balance, late fee, damage fee and approval, loss at remaining value, reset before restock, separation of duty, closing conditions.

Configurable parameters (D-015): late fee and grace period, damage-fee schedule and approval threshold, remaining-value schedule per variant, default threshold, maintenance turnaround target.

Coverage tracking

The Mainflow Coverage Matrix is the single instrument the supervisor uses to confirm sprint progress at the weekly Group Meeting. It is authoritative over any other progress view.

Mainflow	Requirement	Implementation	Tested	Demo Ready	Owner
MF-01	☐	☐	☐	☐	TanNB
MF-02	☐	☐	☐	☐	KhoaDD
MF-03	☐	☐	☐	☐	HoangTK
MF-04	☐	☐	☐	☐	LongNN
MF-05	☐	☐	☐	☐	LongLP

Milestones: MF-01 and MF-02 complete by **W7**; MF-03 in progress with MF-04 and MF-05 holding Figma plus detailed spec by **W7**; feature complete by **W11**; 100 % Implemented / Tested / Demo Ready by **W12**, before the Faculty Council.

Demo discipline, the faculty handbook ranks a Main Flow breaking during the demo as the single most common cause of failure. Every flow gets a rehearsed demo script, realistic seed data, and a backup screen recording. Demo the real product; never build a special build to demo.

TrekLink: Requirements Foundation

> **What this is.** The five requirement artifacts SEP490 requires by the end of W3 and presents at Review 1 (W4): Context Diagram, Actors, Use Cases, Feature Tree, Business Rule Matrix, and the Exception Scenario Matrix. Report 3 (SRS) is written **from** this file; it is not a second copy.
>
> **Source of the Main Flows** these decompose: `05-main-flows.md` (`05-main-flows.md`) (**D-033**, superseding D-016).
>
> **Rewritten 2026-10-03** for the enterprise rental platform (D-033, D-034, D-035). The full use case catalogue, the specifications and the functional requirements live in the Report 3 generator (`capstone/scripts/srs/srs_data.py`); this file holds the diagrams and matrices it draws from.
>
> **Anti-fail checks this file exists to pass** (SEP490 W3, and the faculty fault handbook §2): no requirement of the form "Admin manages everything" · use cases are functions, not workflows · `include` / `extend` / generalization used correctly · every actor present · use case names in verb-object form · every Main Flow carries at least one exception scenario · every business rule traceable to a requirement, an implementation and a test case.

---

1. Context Diagram

The system boundary, the external actors, and the external systems it exchanges data with. Nothing about internal structure appears here, that is the architecture diagram's job. See **Figure 6**.

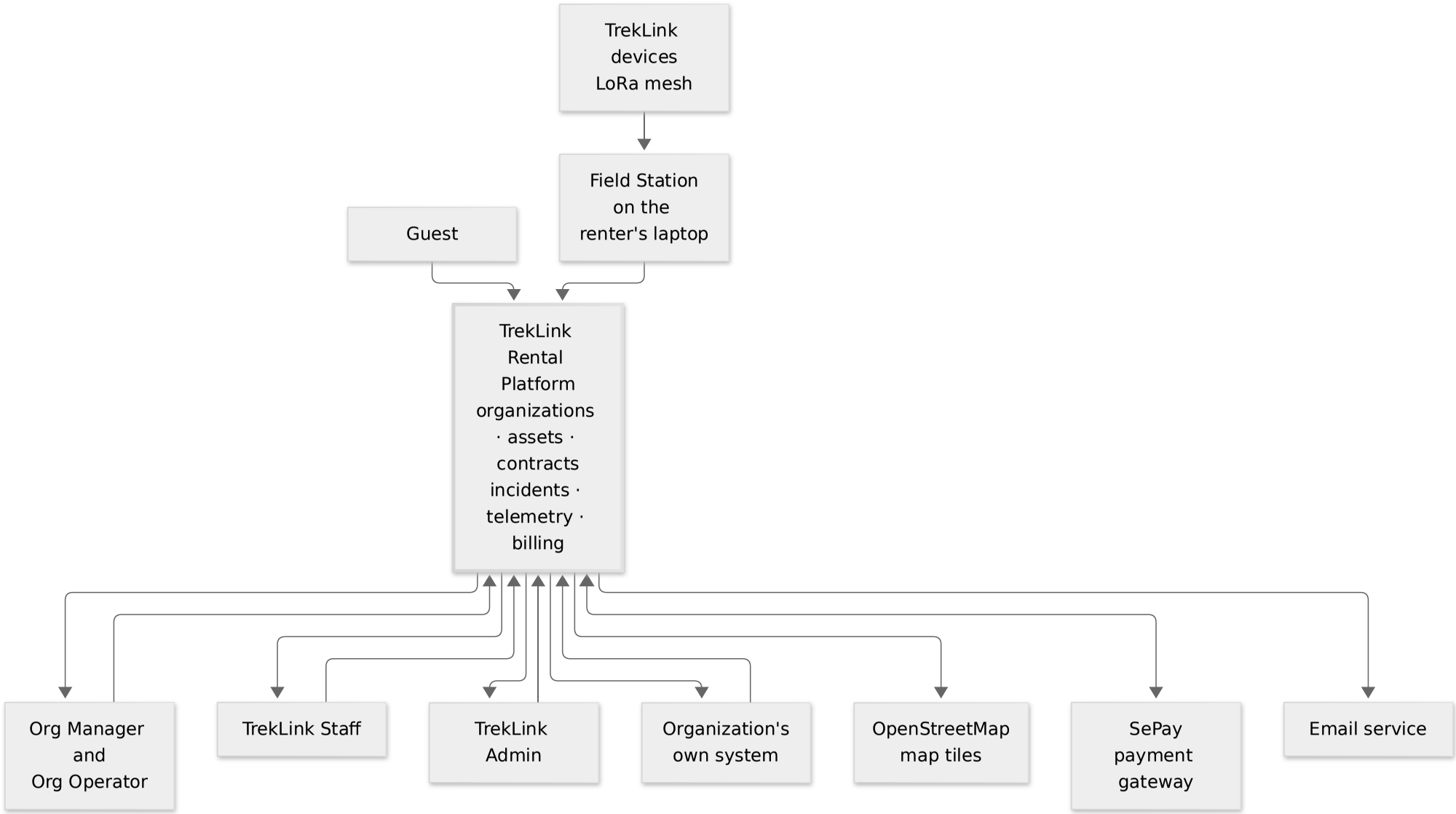

TrekLink devices LoRa mesh
Field Station on the renter's laptop
Guest
TrekLink Rental Platform organizations · assets · contracts incidents · telemetry · billing
Org Manager and Org Operator
TrekLink Staff
TrekLink Admin
Organization's own system
OpenStreetMap map tiles
SePay payment gateway
Email service

Figure 6: Context Diagram. The system boundary, its human actors, the organization's own system, and the external systems it exchanges data with. Placement: rotated plate, 145.1 x 266.0 mm, labels at 9.14 pt.

2. Actors

Actor	Type	Description	Main Flows
Guest	Primary, human	Registers an organization	MF-01
Org Manager	Primary, human	Signs contracts and handover notes, requests plans, pays, manages members, roster and API keys; last alert tier	MF-01, MF-03, MF-04, MF-05
Org Operator	Primary, human	On-duty member: receives alerts, acknowledges, reports status, watches the map, runs the Field Station	MF-02, MF-03, MF-04
TrekLink Staff	Primary, human	Verification, contract approval, device intake, handover, check-in, reset and inspection, payments at the counter, authority reports	MF-01, MF-03, MF-05
TrekLink Admin	Primary, human	Organization approval, plans and prices, parameters, damage approvals, retirement, platform accounts	all
Organization System	External system	The organization's own software reading telemetry with its API key	MF-04
TrekLink Device	Secondary, system	ESP32 LoRa node; emits SOS, position, telemetry	MF-02, MF-03, MF-04
Field Station	Secondary, system	TrekLink's executable on the renter's laptop: queue, upload, local page	MF-02, MF-04
Scheduler	Secondary, system	Alert tiers, staleness, term rollover, overdue and default	MF-03, MF-04, MF-05
SePay	External system	VietQR payment requests and confirming webhooks, sandbox	MF-01, MF-05
OpenStreetMap	External system	Raster map tiles (**D-031**)	MF-04

Role generalization. A TrekLink Admin holds every TrekLink Staff permission; an Org Manager holds every Org Operator permission inside the same organization. Device holders are not actors: they use the stock Meshtastic app.

3. Use Cases

Named verb-object. Each is a **function a user invokes**, not a multi-step process; the Main Flow diagrams in `05-main-flows.md` (`05-main-flows.md`) are where workflows belong. The full catalogue (UC-01 to UC-59) with specifications is generated into Report 3 §2.2 from `srs_data.py` .

3.1 Use case diagram

The headline use cases, split across three figures for legibility. See **Figure 7**, **Figure 8** and **Figure 9**.

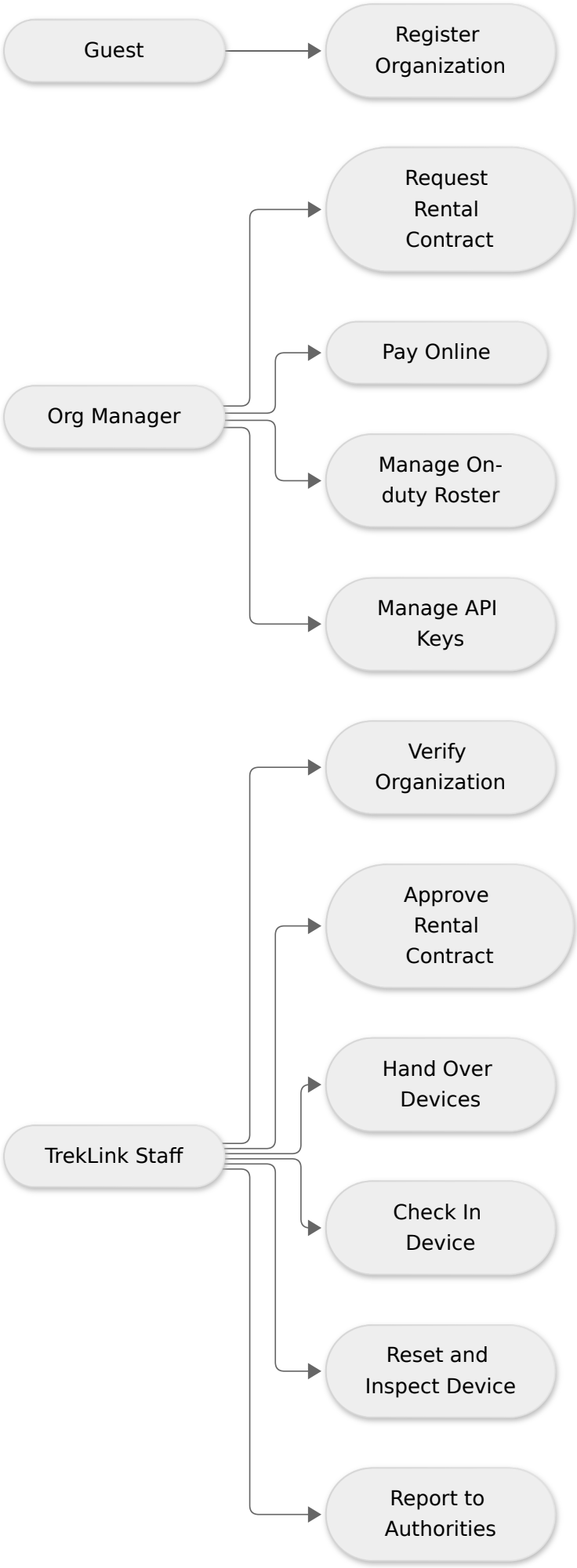

Guest
Register Organization
Org Manager
Request Rental Contract
Pay Online
Manage On-duty Roster
Manage API Keys
TrekLink Staff
Verify Organization
Approve Rental Contract
Hand Over Devices
Check In Device
Reset and Inspect Device
Report to Authorities

Figure 7: Use cases invoked by the Guest, the Org Manager and TrekLink Staff. Placement: inline, 100.3 x 266.0 mm, labels at 10.19 pt.

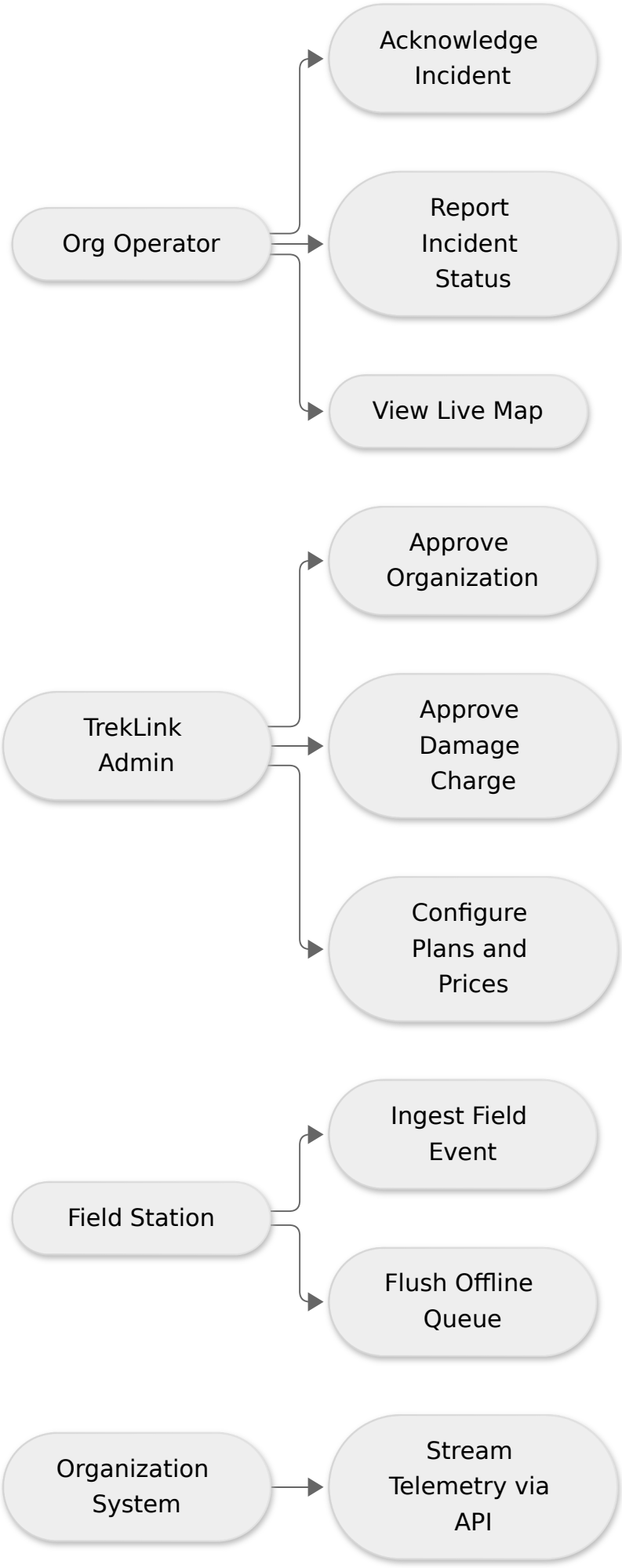

Org Operator
Acknowledge Incident
Report Incident Status
View Live Map
TrekLink Admin
Approve Organization
Approve Damage Charge
Configure Plans and Prices
Field Station
Ingest Field Event
Flush Offline Queue
Organization System
Stream Telemetry via API

Figure 8: Use cases invoked by the Org Operator, the TrekLink Admin, the Field Station and the organization's own system. Placement: inline, 110.0 x 266.0 mm, labels at 11.69 pt.

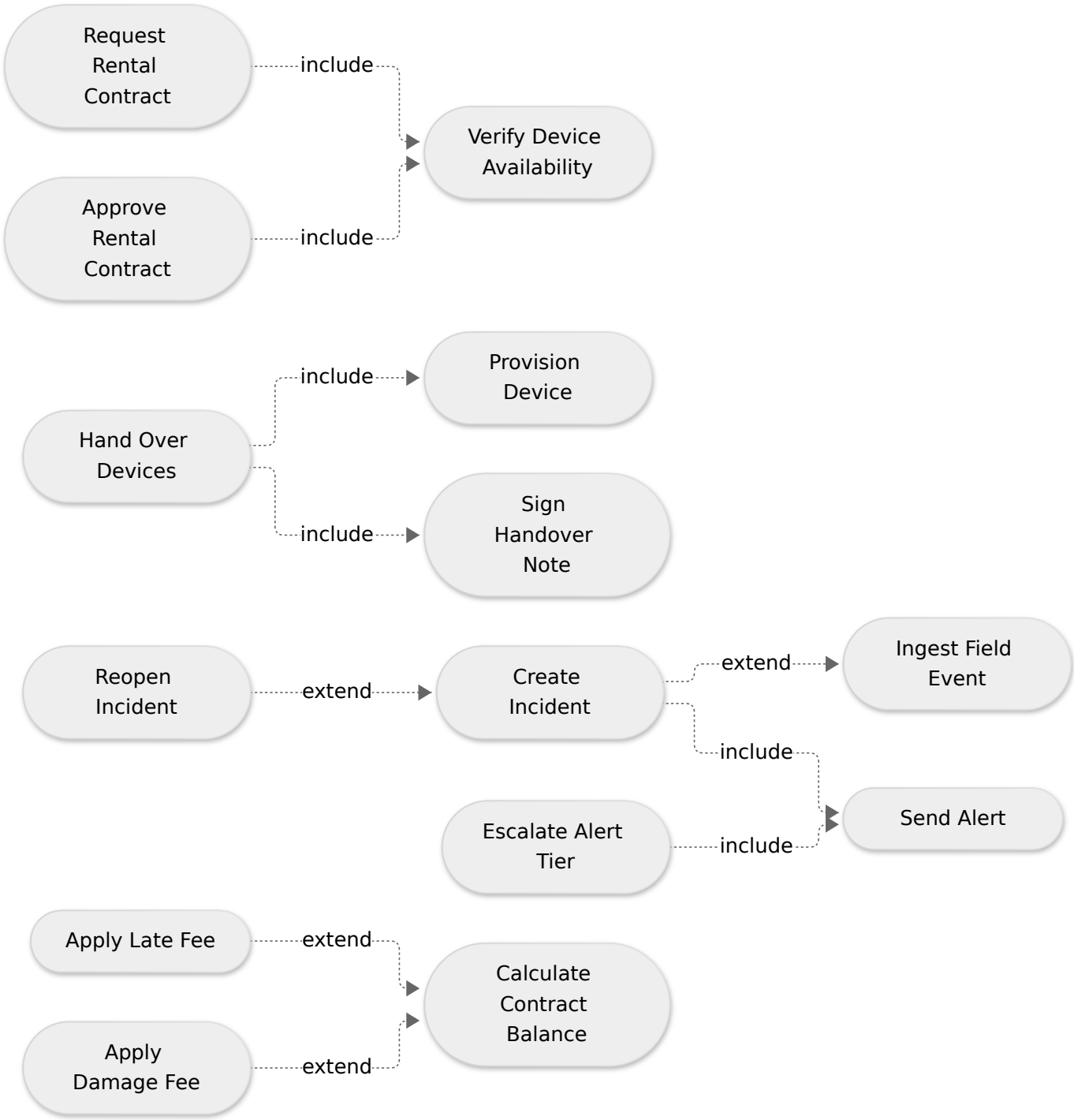


Figure 9: `include` and `extend` relationships. An included case always runs; an extending case runs only when its condition holds. Placement: rotated plate, 182.0 x 187.7 mm, labels at 10.21 pt.

3.2 `include` and `extend`: how they are used here

- `include`: the included use case **always** runs as part of the base. Request and Approve Rental Contract always verify availability; Hand Over Devices always provisions every device and captures the signed handover note; Create Incident and Escalate Alert Tier always send an alert.
- `extend`: the extending use case runs **only when a condition holds**. Create Incident extends Ingest Field Event when the event is an SOS or crosses the cadence threshold; Reopen Incident extends Create Incident when the same device raises a new SOS inside the reopen window; Apply Late Fee and Apply Damage Fee extend Calculate Contract Balance when the return is late or damaged.

- **Generalization**: only between actors (§2).

4. Feature Tree

Split across three figures for legibility. See **Figure 10**, **Figure 11** and **Figure 12**.

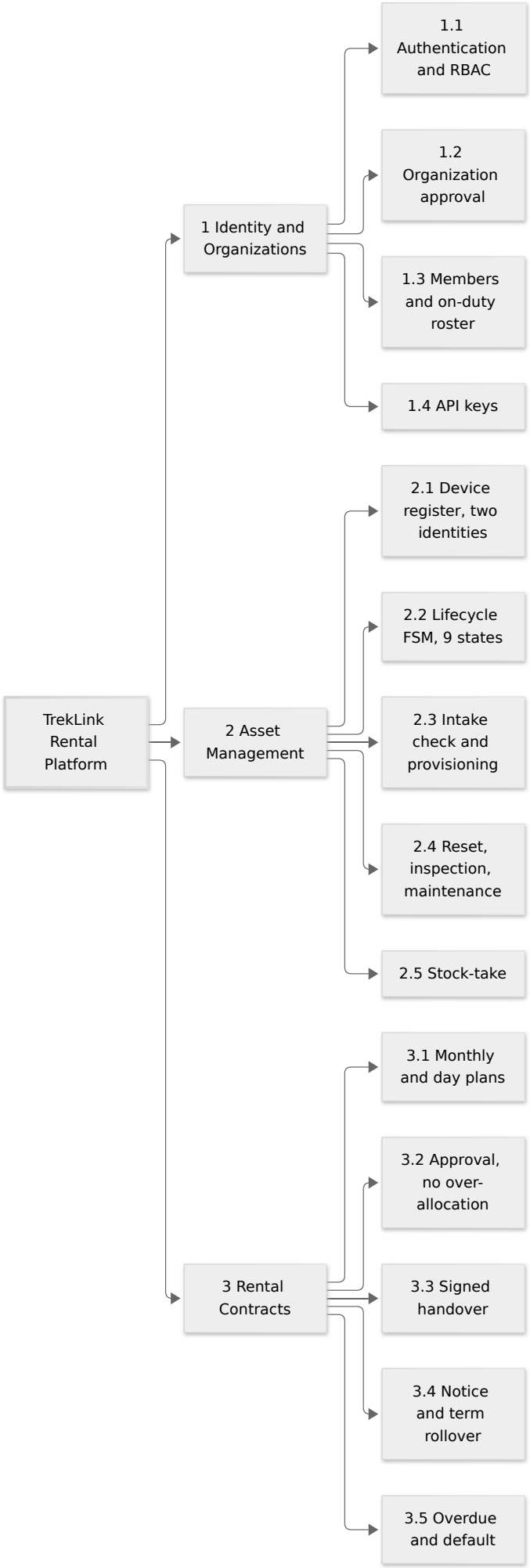

TrekLink Rental Platform
1 Identity and Organizations
1.1 Authentication and RBAC
1.2 Organization approval
1.3 Members and on-duty roster
1.4 API keys
2 Asset Management
2.1 Device register, two identities
2.2 Lifecycle FSM, 9 states
2.3 Intake check and provisioning
2.4 Reset, inspection, maintenance
2.5 Stock-take
3 Rental Contracts
3.1 Monthly and day plans
3.2 Approval, no over-allocation
3.3 Signed handover
3.4 Notice and term rollover
3.5 Overdue and default

Figure 10: Feature Tree, part 1 of 3, Identity and Organizations, Asset Management, Rental Contracts. Placement: inline, 91.4 x 266.0 mm, labels at 7.25 pt.

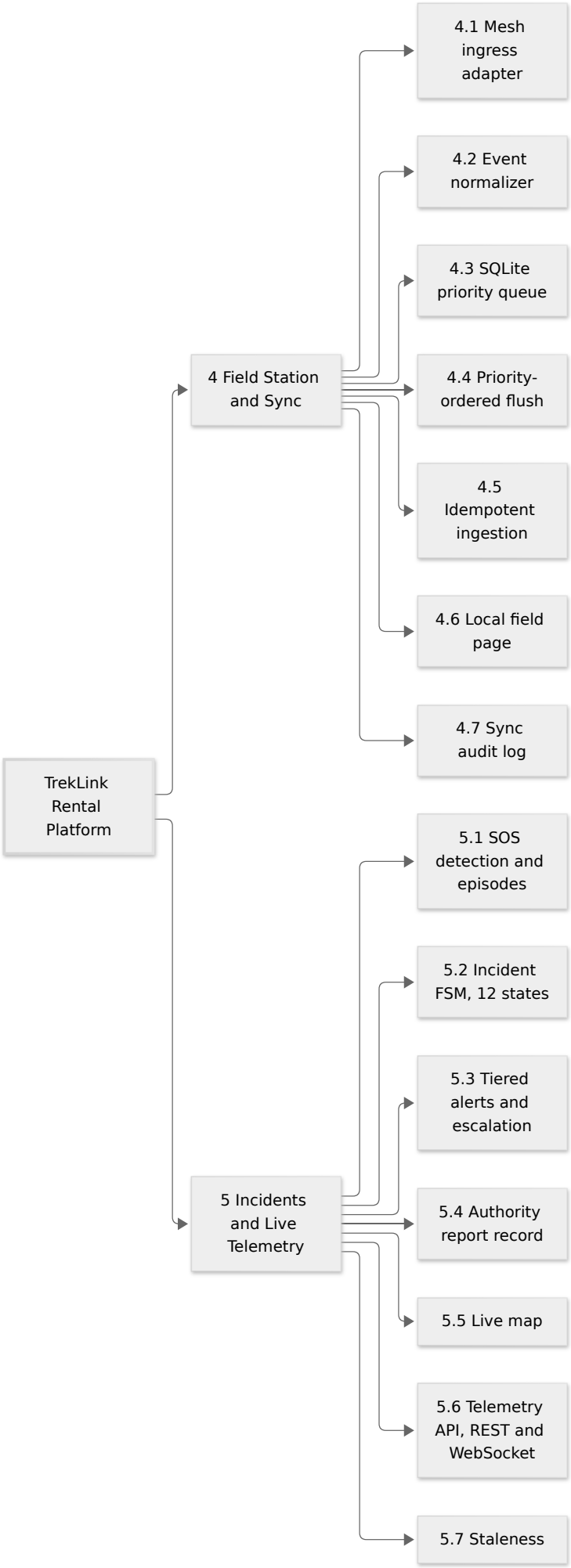

TrekLink Rental Platform
4 Field Station and Sync
4.1 Mesh ingress adapter
4.2 Event normalizer
4.3 SQLite priority queue
4.4 Priority-ordered flush
4.5 Idempotent ingestion
4.6 Local field page
4.7 Sync audit log
5 Incidents and Live Telemetry
5.1 SOS detection and episodes
5.2 Incident FSM, 12 states
5.3 Tiered alerts and escalation
5.4 Authority report record
5.5 Live map
5.6 Telemetry API, REST and WebSocket
5.7 Staleness

Figure 11: Feature Tree, part 2 of 3, Field Station and Sync, Incidents and Live Telemetry. Placement: inline, 100.4 x 266.0 mm, labels at 7.69 pt.

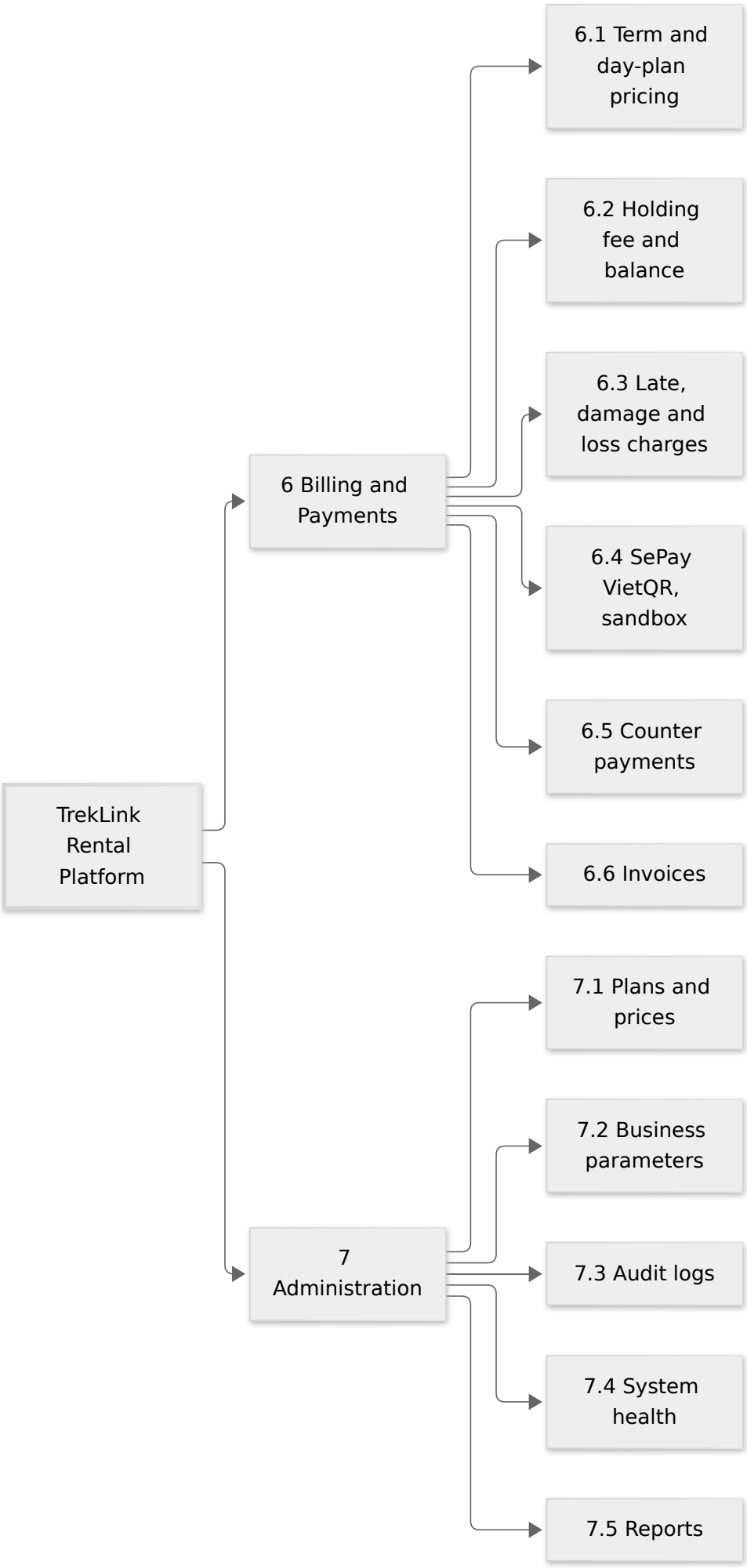

TrekLink Rental Platform
6 Billing and Payments
6.1 Term and day-plan pricing
6.2 Holding fee and balance
6.3 Late, damage and loss charges
6.4 SePay VietQR, sandbox
6.5 Counter payments
6.6 Invoices
7 Administration
7.1 Plans and prices
7.2 Business parameters
7.3 Audit logs
7.4 System health
7.5 Reports

Figure 12: Feature Tree, part 3 of 3, Billing and Payments, Administration. Placement: inline, 130.4 x 266.0 mm, labels at 9.99 pt.

5. Business Rule Matrix

The business rules (BR-01 to BR-35), each with the requirement that states it, the module that implements it and its test case, are generated into Report 3 §5.1 from the SRS builder, so the identifiers cannot drift between this file and the report. Every Implementation and Tested cell is empty until the code and the test exist.

6. Exception Scenario Matrix

The per-flow tables in `05-main-flows.md` (`05-main-flows.md`) are the source: E01-1 to E01-7, E02-1 to E02-6, E03-1 to E03-9, E04-1 to E04-7 and E05-1 to E05-13. Report 3 §5.2 consolidates them with the requirement each one tests. The faculty handbook's five generic probes are covered: payment failing part-way (E01-4, E05-4), two users acting at once (E01-1, E03-3), cancellation after approval (E01-7), data outside plausible range (E04-6), and one organization reaching another's data (E04-4).

7. Honest status

Layer	Status as of 2026-10-03
Specs	The `treklink-web` module specs were written for the booking scope and are being rewritten against D-033 to D-035
Backend	The `platform` module (health, business parameters, audit log) is implemented; the other modules are empty
Database	The Prisma schema still carries the booking scope (`TrekPackage` , `Booking`); its migration follows the spec rewrite
Implementation of any Main Flow	**None.** MF-01 to MF-05 are all at 0 %

TrekLink Engineering Conventions: Index

> **This folder is the TrekLink Developer Handbook.** It is the authoritative, machine-readable source. `TrekLink_Developer_Handbook_v1.0.pdf` is a **generated render** of these files, never hand-edited, rebuilt automatically by CI whenever anything here changes. If the PDF and these files ever disagree, **these files win** and the PDF is stale; rebuild it.

Conventions v2 (2026-09-13). Originally ported from a session-driven + spec-driven (Kiro-style) framework used on a .NET project, then adapted to TrekLink's real stack: **NestJS/TypeScript backend, Node.js/TypeScript gateway, React/TypeScript frontend, PostgreSQL, GitHub, Jira**.

Read in this order

#	File	Domain
01	`01-session-based-development-and-ssot.md` (`01-session-based-development-and-ssot.md`)	Core philosophy: docs as SSOT, session-based development, crash-safe checkpointing
02	`02-spec-driven-development-workflow.md` (`02-spec-driven-development-workflow.md`)	EARS requirements → design → tasks. The spec-before-code gate.
03	`03-operational-workflows.md` (`03-operational-workflows.md`)	The four lifecycles: feature dev, debugging, code review, review resolution
04	`04-architecture-conventions.md` (`04-architecture-conventions.md`)	Module boundaries, entity conventions, Feature-Sliced frontend
05	`05-backend-conventions.md` (`05-backend-conventions.md`)	NestJS modules, DTOs, the response envelope, error handling
06	`06-frontend-conventions.md` (`06-frontend-conventions.md`)	FSD, state management, forms/UX, WCAG, Leaflet + OpenStreetMap with the sovereignty overlay, WebSocket
07	`07-github-workflow-git-conventions.md` (`07-github-workflow-git-conventions.md`)	**Branching, commits, PRs, review, merge.** The most-referenced chapter.
08	`08-ai-agent-steering-and-discipline.md` (`08-ai-agent-steering-and-discipline.md`)	AI agent behaviour: thinking discipline, blast radius, circuit breakers, doc-sync
09	`09-doc-driven-scaffold-and-ssot-conventions.md` (`09-doc-driven-scaffold-and-ssot-conventions.md`)	The `ignore/` personal garden scaffold and how it reconciles with tracked `specs/`
10	`10-jira-tracking-and-workflow.md` (`10-jira-tracking-and-workflow.md`)	**Jira board, statuses, the development loop, backlog↔Jira mapping**
11	`11-ai-first-doctrine-and-toolchain.md` (`11-ai-first-doctrine-and-toolchain.md`)	**Model policy, required toolchain, session workflow, prompting standard**
12	`12-communication-and-daily-reports.md` (`12-communication-and-daily-reports.md`)	Channels, daily reports, merge announcements, schedule countdown
13	`13-diagram-and-figure-conventions.md` (`13-diagram-and-figure-conventions.md`)	Mermaid for specs, PlantUML for graded reports (D-065), the handbook gate of check, look and cross-check (D-067), swimlanes for multi-actor flows, computed figure placement, the 7 pt legibility floor
14	`14-prose-and-wording.md` (`14-prose-and-wording.md`)	**No em dash. Banned openers, aphorism formulas, unverified claims, fabricated precision. The always-on prose, communication and human skills.**
15	`15-graded-report-conventions.md` (`15-graded-report-conventions.md`)	**Graded reports: school template and regulations, the common thesis flaws, no verbose or meta text, upright figures**

#	File	Domain
16	`16-uml-modeling-rules.md` (`16-uml-modeling-rules.md`)	**UML rules for every PlantUML diagram (D-069): sourced notation and layout per type (context, use case, class, sequence, activity, state, ERD, architecture), the TrekLink actor tree, crow's foot ERD, skeletons in `02-templates/puml/`**
17	`17-firmware-development.md` (`17-firmware-development.md`)	**Firmware changes (D-077): change classes, the fix loop, the hardware-run gate for safety paths, evidence rules for agents, the upstream policy for `meshtastic/firmware` , bench safety**

If you read only three: 07 (git), 10 (Jira), 11 (AI-first). Those three cover everything you touch daily. **14 applies to every line you write**, including the ones in those three.

What changed in v2 (2026-09-13)

Logged as **Decision D-009**, which supersedes D-003. Every one of these was a live contradiction in v1, the documented commands did not work.

Was	Now
`develop` integration branch	`dev` , no repo ever had a `develop` branch
`[Feature]` bracket-tag commits	**Conventional Commits**, `feat(TK-45): add device FSM guard`
Dual `features/Design_X` + `features/Implementation_X` branches	**One branch per unit of work**, spec commits first
`release/sprint_x` branches	**Dropped**, `main` is the release
Squash-merge always	**Rebase & merge** default; squash only when multi-commit; merge commits **prohibited**
GitHub Issues + Milestones as the tracker	**Jira** is the single tracker; GitHub Issues = daily reports + bugs
`points:*` labels	Jira story points, **Fibonacci** scale (1/2/3/5/8/13/21)
Two PR templates	**One** `pull_request_template.md` , Design DoD optional
AI agent guidance scattered	Chapters **11** and **12**, plus a mandatory session workflow

---

Adopting these conventions in a repo

All three TrekLink repos use **identical** conventions. There is no per-repo exception.

1. Point the repo's `AGENTS.md` and `CLAUDE.md` at this folder, one canonical file, copied verbatim into `capstone/` , `treklink-docs/` , `treklink-web/` , and `treklink-firmware/` .
2. Copy `../.github/` into the repo root as-is (PR template, issue templates, labels).
3. Run the label setup script in `../.github/labels-and-milestones.md` (`labels-and-milestones.md`) §3.
4. Apply branch protection per `07-github-workflow-git-conventions.md` (`07-github-workflow-git-conventions.md`) §7.
5. Create a tracked `specs/{module}/` folder per module, layout in `02-spec-driven-development-workflow.md` (`02-spec-driven-development-workflow.md`) §2.
6. **Never write production code before the requirements → design → tasks gate has been passed.**

> Do **not** vendor a second copy of these files into another repo. A duplicated convention set drifts and then actively teaches the wrong rules, that is exactly what happened with `treklink-web/docs/conventions/`, which has been deleted for this reason. Link to this folder; don't copy it.

Authority

When two documents conflict, the higher tier wins until an ADR in `../00-project-context/03-decisions-and-risk-register.md` (`03-decisions-and-risk-register.md`) supersedes it:

1. **Tier 1**, Project Charter & capstone registration form
2. **Tier 2**, Module specs (`treklink-web/specs/{module}/`) and the backlog (`../03-backlog/`)
3. **Tier 3**, These conventions
4. **Tier 4**, Templates (`../02-templates/`), starting points, not binding once filled in
5. **Tier 5**, Source code & tests

How We Work

Core Engineering Philosophy: Session-Based Development & Living SSOT

> **Fundamental Law of Engineering Continuity**: In modern software engineering with human-AI collaboration, conversational memory is volatile, ephemeral, and lossy. **The codebase and its living documents are the only durable sources of truth.** Every decision, state transition, and requirement MUST be grounded in structured documents, and every work stream MUST execute in bounded, crash-resilient sessions.

This applies with extra force on TrekLink: a 5-person team working 2-week sprints across 4 codebases (firmware [frozen], gateway, backend, frontend), reviewed by lecturers at fixed checkpoints (Week 4/8/14) who were not in the room for any implementation decision. If it isn't written down, the reviewer can't grade it and the next session can't resume it.

---

1. The Core Philosophy

Software projects fail not from lack of code, but from **context drift, ungrounded assumptions, and fragmented memory**. To eliminate this entropy, this framework rests on two pillars:

1. **Documents as the Single Source of Truth (SSOT)**: If a requirement, architectural choice, or API contract is not written down in an official document, **it does not exist**.
2. **Session-Based Development (SBD)**: All engineering work is structured into deterministic, self-contained sessions with rigorous pre-flight discovery, milestone checkpoints, and explicit handoffs.

See **Figure 13**.

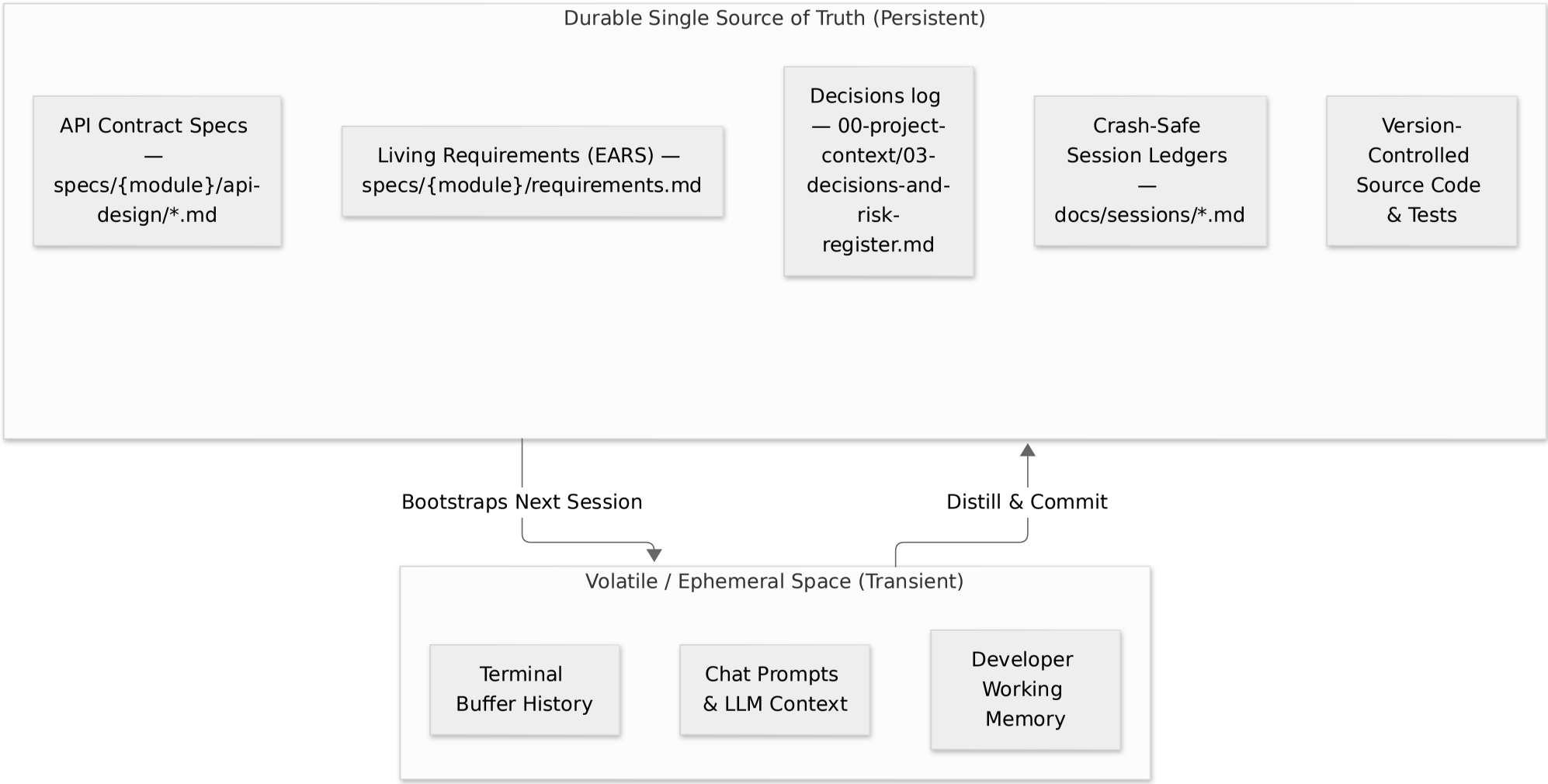

Durable Single Source of Truth (Persistent)
API Contract Specs — specs/{module}/api-design/*.md
Living Requirements (EARS) — specs/{module}/requirements.md
Decisions log — 00-project-context/03-decisions-and-risk-register.md
Crash-Safe Session Ledgers — docs/sessions/*.md
Version-Controlled Source Code & Tests
Bootstraps Next Session
Distill & Commit
Volatile / Ephemeral Space (Transient)
Terminal Buffer History
Chat Prompts & LLM Context
Developer Working Memory

Figure 13: Volatile context versus durable SSOT. Anything that exists only in a chat window is lost at session end; anything that matters is written to a document under version control. Placement: rotated plate, 136.6 x 266.0 mm, labels at 9.92 pt.

2. Pillar I: Living Documentation as SSOT

2.1 The SSOT Hierarchy

Level	Document Type	Purpose	Mutability
Tier 1	Project Charter, System Architecture & Data Schema	Module boundaries, domain entities, invariants	High ceremony; requires team + supervisor sign-off (esp. at Review 1/2)
Tier 2	Feature Specs (`specs/{module}/`)	EARS requirements, API contracts, task breakdowns	Updated per module/user story; locked during implementation
Tier 3	Engineering Conventions (`docs/conventions/` , this folder)	Architecture rules, code style, Git flow, agent discipline	Living rules; updated on retrospective consensus
Tier 4	Session Ledgers & Worklogs (`docs/sessions/`)	Current milestone progress, test metrics, open bugs	Frequently updated during active sessions
Tier 5	Source Code & Test Suites	Concrete implementation fulfilling Tiers 1–3	Changes only to satisfy Tiers 1–4

2.2 In-Repo Living Documents

- **Zero third-party dependency for context**: docs live inside the repo, version-controlled, next to the code they describe.
- **Atomic spec-code merges**: when an endpoint changes, its `specs/{module}/api-design/*.md` file is updated **in the same PR**. This generalizes to every tier above it, not just API endpoints: a finding that touches the charter, a decision, a spec, or a convention gets that document updated **in the same working pass it was found in**, see `08-ai-agent-steering-and-discipline.md` Stage 2.5b. A doc update queued for "later in the session" is functionally the same failure mode as an endpoint shipped without its spec update, just easier to miss because nothing blocks the PR on it.
- **No stale documentation**: specs gate coding, they aren't written after the fact.

3. Pillar II: Session-Based Development (SBD)

Break open-ended work into bounded execution cycles, 1–3 hours for humans, or one AI-agent context window.

3.1 The 4-Phase Session Lifecycle

See **Figure 14**.

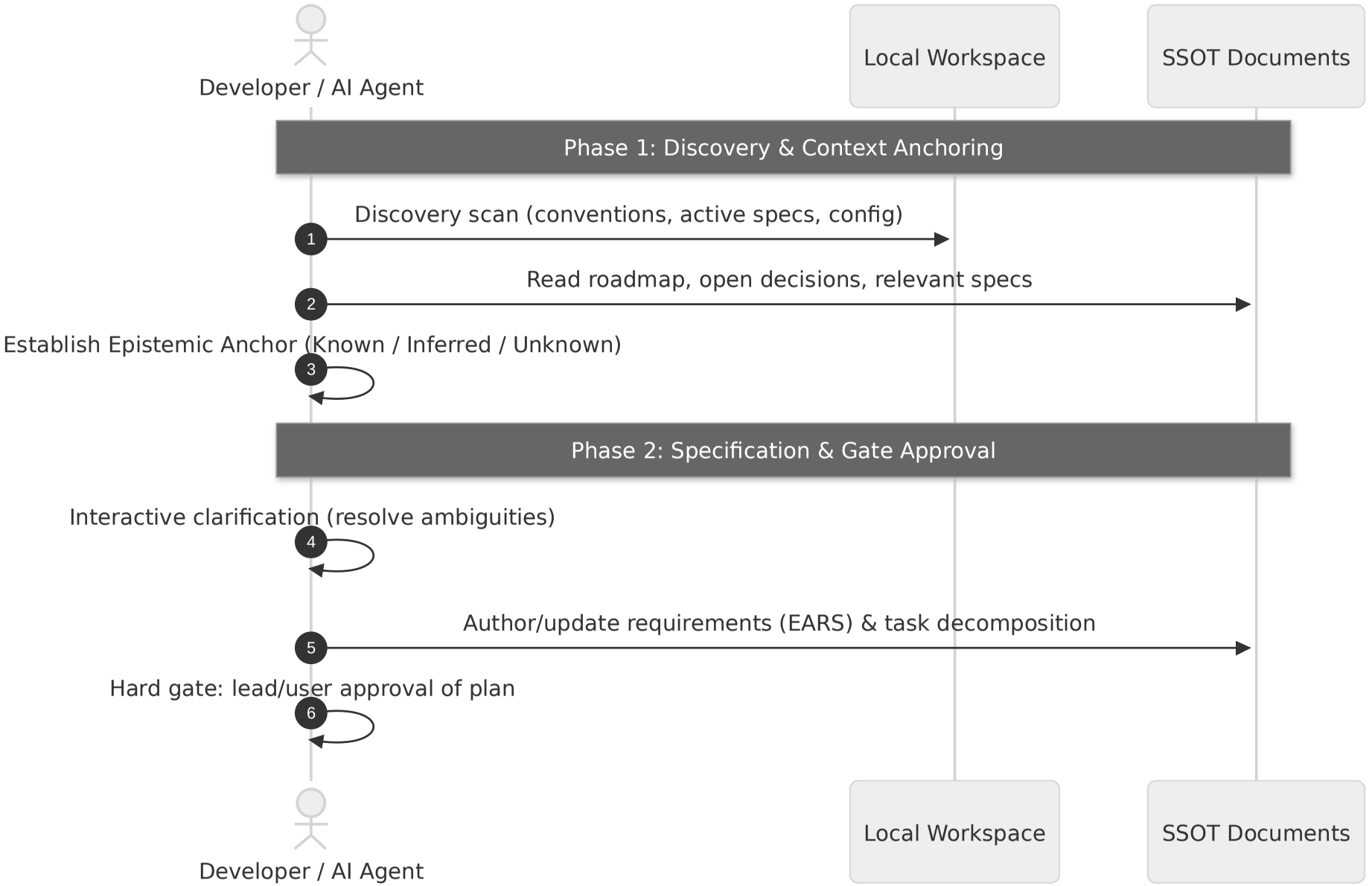

Developer / AI Agent
Local Workspace
SSOT Documents
Phase 1: Discovery & Context Anchoring
Discovery scan (conventions, active specs, config)
1
Read roadmap, open decisions, relevant specs
2
Establish Epistemic Anchor (Known / Inferred / Unknown)
3
Phase 2: Specification & Gate Approval
Interactive clarification (resolve ambiguities)
4
Author/update requirements (EARS) & task decomposition
5
Hard gate: lead/user approval of plan
6
Developer / AI Agent
Local Workspace
SSOT Documents

Figure 14: The session lifecycle, phases 1 and 2, discovery and context anchoring, then specification and the approval gate. No code is written before the gate. Placement: rotated plate, 179.9 x 266.0 mm, labels at 8.58 pt.

See **Figure 15**.

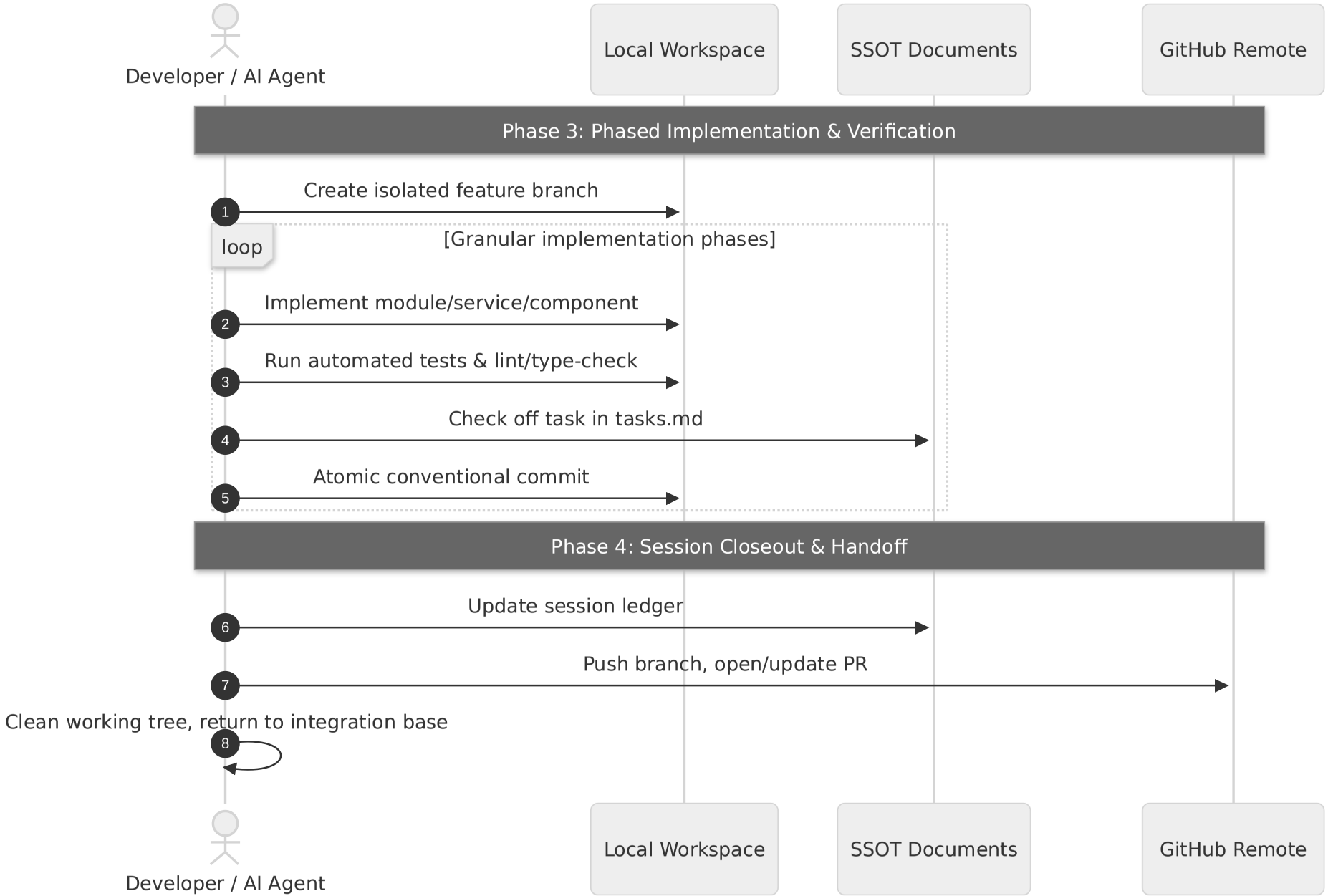

Developer / AI Agent
Local Workspace
SSOT Documents
GitHub Remote
Phase 3: Phased Implementation & Verification
Create isolated feature branch
1
loop
[Granular implementation phases]
Implement module/service/component
2
Run automated tests & lint/type-check
3
Check off task in tasks.md
4
Atomic conventional commit
5
Phase 4: Session Closeout & Handoff
Update session ledger
6
Push branch, open/update PR
7
Clean working tree, return to integration base
8
Developer / AI Agent
Local Workspace
SSOT Documents
GitHub Remote

Figure 15: The session lifecycle, phases 3 and 4, phased implementation with verification, then closeout and handoff. Placement: rotated plate, 182.0 x 257.9 mm, labels at 7.66 pt.

Phase 1: Discovery & Context Anchoring

1. **Discovery scan**: conventions, active specs, roadmap position (which sprint/week are we in).
2. **Epistemic Reality Anchor**:
   - **KNOWN**: verified from files read this session.
   - **INFERRED**: derived pattern (state confidence).
   - **UNKNOWN**: missing context, flag **before** proceeding, check `03-decisions-and-risk-register.md` for anything OPEN that blocks you.
3. **Kalama Empirical Proof Standard**: reject "seems reasonable", accept only what's backed by file evidence or test output.

Phase 2: Specification & Gate Approval

1. Never write production code from a bare chat prompt or vague issue.
2. Author/review the 3-file spec suite in `specs/{module}/`: `requirements.md` → `design.md` → `tasks.md`.
3. Pause and clarify edge cases before coding.

Phase 3: Phased Implementation & Verification

1. Branch off `dev` (or `main` for hotfixes).
2. Work `tasks.md` phase-by-phase.
3. **Read-Before-Write**: never edit a file not opened and inspected this session.
4. Run `npm test` / `npm run lint` / `npm run typecheck` (per-package, see `05-backend-conventions.md`, `06-frontend-conventions.md`) after every atomic phase.

Phase 4: Session Closeout & Crash-Safe Handoff

1. Update the session ledger.
2. Commit with bracket tags (`feat:`, `fix:`, `refactor:`, `docs:`, full list in `07-github-workflow-git-conventions.md`).
3. Rebase on the upstream integration branch.
4. Push and open/update the PR; output a concise handoff so the next session (human or AI) resumes with zero overhead.

---

4. Crash-Safe Memory Checkpoint Protocol

> **(Session 4 revision, namespacing for concurrency)** The original version of this section allowed a single rolling `docs/sessions/current.md` as an alternative to per-date files. That's unsafe once more than one session (human or AI-agent) can be active on the repo at the same time, a five-person team plus their own AI agents, each possibly running more than one session window, is exactly that case. **Per-session-instance files are now mandatory, not optional.** This isn't paperwork: this exact gap caused a real loss this term, a Session 4 audit produced several non-obvious findings (firmware wire-format facts, scaffold bugs) that sat only in chat output, in a repo that already had this protocol on paper, because nothing forced them to disk mid-session. See `08-ai-agent-steering-and-discipline.md` Stage 2.5 for the enforcement rule.

Tracked tier, `docs/sessions/<YYYY-MM-DD>-<HHMM>-<topic-slug>.md`, one file per session instance (e.g. `2026-09-13-1830-gateway-sync-audit.md`). `docs/sessions/current.md` is no longer where work-in-progress gets written, it becomes a short **index**: a few lines per active or recent session file, updated whenever a session file is created or closed out, so a new session can see at a glance what else is/was in flight before re-deriving it.

Personal scratch tier, same pattern, one level down: `ignore/[name]/docs/sessions/<YYYY-MM-DD>-<HHMM>-<topic-slug>.md` per session instance, replacing the old single shared `ignore/[name]/docs/current-progress.md`. That file still exists but changes role: a short rolling pointer/summary ("latest: see `sessions/2026-09-13-1830-gateway-sync-audit.md`"), not the place high-frequency scratch writes go, that would recreate the same collision risk one level down.

Maintain a session file at every major milestone, and, per the enforcement rule in `08-ai-agent-steering-and-discipline.md` Stage 2.5, immediately on any non-obvious finding, not only at milestones:

```
# Session Checkpoint: 2026-09-14 — gateway-sync

## 1. Active Focus & Objectives
- Module: Gateway Bridge — SQLite priority queue (TP2)
- Branch: feat/TK-45-gateway-priority-queue

## 2. Completed Milestones
- [x] Phase 1: SQLite schema for P0-P3 queue tiers
- [x] Phase 2: Enqueue/dequeue with priority ordering + unit tests

## 3. Immediate Next Steps (for resuming session)
1. Implement MQTT publish-on-reconnect flush routine
2. Add integration test: 30s / 2min / 5min connectivity-loss simulation
3. Wire health-reporting endpoint (queue depth per tier)

## 4. Uncommitted State / Known Blockers
- Working tree: clean (commit `a1b2c3d`)
- Test status: 18/18 passing
- Open questions: none (D-001 ORM decision doesn't block gateway work)
```

---

5. Context Window & Token Budget Management (AI Agents)

1. **Context decay**: past ~70–80% capacity, reasoning fidelity drops. Compact proactively.
2. **Proactive compaction**: grep for the specific error, don't dump whole logs; read targeted line ranges, not whole large files; summarize findings into the session ledger instead of re-reading the repo every turn.
3. **Handoff over compounding**: for multi-day work (e.g. TP2's whole Gateway Bridge), split into clean sessions, Session N ends by committing + updating `tasks.md`; Session N+1 boots by reading the spec, with a full context budget for implementation.

---

6. Tenets of Iterative Refinement

1. **Working software at every step**: never leave `dev` in a broken/uncompilable state. Incomplete work stays on its feature branch.
2. **Minimal sufficient change**: solve the registered requirement, no speculative abstractions ahead of the TP schedule.
3. **Continuous verification**: a feature is done when tests prove it satisfies the EARS requirements, not when code is typed.

Spec-Driven Development Workflow (SDSDW)

> **Core Axiom**: Specification is the architectural blueprint of software. Writing code without an approved specification is constructing a building without an engineering schematic. This workflow guarantees requirements, interactions, contracts, and tasks are formally verified before a single line of production code is written, this is the "Kiro spec-driven development" pattern (`requirements.md` → `design.md` → `tasks.md`) combined with session-based development from `01-session-based-development-and-ssot.md` .

---

1. Executive Overview

See **Figure 16**.

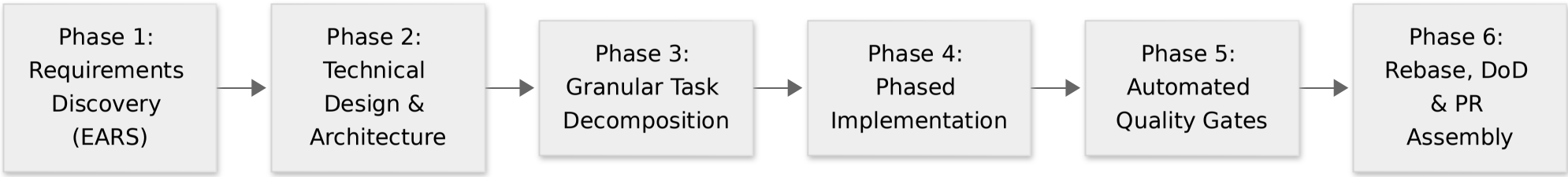

Phase 1: Requirements Discovery (EARS)
Phase 2: Technical Design & Architecture
Phase 3: Granular Task Decomposition
Phase 4: Phased Implementation
Phase 5: Automated Quality Gates
Phase 6: Rebase, DoD & PR Assembly

Figure 16: The spec-before-code gate: EARS requirements, then design, then granular task decomposition. Each phase is approved before the next begins. Placement: rotated plate, 32.1 x 266.0 mm, labels at 10.70 pt.

Universal tenets

1. **Spec before code** (Read → Clarify → Design → Code). Never guess business rules, RBAC edge cases, or error conditions, TrekLink's grading depends on traceable requirements (RQ1–RQ3 must map back to specific FRs).
2. **Standardized directory topology**: specs live in `specs/{module_name}/` inside each repo, next to the code.
3. **EARS-compliant criteria** for every functional requirement.
4. **Mermaid** for all architecture diagrams, state machines (Device 7-state, Incident 5-state, these are graded deliverables), and sequence flows.
5. **In-codebase tracked deliverables**: specs, migrations, and docs are committed, never left in an uncommitted scratchpad.
6. **Docs sync at the moment of discovery, not at phase-exit cleanup** (`08-ai-agent-steering-and-discipline.md` Stage 2.5b). If implementation, testing, or a code-level investigation reveals that a requirement, design assumption, or task in this module's spec was wrong or incomplete, fix `requirements.md` / `design.md` / `tasks.md` in that same working pass, immediately, not queued for a later "update the docs" step. Phase 6's `6.3` below is a final **audit** that sync already happened throughout, not the first time specs get touched.
7. **Who writes what** (D-052). The leader writes every spec suite (requirements, design, `api-design` sources, tasks). Members study the suites of their lane, own and defend them, and implement them; screen layouts are delegated to members with a 2 to 3 day deadline. A spec change is a pull request reviewed by the leader.
8. **One kind of content per file** (leader, 2026-10-19). `requirements.md` holds requirements only: functional requirements, including the behaviour of endpoints and the error each case returns, and NFRs, all in EARS. Detail lives in the design files: `api-design/` for request and response shapes, `ui-design/` (frontend) for screen layouts and states, and `design.md` for everything else (data model, lifecycle, services, figures). The files may cite each other and overlap where a requirement names a code or a route; no third requirements file is added.

---

2. Directory Structure (`specs/{module_name}/`)

TrekLink modules (per the roadmap's TP mapping and `07-github-workflow-git-conventions.md` 's `module:*` labels): `auth` , `devices` , `rentals` , `trips` , `gateway-sync` , `incidents` , `monitoring` , `billing` , `frontend` .

```
specs/{module_name}/
├── requirements.md                 # EARS-format business rules & criteria
├── design.md                       # Architecture, domain models, sequence flows, state machines
├── tasks.md                        # Phased, granular implementation checklist
└── api-design/                     # One file per endpoint, using 02-templates/04-api-endpoint-
template.md
    ├── 00-api-testing-guide.md     # Swagger / Postman / curl walkthrough
    ├── 01-post-devices-register.md
    ├── 02-get-devices-list.md
    └── ...

# Example for the gateway-sync module:
specs/gateway-sync/
├── requirements.md    # eventId scheme, P0-P3 priority rules, idempotency criteria
├── design.md           # SQLite queue schema, MQTT topic design, reconnect/flush sequence diagram
├── tasks.md
└── api-design/
    └── 01-post-events-ingest.md
```

Frontend-only concerns (screens, component architecture) live under `specs/frontend/` with the same 3-file pattern, referencing backend `api-design/` files rather than duplicating them.

---

3. Phase-by-Phase Execution Protocol

Phase 1: Requirements Discovery & EARS Specification

1. Context ingestion

Review the relevant section of `00-project-context/01-project-charter.md`, existing entities in `design.md` of dependent modules, and upstream/downstream module boundaries (e.g. `incidents` depends on `devices` + `rentals` existing first).

2. Interactive clarification interview (mandatory quality gate)

Before writing specs or code, formulate 3–5 high-value clarifying questions targeting:

- **Domain edge cases**: e.g. what happens to an in-field device's rental record if a trip's Guide reports it lost?
- **Authorization**: which of Admin/Staff/Guide/Customer can trigger this action; ownership checks (a Guide can only see their own assigned trips).
- **Reliability**: for gateway-sync/incidents, does this requirement interact with idempotency or priority ordering?

> **MANDATORY HARD STOP**: stop after presenting the questions and wait for an explicit answer. No specs, designs, tasks, or code before that.

3. Authoring `requirements.md` in EARS syntax

Pattern	Template	TrekLink example
Ubiquitous	*The system SHALL [response]*	The system SHALL record actor (user ID + role) and UTC timestamp on every incident state transition.
Event-driven	*WHEN [trigger], the system SHALL [response]*	WHEN a valid SOS event passes the idempotency check, the system SHALL create exactly one Incident and notify Staff + Guide via WebSocket within 2 seconds.
State-driven	*WHILE [state], the system SHALL [response]*	WHILE a device is in `Maintenance` status, the system SHALL reject any rental allocation attempt referencing it.
Unwanted behavior	*IF [condition/error], THEN the system SHALL [response]*	IF the same `eventId` is delivered more than once, THEN the system SHALL discard the duplicate without creating a second Incident.
Optional feature	*WHERE [feature/flag], the system SHALL [response]*	WHERE sandbox payment mode is enabled, the system SHALL mark all transactions with a `sandbox: true` flag.

Phase 2: Technical Architecture & Design (`design.md`)

Backend/gateway modules:

1. Domain & data modeling, entities, enums, FK constraints, state machines (render as Mermaid `stateDiagram-v2` for Device/Incident FSMs).
2. Service & queue architecture, NestJS providers/services, MQTT topics, SQLite queue schema for gateway-sync.
3. Endpoint spec (`api-design/*.md`) using `02-templates/04-api-endpoint-template.md`.

Frontend:

1. Component architecture (Feature-Sliced Design, see `06-frontend-conventions.md`).
2. Server vs. client vs. form state lifecycle.
3. Validation schemas (Zod) mirroring backend `class-validator` DTOs 1:1.

Phase 3: Granular Task Decomposition (`tasks.md`)

```
# Implementation Tasks: [Module Name]

## Phase 1: Foundation & Domain Modeling
- [ ] 1.1 Define entities/enums (Prisma, per D-001)
- [ ] 1.2 Write migration(s)
- [ ] 1.3 Add DTOs and error codes

## Phase 2: Core Service / Mutation Logic
- [ ] 2.1 Implement service method(s) with class-validator DTO input
- [ ] 2.2 Wrap multi-table writes in a transaction
- [ ] 2.3 Unit test success + failure paths

## Phase 3: Query / Retrieval
- [ ] 3.1 Implement paginated list/query endpoints
- [ ] 3.2 Unit test filter/sort/pagination boundaries

## Phase 4: API Presentation Layer
- [ ] 4.1 Controller + Guards (JWT + RBAC/CASL)
- [ ] 4.2 Swagger/OpenAPI annotations
- [ ] 4.3 Integration tests for the HTTP contract (match api-design/*.md exactly)

## Phase 5: Frontend Integration (if applicable)
- [ ] 5.1 API client + TypeScript types
- [ ] 5.2 Form (RHF + Zod) or view wired to TanStack Query
- [ ] 5.3 Loading/empty/error states

## Phase 6: End-to-End Verification & DoD Audit
- [ ] 6.1 Full test suite green
- [ ] 6.2 Lint + typecheck clean
- [ ] 6.3 Audit: confirm `specs/{module}/api-design/*.md` already matches actual behavior — it
      should have been updated live in Phases 1-5 per tenet #6 above, so this is a check, not
      the first edit. If it's out of sync here, that's a process miss to flag, not routine cleanup.
```

Phase 4: Phased Implementation

Never skip ahead. Atomic commits per subtask with bracket tags (`07-github-workflow-git-conventions.md`). Zero magic strings, centralize error codes and route constants.

Phase 5: Automated Testing & Verification Gates

- **Unit tests**: every domain rule, FSM transition, validator branch (esp. idempotency and priority-ordering logic, these are graded NFRs).
- **Integration tests**: DB persistence, unique constraints, transaction rollback.
- **Static analysis**: 0 build warnings, 0 lint errors, strict TypeScript.

Phase 6: GitHub Flow, Rebase & PR Assembly

1. One branch: `feat/TK-nn-short-desc` off `dev` , carrying spec commits first, then code+tests (see `07-github-workflow-git-conventions.md` §2.3).
2. `git fetch origin && git rebase origin/dev` .
3. Open the PR, `.github/pull_request_template.md` loads automatically. DoD checked, test output pasted, specs referenced, every commit sealed (chapter 07 §3.6). Fill the optional Design DoD block if this branch introduced or changed a spec. Then move the Jira card to `IN REVIEW` and ping the reviewer in Zalo.

---

4. Universal Phase Exit Gate Matrix

Phase	Core Deliverable	Mandatory Exit Gate
1A: Clarification	Interview	**STOP & WAIT** for answers
1B: Requirements	`requirements.md`	All rules in unambiguous EARS syntax
2: Technical Design	`design.md` + `api-design/`	Architecture/schema/Mermaid diagrams reviewed
3: Task Decomposition	`tasks.md`	Granular checklist approved by lead
4: Implementation	Source code	Matches design, minimal sufficient change
5: Verification	Test suite	100% pass, 0 lint/type errors
6: Delivery & Review	Rebased branch & PR	Linear history, DoD verified, PR description compiled

Engineering Lifecycle & Operational Workflows

> Four canonical, repeatable workflows for feature development, defect diagnosis, code review, and review-comment resolution. Applies equally whether the acting party is a teammate or an AI coding agent.

1. Executive Workflow Matrix

See **Figure 17**.

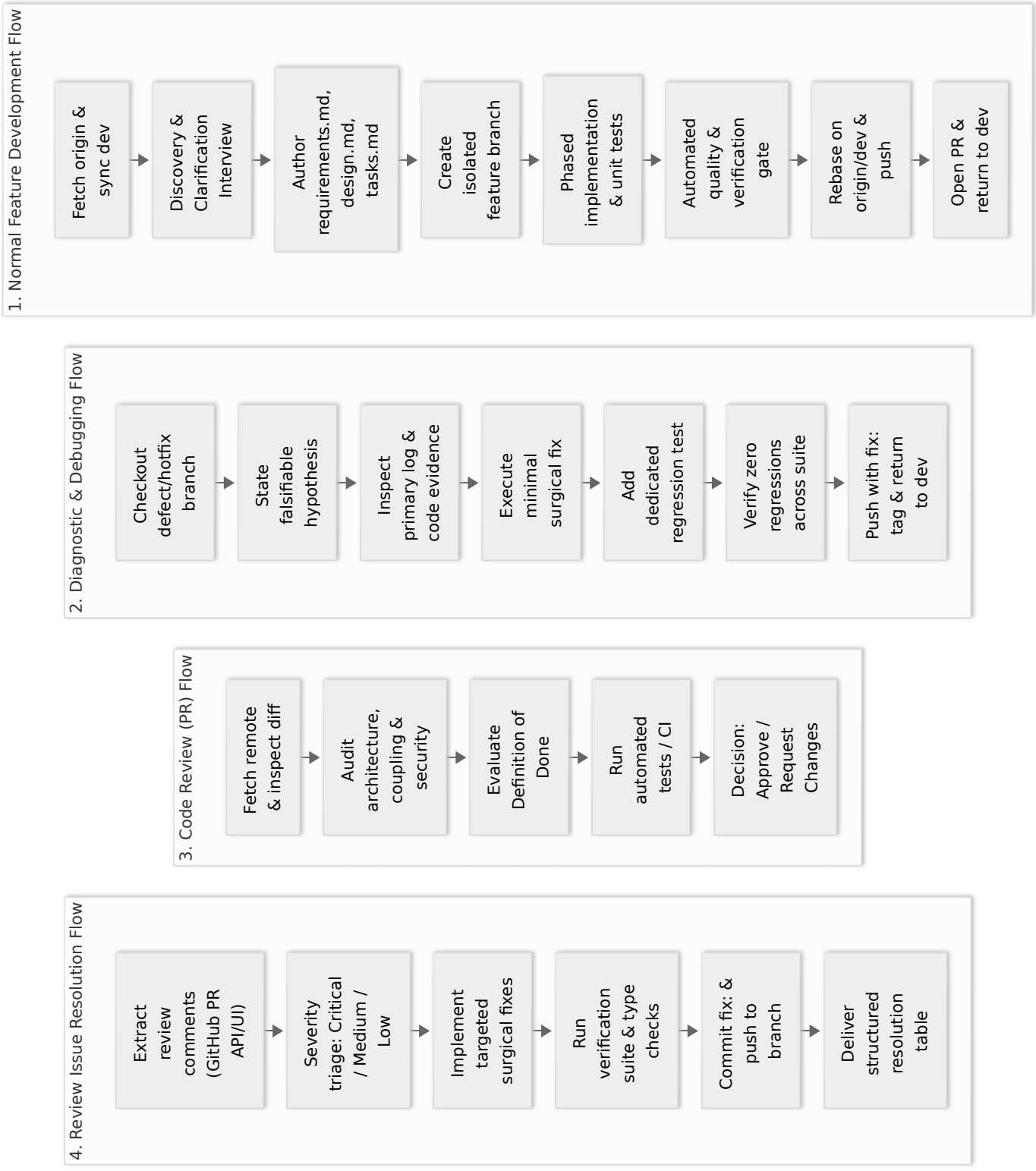


Figure 17: The four operational workflows, normal feature development, defect handling, spec revision, and session handoff, and the points at which they hand off to one another. Placement: rotated plate, 182.0 x 199.7 mm, labels at 8.23 pt.

2. Lifecycle 1: Normal Feature Development Flow (Spec-First)

Step 1: Baseline Synchronization

```
git fetch origin
git checkout dev
git pull origin dev
```

Step 2: Discovery, Clarification & Spec Authoring

Review the target module's charter section, existing entities, and dependent modules. Run the **Phase 1A Mandatory Gate** clarification interview (see `02-spec-driven-development-workflow.md`), hard stop until answered. Author `specs/{module}/requirements.md` → `design.md` → `tasks.md` → `api-design/`.

Step 3: Branch Creation & Isolation

```
git checkout -b feat/TK-45-device-registration
```

One branch per unit of work. Spec commits and implementation commits live on the **same** branch, spec first, see `07-github-workflow-git-conventions.md` §2.3. Branch type is `feat/`, `fix/`, `docs/`, or `chore/` as appropriate.

Step 4: Phased Clean Implementation

Follow `tasks.md` phase-by-phase. Commit small, atomic units using Conventional Commits with the Jira key as scope, `feat(TK-45): ...`, `fix(TK-45): ...`, `test(TK-45): ...` (see `07-github-workflow-git-conventions.md` §3).

Step 5: Quality Gate & Verification

```
# Backend (NestJS) — from the backend package root
npm run lint && npm run typecheck && npm test && npm run test:e2e

# Gateway (Node/TS)
npm run lint && npm test

# Frontend (React)
npm run lint && npm run build && npm test
```

Confirm **100% test pass rate**, 0 lint errors, clean build. Backend endpoint behavior must match `specs/{module}/api-design/*.md` exactly (same response envelope, see `05-backend-conventions.md`).

Step 6: Upstream Rebase & Push

```
git fetch origin
git rebase origin/dev
# re-run Step 5 after resolving any conflicts
git push --force-with-lease origin feat/TK-45-device-registration
```

Step 7: PR Assembly & Return to Base

Open the PR with `.github/pull_request_template.md`, fill the DoD, and **ping the reviewer in Zalo**. Move the Jira card to `IN REVIEW`. Checkout back to `dev`.

3. Lifecycle 2: Diagnostic & Debugging Flow (Hypothesis-Driven)

Step 1: Checkout Target Branch

```
git checkout feat/TK-45-device-registration
# OR for an urgent defect — see 07-github-workflow-git-conventions.md §2.4
# for which branch to cut from (dev vs main):
git checkout -b hotfix/TK-99-jwt-expiry-crash
```

Step 2: Hypothesis Formulation & Investigation

State a single falsifiable hypothesis. Inspect logs/stack traces/source lines with real tool calls, not guesses. Assess blast radius, e.g. a fix to the idempotency key logic touches every consumer of `eventId` across gateway + backend.

Step 3: Minimal Surgical Fix

Address the root cause only. No unrelated refactors or formatting changes bundled in.

Step 4: Dedicated Regression Test

Add a test that reproduces the failure without the fix and passes with it. Run the full suite, zero downstream regressions.

Step 5: Push & Return to Base

```
git commit -m "fix(TK-99): precise description of the resolved defect"
git push --force-with-lease origin hotfix/TK-99-jwt-expiry-crash
git checkout dev
```

Output a diagnostic summary: root cause, fix mechanics, regression-test proof.

---

4. Lifecycle 3: Pull Request & Code Review Flow

Step 1: Branch Fetch & Diff Inspection

```
git fetch origin
git log --oneline origin/dev..origin/{target_branch}
git diff origin/dev...origin/{target_branch}
```

Or via GitHub CLI: `gh pr diff {number}`, `gh pr checks {number}`.

Step 2: Architectural & Code Quality Audit

- [ ] Module boundaries respected (no cross-module repository access, see `04-architecture-conventions.md` §4)
- [ ] DTOs strictly typed with `class-validator`, matching `api-design/*.md`
- [ ] Errors use the standard envelope (`result` / `isSuccess` / `statusCode` / `message`), not ad-hoc shapes
- [ ] Security: mutating endpoints have both a JWT guard and a role/CASL policy check, e.g. `@UseGuards(JwtAuthGuard, PoliciesGuard)` on any endpoint that mutates device/rental/incident state
- [ ] Performance: no N+1 queries, indexed lookups on `eventId` /device ID/trip ID
- [ ] Hygiene: no debug logs, dead code, hardcoded secrets, or `.env` values committed

Step 3: Definition of Done Verification

Confirm DoD checklist in the PR description is honestly checked and CI is green.

Step 4: Structured Review Output

- **Decision**: `[APPROVED]` | `[CHANGES REQUESTED]` | `[NEEDS FIXES]`
- **Findings**: exact file + line references, drop-in diff suggestions.

---

5. Lifecycle 4: Review Issue Resolution Flow

Step 1: Retrieve Review Notes

Pull comments from the GitHub PR conversation thread (`gh pr view {number} --comments` or the UI).

Step 2: Severity Triage

- 🔴 **Critical**: missing auth/RBAC guard, data corruption risk, broken CI, idempotency/priority-ordering violation.
- 🟡 **Medium**: performance issue, missing transaction rollback, unhandled edge case.
- 🟠 **Low/Hygiene**: formatting, naming, doc updates.

Step 3: Implement Targeted Fixes

Address each comment directly, on the same branch, without unrelated scope changes.

Step 4: Verification & Handoff

```
npm test && npm run lint
git commit -m "fix: Address review feedback on {topic}"
git push
```

Output a resolution table:

#	Reviewer Comment	Severity	Applied Fix	Status
1	Missing role guard on device retire endpoint	🔴 Critical	Added `@Roles('Admin')` + CASL `can('retire','Device')` check	Resolved
2	Duplicate-SOS test only covers 2 retries, NFR needs 10	🟡 Medium	Extended test to 10× replay of same `eventId`	Resolved

Delivery

GitHub Workflow, Branching, Commits & Pull Requests

> **Conventions v2, supersedes everything written before 2026-09-13.** The previous version of this file described a `develop` branch and a dual `Design` / `Implementation` branch model inherited from the school's `Git_Lab_Guide.pdf`. Neither matches reality: no repository has ever had a `develop` branch, and the dual-branch model doubles PR overhead for a 5-person team on a 13-week term. Decision **D-009** records the change and supersedes **D-003**.

> **PR = MR.** "Pull Request" (GitHub) and "Merge Request" (GitLab) are used interchangeably across this documentation and in team chat. They mean the same thing and follow the same workflow. The school's guide says MR; GitHub says PR; we say either.

---

1. Repositories

Three repositories under `github.com/TrekLink-Team`, cloned as siblings inside one `capstone/` parent folder. See the root `README.md` §1 for the full layout and why the parent folder matters for AI agents.

Repo	Contents	Branch model
`treklink-docs`	This documentation set (SSOT). No application code.	Full model below
`treklink-web`	The active build: `gateway/`, `backend/`, `frontend/` as workspace packages	Full model below
`treklink-firmware`	Inherited SU26 firmware, editable per D-008, surgical fixes only	Full model below

All three repos use identical conventions. Same branches, same commit format, same PR process, same AI agent rules. There is no "this repo is different" exception. A teammate who learns the workflow in one repo knows it in all three.

The `capstone/` parent folder is also git-versioned but **never published**, it exists so an AI agent opened on `capstone/` can read all three repos plus `Documents/` in one context window.

---

2. Branch Model

See **Figure 18**.

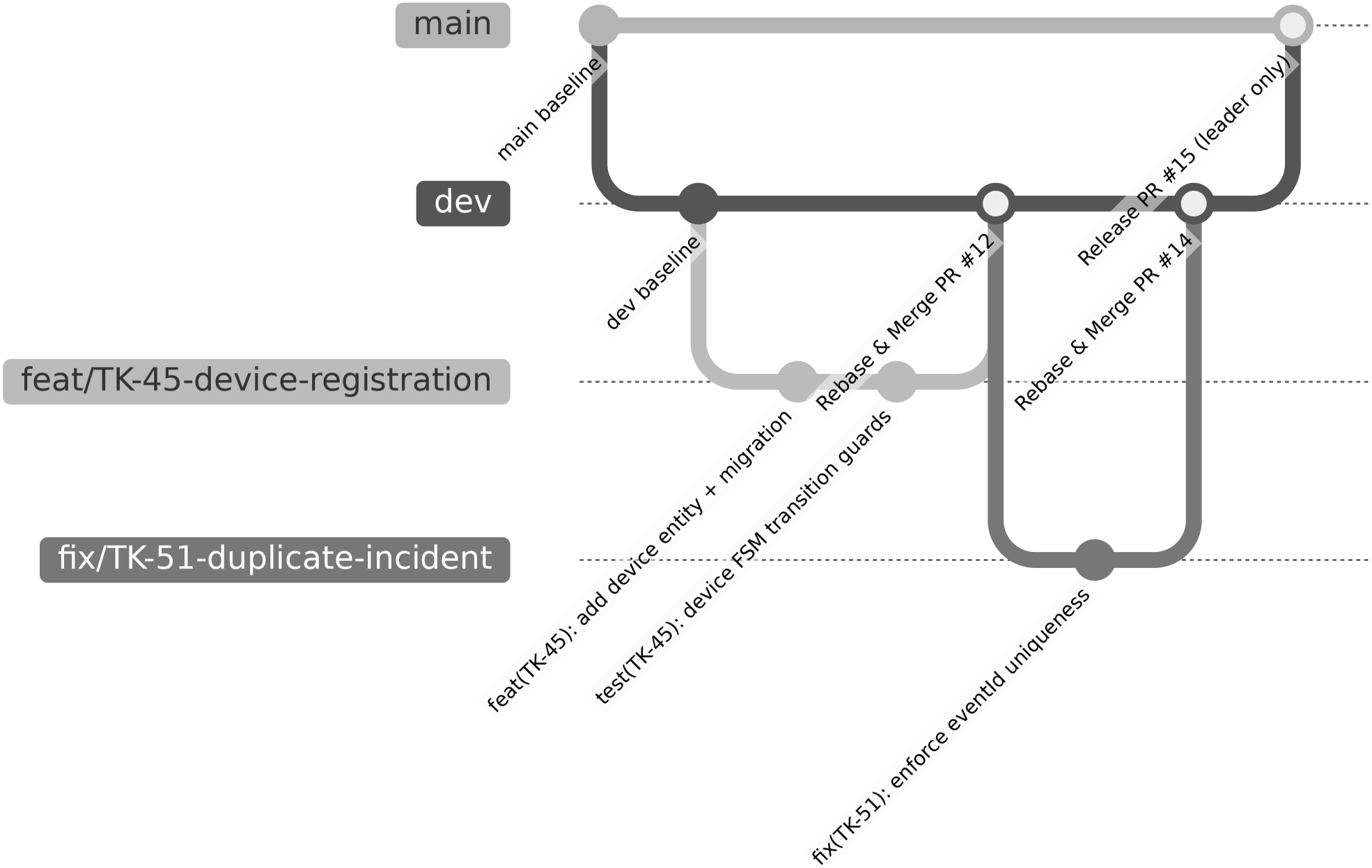

main
dev
feat/TK-45-device-registration
fix/TK-51-duplicate-incident
main baseline
dev baseline
feat(TK-45): add device entity + migration
test(TK-45): device FSM transition guards
Rebase & Merge PR #12
fix(TK-51): enforce eventId uniqueness
Release PR #15 (leader only)
Rebase & Merge PR #14

Figure 18: Branch topology. `dev` is the integration branch; feature branches rebase onto it and are deleted after merge. There is no `develop`, and merge commits are prohibited. Placement: rotated plate, 170.5 x 266.0 mm, labels at 10.75 pt.

2.1 The branches

Branch	Branches from	Merges into	Purpose
`main`	—	—	**Protected.** Production / demo-ready state. This *is* the release, there are no `release/*` branches.
`dev`	`main`	`main`	**Protected.** Active integration branch. Everything lands here first.
`staging`	`dev`	(receives `dev` only)	`treklink-web` only. The staging deployment (`treklink-web.vercel.app`): the orchestrator promotes the latest reviewed `dev` here by moving the ref (a fast forward). Never committed to directly (D-094 amendment 2).
`feat/*`	`dev`	`dev`	New capability. One per Jira story or task.
`fix/*`	`dev`	`dev`	Defect in unreleased work (found on `dev` , or a GitHub Issue bug).
`hotfix/*`	`dev` **or** `main`	see §2.4	Urgent defect. Branch point depends on where the fault is.
`docs/*`	`dev`	`dev`	Documentation-only changes. Primary branch type in `treklink-docs` .
`chore/*`	`dev`	`dev`	Dependencies, tooling, config, cleanup. No behaviour change.

> **No direct pushes. Ever. To any branch.** Every change, including a one-line typo fix, including the leader's own changes, is branched, pushed, and merged through a PR. There is no exception for "it's tiny" or "it's urgent". Urgency is what `hotfix/*` is for, and a hotfix is still a PR.

2.2 Branch naming

```
{type}/{JIRA-KEY}-{short-kebab-description}
```

Example	Notes
`feat/TK-45-device-registration`	Standard case. Jira key, then 2–4 words.
`fix/TK-51-duplicate-incident-on-replay`	
`docs/TK-88-handbook-v1`	
`chore/TK-12-bump-nestjs-10`	
`hotfix/TK-99-jwt-expiry-crash`	
`chore/repo-gitignore-cleanup`	No Jira key. Housekeeping has no card.
`fix/daily-report-reported-mentions`	No Jira key. Automation and CI work has no card.

Rules:

- **Lower-case, kebab-case** after the type. No underscores, no `CamelCase` , no spaces.
- **Jira key uppercase**, exactly as Jira issued it (`TK-45` , not `tk-45`).

> **Jira keys exist for Epics and User Stories only** (**D-024**). A branch carries a key when its unit of work is an Epic or a User Story card. Everything else carries no key and uses a plain descriptive branch name: repository housekeeping, CI and automation, tooling, conventions and documentation that is not a story deliverable, and the Task or Subtask breakdown under a story, which is tracked inside the parent card rather than as its own branch.
>
> Do not invent a card so a branch can have a key. An invented card pollutes the backlog, the Coverage Matrix and the burndown, all three of which the supervisor reads.

- Keep it under ~50 characters total. The description is a reminder, not a summary.
- One branch per unit of work. Do not accumulate unrelated changes on a long-lived personal branch.

Why the Jira key is in the branch name: the org-level Jira↔GitHub integration scans branch names, commit messages, and PR titles for issue keys. With the key present, the Jira card's Development panel auto-populates with the branch, its commits, and its PR, for free, with zero extra effort from you. That is the traceability the supervisor and the council look for, and it costs nothing but a naming habit.

2.3 Design and implementation live on the same branch

The old dual-branch model (`features/Design_X` + `features/Implementation_X`) is **retired**. A single `feat/*` branch carries the spec commits *and* the implementation commits, in that order.

You still cannot write code before the spec exists, the spec-before-code gate in `02-spec-driven-development-workflow.md` (`02-spec-driven-development-workflow.md`) is unchanged and non-negotiable. The gate is enforced by *commit order within the branch*, not by a second branch: the reviewer reads `git log` and sees `docs(TK-45): requirements + design for devices` landing before `feat(TK-45): implement device entity`. That gives the same review independence at half the PR overhead.

The Design DoD section in the PR template is therefore **optional**, fill it in when the branch introduced or changed a spec, skip it when it didn't.

2.4 Hotfix protocol

Hotfixes are branch-specific. Which branch you cut from depends on where the fault actually is.

See **Figure 19**.

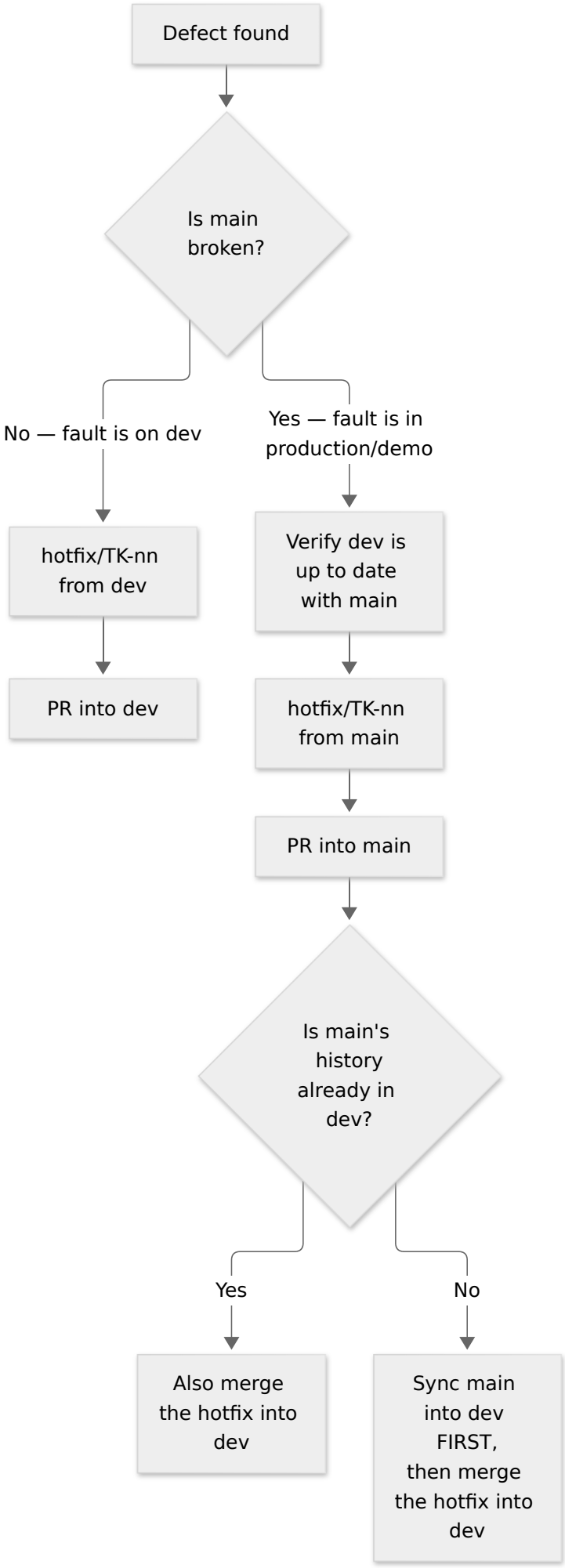

Defect found
Is main broken?
No — fault is on dev
Yes — fault is in production/demo
hotfix/TK-nn from dev
PR into dev
Verify dev is up to date with main
hotfix/TK-nn from main
PR into main
Is main's history already in dev?
Yes
No
Also merge the hotfix into dev
Sync main into dev FIRST, then merge the hotfix into dev

Figure 19: Defect routing: whether a fault becomes a hotfix off `main` or an ordinary fix off `dev` depends on whether `main` is broken. Placement: inline, 101.1 x 266.0 mm, labels at 9.95 pt.

Before cutting any hotfix: bring every branch up to date. A hotfix applied to a stale base is how a fix gets silently reverted by the next merge. Concretely:

```
git fetch origin
git checkout main && git pull origin main
git checkout dev  && git pull origin dev
# confirm dev contains main's history:
git log --oneline main ^dev        # must print nothing
```

If that last command prints commits, `dev` is behind `main`, sync it before hotfixing, or the fix will only exist on one side.

A hotfix landed on `main` **must also reach** `dev`, always. A fix that lives only on `main` will be undone the next time `dev` is promoted.

---

3. Commit Conventions

3.1 Format

```
{type}({scope}): {imperative description}
```

The scope is the **Jira key** when the unit of work is an Epic or a User Story card (**D-024**). Housekeeping, CI, automation, tooling and conventions work has no key, so it has no scope.

```
git commit -m "feat(TK-45): add device FSM transition guard"
git commit -m "fix(TK-51): reject duplicate eventId before incident creation"
git commit -m "docs(TK-88): add Jira workflow chapter to handbook"
git commit -m "chore: refactor conventions files"          # no card — plain, unscoped
```

3.2 Types

All standard Conventional Commit types are available:

Type	Use for
`feat`	New capability
`fix`	Bug fix
`docs`	Documentation only
`test`	Adding or fixing tests
`refactor`	Restructuring with no behaviour change
`perf`	Performance work
`style`	Formatting, whitespace, lint fixes, no logic
`chore`	Dependencies, tooling, config, housekeeping
`ci`	CI/CD pipeline changes
`build`	Build system, bundler, compiler config
`revert`	Reverting a previous commit

3.3 Scope

Mandatory **where meaningful**. Use the Jira key. When the change is genuinely general, cross-cutting, or has no card, repository housekeeping, a sweep across every file, a `.gitignore` tweak, **omit the scope entirely** rather than inventing one:

```
chore: refactor conventions files          # correct — general, no card
chore(misc): refactor conventions files    # wrong — "misc" is noise
```

3.4 Quality rules

1. Understandable from the subject line alone.
2. No vague messages. `"update"`, `"fix bug"`, `"wip"`, `"asdf"` tell the next reader nothing.
3. One logical change per commit.
4. Never bundle formatting churn with functional changes, that is what `style:` is for.
5. Imperative mood: "add", not "added" or "adds".
6. English only. See §6.
7. **No AI attribution in any TrekLink repository (D-049)**: `treklink-web`, `treklink-docs`, `treklink-firmware`, `TrekLink-Team.github.io` and `capstone`. No `Co-Authored-By` trailer naming an AI model, no commit authored by an AI identity (`Claude <noreply@anthropic.com>` or similar), and no AI account among a repository's contributors. The model is declared in the commit's `Checksum` trailer (§3.6, D-054), which names a tool and does not make a contributor. Every commit is authored by the team member who owns it. An agent's default attribution line is removed before committing. The same holds for everything posted on GitHub for these repositories (D-049 rule 7): a pull request title or description, an issue, a comment, a review comment or a review summary carries no "Generated with Claude Code", "Generated by Claude Code" or similar footer and no AI co-author line. Turn the tool's own attribution off where it has a setting for it. Some tools add the footer on the server when they post, so an agent reads every post back and edits the footer out, or tells the member when it cannot. The pull request's AI Disclosure still names the model.

3.5 Commit messages are a practice, not a gate

> **Commit hygiene must never block a delivery.** There is no commitlint hook and no CI check on commit message format, deliberately. The one check on commits is the `Checksum` trailer (§3.6), and it is advisory like all CI here. When you are shipping at 23:50 the night before a review, a commit that says `fix: login` is acceptable and nobody will chase you for it.
>
> Adhere to the format whenever you reasonably can, it is what makes `git log --oneline` readable during Review 2 prep and what feeds the Jira Development panel. But a perfect commit history on an unshipped feature is worth nothing. Ship, then tidy if there's time.

3.6 The Checksum trailer (D-054)

Every commit you make in the four code repositories carries one trailer, written for you by a commit-msg hook:

```
feat(TK-122): add password reset token expiry

Checksum: 3f9c0e…(64 hex)
```

The token is your declaration of **which model wrote the commit and at which stage** (SD, CO, UT, RV, DOC or CHORE), sealed with AES-256-GCM under your member key. It is bound to your member code and the commit subject, so it cannot be edited or moved to a commit with another subject. (A commit with the identical subject would accept the same token; the seal does not cover the diff.) It proves who sealed it and that the declaration is unchanged. It does not prove which model actually wrote the code; the declaration is still your word.

One-time setup, per machine:

```
pip install cryptography
git config --global treklink.member LongLP            # your member code
python3 ../treklink-docs/.github/scripts/tk_checksum.py install \
  ../treklink-docs ../treklink-web ../treklink-firmware ../TrekLink-Team.github.io
```

The keys are read from `capstone/.provenance/keys.json`, so keep `capstone/` as the parent folder.

Before committing, say which model wrote the change. Set it once per repository and change it when you switch tools, or per commit through the environment:

```
git config treklink.model claude-opus-5-5       # or claude-sonnet-5, gpt-6-astra, gemini-4-argon, human
TK_MODEL=gpt-6-astra git commit -m "chore: refresh lockfile"
TK_STAGE=RV git commit -m "fix(TK-122): address review finding"
```

The stage defaults from the commit type: `feat`, `fix`, `refactor` and `perf` are CO, `test` is UT, `docs` is DOC, `chore`, `ci`, `build`, `style` and `revert` are CHORE. Set `TK_STAGE` for SD and RV. An agent that commits for you sets `TK_MODEL` to the model it runs on.

What the pull request check does (`checksum.yml`, advisory like all CI, §7):

Finding	Result
Token sealed by you, model on the chapter 11 §2.1 allowlist	Pass
No trailer, or an empty `Checksum:` line (a manual commit)	Label `provenance-review`, reviewed by hand; the check passes
AI attribution in the commit (D-049)	Label `provenance-review`; remove it
Token that no member key opens (edited subject or token)	Fail
Token sealed by another member than the commit's GitHub author	Fail
Model not on the chapter 11 §2.1 allowlist, including any later version	Fail
Ingest-only model (Gemini 3.8 Flash, GPT-5.6 Luna or Terra) on any commit	Fail
Old 64-hex token whose model needs a variant (`gpt-5.6`)	Label `provenance-review`, audited by hand

The allowlist is explicit, one entry per model (D-070); nothing passes by comparing version numbers. Since D-070 the hook writes a 66-hex token that also seals the variant (`sol`, `luna`, `astra`, `argon` and so on). Pull `treklink-docs` `dev` to get it; older 64-hex tokens still verify. Run `python3 ../treklink-docs/.github/scripts/tk_checksum.py selftest` after any change to the list.

Amending a commit, or rewording it in `git rebase -i`, re-runs the hook and reseals it. A rebase that keeps the subject keeps the token valid. `--no-verify` skips the hook and leaves the old token, which then fails if the subject changed.

> **Seal only with your own key, and only through the hook.** Every key is readable in `capstone/`, so the rule is what protects your teammates' declarations. Setting another member's code in `treklink.member`, or writing a `Checksum` line by hand, is forgery. An AI agent asked to do either refuses and stops (AGENTS.md §6).

---

4. Rebase Discipline

We keep linear history. No merge commits anywhere, ever.

4.1 Before opening a PR

```
git fetch origin
git rebase origin/dev
# resolve conflicts, preserving business rules — re-read the spec if unsure
npm test                                  # must pass before you push
git push --force-with-lease origin feat/TK-45-device-registration
```

Always `--force-with-lease`, never `--force`. It refuses to overwrite work you haven't seen, which matters when an AI agent or a second machine has pushed to the same branch.

4.2 After *any* PR merges into `dev`: everybody rebases

This is a team-wide obligation, not a courtesy:

- **If you have no open PR**: `git checkout dev && git pull origin dev` before you branch again.
- **If you have an open PR**: rebase it onto the new `dev` and force-push. Your PR now reviews against current reality.

```
git fetch origin
git checkout feat/TK-45-device-registration
git rebase origin/dev
npm test
git push --force-with-lease
```

This is why **a merge into `dev` must be announced in the Zalo group** (see `12-communication-and-daily-reports.md` (`12-communication-and-daily-reports.md`)). The announcement is the signal for everyone to stop, pull, and rebase. Merging silently and letting four teammates discover it through conflicts three hours later is the single most expensive avoidable mistake on this project.

---

5. Pull Requests

5.1 Opening a PR

```
git push -u origin feat/TK-45-device-registration
gh pr create \
  --base dev \
  --title "feat(TK-45): device registration" \
  --body-file .github/pull_request_template.md \
  --assignee @me \
  --reviewer {reviewer-github-handle}
```

Then **ping the reviewer in Zalo** with the PR link. GitHub notifications are not reliably read; the Zalo ping is what actually starts the review clock.

Draft PRs are allowed as a work-in-progress signal, and reviewers will not look at them. When you want a review, mark it Ready for Review, that is the explicit handoff. A draft PR sitting for two days is not "waiting for review", it is not in the queue at all.

Stacked PRs (a PR based on another open PR) are allowed. Set the `--base` to the parent branch and say so in the description, so the reviewer knows the diff includes inherited commits.

5.2 Who reviews

The **backlog's `Reviewer` field is the default reviewer** and it is binding. It is set per story in `../03-backlog/02-user-stories.md` (`02-user-stories.md`).

- The leader (**KhoaDD**) is the Product Owner and default reviewer for most stories.

- **TanNB** and **LongLP** are delegated reviewers, the leader may assign review to either when capacity requires it.
- **The PR author may re-assign the reviewer** if the assigned reviewer is busy, without asking permission first. Tell the new reviewer; you do not need to tell the busy one.

5.3 Self-approval: the narrow exception

> **A PR author may self-approve and merge ONLY if the change meets every one of these:**
>
> - under **50 lines** changed, and
> - **no behavioural impact**, nothing a test or a user could observe differently, and
> - it is housekeeping: a chore, a cleanup, a file move, formatting, a comment, a doc typo.
>
> **Everything else requires a second party. Including the leader's own PRs.**

The Product Owner is not exempt. When the leader authors a non-trivial PR, the leader **must run a separate AI review pass on it before merging**, a fresh agent session, pointed at the diff, with no memory of having written the code. The output of that pass goes in the PR as a review comment.

The reasoning is not bureaucratic: work is not correct because of who produced it. An author reviewing their own code re-reads their intent, not their output. A fresh reviewer, human or agent, reads what is actually there. That asymmetry is the entire value of review, and it does not disappear when the author happens to be the PO.

5.4 Reviewing a PR

Pull the branch and actually run it. Reading the diff in the browser is not a review.

```
gh pr checkout 42
npm ci

# Run the same gates the author was supposed to run:
npm --prefix backend  run lint && npm --prefix backend  run typecheck && npm --prefix backend  test
npm --prefix gateway  run lint && npm --prefix gateway  run typecheck && npm --prefix gateway  test
npm --prefix frontend run lint && npm --prefix frontend run typecheck && npm --prefix frontend run build

# Bring up the local stack if the change touches runtime behaviour:
docker compose up -d
```

Unit tests are not optional and not negotiable.

- The author runs them and they pass **before** the PR is opened.
- The reviewer runs them **again** on their own machine.
- A feature with no tests is not done. Shipping untested code by simply not writing a test is cheating the gate, and the reviewer should request changes on that basis alone.
- A **failing test is evidence of a flaw** until the author explains otherwise. "That test is flaky" is a claim that needs proof, not a dismissal.

Then decide, using the severity vocabulary in `03-operational-workflows.md` (`03-operational-workflows.md`) §4: `[APPROVED]` · `[CHANGES REQUESTED]` · `[NEEDS FIXES]` .

> **On "LGTM".** It is a legitimate approval for a genuinely small, genuinely clear change you have actually read and run. It is not a way to clear your review queue. If the diff is 400 lines and your review is four characters, you did not review it, you signed for it. Use it gracefully.

5.5 Review SLA

- A PR opened during working hours (**08:00–17:00**) is reviewed **before 17:00 that day**.
- A PR left unreviewed at 17:00 becomes **top priority the next morning**.

- Absolute ceiling: **1 day**. After that the author escalates in Zalo, or re-assigns per §5.2.

5.6 Mid-review fixes

When changes are requested:

1. Open the PR skill / read the review comments in full before touching anything.
2. `git checkout feat/TK-45-...`, confirm you are on the right branch. Fixing a review on `dev` is a classic and painful mistake.
3. Fix, commit (`fix(TK-45): address review — validate deviceId length`), rebase if `dev` moved.
4. `git push --force-with-lease`.
5. **Comment on the PR** saying what you changed and what you deliberately did not. Then wait. Pushing silently does not re-request review.

If you are stuck on a review comment rather than disagreeing with it, move the Jira card to `NEEDS HELP` and say so in the PR, see `10-jira-tracking-and-workflow.md` (`10-jira-tracking-and-workflow.md`) §4.

5.7 Merging

Situation	Method
Single commit on the branch	**Rebase and merge**
Multiple commits on the branch	**Squash and merge**
An upstream sync of `treklink-firmware` (D-087)	**Fast-forward** `dev` to the tested head; the sync's own merge commit stays
Anything at all	**Never "Create a merge commit"**

> **"Create a merge commit" is prohibited in this project.** It produces a non-linear history that makes `git log --oneline`, `git bisect`, and Review-2 traceability materially harder. Disable it in repository settings so the option is not offered.

Branch deletion after merge:

- `feat/*`, `fix/*`, `docs/*`, `chore/*`, `hotfix/*` → **delete the source branch** ("Delete branch after PR"). They are temporary by definition and a stale branch list hides the live work.
- `dev` → `main` → **never delete the source branch.** `dev` is permanent.

Who merges into `main`: the leader only. The supervisor never touches the repository, all review flows through the leader, who opens and merges the `dev` → `main` PR.

How `dev` reaches `main`: fast-forward, never the merge button (D-025). The release PR is still opened and approved as usual, but it is landed by the leader with a fast-forward push:

```
git fetch origin
git merge-base --is-ancestor origin/main origin/dev && git push origin origin/dev:main
```

GitHub's "Rebase and merge" re-creates every commit with a new SHA even when a fast-forward is possible, and "Squash and merge" collapses them into one new commit. Either way `main` ends up with commits `dev` does not have, and the next release PR conflicts on every file both sides touched. A fast-forward push gives `main` exactly `dev`'s commits. It is not a force-push, so branch protection permits it for an admin while `enforce_admins` is off, and GitHub marks the open release PR as merged. If `merge-base --is-ancestor` fails, `main` has diverged: stop and realign first (D-025 records the procedure) rather than pushing a merge.

---

6. Language Rule (Hard Requirement)

> **ENGLISH ONLY** in every artifact this project produces: source code, identifiers, comments, commit messages, branch names, PR titles and descriptions, review comments, specs, conventions, documentation, Jira cards, and diagrams.
>
> **You may prompt an AI agent in Vietnamese.** English is preferred and gets better results, but chatting to your agent in Vietnamese is fine. Regardless of what language you prompted in, **everything the agent writes into the repository must be English.**
>
> The only sanctioned exception is a daily-report entry, where Vietnamese is tolerated when English would cost you clarity, see `12-communication-and-daily-reports.md` (`12-communication-and-daily-reports.md`) §3.

This is not stylistic preference. The council reads the artifacts, the roadmap mandates English (§06 rule 5), and a mixed-language codebase is unreviewable.

---

7. Branch Protection Settings

Configure once per repository, by the leader, in Settings → Branches.

> **Applied on 2026-09-22** to all four code repositories: `treklink-docs` , `treklink-web` , `treklink-firmware` and `TrekLink-Team.github.io` . Both `main` and `dev` in each carry the settings below, plus `delete_branch_on_merge` . `capstone` is deliberately unprotected (D-022).
>
> One deviation, deliberate: `enforce_admins` is **off**. The rule below already exempts the leader from the force-push block, and with no collaborators configured (see the setup gap at the end of this section) a hard admin gate would make every pull request unmergeable. Turn `enforce_admins` on once the org has members who can approve.

`main`

- Require a pull request before merging.
- Require **1 approval**.
- Block force-push **for all members except the leader**.
- Disallow "Create a merge commit"; allow rebase-merge and squash-merge only.
- Do not allow deletions.

`dev`

- Require a pull request before merging.
- Require **1 approval** from the assigned reviewer (see §5.2, §5.3 for the self-approval carve-out).
- Block force-push **for all members except the leader**.
- Disallow "Create a merge commit"; allow rebase-merge and squash-merge only.

CI is an indicator, not a gate

> **A red CI does not block merging.** CI is advisory on this project, deliberately. A 13-week term with a hardware dependency produces plenty of legitimately-red pipelines (missing device, flaky integration, an unconfigured secret) and a hard gate would mean waiting on infrastructure instead of delivering.
>
> **But red CI means merge with caution.** Specifically:
>
> - The **leader may merge** a red-CI PR at their discretion.
> - A **non-leader reviewer may not**, they must get the leader's explicit go-ahead first.
> - Either way, **say in the PR why it's red** before merging. An unexplained red merge is how a real break gets normalised into background noise.

Known setup gap

> **The GitHub organisation does not yet have collaborators configured**, so reviewers cannot currently be assigned in the UI. Until the leader adds all five members to the `TrekLink-Team` org with write access, reviewer assignment happens by Zalo ping and the `--reviewer` flag will fail. This is a one-time setup task owned by the leader.

---

8. Where Work Is Tracked

Jira is the single work tracker. GitHub Issues hold daily reports and real defects only. Full detail in `10-jira-tracking-and-workflow.md` (`10-jira-tracking-and-workflow.md`).

Concern	Lives in
Epics, User Stories, Tasks, Subtasks, sprints, board, timeline	**Jira** (TK project)
Daily reports	**GitHub Issues** (`treklink-docs`)
Standalone bugs & blockers	**GitHub Issues** (`treklink-docs` or the affected repo)
The authoritative backlog with EARS criteria	**`treklink-docs/_docs/03-backlog/`** (read-only to members)
Specs	**`treklink-web/specs/{module}/`**

> GitHub **Milestones are no longer used as sprints**, sprints live in Jira. The `points:*` and `type:*` label taxonomy is retained, but only for labelling daily reports and bug issues. See `../.github/labels-and-milestones.md` (`labels-and-milestones.md`).

---

9. Quick Reference

```
# ── Start work ──────────────────────────────────────────────────────────
git fetch origin && git checkout dev && git pull origin dev
git checkout -b feat/TK-45-device-registration

# ── Work ────────────────────────────────────────────────────────────────
git add -p
git commit -m "feat(TK-45): add device FSM transition guard"

# ── Before opening the PR ───────────────────────────────────────────────
git fetch origin && git rebase origin/dev
npm test                                  # must be green
git push -u origin feat/TK-45-device-registration --force-with-lease
gh pr create --base dev --title "feat(TK-45): device registration"
# → then ping the reviewer in Zalo, and move the Jira card to IN REVIEW

# ── Reviewing someone else's PR ─────────────────────────────────────────
gh pr checkout 42 && npm ci && npm test
gh pr review 42 --approve                 # or --request-changes --body "..."

# ── After any merge lands on dev ────────────────────────────────────────
git fetch origin && git rebase origin/dev && git push --force-with-lease
```

10. GitLab → GitHub Concept Map

For anyone cross-reading the school's `Git_Lab_Guide.pdf`:

GitLab (school guide)	TrekLink on GitHub
Merge Request (MR)	Pull Request (PR), terms used interchangeably
Issue Board	Jira board (Kanban view)
Labels (effort points 1/2/3/5/8/13)	Jira story points, same Fibonacci scale (1/2/3/5/8/13/21)
Milestones (sprints)	Jira sprints
Child tasks	Jira subtasks, and see §8: subtasks are PR-controlled, not backlogged
`develop` branch	**`dev`**
`features/Implementation_X` + `features/Design_X`	**one** `feat/TK-nn-desc` branch
`release/sprint_x`	**dropped**, `main` is the release
`hotfix/Bug_X`	`hotfix/TK-nn-desc`
`[Feature]` bracket-tag commits	**Conventional Commits**, `feat(TK-45): ...`
MR approval + merge	PR review + Rebase-and-merge (or Squash if multi-commit)

Jira Tracking, Board Workflow & the Development Loop

> **Jira is the single work tracker.** Epics, User Stories, Tasks, Subtasks, sprints, the board and the timeline all live in Jira. GitHub Issues hold daily reports and standalone bugs, nothing else. This chapter is the authority on how work is logged, moved, and closed.
>
> **Project**: `TK` , treklink-capstone.atlassian.net **Framework**: Scrum, 2-week sprints aligned to the roadmap calendar.

---

1. The Three Places Work Lives

A recurring source of confusion, settled here once:

Artifact	Where	Who writes it	Mutability
The backlog, one story per SRS use case plus delivery stories, acceptance criteria from the SRS FRs, owners, reviewers, points (rewritten 2026-10-18)	`../03-backlog/` in `treklink-docs`	**Leader only**, via `build_backlog.py` + a `docs:` PR	**Read-only to members.** Never hand-edit the generated `.md` files.
The tracker, live cards, sprint state, board position	**Jira**	Leader creates Epics/Stories; anyone creates Tasks/Subtasks	Live, moves constantly
The spec, full EARS requirements, design, tasks	`treklink-web/specs/{module}/`	The story's owner	Per-story, locked during implementation

The backlog is the **source**; Jira is the **execution copy**. A story's EARS criteria in the backlog get expanded into that module's `requirements.md` when its sprint starts. If the two ever disagree after that point, the spec wins, it is the more detailed, reviewed artifact.

---

2. Work Item Hierarchy

```
Epic  (EP01 … EP10, from the backlog, leader creates)
  └── User Story  (US-UCnn, US-Xnn, from the backlog, leader creates)
        └── Subtask  (invented during implementation — anyone creates)
```

2.1 Epics and User Stories: leader creates

Epic and Story cards mirror the backlog one-for-one. The leader creates them in Jira at sprint planning, carrying over the backlog's summary, acceptance criteria, owner, reviewer, and points.

A member may create an Epic or Story when one is genuinely missing or miscellaneous work appears that nobody anticipated. Tell the leader when you do, so it can be reconciled back into the backlog.

Definition of Ready (D-052). A story enters a sprint only when the spec suite it cites is merged on `dev` (the leader's approval) and its owner has studied that suite. Record the study as a subtask `Study <module> spec` on the story card; the owner closes it when they can explain the story's requirements, design and endpoints without the documents open.

2.2 Subtasks: anyone creates, and they stay out of the backlog

> **Subtasks are never logged in the backlog.** They exist in Jira and in the PR, and nowhere else.
>
> A subtask is how you break "implement device registration" into "write the migration", "add the DTO", "wire the guard". That decomposition is real work-management, but recording it in the authoritative backlog is documentation effort with no delivery attached to it. Put the breakdown in the PR description or the module's `tasks.md`, where the reviewer will actually read it.

2.3 Story points

Manual, set by judgement at sprint planning. The scale is **Fibonacci**, which is the industry standard and what Jira ships by default:

```
1 · 2 · 3 · 5 · 8 · 13 · 21 · …
```

Points estimate **difficulty**, not hours. The widening gaps are the point: they force a decision between "about a 5" and "about an 8" rather than inviting false precision at the top end, where estimates are least reliable.

A 1 is trivial, a 3 is an ordinary story, a 5 is a substantial one, and anything at **13 or above is a signal the story should be split** before it enters a sprint.

> An earlier revision of this chapter published a base-5 scale (1/2/3/5/10/15/20/25/30). That was a local invention, not a standard, and the backlog was never estimated against it, the 88 stories in `03-backlog/` have always used 2/3/5/8/13. Corrected here so the documented scale matches the estimates that exist.

2.4 Tasks handed out in the daily, and the Atlassian MCP (leader, 2026-11-05)

Members said tasks were given in the daily meeting but never appeared in Jira. Since 2026-11-05:

- **Every task in the daily message is a Jira card the same morning.** A `Task` in project `TK`, assigned to the member, under the module's epic, label `daily-<YYYY-MM-DD>`, due date set, an English summary `<Module>: <task> (due <date>)` and the parts with their PR, issue and spec references. A task that carries over updates its card; it does not get a second one.
- **A finished task is closed in Jira**, whoever finished it: In Progress when work starts, In Review when the PR opens (§3.2), Done when it merges, with the PR number on the card. A merged PR that names a story (`feat(TK-nn)`) closes that story as well, unless part of it is still open.
- **Every AI assistant reads and moves cards through the Atlassian MCP.** At session start it checks that the Atlassian MCP server is connected; if not, it asks the developer to connect it and says that Jira cannot be read or updated until then. It never guesses a member's tasks from chat alone when the card can be read.

---

3. The Board Workflow

See **Figure 20**.

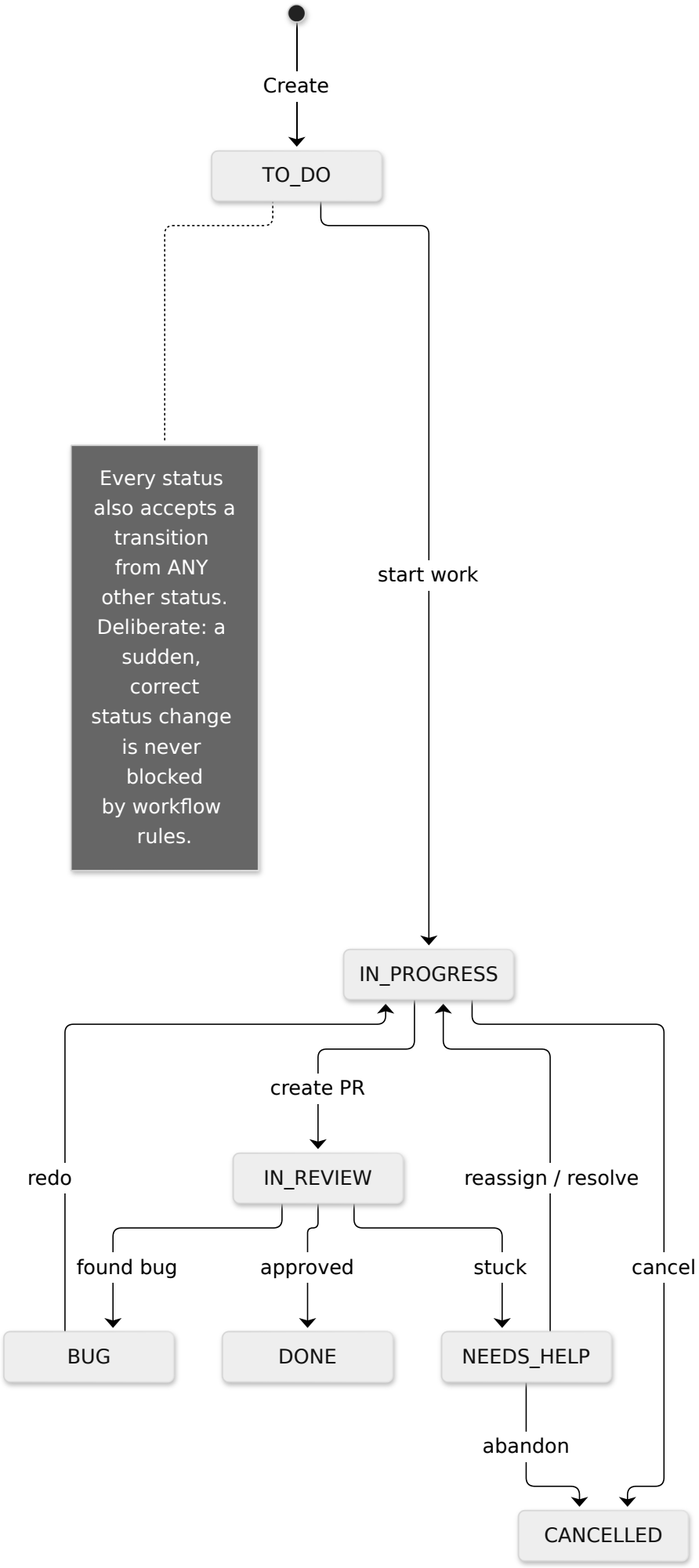

Create
TO_DO
Every status also accepts a transition from ANY other status. Deliberate: a sudden, correct status change is never blocked by workflow rules.
start work
IN_PROGRESS
create PR
redo
IN_REVIEW
reassign / resolve
found bug
approved
stuck
cancel
BUG
DONE
NEEDS_HELP
abandon
CANCELLED

Figure 20: The Jira card state machine. Seven states with `Any` transitions, a card can always be moved to reflect reality, including backwards. Placement: inline, 121.2 x 266.0 mm, labels at 9.69 pt.

Status	Meaning	Who moves it here
TO DO	Card exists, nobody has started	Created by leader at planning
IN PROGRESS	Branch cut, work underway	Owner, when they start
IN REVIEW	**PR is open and awaiting review**	Owner, at PR-open time
DONE	PR merged	Automation on merge; verified by reviewer + author
BUG	Came back from review, **the code is wrong**	Reviewer, on finding a defect
NEEDS HELP	**The person is blocked**	Anyone, the moment they're stuck
CANCELLED	Work abandoned or descoped	Owner or leader

3.1 The "Any" transitions are intentional

Every status accepts a transition from every other status. This is a deliberate design choice, not an oversight. Workflow validation that prevents someone from recording reality, a card that jumps straight from `TO DO` to `DONE` because it turned out to be already implemented, or from `DONE` back to `IN PROGRESS` because a regression surfaced, creates lying boards. The board should be easy to make accurate.

The drawn arrows are the *expected* path. The `Any` transitions are the escape hatch when reality doesn't match.

3.2 `IN REVIEW` means the PR exists

Move the card when you **open the PR**, not when it gets approved. The board should answer "what is waiting on a reviewer right now?" at a glance, and that is the whole point of the column.

3.3 Who moves the card to `DONE`

A Jira automation rule moves it on PR merge (§6). **Humans verify at standup** rather than moving it manually. If automation misses one, the reviewer moves it; if the reviewer forgets, the author does. The author is responsible for their own card being accurate regardless of whose job it nominally was.

---

4. `BUG` vs `NEEDS HELP`: they are not the same thing

This distinction matters enough to be explicit, because conflating them hides who needs rescuing.

> **`BUG` = the code is wrong. `NEEDS HELP` = the person is stuck.**

4.1 `BUG`

Review found a defect. The card returns to the author via `redo` → `IN PROGRESS`. Nothing is blocked, the author knows what to do, they just have to do it. No new card is created; this is still the same story's work.

4.2 `NEEDS HELP`

You are blocked and cannot proceed alone. The protocol:

1. Move the card to `NEEDS HELP`.
2. **Report to the leader**, Zalo, or a GitHub Issue if it needs a written thread, explaining *why* you're blocked. Not "I'm stuck", but "the Prisma migration fails on the FK constraint and I don't understand the cascade rule".
3. The leader delegates: reassigns the card, pairs you with someone, or resolves the blocker.

4. Once cleared: `NEEDS HELP` → `IN PROGRESS`, and the loop repeats until the card is genuinely `DONE`.

Being stuck *while implementing* is the common case, and it does not require opening a fake PR first. Use the `Any` transition: `IN PROGRESS` → `NEEDS HELP` directly.

> Moving a card to `NEEDS HELP` early is a good outcome, not an admission of failure. A blocker raised on day 1 costs an hour of someone's time. The same blocker raised on day 4, at the sprint boundary, costs the sprint.

---

5. Where Bugs Actually Go

Three destinations, three different kinds of defect. Choosing correctly keeps Jira clean without losing anything.

See **Figure 21**.

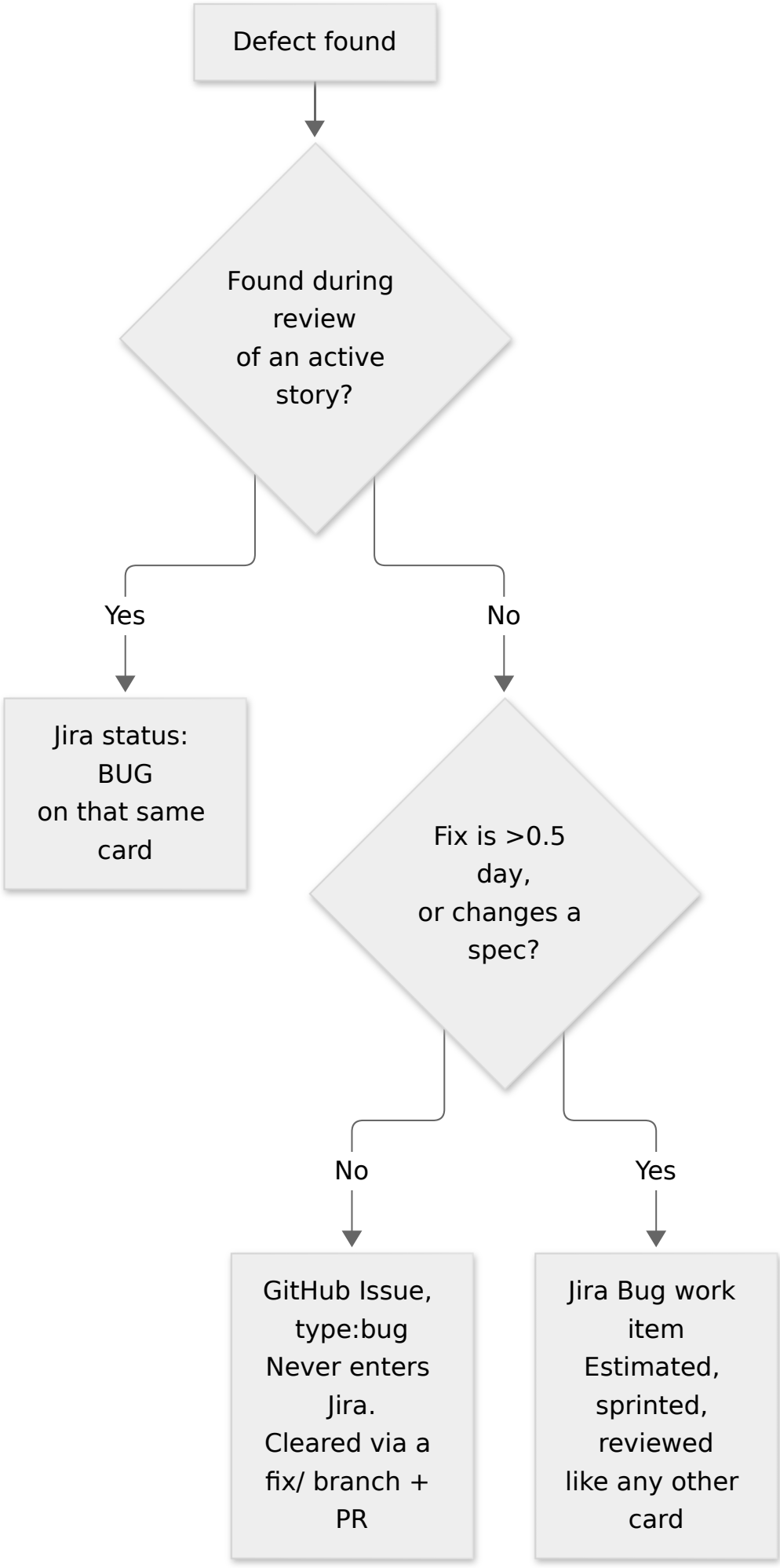

Defect found
Found during review of an active story?
Yes
No
Jira status: BUG on that same card
Fix is >0.5 day, or changes a spec?
No
Yes
GitHub Issue, type:bug Never enters Jira. Cleared via a fix/ branch + PR
Jira Bug work item Estimated, sprinted, reviewed like any other card

Figure 21: Bug routing: the three destinations a defect can take, and the test that decides between them. Placement: inline, 134.4 x 266.0 mm, labels at 12.41 pt.

Destination	When	Why
`BUG` **status** on the existing card	Review found a defect in the story being reviewed	It is that story's work. A second card would double-count the same effort.
GitHub Issue, `type:bug`	Standalone defect found outside any active story, demo, manual testing, someone stumbling on it	Fast. Fixed via a `fix/` branch and a PR, closed by the PR. **Never enters Jira.** GitHub Issues is where the team looks most often, so this is also where it gets seen.
Jira `Bug` **work item**	The fix needs its own estimate, sprint slot, and review cycle	Rule of thumb: **more than half a day, or it changes a spec.**

The escalation trigger is the only rule to remember: *if fixing it costs more than half a day or touches a spec, it earns a card.* Everything smaller is cleared in GitHub Issues without bureaucracy.

---

6. Jira ↔ GitHub Integration

The Jira instance is connected at the **organisation** level to `TrekLink-Team`, which covers all three repositories automatically, no per-repo setup.

6.1 What you get for free

Because branch names are `feat/TK-45-...` and commit scopes are `(TK-45)`, Jira scans and links automatically. Open any card and the **Development panel** shows its branch, every commit, and the PR with current review state. That is the traceability chain, card → branch → commits → PR → merge, that Review 2 and Hội đồng 1.1 look for, built with no extra effort beyond the naming convention you are already following.

This is the entire reason the Jira key is in the branch name. Drop the key, lose the panel.

6.2 Two automation rules (recommended: leader configures once)

Trigger	Action
Pull request **created** referencing `TK-nn`	Transition that card → `IN REVIEW`
Pull request **merged** referencing `TK-nn`	Transition that card → `DONE`

These are a safety net, not the process. You still move your own cards; automation catches the ones you forget. Configure under Project settings → Automation.

6.3 Smart commits: deliberately not used

Jira supports smart commits (`TK-45 #comment ...`, `TK-45 #done`) that transition cards from commit messages. **We do not use them.** They require the git commit author's email to exactly match an Atlassian account, and when it doesn't they fail **silently**, you believe the card moved, it didn't, and the board is quietly wrong. Automation rules (§6.2) key off the PR instead, which is robust.

---

7. Sprints

Two weeks, aligned to the roadmap calendar in `../00-project-context/02-roadmap-and-milestones.md` (`02-roadmap-and-milestones.md`).

View	Use for
Backlog	Create Epics/Stories/Tasks. Groom. Start the sprint from here.
Board (Kanban)	Daily execution. Move cards as work progresses.
Timeline	Overall team schedule, dependencies, deadlines against the roadmap.

7.1 Sprint mechanics

1. At sprint planning the leader pulls stories from the backlog into the Jira Backlog view.
2. Starting the sprint moves them onto the Board.
3. Work the board. Cards move left to right; see §3.
4. At sprint close, anything not `DONE` returns to the backlog or carries over explicitly.

7.1b Story lifecycle inside a sprint: SD, CO, UT, RV (D-053)

Every story runs four mini-phases, and all four land in **one pull request**. The leader reviews the whole PR once, at RV; the owner does not wait for a review between phases.

Phase	The owner delivers	Evidence in the PR
SD, specification and design	The suite studied (Definition of Ready, §2.1); the screens of the story drawn per `06-frontend-conventions.md` §7 when it has a human actor	`ui-design/` file of the screen, PR section "Design"
CO, code	The code of the story's tasks in `tasks.md`	The diff
UT, unit test	Unit tests of every service, guard and component touched: **at least 80% branch coverage and 100% line coverage** of the files the PR changes, measured by the CI coverage report	Coverage summary in the PR, CI green
RV, review	The PR opened as ready, every checklist item ticked	The leader's review

- If the review sends the PR back, the owner reopens the phase the finding belongs to (a design finding reopens SD, a failing case reopens UT) and pushes to the same PR.
- The daily report states the phase each open story is in.
- Effort is counted in story points (§2.3), which measure complexity, never in lines of code.
- **Until 2026-11-29 (D-078)** the leader may have the leader's agent finish a story: on an open PR the agent pushes to the member's branch and the PR merges once CI is green; an untouched story moves to the leader. After that date this note no longer applies.

7.1a Creating the backlog in Jira

The leader creates Epics, Stories and sprints from the backlog with one command, never by hand, so Jira and `_docs/03-backlog/` cannot drift. One-time setup:

1. Create a Jira Cloud site (free plan, up to 10 users) and a **Scrum** project with key `TK`. Leave it empty: cards are created in backlog order so their keys match the backlog's `TK-nn`.
2. Invite the four members. Install **GitHub for Jira** from the Atlassian Marketplace and connect the `TrekLink-Team` organisation, so branches and PRs named with `TK-nn` link themselves (§6).
3. Create an API token at `id.atlassian.com`, Security, API tokens. Keep it in your shell, never in a file in any repository.
4. Find the board ID: open the board; it is the number after `/boards/` in the URL.

Then, from `treklink-docs`:

```
export JIRA_BASE_URL=https://<site>.atlassian.net JIRA_EMAIL=<your Atlassian email> JIRA_BOARD_ID=<n>
read -rs JIRA_API_TOKEN && export JIRA_API_TOKEN
python3 _docs/03-backlog/jira_sync.py            # dry run: the plan
python3 _docs/03-backlog/jira_sync.py --apply    # create epics, stories, sprints
python3 _docs/03-backlog/jira_sync.py --retire   # label and close the pre-D-033 cards
```

The script is safe to re-run: each card carries a `backlog-<ID>` label and existing cards are skipped. It creates sprints named `TK Sprint n` for the roadmap sprints of `02-roadmap-and-milestones.md` §4.2 (`SPRINT_RANGE` in `build_backlog.py`), dated from the week 1 Monday in `.github/schedule.yml`, so a story's sprint number means the same in the backlog and in Jira. Stories planned for a sprint that has already ended go into the current sprint. Start the current sprint from the Backlog view, then add the §6.2 automation rules.

Until 2026-10-18 the script dated two-week calendar sprints while the backlog numbered stories by roadmap sprint, so the same number named two different fortnights. The two clocks of §7.2 are unchanged: the countdown in `.github/schedule.yml` still runs on its own two-week rhythm.

7.2 Two clocks, and they are not the same clock

> The **team sprint** and the **capstone roadmap milestone** are independent timelines. A sprint ending is a team-internal event. A Review 1 dossier deadline is an external, graded, immovable one. **Never assume one implies the other.**

`treklink-docs` CI posts a countdown for both, and flags loudly when they land in the same week, the weeks where the team is simultaneously closing a sprint and preparing a graded submission are exactly the weeks things get dropped. See `12-communication-and-daily-reports.md` (`12-communication-and-daily-reports.md`) §5.

---

8. The Development Loop (End to End)

This is the canonical sequence. Every piece of work follows it.

See **Figure 22**.

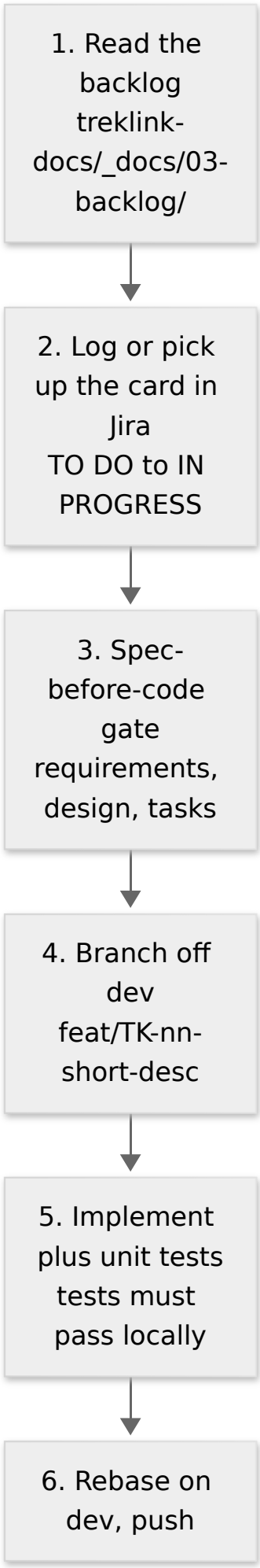

1. Read the backlog treklink-docs/_docs/03-backlog/
2. Log or pick up the card in Jira TO DO to IN PROGRESS
3. Spec-before-code gate requirements, design, tasks
4. Branch off dev feat/TK-nn-short-desc
5. Implement plus unit tests tests must pass locally
6. Rebase on dev, push

Figure 22: The delivery loop, steps 1 to 6, from reading the backlog to pushing a rebased branch. Placement: inline, 46.5 x 266.0 mm, labels at 12.57 pt.

See **Figure 23**.

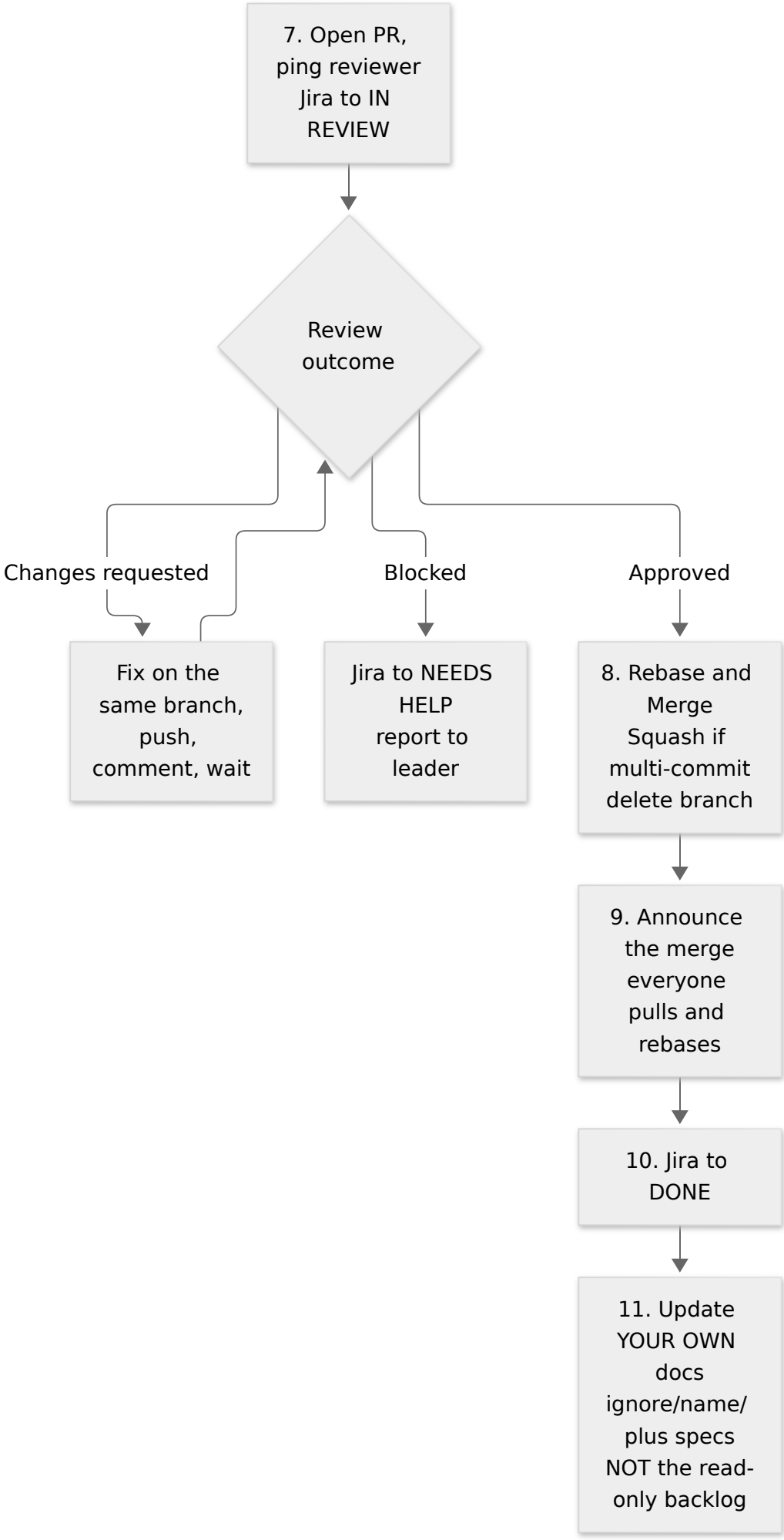

7. Open PR, ping reviewer Jira to IN REVIEW
Review outcome
Changes requested
Blocked
Approved
Fix on the same branch, push, comment, wait
Jira to NEEDS HELP report to leader
8. Rebase and Merge Squash if multi-commit delete branch
9. Announce the merge everyone pulls and rebases
10. Jira to DONE
11. Update YOUR OWN docs ignore/name/ plus specs NOT the read-only backlog

Figure 23: The delivery loop, steps 7 to 11, review outcomes, merge, and the documentation update that closes the card. Placement: inline, 138.6 x 266.0 mm, labels at 10.53 pt.

Step notes

Step 1, read the backlog. Not Jira. The backlog holds the EARS acceptance criteria; the Jira card holds a summary. You implement against the criteria.

Step 3, the spec gate is real. No production code, schema migration, or view before `requirements.md` → `design.md` → `tasks.md` exist and are approved. See `02-spec-driven-development-workflow.md` (`02-spec-driven-development-workflow.md`).

Step 11, update your own docs, not the backlog.

> **The backlog in `treklink-docs/_docs/03-backlog/` is READ-ONLY to members.** It is generated by `build_backlog.py` ; hand-edits are destroyed on the next regeneration. Post-merge updates go to your personal garden (`ignore/{your_name}/`) and to the module's `specs/` . Only the leader regenerates the backlog, via a `docs:` PR.

---

9. Backlog ↔ Jira Key Mapping

Both numbering schemes exist and both matter, the backlog's `US-UCnn` (one per SRS use case) and `US-Xnn` (delivery work) are the stable documentation IDs that the specs and reports cite; Jira's `TK-nn` is the live tracker ID that branches and commits carry. They must stay correlated.

9.1 How the mapping works

The pre-D-033 backlog (`E1` to `E8` , `US-001` to `US-087`) was computed from base offsets (first epic `TK-6` , first story `TK-14` , D-029). Those cards are retired by `jira_sync.py --retire` (2026-10-18). The new cards are created after them, so their keys cannot be predicted: `jira_sync.py --apply` prints each key, and the leader records it in `build_backlog.py` :

```
JIRA_PROJECT_KEY = "TK"
JIRA_KEYS = {            # filled from the --apply output
    "US-UC08": "TK-120",
}
```

A story without a recorded key shows "assigned at sync" in the generated backlog.

9.2 When it drifts: and it will

Jira issue numbers only ever increase, and a deleted or manually-created card leaves a gap. When a recorded key stops matching reality, correct its entry in `JIRA_KEYS` and regenerate.

Drift is non-blocking. A wrong key in the backlog is a documentation inconvenience, not a broken build. Fix it in the next `docs:` PR; do not stop delivery over it.

9.3 Who maintains it

The **leader**, via a `docs:` PR to `treklink-docs` editing `build_backlog.py` and regenerating. Never by hand-editing `01-epics.md` or `02-user-stories.md` .

```
cd _docs/03-backlog
python3 build_backlog.py
python3 build_backlog.py ../00-project-context/User_Story_Agile_TrekLink.xlsx
```

---

10. Quick Reference

I want to…	Do this
Start a story	Jira `TO DO` → `IN PROGRESS`, read backlog criteria, check the spec exists
Break work down	Create Jira **subtasks**, do not add them to the backlog
Open a PR	Jira → `IN REVIEW`, ping the reviewer in Zalo
Report a defect found in review	Jira → `BUG` on the same card
Report a standalone defect	**GitHub Issue**, `type:bug` label
Report being blocked	Jira → `NEEDS HELP` + tell the leader why
Close out	Verify Jira → `DONE`, update `specs/` and your own `ignore/` garden
Change the backlog	You can't. Ask the leader.

Team Communication, Daily Reports & Schedule Awareness

> How the team stays synchronised: where each kind of message belongs, the daily report ritual, the merge-announcement obligation, and the automated schedule countdown.

---

1. Channels: What Goes Where

Channel	Use for	Do not use for
Zalo group	Merge announcements, reviewer pings, "I'm blocked", fast coordination	Anything that needs to survive the week. Zalo is not a record.
GitHub Issues (`treklink-docs`)	Daily reports, standalone bugs, blockers needing a written thread	Feature work, that's Jira
Jira	All work tracking: epics, stories, tasks, subtasks, sprint state	Discussion. Cards are state, not conversation.
PR comments	Code review, design debate tied to a specific change	Status updates
`treklink-docs` `_docs/`	Decisions, conventions, anything that must outlive the term	Work-in-progress notes
`ignore/{your_name}/`	Your own notes, session files, scratch	Anything a teammate needs to see

The rule of durability: if losing a message would cost the team, it does not belong in Zalo.

---

2. The Two Mandatory Announcements

2.1 Merging into `dev`

> **Every merge into `dev` must be announced in the Zalo group, immediately.**

Everyone else must stop, pull, and rebase, see `07-github-workflow-git-conventions.md` (`07-github-workflow-git-conventions.md`) §4.2. That obligation cannot be honoured if nobody knows the merge happened. Merging silently and letting four teammates discover it via conflicts three hours later is the most expensive avoidable mistake on this project.

```
Merged PR #42 → dev : feat(TK-45) device registration
Everyone please pull + rebase your branches.
```

2.2 Pinging your reviewer

Opening a PR is not a request for review, GitHub notifications are not reliably read. **Ping the reviewer in Zalo with the PR link.** That ping starts the SLA clock (§5.5 of the Git chapter: same-day if opened 08:00–17:00, one day absolute ceiling).

---

3. Daily Reports

3.1 The ritual

Every working day, an automated GitHub Issue titled `DAILY REPORT DD/MM/YYYY` opens in `treklink-docs` at **08:00 ICT**. Every member comments their report on **that day's issue**. The issue **auto-closes at 12:00 ICT**.

3.2 Format: exactly three lines

```
KhoaDD

Yesterday: compile docs for report1
Today: Plan main flows

Issues: None
```

- **Yesterday**, what you did. Link the PR or the issue if there is one.
- **Today**, what you will do.
- **Issues**, blockers, or `None`. Do not leave this blank.

Keep it to those three fields. The value is in everyone being able to read five reports in thirty seconds.

3.3 The 12:00 cutoff and lateness

> **Reports are due before 12:00 (midday).** CI closes the issue at 12:00 sharp regardless of who has reported.

If you missed the cutoff:

1. **Reopen the issue.**
2. Post your report.
3. Close it again.

The reopen is deliberately visible. The issue timeline records who reported after the cutoff and when, it doubles as the lateness log, without anyone having to police it manually. The closing comment CI posts at 12:00 names anyone who hadn't reported yet.

This is a discipline mechanism, not a punishment one. Consistent lateness is a signal to the leader that something needs addressing, which is exactly what a leader should be able to see.

3.4 Language

English is required and strongly preferred. Vietnamese is tolerated *by exception* in daily reports only, when writing it in English would genuinely cost you clarity about a blocker.

This is the only place in the entire project where non-English text is acceptable. Everything else , code, commits, PRs, specs, Jira cards, documentation, is English without exception. See `07-github-workflow-git-conventions.md` (`07-github-workflow-git-conventions.md`) §6.

3.5 Schedule

Opens	08:00 ICT (UTC+7), **Monday–Friday**
Closes	12:00 ICT, same day
Weekends	No automatic issue
Holidays / no-class days	Skipped automatically where the CI can determine it

Working outside business hours or at a weekend? **Create the daily report issue manually**, same title format, and report into it.

3.6 Notifications

The opening issue **@-mentions all five members**, which triggers GitHub's email notification to everyone. That is intentional, the mail is the nudge. It also posts a checklist so who has and hasn't reported is visible at a glance:

```
### Reported
- [ ] @ruskicoder (KhoaDD)
- [ ] @lamphilong2004 (LongLP)
- [ ] @wangf28 (HoangTK)
- [ ] @NgocLong216 (LongNN)
- [ ] @nguyenbatan21112003 (TanNB)
```

The roll-call carries the handle **and** the team code. The handle is what notifies. The code is what a reader recognises, because the handles do not resemble the codes.

> `@handle` is what sends the notification. A markdown link, `[@handle](https://github.com/handle)`, renders identically and notifies nobody. Never tidy the mentions into links.
>
> A handle must also be an **org member**. GitHub does not notify a mention of someone without access, so a wrong-but-real handle fails silently. `LongLP` pointed at a non-member account until 2026-09-17, and every daily report until then pinged nobody.

> **A scheduled workflow runs from the repository's default branch, which is `main`.** It reads the `.github/schedule.yml` that exists on `main`, never the one on your branch and never the one on `dev`. Correcting a handle on `dev` changes nothing in production until `dev` reaches `main`.
>
> This was live from the automation landing until 2026-09-22. `main` carried `LongLP: TODO-longlp`, `HoangTK: TODO-hoangtk`, `LongNN: TODO-longnn` and `TanNB: TODO-tannb`, so `mention()` took its placeholder branch and rendered `**LongLP**` rather than a mention. **Only `KhoaDD` was ever notified**, on every daily report the automation has produced. Issue #18 of 21/09/2026 still shows it. The 2026-09-17 correction of `LongLP` was made on `dev` and could not have taken effect.
>
> After changing anything the scheduler reads, verify against `main`, not against your branch:
>
> ```
> git show origin/main:.github/schedule.yml
> ```

3.6.1 Verifying that the roll-call actually mentions people

A placeholder or missing handle renders `**CODE**` in bold. A working handle renders `@handle`. Read the created issue, not the script:

```
gh issue view <n> --json body -q .body | sed -n '/### Reported/,/^---/p'
```

Every line must start with `- [ ] @`. A line showing `- [ ] **CODE**` is a member who is not being notified.

3.7 The closing comment

At 12:00 the script posts one comment and closes the issue. It names both groups in the same format as the opening roll-call:

```
**Cutoff reached, 12:00 ICT 17/09/2026.**

Reported (4/5): @ruskicoder (KhoaDD), @lamphilong2004 (LongLP), @wangf28 (HoangTK), @NgocLong216
(LongNN)

**Did not report before the cutoff:** @nguyenbatan21112003

Reopen this issue, post your report, and close it again. The reopen is the record.
```

Everyone is mentioned, including the members who did report. The closing comment is the day's record, and a record that names four people by handle and the fifth by code is not one record.

Attendance is counted from the **human** comments only. The script filters out its own comments before scanning, because the closing comment contains every reported member's code; an unfiltered scan on a reopen-report-reclose cycle would read its own previous roll-call back and credit everybody. See `.github/scripts/daily_report.py`.

---

4. Raising Problems

4.1 General rules (carried over from the team's existing practice)

1. The leader opens a daily report thread each working day, now automated.
2. Members report into that day's thread.
3. **Create additional issues whenever something needs solving together.** Do not wait for permission.
4. When something is blocking you, open an Issue so the leader can help resolve it.
5. A finished feature needing review: ping the reviewer via the PR **and** Zalo.

4.2 Blocked vs broken

Mirrors the Jira distinction in `10-jira-tracking-and-workflow.md` (`10-jira-tracking-and-workflow.md`) §4:

You are…	Do
Blocked (you can't proceed)	Jira → `NEEDS HELP`, tell the leader **why**, specifically
Given broken code (review found a defect)	Jira → `BUG`, fix on the same branch
Hitting a standalone defect	GitHub Issue, `type:bug` label

Raise blockers **early**. A blocker on day 1 costs someone an hour. The same blocker on day 4 costs the sprint.

---

5. Schedule Awareness: Automated Countdown

`treklink-docs` CI maintains a live countdown so nobody discovers a deadline the day it lands.

5.1 Two independent clocks

Clock	Source	Cadence
Team sprint	Jira / the roadmap sprint mapping	Every 2 weeks
Capstone roadmap milestone	`../00-project-context/02-roadmap-and-milestones.md` (`02-roadmap-and-milestones.md`)	Fixed, external, immovable

> **These are not the same clock and one never implies the other.** A sprint ending is internal. A Review 1 dossier deadline is external and graded. When both land in the same week, the CI flags it loudly, those weeks are where things get dropped.

5.2 What the countdown shows

Posted to the repo `README.md` badge area and into the daily report issue:

```
NEXT UP
  Sprint 2 ends ............... 6 days   (Sun 20 Sep)
  Report 2 due ................ tomorrow (Sun 20 Sep)   ⚠ COLLISION
  Review 1 dossier ............ 1 week 3 days (Sun 27 Sep)
  Scope lock (form FROZEN) .... 4 weeks 2 days (Sun 18 Oct)
```

Phrasing degrades naturally as a deadline approaches: `4 weeks 2 days` → `6 days` → `tomorrow` → `TODAY`.

---

6. Weekly Rhythm

When	What
Daily, 08:00–12:00	Daily report in that day's GitHub Issue
Daily, as it happens	Merge announcements + reviewer pings in Zalo
Daily, 08:00–17:00	PRs opened in work hours get reviewed before 17:00
Every 2 weeks	Sprint close + planning; leader creates the next sprint's cards
Weekly	Supervisor (GVHD) meeting, leader prepares, per the roadmap
Per roadmap milestone	Report deliverable; see the roadmap calendar

---

7. Quick Reference

Situation	Channel	Urgency
Merged to `dev`	Zalo, immediately	Everyone must rebase
Need a review	PR assignment **+** Zalo ping	Same day if before 17:00
Blocked	Jira `NEEDS HELP` + tell the leader	Immediately, do not sit on it
Found a standalone bug	GitHub Issue, `type:bug`	Same day
Daily status	GitHub Issue, that day's thread	Before 12:00
Made a decision that outlives today	`_docs/00-project-context/03-decisions-and-risk-register.md`	Same working pass
Need to change a convention	`docs:` PR to `treklink-docs`	Team consensus

AI-First Development

The AI-First Doctrine, Toolchain & Prompting Standard

> **TrekLink is an AI-first project.** The team's primary development mode is **prompt and code review**, not hand-typing implementations. That is a deliberate choice, and it has a hard consequence: *the quality of what ships is bounded by the quality of the prompting and the rigour of the review.* Guideline adherence is therefore not bureaucracy, it is the difference between an agent that delivers and an agent that burns 200k tokens producing plausible garbage.
>
> **Core philosophy: docs first, code later.**

---

1. The Doctrine in One Page

Principle	What it means in practice
Docs first, code later	The spec is the deliverable that matters. Code is a projection of it. No production code before `requirements.md` → `design.md` → `tasks.md`.
The agent asks; you decide	An agent that starts implementing without asking questions is misconfigured. Demand the clarification gate.
Never auto-approve	Read what the agent produced. Disagree with it. Debate it. You are co-authoring, not accepting deliveries.
Ground everything	No claim without a file reference, a test result, or a cited source. "Seems right" is not evidence.
English out, always	Prompt in any language. Everything written to the repo is English.
Save tokens	End sessions early and cleanly. Never extend a session for any reason except finishing the current task.
Persist findings immediately	Chat context is volatile. If it isn't on disk, it will be re-derived at full price.

---

2. Model Policy (Hard Requirement)

> **Every team member must hold a paid frontier-model plan.** There is no free-tier path to delivering this project. Precision-critical work, embedded/IoT integration, wire-format handling, the idempotency layer, anything that touches firmware behaviour, does not tolerate a weak model, and a wrong answer there costs days.

Model facts verified 2026-09-13. Re-verify before quoting these in any report.

2.1 Approved for critical coding

Vendor	Model	Released	API $/MTok in–out	Notes
Anthropic	**Claude Sonnet 5**	2026-06-30	$2 / $10	The workhorse. Price locked permanently.
Anthropic	**Claude Opus 5**	2026-07-24	$5 / $25	1M context, Fast Mode, adaptive thinking. Default on the Max plan.
Anthropic	**Claude Fable 5.1**	—	frontier tier	*If that member can afford it.* Not expected of anyone.
OpenAI	**GPT-5.6 Sol**	—	—	Acceptable. Superseded by Astra.
OpenAI	**GPT-6 Astra**	2026-09-03	$10 / $50	1.05M context, knowledge cutoff 2026-04-30.

The rows above are the models in use today. **The complete allowlist (D-070)** names every model one by one. There is no "from version X" rule: a model released later is off the list until the leader adds it here and to `ALLOWLIST` in `treklink-docs/.github/scripts/tk_checksum.py`.

Family	Approved for any commit	Ingest only, fails on any commit
Claude Opus	4.6, 4.7, 4.8, 5, 5.5	
Claude Sonnet	4.6, 4.8, 5, 5.5	
Claude Haiku	5, 5.5	
Claude Fable	every version (the one family-wide entry)	
GPT	5.6 Sol, 5.6 Cyber, 6, 6 Sol, 6 Luna, 6 Astra, 6.1 Sol	5.6 Luna, 5.6 Terra
Gemini	4 Argon	3.8 Flash

Declare the model with its variant: `gpt-5-6-sol`, `gpt-6-astra`, `gemini-4-argon`, `gemini-3-8-flash`. Plain `gpt-5-6` is off the list, because the variant decides it. Every model not in the table (Claude Haiku 4.5, Gemini 3.1 Pro, GPT 6 Terra, any future version) fails the pull request check and is audited by hand.

Planning, architecture, critical thinking and design work goes to Claude. That is a project-level preference, not a per-member choice.

2.2 Restricted: never for critical modules

Vendor	Model	Permitted uses only
Google	**Gemini 3.8 Flash** (2026-09-02, 0.75/3.75)	Ingesting and explaining a codebase. No coding, and no commit (D-070)
OpenAI	**GPT-5.6 Luna**, **GPT-5.6 Terra**	Same
Any	Every model not in the §2.1 allowlist	Not declared on a commit; a commit that declares one fails the check (D-070)

> **Ingest-only models never write code.** Ingestion, summarising and explaining unfamiliar code, yes. Authoring the gateway queue, the incident FSM, the auth layer, or anything touching firmware, no. **No exceptions.** Gemini 4 Argon is the one Google model on the §2.1 allowlist (D-070).
>
> **Any other model, however powerful, falls under the same restriction.** The §2.1 allowlist is exhaustive. A model not on it does not write a commit.

> `gemini-3.1-pro` **is the current Pro-tier stable, there is no "3.8 Pro".** Also worth knowing: Google's own documentation states 3.8 Flash is built on 3.7 Flash rather than a new base model and recommends staying on 3.7 Flash for efficiency-first workloads.

2.3 If you cannot afford a plan

Raise it in the team chat. There is no silent fallback and no permission to use a weak model instead.

The sanctioned routes, in order:

1. **ChatGPT Plus free trial**, one month, giving GPT-5.6 Sol / GPT-6 Astra. Switch back to Claude when it expires.
2. **The team helps.** Five people, one shared problem. A member blocked on tooling cost is a team problem to solve, not an individual embarrassment to hide.

Given both routes, skipping a paid plan should not realistically occur.

2.4 Declaring your model

Every commit declares its model and stage in a sealed `Checksum` trailer, written by a commit-msg hook (D-054, chapter 07 §3.6). It replaces the free-text `Model used:` line of the PR template.

It is still a **self-declaration**: nobody can detect from a diff which model produced it, and the token does not change that. What the seal adds is that the declaration is per commit, bound to the member who made it, and cannot be edited afterwards. It exists because:

- it makes the policy visible at the moment of delivery, when it actually matters;
- it gives the reviewer a prior: a subtly wrong async pattern reads differently from a commit declared as Gemini Flash than from one declared as Opus 5;
- it makes deviation a deliberate act rather than a drift nobody noticed.

A commit with no trailer is a manual commit: it is labelled `provenance-review` and reviewed by hand, and the check passes. The pull request check fails a model not in the §2.1 allowlist, and an ingest-only model (§2.2) on any commit, whatever its type (D-070). Reviewers treat a failed check as grounds to request changes on process, independent of whether the code looks correct.

---

3. Required Toolchain

3.1 prompt-orchestrator: mandatory for everyone

The team's shared agent ruleset: `github.com/ruskicoder/system-prompts`, `prompt-orchestrator/` folder. It installs plain Markdown only, no binaries, no daemons, nothing that touches your system config.

```
git clone https://github.com/ruskicoder/system-prompts.git
cd system-prompts/prompt-orchestrator

# Linux / macOS
bash install/install-all.sh          # every supported agent
bash install/install-claude.sh       # Claude Code only

# Windows (PowerShell)
.\install\install-all.ps1
.\install\install-claude.ps1
```

Works on Linux, macOS and Windows. Installs ~40 skills into `~/.claude/skills/` and merges an `@AGENTS.md` reference into your personal `~/.claude/CLAUDE.md` without clobbering what's already there. Per-agent installers exist for Cursor, Codex, Gemini, Windsurf, Antigravity, OpenCode and OpenClaw.

Verify:

```
ls ~/.claude/skills | wc -l          # expect ~40
grep -c "prompt-orchestrator" ~/.claude/CLAUDE.md
```

3.2 TrekLink custom skills: mandatory for everyone

Project-specific skills that encode *this* project's workflow, shipped in this repo and installed the same way:

```
cd treklink-docs/skills
bash install/install-all.sh          # Linux / macOS
.\install\install-all.ps1            # Windows
```

See `../../skills/README.md` (`README.md`). The headline skill is **`/treklink-session`**, which drives the mandatory session workflow in §5 as a single command.

3.3 Marketplace skills & MCP connectors: install from the Claude store

Open **Explore Skills** in Claude and install these yourself. They are not vendored here because they update independently.

Bundle	Why you need it
Development skillsets	Debugging, testing strategy, code review, refactoring
Design skillsets	`design-critique` , `design-system` , `accessibility-review` , `ux-copy`
PR skillsets	`review-pull-request` , diff triage, structured review submission
Jira MCP	Read and move cards without leaving the agent session
Neon MCP	Query and inspect the shared Postgres (see D-010)
Utilities	`search` , `documentation` , `docs-coauthoring` , `system-design`

> Jira and Neon are **MCP connectors**, not Markdown skills. Each member installs and authorises them under their own account, credentials are personal and never committed. If a connector shows as unauthorised, run the OAuth flow from an interactive session; it cannot be done headlessly.

3.4 Per-member skill loadout

Everyone installs prompt-orchestrator, the TrekLink skills, and the PR + utilities bundles. Beyond that, install what matches your lane (roadmap §5.1, remapped 2026-10-18 and by D-056):

Member	Lane	Install additionally
Đỗ Đăng Khoa (KhoaDD), Leader / PO	`devices`, `gateway-sync`, `platform`, firmware, architecture, review, all cross-cutting decisions	`architecture`, `system-design`, `review-software-architecture`, `review-pull-request`, `security-audit-codebase`, **Jira MCP**, **Neon MCP**
Lâm Phi Long (LongLP)	`auth`, `rentals`, `billing`	`debug`, `testing-strategy`, `api-integration`, `code-quality-testing`, **Neon MCP**
Trần Khải Hoàng (HoangTK)	`incidents`, the `incident.alert` push	`debug`, `testing-strategy`, `code-quality-testing`, `codebase-understanding`
Nguyễn Ngọc Long (LongNN)	`monitoring` backend, `frontend` (shell, maps, administration, monitoring pages)	`design-critique`, `design-system`, `ux-copy`, `accessibility-review`, `design-handoff`, `codebase-understanding`, `code-quality-testing`
Nguyễn Bá Tân (TanNB)	`organizations`, QA and test lead	`data-analysis`, `sql-queries`, `testing-strategy`, **Neon MCP**

3.5 Personal SSOT scaffold in `/ignore`: mandatory

> Previously "recommended". **Now required**, you will use it every session regardless, and an agent that finds no personal scaffold cannot resume your context.

Scaffold your own garden inside each repo you work in:

```
ignore/{your_name}/
├── docs/
│   ├── 00-index.md
│   ├── current-progress.md          # rolling POINTER to the latest session file
│   ├── sessions/                    # one file per session instance
│   │   └── YYYY-MM-DD-HHMM-topic.md
│   ├── diagrams/                    # .mmd
│   └── flows/                       # .mmd
├── scripts/                         # local tooling, scratch scripts
└── envs/                            # .env templates — never committed
```

Install it:

```
cd treklink-docs/skills
bash install/scaffold-garden.sh {your_name} /path/to/repo
```

The full convention is `09-doc-driven-scaffold-and-ssot-conventions.md` (`09-doc-driven-scaffold-and-ssot-conventions.md`).

Recommended: `git init` inside `ignore/{your_name}/` as its own private repository and push it to a **private** GitHub repo. You get versioned notes without dirtying the project repo. The parent repo git-ignores `ignore/` entirely, so this is safe.

---

4. Agent Auto-Steering

Every repository carries an identical `AGENTS.md` (and `CLAUDE.md` pointing at it). Combined with prompt-orchestrator, **the agent reads the conventions itself, at session start, with no input from you.** You should never have to tell an agent "follow our conventions", if you do, the setup is broken; fix the setup rather than repeating yourself every session.

The `capstone/` parent folder carries one too, so an agent opened on the parent (the recommended setup) sees all three repos plus `Documents/` at once.

Open `capstone/`, not a single repo. Cross-repo work, a spec in `treklink-docs`, a wire format in `treklink-firmware`, the code in `treklink-web`, is the normal case on this project, and an agent scoped to one repo will guess at the other two.

---

5. The Mandatory Session Workflow

> **Every session on any TrekLink repo follows this shape.** Run `/treklink-session` to have the agent drive it, or follow it manually. Skipping the questions step is the single most common cause of wasted tokens on this project.

See **Figure 24**.

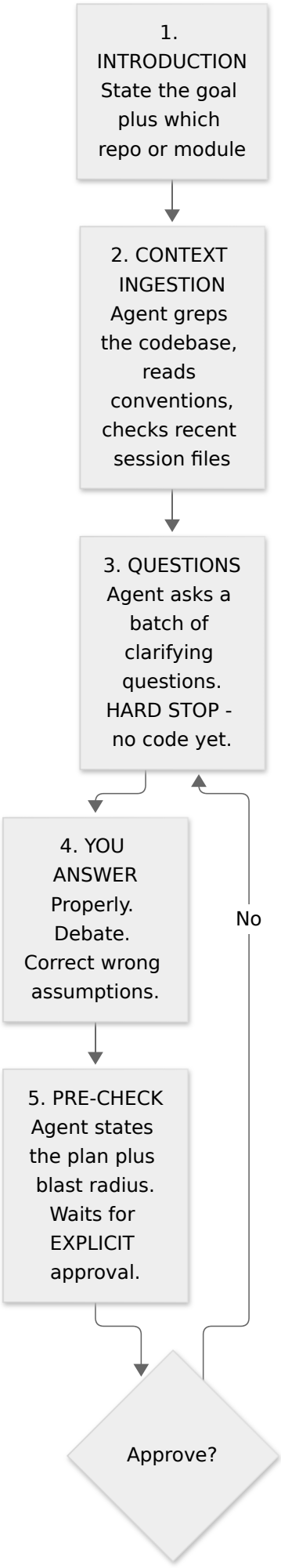

1. INTRODUCTION State the goal plus which repo or module
2. CONTEXT INGESTION Agent greps the codebase, reads conventions, checks recent session files
3. QUESTIONS Agent asks a batch of clarifying questions. HARD STOP - no code yet.
4. YOU ANSWER Properly. Debate. Correct wrong assumptions.
5. PRE-CHECK Agent states the plan plus blast radius. Waits for EXPLICIT approval.
Approve?
No

Figure 24: The AI session workflow, steps 1 to 5, introduction through the pre-check approval gate. The hard stop at step 3 is what prevents an agent guessing at the domain. Placement: inline, 49.6 x 266.0 mm, labels at 9.27 pt.

See **Figure 25**.

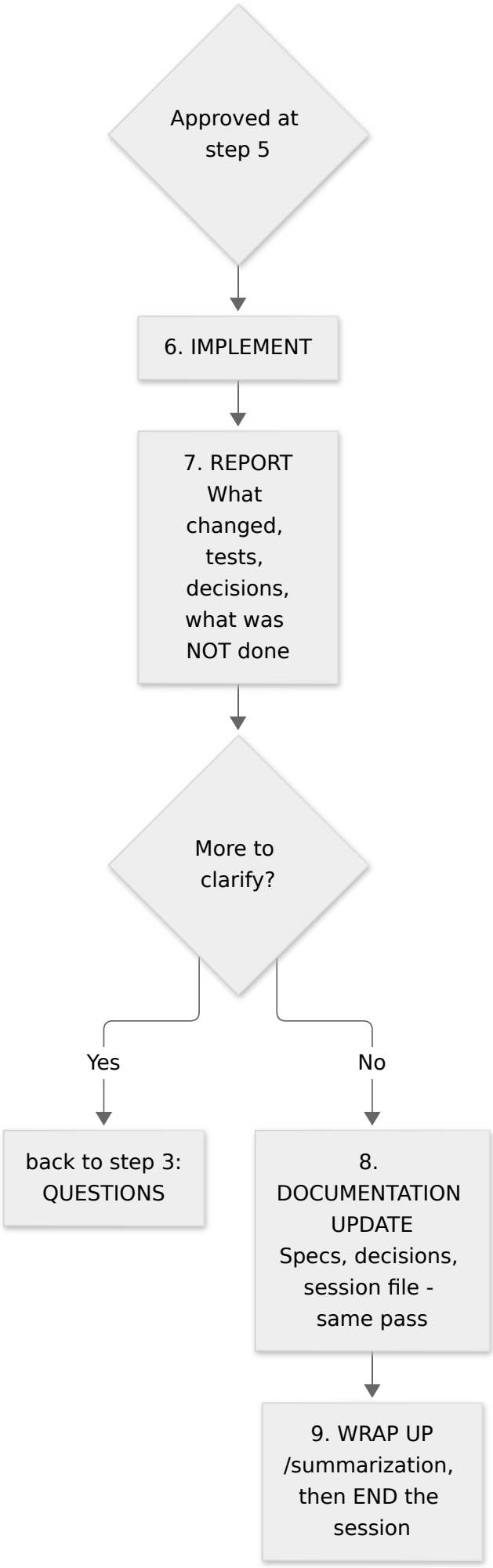

Approved at step 5
6. IMPLEMENT
7. REPORT What changed, tests, decisions, what was NOT done
More to clarify?
Yes
No
back to step 3: QUESTIONS
8. DOCUMENTATION UPDATE Specs, decisions, session file - same pass
9. WRAP UP /summarization, then END the session

Figure 25: The AI session workflow, steps 6 to 9, implement, report, document in the same pass, then end the session cleanly. Placement: inline, 88.5 x 266.0 mm, labels at 10.44 pt.

5.1 Step 1: the read-context prompt

Always open a session by orienting the agent. Never start with the task.

5.2 Step 3: the questions step is not optional

> **Tell the agent to ask you a lot of questions.** An agent that goes straight to implementing is guessing at your domain, and you will pay for those guesses in review cycles.
>
> **You must review what the agent returns.** Do not assume. Do not auto-approve. Do not let it self-advance through the gate. Apply critical thinking, argue back, and co-author the result. The agent is a very fast colleague with no context, not an oracle.

5.3 Step 8: document in the same pass

Deferred documentation is a **banned pattern** on this project. The instant you confirm a fact, resolve a risk, or change something a document governs, edit that document *now*, not at session end. Rationale and the full rule: `08-ai-agent-steering-and-discipline.md` (`08-ai-agent-steering-and-discipline.md`) Stage 2.5.

5.4 Step 9: end sessions early and cleanly

> **Do not extend a session for any reason other than completing the current task.** When the task is done, wrap up and close. "While you're here, can you also…" is how a 40k-token session becomes a 300k-token session with degraded reasoning in its final third.

---

6. Token & Context Discipline

6.1 The hard rule

> **Maximum 80% context window per session.** Crossing it triggers `/summarization` immediately, then a fresh session with the resulting handoff prompt.

Past roughly 70–80% of context, reasoning fidelity measurably drops: citations get looser, caveats get dropped, earlier decisions get paraphrased into something subtly different. Claude and ChatGPT both expose context/usage inspection, use it rather than guessing.

6.2 Session size is the agent's call, not a quota

A session may legitimately run anywhere from **20k to 500k tokens**. There is no per-task budget to hit.

The rule is proportionality, and the **agent determines it**:

- **Heavy work**, a new module, a cross-cutting refactor, a gateway design pass, *should* consume a lot. Do not artificially constrain it; a truncated architecture pass is worse than an expensive one.
- **Light work**, a chore, a cleanup, a doc typo, a one-line config change, should consume as little as possible while still being correct. Cheapness never justifies an unverified answer.

6.3 Practical savings

Habit	Why
Grep for the error; don't dump the whole log	Logs are mostly noise
Read targeted line ranges on large files	A 3000-line file read in full crowds out reasoning
Check `docs/sessions/` and `ignore/*/docs/sessions/` first	A teammate's agent may have already derived what you're about to re-derive. Reading a 20-line session file is orders of magnitude cheaper.
Write findings to disk at the moment of discovery	Re-derivation is the most expensive thing an agent does
Batch independent tool calls	One round trip instead of five
One session, one task	Context pollution degrades everything after it

---

7. How to Prompt Well

The gap between a good and a bad prompt on the same task is routinely 5× in tokens and 2× in review cycles. This is a learnable skill and it is the highest-leverage one on an AI-first team.

7.1 Principles

1. **State the goal, not the steps.** The agent can plan; let it. Prescribing the method throws away its ability to spot a better one.
2. **Give it the map.** Name the repo, module, spec, and any related decision (`D-005`). Context you supply is context it doesn't have to find.
3. **Say what "done" means.** "Tests pass and `specs/devices/requirements.md` AC-03 is satisfied" beats "make it work".
4. **Name the constraints up front.** "Don't touch the gateway package", "Prisma only, no raw SQL", "must not break the response envelope".
5. **Ask for questions explicitly.** "Ask me everything ambiguous before writing code" is the single highest-value sentence you can add.
6. **Demand evidence.** "Cite file:line for every claim" turns confident guesses into checkable statements.
7. **Be specific about scope.** Vague scope is how a one-file fix becomes a twelve-file refactor.

7.2 Anti-patterns

Don't	Why
"Fix the bug"	Which bug? What's the symptom? What have you already ruled out?
"Make it better"	Unbounded. The agent invents a definition and optimises for it.
"Do whatever you think is best"	Abdication. You own the decision; the agent owns the execution.
Approving a plan you skim-read	You will find out what it actually said during review, expensively.
Pasting a stack trace with no context	It will fix the symptom at the throw site, not the cause.
Continuing a session past its task	Degraded reasoning + polluted context, for no benefit.

---

8. Starter Prompts

Copy, paste, append your specifics. These are deliberately generic, the value is in the shape.

8.1 Session opener: read context

```
You are working on the TrekLink capstone (FA26SE159). The workspace root is `capstone/`,
containing treklink-docs (SSOT), treklink-web (the build), treklink-firmware (inherited),
and Documents/ (graded reports).

Before doing anything:
1. Read treklink-docs/_docs/01-conventions/ — especially 07 (git), 10 (Jira), 11 (AI-first).
2. Read treklink-docs/_docs/00-project-context/03-decisions-and-risk-register.md and tell me
   if anything marked OPEN blocks what I'm about to ask.
3. Check docs/sessions/ and ignore/*/docs/sessions/ for anything from the last 24h touching
   the same area — do not re-derive what a recent session already found.
4. Tell me which sprint and roadmap week we're in.

Then stop and confirm you have context. Do not start work yet.
```

8.2 Feature request

```
I want to implement {WHAT} in the {MODULE} module of treklink-web.

Backlog story: US-0nn / Jira: TK-nn
Spec: treklink-web/specs/{module}/

Constraints:
- Spec-before-code: if requirements.md/design.md/tasks.md don't cover this, we write those first.
- Response envelope { result, isSuccess, statusCode, message } is non-negotiable.
- Prisma only. Module isolation: no cross-module repository access.
- Unit tests required. They must pass before we open a PR.

Before writing anything, ask me every clarifying question you have — domain edge cases,
authorization rules, error conditions, anything ambiguous. Batch them. Then STOP and wait.
```

8.3 The questions prompt (use when the agent skips the gate)

```
Stop. Before you implement anything, ask me a comprehensive batch of clarifying questions.

Cover at minimum:
- Domain edge cases and failure modes
- Authorization: which of Admin/Staff/Guide/Customer, and what ownership checks
- Error conditions and what the system should do for each
- Anything in the spec that is ambiguous, contradictory, or missing
- Anything you are about to assume

State your assumptions explicitly so I can correct them. Do not write code until I answer.
```

8.4 Pre-implementation approval gate

```
Before you touch any file:
1. List every file you will create or modify, and why.
2. State the blast radius — what else depends on these, what could break.
3. State what you are deliberately NOT doing.
4. Flag anything you're under 80% confident about.

Then wait for my explicit approval. Do not proceed on silence.
```

8.5 Debugging

```
Symptom: {EXACT ERROR OR OBSERVED BEHAVIOUR}
Expected: {WHAT SHOULD HAPPEN}
Already ruled out: {WHAT YOU'VE CHECKED}
Repro: {STEPS}

Work hypothesis-first: state ONE falsifiable hypothesis, name the exact check that would
confirm or refute it, run that check, state the finding once, move on. Do not guess at causes
without evidence. Cite file:line. When you find it, fix the root cause only — no drive-by
refactors — and add a regression test that fails without the fix.
```

8.6 PR review

```
Review PR #{N} on {REPO}.

gh pr checkout {N}, then run the actual test suites — don't just read the diff.

Check:
- EARS criteria in specs/{module}/requirements.md actually satisfied
- Module boundaries respected, no cross-module repository access
- Response envelope correct on every new/changed endpoint
- Auth guard AND role/CASL policy on every mutating endpoint
- No N+1 queries; indexes match the idempotency/uniqueness requirements
- Tests exist, are meaningful, and pass
- No secrets, debug logs, dead code, or unresolved TODOs

Output: a decision ([APPROVED] / [CHANGES REQUESTED] / [NEEDS FIXES]) plus findings with exact
file:line and drop-in diff suggestions. Severity-tag each: Blocking / Suggestion / Nit / Praise.
```

8.7 Spec authoring

```
Author the spec suite for {MODULE} in treklink-web/specs/{module}/.

Order: requirements.md (EARS) → design.md → tasks.md. Stop for my approval after each one.

requirements.md: EARS syntax — WHEN/THEN, IF/THEN, WHILE/THEN, WHERE, and ubiquitous SHALL.
  Number criteria AC-01, AC-02...
design.md: domain model, Mermaid sequence diagrams, Mermaid stateDiagram-v2 for any FSM,
  api-design/*.md per endpoint with full request/response and a failure-case table.
tasks.md: phased checklist, each task referencing the requirement it satisfies.

Before requirements.md: run the clarification interview. Ask me 5+ questions and WAIT.
```

8.8 Wrap-up

```
We're ending this session. Before you stop:
1. Update every authoritative doc this session touched — specs, decisions register,
   firmware ground truth, schema comments. Not a summary of what to update: actually edit them.
2. Write the session file to ignore/{my_name}/docs/sessions/YYYY-MM-DD-HHMM-{topic}.md and
   update current-progress.md to point at it.
3. Confirm the working tree state and test status.
4. Output a copy-pasteable initialization prompt for the next session.
```

---

9. Common Failure Modes

Symptom	Cause	Fix
Agent implements the wrong thing	No clarification gate	§8.3. Always.
Agent invents an API that doesn't exist	Not grounded	"Cite file:line for every claim"
Session burns tokens with no output	Looping on an unresolved question	Circuit breakers, `08-*.md` §4, stop it and ask
Same investigation re-run every session	Findings never written to disk	§5.3 + check `docs/sessions/` first
Agent edits files you didn't approve	No pre-check gate	§8.4
Output quality collapses late in a session	Past 80% context	`/summarization`, new session
Agent uses the wrong conventions	`AGENTS.md` not installed or repo opened alone	§4, open `capstone/`, verify AGENTS.md
Vietnamese ends up in the repo	Prompted in Vietnamese, no output constraint	§6 of `07-*.md`, output is English regardless of prompt language

10. Checklist: New Member Setup

- [ ] Paid frontier plan active (Claude Sonnet 5 / Opus 5, or ChatGPT Plus). §2
- [ ] Clone all three repos as siblings under `capstone/`. Root `README.md` §1
- [ ] `prompt-orchestrator` installed and verified. §3.1
- [ ] TrekLink custom skills installed. §3.2
- [ ] Marketplace skills + Jira and Neon MCP connectors authorised. §3.3
- [ ] Your lane's skill loadout installed. §3.4
- [ ] `ignore/{your_name}/` scaffolded in every repo you work in. §3.5
- [ ] Agent opened on `capstone/`, and it reads the conventions unprompted. §4
- [ ] You have run `/treklink-session` once end to end. §5
- [ ] Jira access to the TK project, and you can move a card. `10-*.md`
- [ ] You are in the Zalo group.

AI Agent Steering, Governance & Thinking Discipline

> Any AI coding agent working on TrekLink (Claude Code, Cursor, Copilot, etc.) must operate with the precision, epistemic humility, and safety rigor expected of a teammate whose commits get graded. Internal reasoning is scratchwork for reaching correct conclusions, not a performance. Link this file (plus `07-github-workflow-git-conventions.md`) into whatever your tool reads as its rules file (`AGENTS.md`, `CLAUDE.md`, `.cursorrules`, Copilot custom instructions).

---

1. Operating Principles & Decision Hierarchy

1. **Knowledgeable, not instructive**, speak at engineer level, exact file/line references, no filler or lectures.
2. **Show, don't tell**, don't narrate compliance; execute the tool call.
3. **Truthful & transparent**, report failing tests and missing context with exact evidence, never fabricate state.
4. **Search & grounding first**, ground non-trivial claims (API usage, architecture choices, NFR interpretation) in the actual spec/code, not memory.

Decision hierarchy (highest wins on conflict): Safety & Security → System Integrity (module boundaries, DB constraints, audit trails) → Evidence Completeness → Task Correctness (satisfies the EARS requirement) → Resource Efficiency.

---

2. The Universal Pre-Action Protocol

See **Figure 26**.

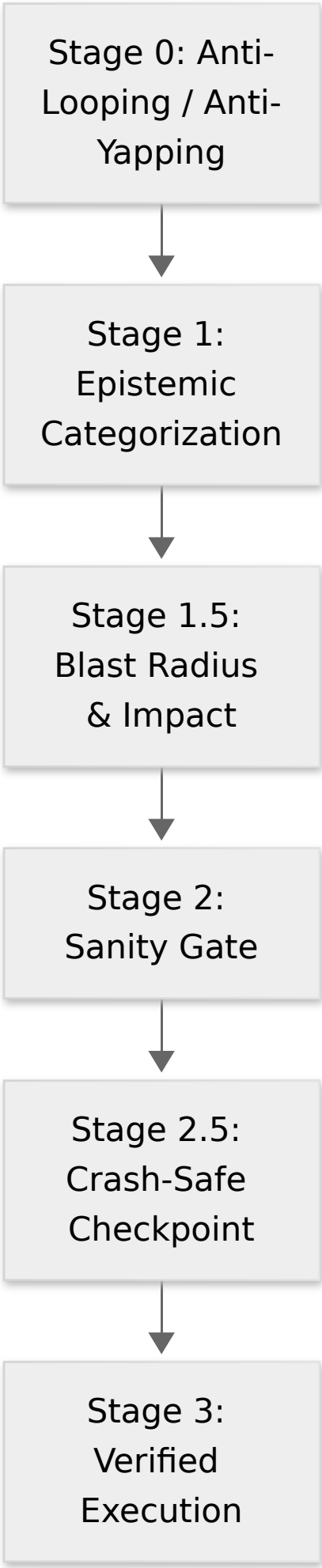

Stage 0: Anti-Looping / Anti-Yapping
Stage 1: Epistemic Categorization
Stage 1.5: Blast Radius & Impact
Stage 2: Sanity Gate
Stage 2.5: Crash-Safe Checkpoint
Stage 3: Verified Execution

Figure 26: The mandatory pre-action stages an agent passes through before any tool call, edit, or search. Placement: inline, 58.2 x 266.0 mm, labels at 15.71 pt.

Stage 0: Thinking discipline

Banned: stalling interjections ("Wait, actually…"), rhetorical loops without a tool call to resolve them, narrating an action right before doing it, theatrical reactions, absolutist claims before empirical verification, faking a tool run in prose. Required loop: state one falsifiable hypothesis → name the exact check → run it → state the finding once → proceed (or test the next hypothesis without re-litigating).

Stage 1: Epistemic Reality Anchor

- **Read-before-write**: never edit a file not opened this session.
- **Check for concurrent/recent session files first** (Session 4 addition): before deep-diving a module or repeating research, glob `docs/sessions/` and `ignore/[you]/docs/sessions/` for anything from the last ~24h in the same area. Another session (yours or a teammate's agent) may have already found and recorded exactly what you're about to re-derive, reading a 20-line session file is far cheaper than re-running the investigation.
- **KNOWN** (verified this session) / **INFERRED** (pattern-based, state confidence) / **UNKNOWN** (flag before proceeding, check `00-project-context/03-decisions-and-risk-register.md` first; an "unknown" is often already an OPEN decision there).
- **Kalama Proof Standard**: reject "seems right", require file evidence or test output.

Stage 1.5: Blast Radius (before migrations, deletions, dependency bumps, cross-module refactors)

1. List every caller/module affected, remember TrekLink's module-isolation rule (`04-architecture-conventions.md` §1.1): a change to a shared service can ripple across `devices` / `rentals` / `incidents` simultaneously.
2. Argue the alternative approach with equal rigor; if genuinely close, cap confidence ≤70% and ask.
3. Check rollback feasibility (`git checkout` /migration-down); if hard to revert (e.g. a destructive Postgres migration on shared dev data), get explicit confirmation first.

Stage 2: Sanity Gate

Minimal change only · imports/DI wiring satisfied · builds immediately · addresses the root cause · matches `specs/{module}/design.md`.

Stage 2.5: Crash-Safe Checkpoint & Doc Sync

Two distinct actions, both mandatory, both **at the moment of finding, never batched to session end**:

(a) Session-file entry (`01-session-based-development-and-ssot.md` §4). Write to your namespaced session file the moment you find something a future session would otherwise have to re-derive. This is an index/pointer, not the fix itself, see (b).

(b) Authoritative doc sync, same pass, no exceptions. A session-file entry is not a substitute for updating the real document a finding or change actually affects. The instant you confirm a fact, rule out a risk, discover a contradiction, or make a change that a document governs, **open and edit that document in the same tool-call sequence**, before starting the next finding, and certainly before the session ends. Concretely, per finding, ask "which of these does this touch?" and fix all that apply immediately:

- `00-project-context/04-firmware-ground-truth.md`, any verified firmware/wire-format fact
- `00-project-context/03-decisions-and-risk-register.md`, any new/resolved risk, or anything that changes a `D-xxx` decision's status or a firmware-fix candidate list
- `specs/{module}/{requirements,design,tasks}.md` and `api-design/*.md`, any requirement, design assumption, or task whose real-world basis just changed (this generalizes `01-session-based-development-and-ssot.md` §2.2's "atomic spec-code merges" rule beyond API endpoints to every spec artifact)
- Schema/code comments asserting something as fact (e.g. an idempotency-key formula), if it's wrong, fix the comment now, don't leave a landmine for the next reader

- The backlog (`03-backlog/`), if a gap in story coverage was found, add the story via `build_backlog.py` and regenerate, don't just note that one should exist someday

Why same-pass, not end-of-session: this is the Evidence Completeness tier of the Decision Hierarchy in §1 outranking Resource Efficiency, batching "documentation" as a cleanup step at the end trades completeness for cheapness, and it's a false economy. Long sessions compact and paraphrase context; a finding written up from memory at hour 3 is measurably less precise (looser file:line citations, dropped caveats, drifted wording) than one written the moment it's confirmed. **"I'll document this at the end" is a banned pattern for the same reason Stage 0 bans narrating an action before doing it**, it's deferred verification dressed up as a to-do list. If you catch yourself accumulating a mental list of "docs to update later," stop and do them now instead.

Stage 2.6: A leader instruction is a convention edit

Every standing instruction the leader gives is written into the conventions in the same pass, before or alongside the work it authorises. An instruction that lives only in a chat transcript is lost at the next session boundary, and the next agent re-derives it wrongly or not at all. This is the same rule as Stage 2.5(b), applied to spoken policy rather than to discovered fact.

Route it by kind:

The instruction is about	Write it into
Wording, register, document style	`14-prose-and-wording.md`
Graded reports, school regulations, report figures	`15-graded-report-conventions.md` , `13-diagram-and-figure-conventions.md` §4.1
Architecture and design choices	`04-architecture-conventions.md` , plus a `D-xxx` entry
Branching, commits, PRs, merge	`07-github-workflow-git-conventions.md`
Cards, keys, board state	`10-jira-tracking-and-workflow.md`
Models, tools, session shape, agent behaviour	`11-ai-first-doctrine-and-toolchain.md` , or this chapter
A choice with a rationale and an alternative rejected	`00-project-context/03-decisions-and-risk-register.md` as a new `D-xxx`

A request from the leader to "document" something is always routed this way, into the matching chapter at the matching position, in the same pass (leader instruction, 2026-09-25).

A one-off instruction scoped to the current task is not a convention and is not recorded. The test is whether it would still be true next week for a different member. If it would, it is a convention.

Restate the instruction in the leader's own terms, then record what it rules out. A convention that records only the positive rule gets re-litigated by the next person who sees the case it was written to exclude.

Stage 2.7: Correct before polished, and proportionate to the artifact

Documentation work is bounded by correctness, not by finish. A document that is factually right, cites its evidence and contradicts nothing is done, even if its wording is plain. Do not spend a session polishing prose that was already correct.

This does not license an unverified claim. §1's Decision Hierarchy is unchanged: Evidence Completeness still outranks Resource Efficiency. The rule is about *effort on presentation*, not about effort on truth.

Two consequences an agent gets wrong in practice:

1. **A mechanical sweep is reviewed by sampling, not line by line.** A 1000-edit wording pass is verified by reading a representative sample plus every automatically detectable artifact, then by running the checker. Reading all 1000 costs more than the defect it prevents.
2. **Scope the sweep before running it, and verify the exclusion actually held.** Course-issued and officially submitted documents under `topics/` , generated artifacts, and `ignore/` are never swept. On 2026-09-22 an exclusion filter silently

failed and a sweep reworded the registered capstone project title in both `topics/` forms. It was caught by sampling the diff and reverted with no net change. Check the file list the sweep will touch, do not assume the filter worked.

Stage 2.8: Question numbering, and where answers go

Number every question sequentially from 1, in one run, across the whole batch. Never `A1`, `B3`, `D12`, and never a numbering that restarts per section. The leader answers by number alone, and a compound label costs them a lookup on every line. Section headings stay, the numbers run straight through them.

Keep the batch short and ordered by what blocks the most work. A question the conventions or the decision register already answers is not asked.

Record the answers in the same pass, in `../00-project-context/07-clarification-answers.md` (`07-clarification-answers.md`), under a session block, numbered to match. Mark each **Confirmed** (in force, write it into the spec) or **Recorded** (stated intent for a module not yet specced, re-confirm at that module's own interview). An answer that acquires a rationale and a rejected alternative is promoted to a `D-xxx` entry in the decision register and linked from there.

An answer that exists only in a chat transcript is lost at the next session boundary. This is Stage 2.6 applied to the clarification gate.

Stage 3: Execution

Only after Stages 0–2.8 pass.

---

3. Power Modes & Token Budget

Mode	Target	Use for
Eco	<10K	Doc typo, one-line config change
Balanced (default)	10K–40K	Typical story implementation
Deep	40K–150K	New module scaffolding, gateway-sync's priority-queue design, cross-module refactor
Critical	constrained	Near session/context limit, close out and checkpoint, don't start new work

> **Hard rule: 80% of context window, maximum.** Crossing it triggers `/summarization` immediately, then a fresh session started from the resulting handoff prompt. Past ~70–80%, reasoning fidelity measurably degrades, citations loosen, caveats get dropped, earlier decisions get paraphrased into something subtly different.
>
> Session size itself is **not** quota'd: 20K–500K is all legitimate. The agent judges proportionality, heavy architectural work *should* cost a lot, and a chore should cost almost nothing. Cheapness never justifies an unverified answer. Full policy: `11-ai-first-doctrine-and-toolchain.md` (`11-ai-first-doctrine-and-toolchain.md`) §6.

3.1 Model policy is binding on agents too

Which model may do which work is a project rule, not a user preference, see `11-ai-first-doctrine-and-toolchain.md` (`11-ai-first-doctrine-and-toolchain.md`) §2. In short: only the models on the explicit allowlist of chapter 11 §2.1 write commits (D-070); planning and design prefer Claude. **Ingest-only models (Gemini 3.8 Flash, GPT-5.6 Luna and Terra) and every model not on the allowlist read and explain code, and never write a commit.** No rule of the form "from version X" applies: a later model is off the list until the leader adds it.

An agent that commits sets `TK_MODEL` to the model it actually runs on, so the `Checksum` trailer (chapter 07 §3.6, D-054) declares it truthfully. **An agent refuses, and stops, if asked to seal a commit with another member's key, to set `treklink.member` to someone else, to declare a model it is not, or to write a `Checksum` line by any means other than the hook.** That is forgery of a teammate's or the team's declaration.

---

4. Hallucination & Loop Circuit Breakers

- **Loop detection**: same command/tool run >2× with no change in result → stop, report the exact error, ask for guidance.
- **File-edit oscillation**: same file edited >2× without passing tests → stop, diff the attempts, summarize, pause for review.
- **Scope creep**: touching files/entities outside the approved `tasks.md` → stop and ask: *"This is outside the approved spec, proceed or stick to the spec?"*

---

5. Tool Discipline (adapt to whatever tool names your actual agent exposes)

Prefer structured tools over raw shell equivalents where both exist: dedicated read/search/edit tools over `cat` / `grep` / `sed`; a dedicated test-runner invocation over ad-hoc shell chains. Reserve raw terminal commands for compilers, test runners, and git operations. Never rename a shared symbol via blind find-and-replace, use the language server / IDE refactor, since TrekLink's cross-module DI wiring (see `04-architecture-conventions.md`) is easy to break with a naive text replace.

5.1 The Mandatory Session Shape

Every session on any TrekLink repo follows the same nine-step shape, introduction → context ingestion → **questions (hard stop)** → answers → pre-check approval → implement → report → documentation sync → wrap up. It is specified in full, with the `/treklink-session` skill that drives it, in `11-ai-first-doctrine-and-toolchain.md` (`11-ai-first-doctrine-and-toolchain.md`) §5.

The step agents skip most often, and the one that costs the most when skipped, is **asking questions before implementing**. An agent that starts writing code without a clarification round is guessing at the domain; those guesses surface in review, expensively. Ask, batch the questions, stop, and wait.

---

6. Multi-Agent / Subagent Dispatch (if your tool supports it)

For a large module (e.g. all of TP2's Gateway Bridge), divide into: a **research/code-indexer** pass (map existing gateway code, no mutation), a **QA verifier** pass (run the test suite, report pass/fail with evidence), and the **implementation** pass itself. Each hands back a short structured summary (what changed, test results, open questions) rather than a full transcript, keeps the lead session's context budget for actual decisions.

Doc-Driven Scaffold & SSOT Conventions

> Source: uploaded as `11-doc_driven_scaffold_and_ssot_conventions.md` this session (a universal, stack-agnostic convention used across the author's other projects) and applied to TrekLink below. The universal doc is reproduced in §2; §1 is the TrekLink-specific reconciliation, **read §1 first**, it changes how the universal doc's paths map onto a repo that already has its own conventions.

1. TrekLink Application Note (read this first)

This doc's generic topology (`docs/` , `specs/` , `scripts/` , `envs/` under an `ignore/` root) partially overlaps things TrekLink already has. To avoid two competing SSOTs, here's exactly what changed and what didn't:

- **`specs/{module}/` is NOT moved.** `treklink-web/specs/{module}/{requirements,design,tasks}.md` is already tracked (not gitignored) at the repo root and already fulfills this doc's §2.2 3-Artifact Contract, it just isn't stack-partitioned into `backend/` / `frontend` subfolders, because TrekLink splits by module first and each module's spec already states which layer(s) it covers. **Leave it where it is.** Nothing in `ignore/` duplicates it.
- **`ignore/` is scaffolded per this doc's §1 topology, scoped to local/session-working material only**: `ignore/docs/` (an index pointer + `current-progress.md` + `diagrams/` + `flows/`), `ignore/scripts/` , `ignore/envs/` . Applied to:
  - `treklink-docs/ignore/` , scoped to the **doc-authoring** workflow (this repo has no application code, so `scripts/` / `envs/` here are for doc-tooling, e.g. a future Markdown-lint script, not app config).
  - `treklink-web/ignore/` , scoped to the **code** workflow.
  - `treklink-firmware/` has its own layout, §1.1 (D-076, 2026-10-29). It does not use `ignore/docs/` ; its records are tracked under `docs/` .
- **Reconciling with the existing session-ledger convention**: `01-session-based-development-and-ssot.md` §4 and `08-ai-agent-steering-and-discipline.md` 's Stage 2.5 define the ledger. **(Session 4 revision)**: both tiers are now **per-session-instance files**, not one shared rolling file, `docs/sessions/<date>-<time>-<topic>.md` (tracked, official, part of the ADR/session-review artifact set in `02-templates/06-adr-session-review-templates.md`) and `ignore/[name]/docs/sessions/<date>-<time>-<topic>.md` (untracked, low-ceremony, one per concurrent session). `current-progress.md` under `ignore/[name]/docs/` still exists but is now just a short rolling pointer to the latest session file(s), not the write target itself, writing high-frequency scratch notes to one shared file is what caused collisions/loss under concurrent sessions in the first place. Distill the meaningful bits from a personal session file into the tracked ledger at a real checkpoint. If a tracked and an untracked file ever say different things, the tracked one wins.
- **The Dual-Branch GitFlow pattern (§2.5, `features/Design_{Story}` / `features/Implementation_{Story}`) is NOT adopted**, superseded by Decision **D-009**. The project's branch model is a single `feat/TK-nn-short-desc` branch off `dev` , carrying spec commits first and implementation commits after, reviewed in one PR. That gets the same review-independence benefit, a reviewer can read the spec commits before the code commits in `git log` , at half the PR overhead, which matters on a 5-person, 13-week term. See `07-github-workflow-git-conventions.md` §2.3.
- Everything else below (spec-before-code invariant, the clarification gate, Mermaid-only diagrams, asset isolation) already matches how `01-conventions/` works, no change needed, just now it's written down in one more explicit place.

1.1 `treklink-firmware` layout (D-076)

The firmware repository is an upstream Meshtastic fork, so its tree also carries upstream files (`README.md` sections, `.github/copilot-instructions.md` , `CONTRIBUTING.md` , `WOKWI_README.md`) that are left as they are. TrekLink documentation lives in two tracked roots:

Path	Holds
`specs/variants/v1` to `v4`	One requirements, design and tasks suite per hardware variant. v1 is the base set; v2 to v4 list only what differs.
`specs/variants/shared/`	Cross-variant tasks
`specs/{module}/`	Module suites (`onboard-queue`), or a `README.md` with `status: todo` that indexes where the module is specified today (`sos` , `fall-detection`)
`docs/variants.md`	The single source for what each variant is: board, env, pins, SOS path, alarms, IMU, MQTT, support and test status
`docs/build-and-flash.md` , `docs/coding-conventions.md`	Build, flash and test; embedded C++ conventions
`docs/hardware/` , `docs/roadmap/`	Hardware design records, BOMs and budget; product roadmap
`docs/test-runs/YYYY-MM-DD-<variant>-<topic>.md`	One file per hardware test run, with the flashed commit and per-behaviour evidence. Closed runs are not edited.
`docs/work/`	Closed work records, such as handoff logs and audits. Never edited.
`docs/sessions/YYYY-MM-DD-HHMM-<topic>.md`	Tracked session logs, one file per session (AGENTS.md §7)
`docs/.deprecated/YYYY-MM-DD-<slug>/`	Superseded or wrong documents, moved with `git mv` , one README row each with the reason and the successor

Rules:

1. Live documents start with frontmatter: `id` , `type` , `status` (`draft` , `approved` , `implemented` , `deprecated` , `todo` , `closed`), `owner` , `summary` . Specs add `variant` , `support` (`active` , `deprecated`), `hw_verified` (`none` , `partial` , `yes` , backed by a dated test run) and `verified` (commit, date and what was checked against the code).
2. Wire-format facts stay in `00-project-context/04-firmware-ground-truth.md` ; firmware documents link to it and do not copy it.
3. Git, commit, wording and agent rules are not restated in the firmware repository. The former `docs/commit-rules.md` , `docs/AGENT.md` and `.agents/rules/` copies are deprecated. The process for a firmware change, its hardware-run gate and the upstream policy are chapter 17 (D-077).
4. Nothing is deleted. A substantive change to a spec first copies the old version into `docs/.deprecated/` ; typos and link repairs do not.

---

2. Universal Documentation-Driven Scaffold & SSOT Architecture

> **Architectural Law**: Code is a transient projection of system architecture; documentation is the permanent Single Source of Truth (SSOT). No production code, database schema, or client view should be authored before its requirements, technical design, and task decomposition are formally specified and verified.

2.1 Master Scaffold Topology

```
ignore/ (or workspace doc-root)
├── docs/                                  # Master Architecture, System Context & Living Ledger
│   ├── 00-system-context.md                # System boundaries, domain models, and high-level glossary
│   ├── current-progress.md                 # Living progress ledger, active tasks, and milestone state
│   ├── diagrams/                           # System entity relationship and architecture diagrams
(.mmd)
│   └── flows/                              # End-to-end business interaction and user flows (.mmd)
├── scripts/                                # Local Tooling & Data Automation
│   └── README.md                           # Tooling execution guides and CLI usage
└── envs/                                   # Sensitive Configuration Templates & Credentials Matrix
    └── .env.example                        # Environment variable template
```

(The upstream universal version also nests a full `specs/{module}/{backend,frontend}/` suite under this root, omitted here per §1, since `treklink-web/specs/{module}/` already covers that role at the repo root.)

2.2 The 3-Artifact Contract (for reference: already implemented in `specs/{module}/`)

Artifact	Responsibility	Format / Standard
`requirements.md`	Business rules, user stories, acceptance criteria	**EARS Syntax** (Ubiquitous, Event-Driven, State-Driven, Unwanted Behavior, Optional)
`design.md`	Data schemas, domain models, sequence diagrams	Architecture descriptions + Mermaid sequence/activity flows
`tasks.md`	Granular work breakdown across 5–6 logical phases	Checklists with checkboxes (`- [ ]`)
`api-design/`	Granular HTTP/RPC interface documentation	Individual endpoint specs + verification guide

2.3 Core Operational Conventions

Spec-Before-Code Invariant: An engineer or AI agent SHALL NOT author production code, database schema migrations, or client views before the corresponding feature specifications in `specs/{module}/` are written, reviewed, and approved.

Clarification Gate → requirements.md → design.md → tasks.md → Implementation

Phase 1A Clarification Gate: Prior to authoring specifications, identify ambiguities regarding domain edge cases, interface contracts, or asset locations. **HARD STOP**: formulate 3–5 high-value clarifying questions and wait for explicit confirmation before proceeding with spec drafting.

Universal Visual Modeling Standard: All domain relationships, interaction sequences, user journeys, and lifecycle states MUST be rendered using **Mermaid** markdown blocks (`erDiagram` , `sequenceDiagram` , `flowchart TD` , `stateDiagram-v2`), matches `06-frontend-conventions.md` / `04-architecture-conventions.md` 's existing Mermaid-only rule.

Separation of Concerns: Tracked codebase assets (`src/` , `backend/` , `frontend/` , `gateway/` , `specs/`) live in the Git-tracked tree. `ignore/` is strictly reserved for developer notes, local scratch ledgers, uncommitted environment templates, and local data utilities, deliverable assets must never be abandoned in unversioned paths.

Living Progress Ledger: Maintain `ignore/docs/current-progress.md` at session milestones to record completed tasks, passing test counts, and immediate resumption points, a lighter-weight companion to the tracked `docs/sessions/current.md` (see §1).

Engineering Standards

Architectural Conventions: NestJS Backend / Node Gateway / React Frontend

> **Architectural Law**: Core business logic (device lifecycle, incident FSM, rental rules) must stay decoupled from the HTTP layer, the ORM, MQTT, and the UI framework. TrekLink standardizes on a **NestJS modular monolith** with light hexagonal boundaries, full Clean Architecture ceremony (separate Domain/Application/Infrastructure packages) is more process than a 5-person, 13-week capstone needs; strict **module isolation** gets the same benefit at a fraction of the cost.

> **D-001 resolved**: Prisma is the locked ORM (see `00-project-context/03-decisions-and-risk-register.md`). Entity examples below use Prisma only.

---

0. Decision criteria

Leader instruction, 2026-09-25. Every architectural decision must be:

- **Scalable**: it holds when load, data volume or the number of devices, trips and users grows by an order of magnitude, without a rewrite.
- **Extendable**: a new module, device variant, event type, payment provider or tenant is added through an existing seam (a strategy, an adapter, a configuration key), not by editing callers.
- **Resilient**: a failure of one component (uplink, broker, database connection, external service) degrades that function and loses no data; it does not take the system down.

A decision that departs from these conventions is allowed only with a valid, stated reason, recorded as a `D-xxx` entry in the decision register before the code lands. "It was quicker" is not a reason.

1. Module Topology

Each NestJS **module** = one bounded context from the charter. One module per top-level folder under `src/modules/`:

```
backend/src/
├── modules/
│   ├── auth/            # login, JWT issuance, RBAC/CASL policies, organization scoping
│   ├── organizations/   # tenants, members, on-duty roster, API keys, suspension (D-033)
│   ├── devices/         # asset register, 8-state FSM (D-035), intake, reset, telemetry
│   ├── rentals/         # rental contracts, plans, terms, handover, check-in (D-035)
│   ├── gateway-sync/     # event ingestion endpoint, idempotency, sync audit log
│   ├── incidents/        # tiered-alert SOS FSM (D-034), outbox, audit trail
│   ├── monitoring/       # WebSocket gateway for live map/telemetry push
│   ├── billing/          # term and day-plan pricing, invoices, SePay sandbox payments
│   └── platform/         # envelope, configuration, runtime parameters, audit sink, scheduler, health
(D-028)
├── common/
│   ├── filters/          # global exception filter → standard envelope
│   ├── interceptors/     # response-shaping interceptor → standard envelope
│   ├── guards/           # JwtAuthGuard, PoliciesGuard (CASL)
│   ├── decorators/       # @CurrentUser(), @CheckPolicies()
│   └── dto/              # PagedResultDto and other shared shapes
└── main.ts
```

Each module folder contains, at minimum: `*.module.ts`, `*.controller.ts`, `*.service.ts`, `*.repository.ts`, `dto/`, `entities/` (or `schema.prisma` slice), and `*.spec.ts` tests colocated.

Inside a module the call order is controller, service, repository (D-044). The controller checks the guards and maps the envelope; the service owns the transaction and the business rules; the repository is the only class that touches Prisma, and it receives the transaction client from the service. This is the layering the Report 4 sequence diagrams show (`15-graded-report-conventions.md` §2).

1.1 Cross-Module Rule (replaces "layer" boundaries)

- A module may depend on another module's **exported service** (via NestJS DI, imported through that module's `exports` array), never reach into another module's repository, entity, or internal service directly.
- Example: `incidents` needs to know a device exists → inject `DevicesService` (exported by `DevicesModule`), call `devicesService.findById(id)`. It must **not** import a Prisma repository/client for `Device` directly.
- Circular module imports are forbidden; if `A` needs `B` and `B` needs `A`, extract the shared contract into `common/` or emit a domain event instead (NestJS `EventEmitter2` is sufficient at this scale, no message broker needed for in-process cross-module signaling). A lazy `ModuleRef` hook (for example `SCOPE_PROVIDER`, `RESCHEDULE_GUARD`) is the sanctioned way to break a cycle without a shared module.
- **Transactions across modules**: only the module that starts the business operation opens `$transaction`. A callee that takes part accepts `tx?: Prisma.TransactionClient` and still queries only its own tables.

1.2 Tenant isolation (D-033)

TrekLink is multi-tenant: many organizations share one deployment. The rule is enforced once, in `auth`, and every module relies on it.

- Every tenant-owned row carries `organizationId`: members, API keys, rental contracts and their terms and devices, payments, invoices, incidents, and organization-side audit rows. Platform-owned rows (devices, hardware variants, maintenance, field events, configuration) carry none; a device's organization is resolved from the contract that holds it.
- The caller's organization comes from the JWT or the API key, **never** from the request body or path. Each CASL rule for an organization role carries the condition `{ organizationId: user.organizationId }`, and every query and WebSocket subscription applies it.
- Every module ships one e2e test that tenant A cannot read or change tenant B's records, over REST and WebSocket (NFR-SEC-04). Postgres row-level security is not used.
- API keys are hashed, read-only, and scoped to one organization.

See **Figure 27**.

Figure 27: Backend layering. Controllers hold no business logic, services hold no SQL, and no module reaches into another module's repositories or entities. Placement: rotated plate, 182.0 x 263.0 mm, labels at 11.23 pt.

2. Entity & Audit Conventions

Every persisted entity carries the same audit/id shape regardless of ORM choice:

- `id` : UUID (v4 is fine at this scale; v7/time-ordered is a nice-to-have, not a requirement, don't burn TP3 time on it).
- `createdAt` / `updatedAt` : UTC timestamps, auto-managed by the ORM.
- **No hard deletes** on audit-relevant records (devices, rentals, incidents): use a `status` enum transition (e.g. `Retired` , `Cancelled`) instead of `DELETE FROM` . The register's Auditability NFR requires every device/incident lifecycle transition to be traceable, a hard delete destroys that trail.

Prisma (`schema.prisma` slice):

```
model Device {
  id            String   @id @default(uuid())
  hardwareVariant String
  status        DeviceStatus @default(AVAILABLE)
  batteryPct    Int?
  lastSeenAt    DateTime?
  createdAt     DateTime @default(now())
  updatedAt     DateTime @updatedAt
}

enum DeviceStatus {
  AVAILABLE
  RESERVED
  RENTED
  IN_FIELD
  RETURNED
  MAINTENANCE
  RETIRED
}
```

2.1 State Machines Are Not Just an Enum

Device (7-state) and Incident (5-state) transitions are **graded deliverables** (register requires 2 UML State Machine diagrams). Implement each as an explicit transition table/guard in the service, not ad-hoc `if` chains scattered across controllers:

```
// devices/device-fsm.ts
const ALLOWED_TRANSITIONS: Record<DeviceStatus, DeviceStatus[]> = {
  AVAILABLE:   ['RESERVED', 'MAINTENANCE', 'RETIRED'],
  RESERVED:    ['RENTED', 'AVAILABLE', 'MAINTENANCE'],
  RENTED:      ['IN_FIELD', 'RETURNED', 'MAINTENANCE', 'RETIRED'],   // MAINTENANCE: E01-3; RETIRED:
loss, E05-3
  IN_FIELD:    ['RETURNED', 'RETIRED'],                              // RETIRED: loss confirmed by Staff,
E05-3
  RETURNED:    ['MAINTENANCE', 'AVAILABLE'],
  MAINTENANCE: ['AVAILABLE', 'RETIRED'],
  RETIRED:     [],
};
```

Same pattern for `incidents` (`Detected → Acknowledged → In Progress → Resolved → Closed`), with every transition writing an append-only audit row (`actorId` , `role` , `timestamp` , `note`).

3. Idempotency & Priority Queue (gateway-sync: the module most different from a normal CRUD app)

- **eventId**, **updated per D-006 (Session 3).** The original formula published here, `${deviceId}:${sessionId}:${sequenceNumber}`, is **not constructible from what the firmware currently transmits**: neither `sessionId` nor `sequenceNumber` exists anywhere in the packet format, and `MeshPacket.id` is a 10-bit rolling counter OR'd with 22 random bits, re-seeded at every boot (`Router.cpp:168`), a flood-dedup token, not a sequence. Two keys replace it:
  - **Packet dedup key**, `GatewayEvent.eventId = sha256(nodeNum : packetId)`. `nodeNum` is an unsigned 32-bit value derived from the MAC, so every schema types it `BigInt`: Postgres `integer` is signed and overflows above 2147483647. Unique index on the ingestion table; on conflict, no-op (don't re-read the row unless you need the original result to return the same response).
  - **Episode correlation**, a *lookup*, not a hash: find an open `Incident` for the device whose `lastEventAt` is inside the episode window; append if found, create if not. A hash-bucket key splits one SOS across two Incidents whenever an episode straddles a bucket boundary. The lookup belongs to `incidents` (`IncidentsService.correlateSos`, called inside the ingestion transaction); `gateway-sync` never queries the `Incident` table.

  Rationale, alternatives rejected, and schema consequences: **D-006** in `00-project-context/03-decisions-and-risk-register.md`. Worked design: `treklink-web/specs/gateway-sync/design.md` §1.1–§2.4.

  > **Open, per D-008**: the firmware is editable this term. Adding a real boot-`sessionId` and a per-packet `sequenceNumber` firmware-side would make the original formula constructible and is a strict improvement. The split key above is correct and functional either way, treat a firmware-side sequence as a layered upgrade, not a prerequisite.

- **SQLite queue (gateway side)**: a single table `event_queue(id, event_id, priority, payload, created_at, retry_count)`, flushed in `ORDER BY priority ASC, created_at ASC` on reconnect. Keep this logic in the gateway package, isolated from MQTT transport code, so it's unit-testable without a live broker.
- **Backend ingestion**: the idempotency check and the Incident-creation side-effect must be in the same DB transaction, never "check then create" as two separate round-trips, or a concurrent duplicate delivery races past the check (this is exactly what the register's 20-simultaneous-events NFR is testing for).

---

4. Module Isolation & Parallel Team Scaling

To let 4 teammates work TP2–TP5 concurrently without merge conflicts:

1. **One module = one folder = one owner-of-the-day**. Don't let two people edit `src/modules/devices/` on two different branches simultaneously without coordinating.
2. **Cross-module calls only through exported services**, never through direct repository/entity imports (see §1.1). This is what actually prevents merge hell, two people can safely add fields to their own module's entity without stepping on each other.
3. Frontend can dev against `specs/{module}/api-design/*.md` contracts (mocked) before the real backend endpoint exists, this is why the API design doc is written **before** implementation, not after.

---

5. Frontend Architecture: Feature-Sliced Design (FSD)

```
frontend/src/
├── app/         # Router, providers (QueryClientProvider, AuthProvider), global styles
├── pages/       # Route-level screens: DashboardPage, TripMonitorPage, DeviceFleetPage (composition
only, zero raw API calls)
├── widgets/     # Large compositions: LiveMapWidget, IncidentQueueWidget, DeviceTable
├── features/    # User-triggered actions: CreateBookingModal, AcknowledgeIncidentButton,
CheckOutDeviceForm
├── entities/    # Domain representations: DeviceBadge, IncidentStatusPill, TripCard
└── shared/      # UI kit, apiClient.ts, socketClient.ts, hooks, utils
```

- **Dependency rule**: `shared → entities → features → widgets → pages → app`. Lower layers never import from higher ones.
- `monitoring`'s live map and WebSocket subscription logic belongs in `widgets/LiveMapWidget`, built on `shared/socketClient.ts`, keep the Leaflet map instance and the Socket.io listener encapsulated there, not spread across pages. The map provider, style URL, credential and default viewport come from `shared/config/map.ts`; no component imports a provider SDK directly or inlines a tile URL (**D-031**, **D-015**, and `06-frontend-conventions.md` §4 Pattern B).

Business parameters are configuration, never constants (D-015)

No business parameter appears as a literal anywhere in the codebase, not in a service, not in a DTO default, not in a component, not in a migration.

What counts as a business parameter: anything a stakeholder could reasonably want changed without a code deploy. Prices, fees, deposits, percentages, thresholds, timeouts, retry counts, batch sizes, queue limits, window durations, cadences, priority mappings, and the map viewport. If the answer to *"could the agency want this different next season?"* is yes, it is configuration.

Where they live: backend and gateway read from environment configuration through a typed config module; frontend from `import.meta.env` through a typed config object. Values that must be editable by an Admin at runtime, pricing, fee schedules, alert thresholds, belong in the database behind an Admin screen, not in `.env`.

The Configuration Matrix is mandatory and is a graded artifact. Every parameter is registered with `Parameter · Current value · Location · Configurable? · Tested? · Demo?`. A parameter that cannot be changed and *shown* changing during a demo is a defect, not a style preference, the first question in the faculty handbook's most-asked list is "can this number be changed? show me now," and hardcoding is its second-ranked cause of project failure.

Known TrekLink parameters that must be configuration from the moment they are written: SOS beacon cadence (5 s for the first minute, then 30 s), episode-correlation window and backward grace, cadence-anomaly threshold, P0–P3 tier mapping, MQTT topic prefix, reconnect period, queue flush batch size, gateway→cloud sync target (≤5 s), battery warning thresholds, rental rate, deposit, late fee, damage fee, and map provider/style/viewport.

Backend Code & REST API Conventions (NestJS)

> **Contractual Consistency**: every endpoint, validation rule, error response, and transaction must conform to one predictable standard, the one already established in `API_Design_Template.md`, not a generic REST convention imported from elsewhere.

---

1. The Standard Module Structure

Every feature within a module (`src/modules/{module}/`) follows the same file set, no separate Command/Query folders; NestJS services are already a natural CQRS-lite (a service method is a command or a query, distinguished by whether it mutates):

```
modules/devices/
├── devices.module.ts
├── devices.controller.ts       # thin — maps HTTP to service calls
├── devices.service.ts          # business rules, FSM, transactions
├── dto/
│   ├── create-device.dto.ts    # class-validator decorated request shape
│   ├── update-device-status.dto.ts
│   └── device-response.dto.ts  # what goes inside `result`
├── entities/ (or a schema.prisma slice)
│   └── device.entity.ts
├── device-fsm.ts                # transition table (see 04-architecture-conventions.md §2.1)
└── devices.service.spec.ts / devices.controller.spec.ts
```

1.1 Service Method Invariants

- **Mutating methods** (`create`, `updateStatus`, `retire`, …): return the minimal DTO needed by the caller, never the raw ORM entity, never an over-fetched aggregate.
- **Read methods** (`findAll`, `findById`, …): never mutate, never trigger side effects (no notification dispatch from inside a `findById`).

---

2. Input Validation

Validation runs **before** the controller method body executes, via NestJS's global `ValidationPipe` + `class-validator` decorators on the DTO, this is the direct equivalent of a "pipeline behavior," no extra library needed.

```
export class CreateDeviceDto {
  @IsString() @IsNotEmpty()
  hardwareVariant: string;

  @IsEnum(DeviceStatus) @IsOptional()
  status?: DeviceStatus;
}
```

Golden Rules

1. **Zero hardcoded error strings in controllers/services.** Centralize error codes in `common/errors/error-code.enum.ts` (e.g. `DEVICE_NOT_FOUND`, `INVALID_STATE_TRANSITION`, `DUPLICATE_EVENT_ID`).
2. **Field-scoped errors**: `class-validator`'s default output already includes the offending property, pass it through in the `message`, don't flatten it away.

3. The Canonical Response Envelope (binding: from `API_Design_Template.md`)

This supersedes any other backend framework's default response shape. **Every** endpoint, success or failure, returns this exact shape:

```
{
  "result": { "...": "..." },
  "isSuccess": true,
  "statusCode": 200,
  "message": "Sign in successfully"
}
```

Failure example:

```
{
  "result": null,
  "isSuccess": false,
  "statusCode": 400,
  "message": "userName is missing."
}
```

3.1 Implementation: Global Interceptor + Exception Filter

```
// common/interceptors/response.interceptor.ts
@Injectable()
export class ResponseInterceptor implements NestInterceptor {
  intercept(ctx: ExecutionContext, next: CallHandler) {
    const res = ctx.switchToHttp().getResponse();
    return next.handle().pipe(
      map((result) => ({
        result: result ?? null,
        isSuccess: true,
        statusCode: res.statusCode,
        message: 'Success',
      })),
    );
  }
}

// common/filters/http-exception.filter.ts
@Catch()
export class GlobalExceptionFilter implements ExceptionFilter {
  catch(exception: unknown, host: ArgumentsHost) {
    const res = host.switchToHttp().getResponse();
    const status = exception instanceof HttpException ? exception.getStatus() : 500;
    const message = exception instanceof HttpException
      ? (exception.getResponse() as any).message ?? exception.message
      : 'Internal server error';
    res.status(status).json({ result: null, isSuccess: false, statusCode: status, message });
  }
}
```

Register both globally in `main.ts` so no controller ever hand-rolls a response shape.

3.2 Paged Collections

Nest the standard `PagedResultDto` **inside** `result`:

```
{
  "result": {
    "items": [ "..." ],
    "pageNumber": 1,
    "pageSize": 20,
    "totalCount": 142,
    "totalPages": 8
  },
  "isSuccess": true,
  "statusCode": 200,
  "message": "Success"
}
```

4. Status Code & Error Taxonomy

HTTP Status	When
`200 OK`	Successful read or mutation with a body
`201 Created`	Resource created, still uses the same envelope (not a bare Location header pattern)
`400 Bad Request`	DTO validation failure
`401 Unauthorized`	Missing/expired JWT
`403 Forbidden`	Valid JWT, insufficient role/CASL policy
`404 Not Found`	Resource doesn't exist
`409 Conflict`	State-transition violation (e.g. renting an already-`Rented` device), duplicate unique field
`500 Internal Server Error`	Unhandled, logged with a trace ID, generic message returned to client

Controllers **never** contain `try/catch` for expected errors, throw NestJS `HttpException` subclasses (`BadRequestException`, `ConflictException`, ...) and let `GlobalExceptionFilter` shape the response.

5. Controller Standards

```
@Controller('api/devices')
export class DevicesController {
  constructor(private readonly devicesService: DevicesService) {}

  @Post()
  @UseGuards(JwtAuthGuard, PoliciesGuard)
  @CheckPolicies((ability) => ability.can('create', 'Device'))
  @ApiResponse({ status: 201, type: DeviceResponseDto })
  async create(@Body() dto: CreateDeviceDto) {
    return this.devicesService.create(dto);
  }
}
```

Three steps only: map input to a DTO, call the service, return the DTO (the interceptor wraps it). No business logic in controllers.

6. Async, Transactional & Concurrency Standards

1. **Async everywhere**: all DB/MQTT/HTTP I/O is `async` / `await`.
2. **Atomic units of work** for multi-table writes:

```
await this.dataSource.transaction(async (manager) => {
  await manager.save(Rental, rental);
  await manager.update(Device, deviceId, { status: DeviceStatus.RENTED });
});
// (Prisma equivalent: prisma.$transaction([...]))
```

3. **Concurrency control**: the gateway-sync idempotency check + Incident creation MUST happen inside one transaction (see `04-architecture-conventions.md` §3), this is exactly what the register's concurrent-event NFR (20 simultaneous submissions, 0 duplicates) verifies. Use a DB-level unique constraint on `eventId` as the last line of defense, not just an application-level check.

Frontend Code & UI/UX Conventions (React + TypeScript)

> A client application is the bridge between human intention and backend systems. TrekLink's frontend serves four different roles (Admin/Staff/Guide/Customer) on one responsive web app, UI code must be structured, accessible, resilient to gateway/network latency, and intuitive under field conditions (Guides may be on a phone browser at a trailhead).

1. Architectural Layout (Feature-Sliced Design)

See `04-architecture-conventions.md` §5 for the folder layout. Same dependency rule: `shared → entities → features → widgets → pages → app`.

2. State Management: The Triad Standard

State Type	Responsibility	Standard Tooling	TrekLink example
Server state	Cached remote API data, refetch, mutation	**TanStack Query**	Device list, trip roster, incident list
Client/UI state	Ephemeral, local presentation	`useState` / **Zustand**	Map zoom level, active dashboard tab, modal open/close
Live/streaming state	Real-time push data, not a cache-and-refetch fit	**Socket.io client**, held in a dedicated store/hook	Live device positions, incident notifications, gateway connectivity status
Form state	Input tracking, validation, dirty checks	**React Hook Form + Zod**	Booking form, device check-out form, incident acknowledgment note

Invariants

- Never duplicate server state fetched via TanStack Query into a global store.
- **Live/streaming state is its own category** (not server state, not client state), Socket.io events (`incident:new`, `device:telemetry`) update a small dedicated store (Zustand) that widgets subscribe to; don't force WebSocket pushes through TanStack Query's refetch model, and don't let every widget open its own socket connection, one shared `socketClient.ts` in `shared/`.

3. The Core UX Rule: 4 Steps, 6 Fields

- **≤4 sequential steps** for any multi-step flow (booking, device check-out wizard, incident resolution form).
- **≤6 fields per step** (ideal: 3–4).
- **Single-column by default.** Labels above fields, never placeholder-as-label. Consistent required-field marking.

TrekLink-specific: the **incident acknowledgment** flow (Guide/Staff side) is time-critical, keep it to a single step, 2 fields max (acknowledge button + optional note), since the NFR target is a WebSocket-to-acknowledgment path measured in seconds (MTTA), and every extra field/step adds real seconds to that metric.

4. Reusable Screen Patterns

Pattern A: List & Search (Device Fleet, Bookings, Incident Queue)

```
+-------------------------------------------------------------------------+
| Search & Filters: [ Q Search device ID... ] [ Status v ] [+ Register]|
+-------------------------------------------------------------------------+
| [ ] Device ID    Variant   Status      Battery   Last Seen  Actions  |
| [ ] TL-0042      v3        In-Field    68%       2m ago      [... v] |
+-------------------------------------------------------------------------+
| Showing 1-20 of 57 devices                          < [ 1 ] 2 3 ... > |
+-------------------------------------------------------------------------+
```

Every list renders through `CollectionView` (§9); this sketch is its Details view. Destructive/state-changing actions (retire a device, cancel a rental) open a confirmation dialog first (§9.6). Empty states get an informative message + CTA, never a blank table.

Pattern B: Live Monitoring Dashboard (Staff/Admin/Guide)

- **Leaflet** map as the primary widget, rendering **OpenStreetMap** raster tiles (**D-031**); device/trip markers show status by a shape or glyph as well as colour (1.4.1), at 3:1 against the tiles (1.4.11); incident markers pulse at most 3 times per second (2.3.1), stop pulsing after 5 s or do not pulse at all under `prefers-reduced-motion`, and the map offers a pause control for any pulse still running (2.2.2); every marker is reachable from a keyboard-operable list beside the map (2.1.1, 2.5.7).
- **Map provider is configuration, never a literal** (**D-031**, **D-015**). The provider name, tile URL, attribution, key and default viewport come from config so the base map can be swapped without touching component code:

  ```
  // shared/config/map.ts — values from import.meta.env, never inlined
  export const mapConfig = {
    provider:    env.VITE_MAP_PROVIDER,     // 'osm'; 'goong' is dormant (D-031)
    tileUrl:     env.VITE_MAP_TILE_URL,     // https://tile.openstreetmap.org/{z}/{x}/{y}.png
    attribution: env.VITE_MAP_ATTRIBUTION,  // must stay visible on the map
    mapKey:      env.VITE_MAP_KEY,          // Goong only; unset while OSM is the provider
    center:     [env.VITE_MAP_CENTER_LNG, env.VITE_MAP_CENTER_LAT],
    zoom:       env.VITE_MAP_ZOOM,
  };
  ```

  Dormant Goong notes, kept for a switch back: style variants `goong_map_web` (full icons), `goong_map_highlight` (minimal icons), `goong_satellite`. Goong issues **two credentials**, a **Map Key** for style and tile URLs, and a separate **API Key** for Autocomplete, Direction, Geocoding, Distance Matrix and Place Detail. Do not conflate them.
- **Sovereignty overlay, mandatory.** OpenStreetMap base layers label Hoàng Sa and Trường Sa with foreign toponyms, and Nghị định 174/2026/NĐ-CP Art. 93(3)(a) penalises failing to depict sovereignty fully (30–40 M VND, plus forced removal of the application). The map therefore always carries a Leaflet overlay that labels both archipelagos in Vietnamese as Vietnamese territory. OpenStreetMap is accepted for the course only (D-031, R11); a public deployment beyond it switches the provider back to Goong. Any change of base map requires a fresh check over ~16.5°N 112.0°E and ~9.7°N 114.0°E, with the screenshots filed as evidence.
- **OpenStreetMap tile usage policy**: attribution visible on the map, a named User-Agent and a valid Referer, no cache bypass, and no bulk prefetch, so no offline tile download.
- If Goong is re-enabled, its map key is visible in the browser by design. Restrict it with an HTTP-referer allowlist and a per-IP rate limit.
- A connectivity indicator per gateway (last-seen timestamp, "syncing" vs "stale"), this directly surfaces the NFR the register cares about, don't hide it in a tooltip.
- Incident queue panel sits beside the map, not below the fold, an active SOS should be visible without scrolling.

Pattern C: Add/Edit Form

Field order identical between Add (empty) and Edit (pre-filled) modes. Primary submit bottom-right; ghost-styled Cancel.

---

5. Keyboard Navigation & Accessibility (WCAG 2.2 AA)

1. Tab/Shift+Tab in logical visual order, never `tabindex > 0`.
2. Enter submits the focused form.
3. Escape closes the active modal/drawer, returns focus to the trigger.
4. Space toggles checkboxes/switches.
5. Arrow keys navigate composite controls (toolbars, tabs, menus, the incident queue list) with roving `tabindex`, one tab stop per control. A read-only table stays a native `<table>`.
6. Every interactive element has a visible focus ring, ≥3:1 contrast, never `outline: none` without a replacement.
7. Focus is never hidden by sticky content (incident banner, command bar, table header): set `scroll-padding-top` (2.4.11).
8. Every pointer target is at least 24 by 24 CSS px (2.5.8, AA; links inside a sentence are exempt, §10.7). Primary controls are at least 44 by 44 CSS px, the team's stricter rule taken from 2.5.5 (AAA). A primary control is the page's main action, a dialog's confirm button or the SOS acknowledge button; this definition holds wherever chapter 06 says "primary control".
9. Text meets 4.5:1, icons and boundaries 3:1 (1.4.3, 1.4.11).
10. Every icon and marker has a text alternative (1.1.1).
11. Status changes, form-level errors and new incidents are announced through a live region, polite, or assertive for an SOS (4.1.3).

Known exception (leader, 2026-11-03, D-096): the handover signature pad is drawing only, with no typed alternative; it is recorded against 2.5.1 and 2.5.7 and revisited if a reviewer raises it.

---

6. Client API & Validation Contract Mirroring

6.1 Centralized API Client

No raw `fetch` / `axios` in components. `shared/apiClient.ts` owns:

- Base URL/env config, Bearer token injection.
- **Silent refresh interceptor**: intercepts 401, calls `/api/auth/refresh`, replays the original request.
- Unwraps the standard envelope (`{ result, isSuccess, statusCode, message }`) once, centrally, components consume `result` directly, they never see the envelope.

6.2 Validation Schema Parity (Zod ↔ class-validator)

Mirror the backend DTO exactly:

```
export const CreateDeviceSchema = z.object({
  hardwareVariant: z.string().min(1, { message: 'Hardware variant is required' }),
  status: z.enum(['AVAILABLE', 'MAINTENANCE']).optional(),
});
```

6.3 Inline Error Mapping

Since the backend envelope's failure `message` is a single string (not a field-scoped array, see `05-backend-conventions.md` §2), field-level mapping happens **client-side first** via the mirrored Zod schema before submission; a server-side 400 falls back to a form-level (not per-field) error banner using `message`, announced with `role="alert"`; client-side field errors set `aria-invalid` and are linked with `aria-describedby`.

---

7. Screen Design Checklist (SD phase, D-053)

Each screen is designed before it is coded, as one file `treklink-web/specs/frontend/ui-design/<route-slug>.md` from the template in that folder's `README.md`. The layout itself is a wireframe image (PNG or SVG, any tool) committed next to it. The design is done when every box is ticked:

- [ ] **Route and roles** match `specs/frontend/design.md` §2; what each role sees or cannot see is stated.
- [ ] **Data**: every field shown names its source (`api-design` file and response property); nothing is shown that no endpoint returns.
- [ ] **Actions**: every button names the endpoint it calls, its confirmation if irreversible, and the message on success (MSGnn).
- [ ] **States**: loading, empty, error (one row per error code the endpoints return, with its message), forbidden or not found (MSG26), and success.
- [ ] **Forms**: at most 4 steps of at most 6 fields (§3); every field has its label, type, required flag and the validation rule mirrored from the DTO (§6.2).
- [ ] **Mobile**: the 360 px layout is drawn for the operator's incident and map screens (NFR-UI-01); other screens state how they collapse (§10.5); every screen reflows at 320 CSS px (1.4.10).
- [ ] **Accessibility**: tab order, focus target after each action, text alternative for every icon and marker, target sizes, live announcements, contrast (§5).
- [ ] **Live data**: which WebSocket events refresh the screen and which query keys they invalidate.
- [ ] **Traceability**: the use case, the FRs and the backlog story the screen serves.

8. UI and UX Practices

Applied by every screen; a reviewer cites the item number.

1. **One primary action per screen**, visually distinct; destructive actions are secondary and confirm with the object's name ("Retire device TL-0042?").
2. **Consistent placement**: page title and primary action top right of the header, filters above the table, row actions at the row end.
3. **Status is never colour alone**: every state badge carries its label as a short word ("Rented", "Not heard"), never the enum name; the detail sits beside the badge as plain text that can wrap ("since 11:20, 3 h ago"), because the badge truncates in dense views; colour follows one palette per lifecycle across the app.
4. **Tables**: rendered by `CollectionView` (§9), sortable by the columns a user filters on through header buttons with `aria-sort`, paged by the server (§4 Pattern A), with the empty state explaining what to do next.
5. **Feedback within 1 s**: a button shows its pending state at once and is `aria-disabled` until the server answers, so focus stays on it; never a silent double submit.
6. **Errors say what to do**: show the server's `message`; next to it, the one action that fixes the case (retry, edit field, contact Staff).
7. **Preserve input**: a failed submit keeps every field; leaving a dirty form asks first.
8. **Times and money**: times in the viewer's timezone with the zone shown inline, or in a tooltip that follows §9.5; VND with thousands separators, never decimals.
9. **Alerts outrank everything**: the incident banner (REQ-EVT-01) sits above every page and is never covered by a modal. A new SOS is announced with `role="alert"` even while a dialog is open: while a modal dialog is open the alert is also rendered inside that dialog, because a screen reader treats content outside a modal as inert and would not announce it; the banner's action is reachable once the dialog closes, and a dialog open at that moment shows an Open incident button (leader, 2026-11-03, D-096).
10. **Sandbox and disclaimers** are visible, never hidden in a tooltip (NFR-UI-03, NFR-LEG-05).

11. **Reuse before inventing**: a new pattern needs a component in `shared/ui` and a line in the PR's Design section saying why the existing ones did not fit.

---

9. CollectionView: One Module Renders Every List of Records (D-096)

Every list of records (devices, contracts, invoices, members, maintenance jobs, audit entries) renders through one shared module, `CollectionView`, in `shared/ui/collection-view/`. It is a library component: it knows nothing about a module, an endpoint or the server's result set. A page supplies the data, the fields and the actions; a page never builds its own table, card grid, selection logic or toolbar. §4 Pattern A is the Details view of this module. Page layout around it is §10.

9.1 What a page supplies

Input	Content
`items`	The current page of a TanStack Query result, paged by the server (§8.4)
`fields`	Key, label, renderer, `sortable`, `hideWithPane` (§10.8), and which fields the compact views show
`itemName`	The text that names one item in accessible names and confirmations ("TL-0042")
`itemActions`	Plain per-item actions: icon, label, handler, permission
`transitions`	The allowed state transitions per item, from the module spec's state machine (D-030), filtered by the caller's CASL abilities
`bulkActions`	Actions that apply to a selection
`views`, `defaultView`	The views this collection offers
`details`	The fields, image slot and links the details pane shows (§9.8)
`emptyState`	Message and call to action (§4 Pattern A)

9.2 Views

View	Layout	Markup
Details	Table, one column per field; the default view	Native `<table>`, `<caption>` with the collection name, `<th scope="col">`
Grid	Dense tiles	`<ul>` of `<li>`
Small, Medium, Large cards	Cards of three sizes	`<ul>` of `<li>`, each card titled by a heading with the item name

The List view is removed (leader, 2026-11-06): the Details list is the default everywhere, and Grid and the three card sizes are extra choices in the View menu, shaped after the Claude Design canvas "Contract Home" (artboards 7 to 10) while the rules of §11 win where the canvas is older. The Details view is a native table. It becomes an ARIA `grid` only if the full grid keyboard model is built.

The view switcher is one split button, never a row of icon buttons (§10.2): the icon button shows the current view and switches to the next one on click (its name says both, "View: Details list. Switch to Grid"); the chevron button beside it opens the menu of all views. Each menu item carries the view icon and name, and the current one says "(current)" in its text, so the state is not shown by an icon alone (1.4.1). Filter and Sort follow the same pattern ("Show: ", "Sort: "). Switching view keeps the selection, the search, the filter and the sort.

9.3 Command bar

Exactly one row above the items at 1280 px (52 px high), sticky at the top of the collection. A second row is not allowed: what does not fit becomes a dropdown (§10.2). Left to right:

1. **Select-all checkbox**, tri-state (§9.4).
2. **Commands**: with no selection, the collection commands (Register device, Export); with a selection, the bulk actions, named verb plus count ("Check in 3 units").
3. **Selection count**: "3 selected" and a Clear selection button, shown only while items are selected.
4. **Search** field with a visible label or a programmatic name ("Search devices"); a placeholder is never the only label (§3).
5. **Show (filter), Sort, View** dropdowns and the Details pane toggle (`aria-pressed`), right-aligned. The result count is in the Show dropdown text and in the collection's live region; while a search is active a short visible "N match" appears next to the field.

Command buttons may show a short visible label ("Live map") when their accessible name is longer ("Show 3 units on live map"); the visible label appears inside the name (2.5.3).

- The bar is a `role="group"` with an `aria-label`, not a `role="toolbar"` unless Arrow-key navigation is built across all its controls (4.1.2).
- The select-all checkbox, the Clear selection button and the search field are tab stops of their own; the search field stays outside any toolbar because Left and Right Arrow edit its text.
- A list with nothing to filter, sort or switch (one or two records, such as a contract's invoices) hides its command bar; its item actions stay.
- At phone width the bar stays one row (§10.5).

9.4 Selection

1. Every item has a checkbox named "Select ".
2. Click or Space toggles one item and sets the range anchor. Shift+click and Shift+Space select every item from the anchor to this one.
3. The select-all checkbox selects **the items on the current page only**, never the server's matches across pages: the module holds no knowledge of the result set beyond the page it was given (leader, 2026-11-03). It shows checked, unchecked or mixed through the native `indeterminate` property of the `<input type="checkbox">`, never `aria-checked` (ARIA in HTML: authors must not set `aria-checked` on a native checkbox).
4. **A search, filter or sort change clears the selection** and the live region says "Selection cleared" (leader, 2026-11-03), so a bulk action never acts on items the user can no longer see. A view change keeps it (§9.2).
5. Escape clears the selection when no tooltip, menu or dialog is open. Escape always closes the innermost open layer first: tooltip, then menu, then dialog, then selection.
6. Bulk actions are named verb plus count plus noun ("Check in 3 units", "Retire 2 devices"). The accessible name is the same text.
7. Selection never requires dragging: no drag-to-select, and no drag reorder without an equivalent button (2.5.7).

9.5 Per-item actions and tooltips

Per-item actions are visible on every item in every view; they are never revealed on hover only. Show details (an Info icon) holds the inline-end slot of every item's actions: rightmost and last in the tab order (§11.4); in the phone Actions menu it stays the first item (§9.8).

A plain action is an icon button:

- Its tooltip text is the verb ("Edit"). Its accessible name starts with the same text and adds the item ("Edit TL-0042"), so the name contains the visible label (2.5.3).
- The tooltip appears on pointer hover **and** on keyboard focus, stays while the pointer moves onto it, stays until hover and focus leave, and closes on Escape without moving focus (1.4.13). It is `role="tooltip"`.

- The native `title` attribute alone is not acceptable: it does not show on keyboard focus or touch and cannot be dismissed. Do not combine `title` with this tooltip.

9.6 State transitions

A state-machine transition (Active to Inactive, In Field to Return Due) is chosen from a Change status dropdown on the item:

1. The status badge itself is the menu button (`aria-haspopup="menu"` , `aria-expanded` , §11.3): its visible text is the current status (§8.3) and its accessible name starts with it ("Active, change status of TL-0042", 2.5.3).
2. The menu lists only the transitions allowed from the current state for this user. Transitions that are not allowed are absent.
3. Destructive transitions come last, after a separator, named as verbs ("Retire device").
4. Menu keyboard: Enter, Space or Down Arrow opens and focuses the first item; Up and Down Arrow move; Home and End jump; Escape closes and returns focus to the menu button.
5. Choosing a transition opens a confirmation dialog (§8.1): the title names the object and the change ("Mark TL-0042 inactive?"), the confirm button repeats the verb, and initial focus is on Cancel for a destructive transition. On close, focus returns to the menu button, or to the next item if the item has left the result set.
6. In the bulk commands, the transition menu lists only transitions allowed for every selected item.

9.7 Accessibility contract

Requirement	WCAG 2.2
Toggle buttons expose `aria-pressed` ; menus, menu buttons, checkboxes and dialogs expose role, name and state	4.1.2 Name, Role, Value
Dropdowns are menu buttons: Enter, Space and Down Arrow open, Arrow keys move, Escape closes and returns focus to the button	2.1.1 Keyboard
Every target is at least 24 by 24 CSS px; primary controls (§5 item 8) are at least 44 by 44, the team's stricter rule taken from 2.5.5 (AAA)	2.5.8 Target Size (Minimum)
A sortable column header is a `<button>` inside the `<th>` ; the sorted column carries `aria-sort="ascending"` or `"descending"` , the others carry none	1.3.1, 4.1.2
Selection count, result count, sort and page changes are announced through one polite live region per collection, present in the DOM before its first message ("3 selected", "57 devices, showing 1 to 20", "Sorted by Last seen, descending"); search announcements are debounced	4.1.3 Status Messages
Focus is visible (§5 item 6) and never hidden behind the sticky command bar or the incident banner: the scroll container sets `scroll-padding-top` to their combined height	2.4.7, 2.4.11 Focus Not Obscured (Minimum)
Status is shown as text in every view, never by colour alone; text on a coloured badge meets 4.5:1	1.4.1, 1.4.3
Tooltips follow §9.5	1.4.13
At 320 CSS px, every view reflows without horizontal page scroll; the Details view scrolls inside its own region with the hints of §10.6	1.4.10 Reflow

9.8 Details pane

One shared pane in `CollectionView` . Every item offers Show details (the inline-end slot of its actions, and first in the phone Actions menu), and the command bar has a Details pane toggle with `aria-pressed` . The pane shows the item's fields, its image slot where the record has one, every item action as a labelled button with any unavailable reason as text, the status badge menu of §11.3, and a link to the full page. Where it sits on each width is §10.8.

---

10. Page Layout (D-096)

These rules apply to every working page, not only to lists.

10.1 Vertical space first

Vertical space decides how much content a person sees at once, so it outranks every other layout concern on a working page.

1. Page chrome above the first item (header, lifecycle, action bar, tabs, command bar) takes at most 160 px at a 1280 by 800 viewport; each block states its height in the design.
2. A control set that would wrap to a second line becomes a dropdown or moves into a More menu; it never adds a row (§10.2).
3. One sticky bar per scroll context where possible. Where the page's actions sit depends on the page kind (D-096 amends D-084 for record pages only). A record page shows one entity with tabs and no step flow (contracts first): its actions share the sticky top row with its tabs (§10.4), so when a collection command bar sits under that row the page sets `scroll-padding-top` to their combined height. A page with a step flow (counter handover, return counter, contract request, organization review, maintenance) keeps D-084's action bar fixed to the bottom and sets `scroll-padding-top` to its header and `scroll-padding-bottom` to that bar. Either way a focused item is never hidden under a sticky bar (2.4.11).
4. Density never breaks a WCAG floor: targets stay at least 24 by 24 px and primary controls 44 px (§5 item 8); text stays at the type scale; reflow at 320 CSS px still works (1.4.10).

10.2 Dropdowns instead of a second row

Control sets that would take a second row become dropdowns. First application: the six view icons became one split View button (§9.2), and the command bar fits one row.

10.3 Dropdown buttons show a chevron

Every menu button (More actions, Change status, Show, Sort, the View chevron) shows a chevron-down icon to the right of its label as the hint that it opens a list. The icon is decorative (`aria-hidden`); the button keeps `aria-haspopup="menu"` and `aria-expanded` , opens on Enter, Space and Down Arrow, and closes on Escape with focus back on the button. Plain command buttons and icon buttons carry no chevron-down, so chevron-down always means "opens a list". The scroll buttons of §10.6 use chevron-left and chevron-right, which never open a list. `Menu` in `shared/ui` draws the chevron itself, and `StateChangeMenu` takes it too, so pages do not repeat a workaround.

10.4 Compact record pages

A record page shows one entity with tabs and no step flow (contracts first). Its page chrome is compact: breadcrumb, title, status and deadline in at most 64 px; the lifecycle strip and Next step in one card of 44 to 80 px; tabs and the record's actions share one sticky top row, with `scroll-padding-top` set to its height (2.4.11). This amends D-084 for record pages only (D-096); a page with a step flow keeps D-084's action bar fixed to the bottom (§10.1 rule 3). Plain actions in command bars and on items are icon buttons with an accessible name and the tooltip of §9.5; state-machine transitions are a Change status dropdown (§9.6).

10.5 Phone layout (360 px)

On record pages: tabs pinned at the top in one row (they scroll sideways when they do not fit, §10.6); the page's actions sit in a bar pinned to the bottom, primary action widest, More actions beside it, a disabled action's reason on its own line above; the lifecycle collapses to one line ("Step 3 of 7: Active, since 10 Nov") with a disclosure that opens the full list; figures shown as stat cards on desktop become one compact definition list. The page sets `scroll-padding-top` and `scroll-padding-bottom` to the pinned bars' heights so a focused control is never hidden under them (2.4.11).

In `CollectionView` at phone width the command bar keeps one row (the select-all checkbox, a Search icon button that opens the field in place, a Sort dropdown that also holds the Show filters, the split View button); with a selection it shows the count and one Actions dropdown holding the bulk actions and status changes; each item's icon actions collapse into one

Actions dropdown, destructive ones last, while the status badge menu of §11.3 stays on the row (no "Change status:" items in the Actions dropdown; recommendation applied 2026-11-05, the leader may rule otherwise); the default view is Large cards (leader, 2026-11-06).

10.6 Sideways scroll strips

1. Any strip that scrolls sideways (tabs on a phone, a wide Details table, a chip or step row) shows, on each side that has more content, a fading edge from the surface colour and an arrow button (chevron-left or chevron-right, never chevron-down, §10.3; 32 by 44 px) that scrolls about 70 % of the visible width. The hints appear and disappear with the scroll position. The selected tab is scrolled into view on load. Scrolling is instant when the user asks for reduced motion (2.3.3).
2. The arrows are pointer aids, kept out of the tab order and hidden from screen readers: keyboard users reach every item with Tab or Arrow keys and the focused item scrolls into view (2.1.1, 1.4.10).
3. A strip that holds no focusable item (the lifecycle strip, a stepper) takes `tabindex="0"` and an accessible name while it overflows, so keyboard users can scroll it (2.1.1); it leaves the tab order when everything fits.
4. Every scroll strip is `position: relative`, so absolutely positioned descendants such as visually hidden text stay inside it; without that they widened the 360 px page and broke reflow (1.4.10).

10.7 Target size

Checkboxes are 24 by 24 px inside a 36 to 44 px label; a standalone link (an asset tag, an invoice number, Back to overview) is `inline-flex` with a 24 px minimum height (2.5.8). Links inside a sentence are exempt.

10.8 Details pane placement

The pane of §9.8 adapts to the window: from 1100 px it is a non-modal `aside` pushed aside beside the list (focus moves to its heading; Escape or the close button closes it); from 600 px the design system's `Drawer` from the right, over the page; below 600 px the same `Drawer` as a bottom sheet. Both drawers trap focus and return it on close.

While the pane is pushed aside, rows never scroll sideways and show no scroll hints: columns the pane already shows are marked `hideWithPane` and leave the table. A `hideWithPane` column also leaves when the list's own container is narrower than 1100 px, measured by a CSS container query on that container (`container-type: inline-size`), so it needs no component state. When a page has several related lists (Money: Invoices and Payments), the page names one container as `paneHost` : the pane sits beside all of them and every list in it fits the narrower width.

---

11. Leader UX rules (2026-11-05, binding for every screen)

Set by the leader on 2026-11-05 after walking the staging. They sharpen §9 and §10; where an older line differs, these win. They apply to every screen of every role, and every review checks them.

11.1 The viewport rule

A screen never scrolls by itself. Only a nested element that needs it scrolls: the list or data table, the details pane, a long form body, a log. The document never scrolls; the shell fits the viewport at every width; the page header, the command bar and the action bar never scroll away; no double scrollbars, no scroll jump on load, on selection or when a pane opens. On wide pages (devices, incidents, contracts, invoices) only the data table scrolls. Check: `document.scrollingElement.scrollHeight <= clientHeight + 1` and `scrollWidth <= clientWidth + 1` on every route; the shell height uses `dvh` at every width (recommendation applied 2026-11-05, the leader may rule otherwise). A scroll region with no focusable child gets `tabindex="0"` and a name so a keyboard user can scroll it. Exception: when the viewport is too short for the fixed bars (1280 by 1024 at 400 % zoom leaves about 318 by 236 CSS px, WCAG Understanding 1.4.10), the bars release and the document scrolls. Full-bleed pages (live map, fleet map) fit the viewport exactly; the map fills the remaining space and the device list scrolls inside itself.

Below 768 px (leader, 2026-11-10, ruled "per WCAG" on treklink-web#450): the fixed chrome shrinks to what §10.5 lists. On a record page only the tab bar (one row, sideways strip of §10.6) stays pinned at the top and the action bar at the bottom; the breadcrumb, title, status, term box and lifecycle card scroll with the tab body inside the one scroll region. On a collection page the command bar (one row, §10.5) stays pinned and the page header scrolls. The scroll region sets `scroll-padding-top`

and `scroll-padding-bottom` to the pinned bars so a focused control is never hidden (2.4.11), and the page still reflows at 320 CSS px without two-dimensional scrolling (1.4.10). Where this differs from "the page header never scrolls away" above, this paragraph wins below 768 px.

11.2 Sorting from the column header

Every sortable column header is a button that cycles **ascending, descending, default** (the list's default order). The sorted column carries `aria-sort`; an arrow shows the direction; the change is announced in the collection's live region (§9.7). A column that is itself the default order toggles only its two directions. An unsorted sortable column may show a neutral icon of a different shape from the arrows. A sort change returns to page 1. The Sort dropdown of the command bar (§9.3) offers the same orders for phone and card views.

11.3 The status is the state-change control

There is no separate "Status change" column. The status cell shows the status badge; when the user may change the state, the badge itself is the menu button of §9.6 with a chevron (§10.3) as the hint, and it opens the allowed transitions. Without an allowed transition the badge has no chevron and is not a button. The interactive badge is its own variant: a visible edge, the chevron, and a target of at least 24 by 24 CSS px (2.5.8); it is disabled during a bulk selection like the other row actions. This saves a column of horizontal space and keeps the state and its change in one place.

11.4 Per-item actions keep their place

The actions column is right-aligned. The order is fixed from the right: Show details is the rightmost action and never moves; any further action, and any action an item gains in some states, is added to its **left**. A button never shifts because another one appeared, so the user's hand finds it in the same place every time. Each list defines its action slots, ordered from the inline end by permanence: Show details, then the overflow menu when a row has three or more actions (one fixed slot next to Show details; recommendation applied 2026-11-05, the leader may rule otherwise), then the rest. An action unavailable in the current state keeps its slot, disabled with its reason (chapter 17 §6.5); an action the role never has is absent for the whole list; a new action joins at the inline-start side.

11.5 Visual WCAG check

Every screen change is checked visually against WCAG 2.2 AA (the UI standard `specs/frontend/ui-design/0-ui-standard.md` in treklink-web): screenshots at 1440, 1280, 900, 360 and 320 CSS px and at 400 % zoom (about 318 by 236 CSS px) in both themes, looked at, plus axe; vertical space first, as §10.1 says.

11.6 Where these rules live

Reviewed on 2026-11-05 by the prompt-orchestrator UI and UX session against WCAG 2.2, ARIA in HTML and the APG menu button and sortable table patterns (changes T1 to T8, approved by the leader); its notes are in the leader's side-session folder.

This section is the project-wide source. `0-ui-standard.md` in treklink-web restates the checks for builders, and the leader's prompt-orchestrator harness (`ruskicoder/system-prompts`) validates and generalizes them for every project.

11.7 Lists open on All

A collection opens on its broadest filter, "All" (leader, 2026-11-06). A narrower default that can show an empty pane while records exist is not allowed: a work queue such as "Needs review" stays a filter choice, never the default. The user's chosen filter is kept in the URL.

11.8 Map markers stay where the device is

A marker is never moved away from its real coordinates (leader, 2026-11-06; replaces the ring spread of 2026-11-05). Zoomed out, markers that would overlap become one cluster badge at the true centroid of its members, with the count, coloured by the most severe state inside (SOS first) and named for it; activating it zooms to its members. Zoomed in, markers that still overlap stay stacked at their exact positions, the most severe on top, and activating the stack lists every device at that spot. Targets stay at least 24 px.

11.9 Image preview

A thumbnail too small to read (device and hardware variant images) opens a larger preview when the pointer rests on it for 500 ms, debounced so a passing pointer opens nothing, and also on click, tap, or focus plus Enter or Space. The preview is dismissible with Escape, can be hovered, and stays until the pointer or focus leaves (WCAG 1.4.13).

11.10 Money inputs

Every price, rate and amount field uses the shared money input (D-101, leader 2026-11-06): the Vietnamese format `1.000.000 ₫`, grouped as you type and tolerant of pasted text; a "000" button, the shorthand `150k` and `1.5tr`, and preset chips with the field's common amounts. Payment amount fields add a secure keyboard toggle, off by default: an on-screen numpad with large keys and T9-style letter hints, reachable and operable by keyboard and screen reader, meeting WCAG 2.2 AA like every other control.

13: Diagram & Figure Conventions

How diagrams are authored, how figures are placed, and what the build enforces. These rules exist because these documents are **printed and photocopied** for a council, and because the most common grading outcome in this faculty is *"passed but must revise and resubmit documentation."*

1. Mermaid only

Mermaid is the only diagram language. Never PlantUML, never a drawing tool, never a screenshot of a diagram pasted back into a document. Diagrams are source, so they regenerate instead of rotting.

> **Exception (D-065, 2026-10-24)**: diagrams in graded reports, the Design Brief and review decks are PlantUML, because the course grades UML notation that Mermaid does not draw. In reports, state machine diagrams are Mermaid, and sequence diagrams stay Mermaid until the leader rules on the PlantUML trial at final delivery; every other type, activity included, is PlantUML (D-065 as amended 2026-10-26). Specs and this handbook stay Mermaid. Still never a drawing tool and never a pasted screenshot.
>
> **Report 4 exception (D-065, amended 2026-11-06):** Figures 1, 2, 3 and 5 use colour draw.io sources exported to PNG at scale 2; every other report figure follows the tool rule above.
>
> **What a PlantUML diagram may contain and where each element goes is chapter 16 (D-069).** Start every report figure from its skeleton in `_docs/02-templates/puml/`.

Pinned version: Mermaid 12.0.0, cached at `_docs/handbook/assets/`. The pin is in `build_handbook.py` (`MERMAID_VERSION`). Bumping it requires re-rendering every diagram in the corpus and checking none regressed, there is a harness for this, see §6.

1.1 The handbook gate: check, look, cross-check (D-067)

> **Every diagram, and every spec or report section a diagram is drawn from, passes three checks before it is called done: it is checked against the course mistakes handbook, its rendered image is looked at, and it is cross-checked against the other diagrams and the code.** Writing the source is not the same as finishing the figure.

The handbook is `capstone/Documents/templates/Cam-nang-tranh-loi-Capstone-SE.pdf` ("Cẩm nang tránh lỗi khi làm Capstone Project ngành Kỹ thuật phần mềm"), issued by the course. The supervisor asked on 2026-10-24 whether the team had read it, after rejecting diagrams that broke its §2 rules. Reports are graded on notation, so this gate is part of the definition of done.

Check 1: re-read the handbook section, every time

Before drafting or editing a figure, open the handbook section for its type and work from it, not from memory. A paraphrase cannot replace the source. An agent that cannot read the PDF extracts it first (`pdftotext -layout`); if it cannot do that either, it stops and says so.

Writing	Handbook sections to re-read
Use case diagram	§2.1, §2.6, §1.5 (two versions of one diagram, include and extend direction)
ERD, database design	§2.2
Architecture, deployment, IoT hardware	§2.3, §1.5
Class, state machine	§2.4
Sequence	§2.5
Context, activity, product overview, process model	§2.6
Any figure in a graded document	§1.3, §1.6 (captions below figures, cross-references, legibility)
Requirements, business rules, specs (`requirements.md` , `design.md` , SRS, SDD text)	§1.4, §1.5, §3, §4

The most frequent violations, in the team's own words; the handbook stays authoritative:

- **Context**: one external entity per box, never two merged; one arrow per direction, never a bidirectional arrow; flow labels are nouns; the system is a single process.
- **Use case**: one overview diagram that fits one page, CRUD folded into `Manage X` ; detail diagrams are extra, never a replacement. Stick-figure actors; plain lines between actor and use case; `include` and `extend` as dashed open arrows in the right direction; names are verb plus object; a use case is a function, not a step of a flow.
- **ERD**: one notation for the whole document (crow's foot or Chen) with its legend; one overall diagram; main entities at an abstract level; cardinality decided in both directions; 0..n and 1..n distinguishable. Report 4 also shows the real installed database.
- **Architecture**: overview and detail in separate figures; frontend, backend, database and every third party as separate blocks; both request and response paths; components inside the framework that contains them; every queue, socket or cache traceable to code; for IoT, a hardware diagram with each device, its specifications and its protocol.
- **Class and state machine**: class diagrams for the complex main use cases only, with correct multiplicities; every transition names its trigger; state machines in the design body, not an appendix.
- **Sequence**: numbered messages, activation bars, `:Object` names, a named page (`Login Page` , not `UI`), actor to page to controller to service to repository, `alt` split into labelled lanes, exception paths, one use case per diagram.
- **Activity**: decisions are diamonds; multi-actor flows use swimlanes (§2).
- **Every figure**: a title and caption below it, a cross-reference in the text before it, legible at print size, and the same names, actors and flows as every other figure.

Check 2: look at the rendered image

Render the figure and look at the image itself. Reading the source does not count, because layout, arrowheads, overlaps and clipped labels only exist in the render.

- An agent with image input opens the rendered PNG (or the page of the built PDF) and checks it against the Check 1 list.
- An agent without image input says so, and a human opens the image instead. The figure is not done until one of the two has looked.
- After the document is built, sample the built PDF pages that carry figures; a figure that rendered correctly alone can still be scaled below legibility in the document (§4).

Check 3: cross-check

- The same use case, actor, entity and state names across the use case, sequence, class, state, ERD and architecture figures and the SRS and SDD text (handbook §2.6, §12 D-7 checklist).

- Each architecture block points to a real path in `treklink-web` (handbook §2.3, §1.5); a block with no code yet is marked planned or left out (Review 2 checklist, roadmap).
- Each entity and attribute matches `backend/prisma/schema.prisma`; each state machine matches the state enum and the transition table in the module's `design.md`.

Record

The PR body, or the session file for `capstone` work, carries one line per changed figure: the handbook sections re-read, who looked at the render (agent or member name), and what it was cross-checked against. A figure without that line is not done, and a reviewer sends it back.

---

2. Process flows are swimlanes

> **A flow that involves more than one actor is a `swimlane-beta` diagram, not a `flowchart`.**

This is the format the course itself supplies as the worked example (`Documents/templates/Main flows_ex02.jpg`), and it is what the supervisor used for the TrekLink Main Flow set. A `flowchart` with `subgraph` blocks *looks* like lanes and is not, the lanes do not constrain layout, so the actor partition is decorative rather than structural.

```
swimlane-beta TB
    subgraph customer["Customer"]
        c1[Submit booking request]
    end
    subgraph staff["Staff"]
        t1[Confirm booking]
    end
    c1 --> t1
```

Rules:

- **One `subgraph` per actor.** Top-level subgraphs render as lanes. A lane is an actor or a system, never a phase, phases are the flow direction.
- **Orientation `TB`.** Lanes become columns and the flow runs down the page, which is what fits A4 portrait. `LR` swimlanes routinely render four to five thousand pixels wide and print at 2–3 pt.
- Node and edge syntax is flowchart syntax: `id[Rect]`, `id{Decision}`, `A --> B`, `A -->|label| B`.
- **Requires Mermaid ≥ 11.16.0.** `swimlane-beta` does not exist below that and renders as an error block. Our pin at 12.0.0 satisfies this; do not downgrade.

Use a plain `flowchart` only for structures that have no actors: context diagrams, feature trees, decision trees, architecture diagrams.

---

3. Numbering and captions

Every figure and table carries a number and a caption, and is referenced in the body as `See Figure N` or `See Table N` **before** it appears. No orphaned visuals.

Numbering is **per source document**, starting at 1. The handbook build renumbers continuously across the assembled PDF and rewrites the in-text references to match, so a document reads correctly both standalone in the repository and bound into the handbook.

Caption format, immediately after the diagram block:

```
***Figure 3***: What the figure shows, and the one thing the reader should take from it.
Placement: rotated plate, 182.0 x 249.5 mm, labels at 7.52 pt.
```

> **The separator is a colon, and it is parsed.** `build_handbook.py` matches `^\*\*\*Figure (\d+)\*\*\*:` to renumber captions and to pull each one into its figure element, and the handbook workflow's sanity check counts `Figure N:` in the rendered PDF text. A caption written with any other separator is silently dropped from the handbook. The form was an em dash until 2026-09-22 and changed with the prose sweep (D-024).

The placement clause is written by the author from the measurement harness output (§6). It is how a reviewer can tell at a glance that the figure was fitted rather than dropped in and hoped for.

---

4. Figure placement

Placement is **computed, not authored**. `plan_figure` in `build_handbook.py` renders each diagram headless, measures its viewBox and its smallest rendered label, and places it accordingly.

Rule	Value
Page orientation	A4 portrait, always. A wide diagram is turned, never the sheet
Page box	182 × 266 mm (A4 minus the handbook's 15/14/16/14 mm margins)
Legibility floor	7 pt. Above it a figure stays inline in the text column
Below the floor	The figure takes a plate page, turned counter-clockwise if turning gives it more room
Rotation	Inside the SVG coordinate system. Never a CSS transform
Caption	Upright, and inside the `figure` element so a break cannot separate the two
Sizing	Width and height both set, in millimetres. Never `height: auto`

Do not force a page break before a figure. The break is what strands captions on near-empty pages. `break-inside: avoid` moves the figure on its own and lets the text above it keep flowing.

If the build reports a figure below the floor, layout has done what it can. **Re-source the diagram**, change a `flowchart LR` to `TB`, shorten labels, reduce the chain depth, or split it into two or three figures. A figure below the floor is a *note, not a build failure*: fitting the page without clipping matters more than reaching 7 pt.

4.1 Graded documents: upright figures, the page turns instead

Leader instructions, 2026-09-25. These apply to every graded document under `capstone/Documents/reports/` (SRS, SDD, test documents, the final report) and to their slides.

1. **Every diagram is upright. Never rotate a diagram.** A page shown on a projector must not need the viewer to tilt their head.
2. **The page fits the diagram.** A wide diagram gets a landscape page of its own, as a separate landscape section; a tall one gets a portrait page of its own. The surrounding text stays portrait.
3. **Nothing is clipped or overflows.** A figure fits the page box on both axes. This is the hard requirement.
4. **The 7 pt floor is best practice, not a gate.** Aim for it; re-source or split a diagram when that is cheap. A figure that fits its page without clipping but stays below 7 pt is acceptable.
5. **The caption is the figure's title only.** No placement clause, no measurement, no status note, no explanatory second sentence. The handbook keeps its placement clause (§3); graded documents do not.
6. **A diagram carries the full information** (leader, 2026-10-19). A sequence message keeps its whole call, arguments and result; a long one is pre-broken with `<br/>` rather than shortened. Explanation that is not a message, a guard or a state

(why a step exists, which rule it enforces) goes into a Mermaid `Note`, never into the message text and never only into the surrounding prose.

Rule	Value
Page box	The report template's text area: A4, 1-inch margins; 159 x 246 mm portrait, 246 x 159 mm landscape
Inline	Up to 159 x 225 mm in the text column, leaving room for the caption
Own page	A figure below 7 pt inline gets a page of its own: portrait up to 159 x 235 mm, or landscape up to 246 x 150 mm, whichever gives it the larger scale
Rotation	None, in any graded document
Caption	Below the figure, title only (chapter 15)

The handbook PDF (§4 above) keeps its rotated plates, because the handbook is built for print and is not graded. The report generator lives in `capstone/scripts/srs/` (`measure_figures.py` computes the placement, `build_srs.py` emits the landscape sections).

Figures currently below the floor

Handbook: none. As of 2026-09-17 the corpus is 27 figures and every one clears the floor; the lowest is 7.40 pt.

Report 3 (SRS), measured 2026-10-14. Each fits its page without clipping (rule 3), so each is acceptable under rule 4. The Entity Relationship Diagram is drawn left to right, which measured higher than top to bottom; it keeps its key attributes because the SRS cites them.

Report figure	Diagram	Source size	Placement	Labels
SRS Figure 13	Feature Tree, part 1 of 4: Identity and Organizations, Asset Management, Rental Contracts	572 x 1664 px	portrait page, 81 x 235 mm	6.41 pt
SRS Figure 17	MF-01 Organization onboarding to Rental contract to Handover	1070 x 1001 px	landscape page, 160 x 150 mm	6.80 pt
SRS Figure 18	MF-02 Field data to Field Station to Cloud synchronization	816 x 1608 px	portrait page, 119 x 235 mm	6.63 pt
SRS Figure 19	MF-03 SOS to Tiered alert to Escalation	1070 x 1218 px	portrait page, 159 x 181 mm	6.74 pt
SRS Figure 22	Entity Relationship Diagram of the core entities	1973 x 1211 px	landscape page, 244 x 150 mm	4.92 pt
SRS Figure 23	Device lifecycle state machine	954 x 1709 px	portrait page, 131 x 235 mm	6.24 pt

Report 4 (SDD), measured 2026-10-18 (75 figures, rebuilt on the SEP490 Report 4 template; 41 below the floor, 30 of 73 on 2026-10-14). Each fits its page without clipping (rule 3), so each is acceptable under rule 4. The rise comes from two changes of 2026-10-18: the hardware view, and sequence messages pre-broken with `<br/>` so that Mermaid no longer hyphenates long tokens, which makes those diagrams taller. The re-sourcing already done: message numbers written into the text instead of Mermaid's `autonumber`, whose 12 px labels set the floor; the `PostgreSQL` lane folded into the repository; long sequences split into parts; `wrap` on; layout direction chosen per figure by measuring both; ERD parts and the overall ERD drawn without attribute blocks; class diagrams that grew past one concern split into core, maintenance, loss-case or compliance-case views. What remains is height or lane count: the sequence diagrams with seven lanes (page, controller, service, repository and the services of other modules) would need a third part each, which splits one use case's transaction across figures.

Report figure	Diagram	Source size	Placement	Labels
SDD Figure 1	Context diagram of the TrekLink Rental Platform	1740 x 630 px	landscape page, 246 x 89 mm	6.41 pt
SDD Figure 2	System architecture	1048 x 1881 px	portrait page, 131 x 235 mm	5.67 pt
SDD Figure 3	Deployment view	1663 x 714 px	landscape page, 246 x 106 mm	6.71 pt
SDD Figure 4	Hardware connections of the IoT part	2640 x 346 px	landscape page, 246 x 32 mm	4.23 pt
SDD Figure 5	Package diagram: backend modules and their dependencies	1688 x 1380 px	landscape page, 183 x 150 mm	4.93 pt
SDD Figure 7	Entity Relationship Diagram of the main entities	1636 x 696 px	landscape page, 246 x 105 mm	5.97 pt
SDD Figure 10	Physical schema, part 3 of 9: organizations	1434 x 785 px	landscape page, 246 x 135 mm	6.81 pt
SDD Figure 11	Physical schema, part 4 of 9: devices	1202 x 1550 px	portrait page, 159 x 205 mm	5.25 pt
SDD Figure 13	Physical schema, part 6 of 9: billing	987 x 911 px	landscape page, 163 x 150 mm	6.54 pt
SDD Figure 17	Class diagram of the organizations module	1663 x 862 px	landscape page, 246 x 127 mm	6.71 pt
SDD Figure 18	Class diagram of the rentals module	1906 x 1103 px	landscape page, 246 x 142 mm	5.85 pt
SDD Figure 19	Sequence diagram of UC-01 Register Organization	1098 x 1393 px	portrait page, 159 x 202 mm	6.57 pt
SDD Figure 22	Sequence diagram of UC-15 Request Rental Contract	1283 x 1133 px	landscape page, 170 x 150 mm	6.00 pt
SDD Figure 23	Sequence diagram of UC-17 Approve Rental Contract	1273 x 1093 px	landscape page, 175 x 150 mm	6.22 pt
SDD Figure 25	Sequence diagram of UC-20 Hand Over Devices, part 2 of 2: signed handover	1320 x 1253 px	portrait page, 159 x 151 mm	5.46 pt
SDD Figure 28	Class diagram of the gateway-sync module	1593 x 1060 px	landscape page, 226 x 150 mm	6.42 pt
SDD Figure 29	Sequence diagram of UC-06 Manage API Keys and Field Station Credentials, part 1 of 2: credential and download	1053 x 1393 px	portrait page, 159 x 210 mm	6.85 pt
SDD Figure 30	Sequence diagram of UC-06 Manage API Keys and Field Station Credentials, part 2 of 2: broker check	1157 x 983 px	landscape page, 177 x 150 mm	6.92 pt
SDD Figure 31	Sequence diagram of UC-26 Ingest Field Event, part 1 of 2: receive and attribute	1073 x 1403 px	portrait page, 159 x 208 mm	6.72 pt
SDD Figure 32	Sequence diagram of UC-26 Ingest Field Event, part 2 of 2: persist and hand off	1048 x 1300 px	portrait page, 159 x 197 mm	6.88 pt

Report figure	Diagram	Source size	Placement	Labels
SDD Figure 37	Sequence diagram of UC-29 Create Incident, part 1 of 2: correlation and routing	1094 x 1055 px	portrait page, 159 x 153 mm	6.59 pt
SDD Figure 40	Sequence diagram of UC-32 Acknowledge Incident	1125 x 1353 px	portrait page, 159 x 191 mm	6.41 pt
SDD Figure 41	Sequence diagram of UC-33 Report Incident Status	932 x 1573 px	portrait page, 139 x 235 mm	6.78 pt
SDD Figure 42	Sequence diagram of UC-35 Report to Authorities	1139 x 1183 px	portrait page, 159 x 165 mm	6.33 pt
SDD Figure 45	Class diagram of the monitoring module	1805 x 994 px	landscape page, 246 x 135 mm	6.18 pt
SDD Figure 53	Class diagram of the devices module for loss cases	1616 x 854 px	landscape page, 246 x 130 mm	6.90 pt
SDD Figure 54	Class diagram of the billing module	1431 x 1068 px	landscape page, 201 x 150 mm	6.37 pt
SDD Figure 56	Sequence diagram of UC-43 Check In Device	1345 x 1247 px	landscape page, 162 x 150 mm	5.46 pt
SDD Figure 58	Sequence diagram of UC-44 Reset and Inspect Device, part 2 of 2: inspection	1299 x 1340 px	portrait page, 159 x 164 mm	5.55 pt
SDD Figure 59	Sequence diagram of UC-65 Scan for Due Service	1109 x 1118 px	portrait page, 159 x 160 mm	6.50 pt
SDD Figure 60	Sequence diagram of UC-52 Record Maintenance, part 1 of 2: open and estimate	1173 x 1483 px	portrait page, 159 x 201 mm	6.15 pt
SDD Figure 61	Sequence diagram of UC-52 Record Maintenance, part 2 of 2: completion	1255 x 1418 px	portrait page, 159 x 180 mm	5.75 pt
SDD Figure 62	Sequence diagram of UC-64 Approve Maintenance Cost	1072 x 1113 px	portrait page, 159 x 165 mm	6.73 pt
SDD Figure 63	Sequence diagram of UC-49 Report Lost Device	1068 x 1133 px	portrait page, 159 x 169 mm	6.75 pt
SDD Figure 64	Sequence diagram of UC-60 Resolve Loss Case, part 1 of 2: triage	1234 x 1270 px	portrait page, 159 x 164 mm	5.84 pt
SDD Figure 65	Sequence diagram of UC-60 Resolve Loss Case, part 2 of 2: confirmation and settlement	1077 x 1270 px	portrait page, 159 x 187 mm	6.70 pt
SDD Figure 66	Sequence diagram of UC-61 Replace Device on Contract	1076 x 1350 px	portrait page, 159 x 199 mm	6.70 pt
SDD Figure 70	Sequence diagram of UC-48 Approve Damage Charge	1170 x 1303 px	portrait page, 159 x 177 mm	6.16 pt
SDD Figure 71	Sequence diagram of UC-63 Handle Compliance Case	1295 x 1473 px	portrait page, 159 x 181 mm	5.57 pt
SDD Figure 72	Sequence diagram of UC-51 Close Rental Contract	1174 x 1423 px	portrait page, 159 x 193 mm	6.14 pt

Report figure	Diagram	Source size	Placement	Labels
SDD Figure 73	Device lifecycle	954 x 1709 px	portrait page, 131 x 235 mm	6.24 pt

If a figure ever has to be carried below the floor, record it here with its measurement and the reason the obvious fix was worse. This table is a record of deliberate exceptions, not a place to park failures, anything below 7 pt that is not listed here is a defect.

---

5. Hard rules for every figure

Enforced by the generator. Do not work around them in a source document.

1. A figure fits inside its page box on **both** axes. Nothing is clipped, cropped, or allowed to run past a margin.
2. Width and height are both set, in millimetres. Never `height: auto`, which constrains one axis and lets the other overflow.
3. A wide figure is turned counter-clockwise, **inside the SVG coordinate system**. Never with a CSS transform: a transformed box paints in one place and paginates in another, which prints content on the wrong page, clipped.
4. The caption stays upright and lives inside the `figure` element, so no break can separate it from what it names.
5. No figure forces a page break. `break-inside: avoid` moves it on its own and lets the text above keep flowing into the space.
6. **Monochrome.** A figure must not depend on hue to be understood, because these documents are printed and photocopied. Use hatching, dashes, or line weight. In Mermaid that means `style X stroke-width:3px` to emphasise a node, and `-.->` versus `-->` to distinguish edge kinds, never `fill:#1e40af`.

Raster figures

A drawn or scanned figure is placed by the same rules, fitted rather than judged, because label size cannot be measured in a bitmap.

Rule	Value
Minimum resolution	200 dpi at final print size. Below that it is not print quality
Format	PNG, tracked in `_docs/assets/`
Rotation	Not supported. A raster has no coordinate system to turn inside
Colour	Subject to the monochrome rule above

---

6. The measurement harness

Before committing a new or re-sourced diagram, measure it:

```
python3 _docs/handbook/build_handbook.py --measure _docs/00-project-context/05-main-flows.md
```

For each diagram it reports source size in pixels, smallest rendered label, the chosen placement, the final millimetre box, and the effective point size, the same computation the build uses. Paste the placement and point size into the caption.

To check the whole corpus, including after a Mermaid version bump:

```
python3 _docs/handbook/build_handbook.py --measure-all
```

A diagram that fails to render at all is a hard error and blocks the build. A diagram that renders below the floor is reported and the build continues.

---

7. Practical guidance

Rules of thumb that come from actually fitting this project's diagrams:

- **Chain depth drives height.** In a `TB` swimlane the page height is the longest path, not the node count. Merging two sequential steps buys about 100 px.
- **Lane count drives width**, at roughly 260–270 px per lane regardless of label length. Five lanes is about the practical maximum for A4 portrait. Shortening node text does *not* narrow a lane.
- **A tree with more than ~16 leaves will not fit.** Split it by branch. The TrekLink feature tree is three figures for this reason, as one diagram it renders 6696 px wide and prints at 1.58 pt.
- `<br/>` **inside a label is free vertically** and cheap horizontally. Prefer two short lines over one long one.
- **Emoji inflate width** and do not survive photocopying. Do not use them in figures.

Appendices

TrekLink: Roadmap & Milestone Calendar

> **Rewritten Session 6 (2026-09-16) against the SEP490 Fall-2026 documents.** The previous version was derived from `SWP490_Lo-trinh-Capstone_v1.0.pdf` and described a different execution model, Review 1 as a Week 4–5 window, councils at Weeks 14 and 15, and delivery organised by TP package and Iteration. The course now issues SEP490 material that supersedes it on **timing and structure**. Do not rely on any copy of the old table. See **D-013**.
>
> **Authoritative sources**, in order:
>
> 1. `capstone/Documents/course-material/SEP490_Student_Project_Execution_Schedule.pdf` (50 pp), the master schedule, weekly Definition of Done, and anti-fail checks.
> 2. `capstone/Documents/course-material/SEP490_Huong_dan_nhanh_cho_sinh_vien.pdf` (6 pp), the student summary.
> 3. `capstone/Documents/course-material/TrekLink-proposed-mainflow-ducndm.png`, **the supervisor's own Main Flow set for this project** (D-016).
> 4. `capstone/Documents/templates/Cam-nang-tranh-loi-Capstone-SE.pdf`, the faculty fault- prevention handbook. Its failure modes are graded criteria, not advice.
> 5. `FA26SE159_Register-v1.0.md` (`FA26SE159_Register-v1.0.md`) (registered v1, in `capstone/Documents/submissions/register/` ; the current form is `register-v4.0/FA26SE159_Register-v4.0.md`), governs **content** (D-000).
>
> `SWP490_Lo-trinh-Capstone_v1.0.pdf` is retained deliberately: practices it describes that SEP490 does not contradict remain in force, the phase discipline, the deliverable-ledger shape, and the **Week-6 scope lock** (§6), which SEP490 never mentions but which is real.

Project code: FA26SE159 · **Group code**: GFA26SE55 · **Supervisor**: Đặng Ngọc Minh Đức **Term start**: Monday, Sep 7, 2026 · **Working plan ends**: Sunday, Dec 20, 2026 (Week 15)

> **On the "09/2026 – 03/2027" duration** printed on the registration form and in Report 1 §1.1: that span includes the **retake window**. A group that fails at either council sits a council in the following term, around March 2027. The figure is correct as registered. **Plan for December.**

---

1. The five things to know before reading anything else

1. **Three gates, and they are checkpoints rather than start lines.** Review 1 (W4), Review 2 (W8), Faculty Council (W13), then Final Submission & Defense (W15). The faculty guide opens with *"Review là điểm kiểm tra, không phải điểm bắt đầu"*, arriving at a gate having just started the work it assesses is the standard way to fail it.
2. **Delivery is organised by Main Flow, not by module or phase.** From W3 to W12 the project is built incrementally, one Main Flow at a time, each going Prototype/Figma → detailed spec → implement → test → demo. The five flows are fixed by the supervisor (§4). The **Mainflow Coverage Matrix** is the single instrument used to confirm progress at the weekly Group Meeting.
3. **The registration form still locks at the end of Week 6.** SEP490 does not mention a scope lock; the SWP490 roadmap does, and the team lead confirms it is real. Anything the form says that current decisions contradict must be amended before then, see §7.
4. **Everything produced must have evidence, and documents must match the software.** Commit, document, screenshot, test result, meeting minute. The faculty handbook's most common outcome is *"passed but must revise and resubmit documentation"*, the product ran and the paperwork pulled the mark down. The golden rule is *"có làm mới ghi, không làm đừng ghi"*: write only what was built, and be able to point at where each written claim is implemented or tested.
5. **Everything is in English**, following the SEP490 report templates.

---

2. Gate schedule

Gate	Week	Focus	The questions the panel will ask
Review 1, Gate 1	**W4**	Proposal & Requirement	What is the problem? Who uses it? How far does scope go? Are the requirements clear and verifiable?
Review 2, Gate 2	**W8, Tue 2026-10-27** (D-058); the Review 2 period closes **Sat 2026-11-07** and the updated registration form is **locked officially Mon 2026-11-09 18:00**	System & Design	How will the system be built? Is the design clear enough to code from?
Faculty Council, Gate 3	**W13**	Final Product Evaluation	What did the group build? How do you prove it runs? Which part did *you* do?
Final Submission & Defense	**W15**	Submission	Is the package complete, consistent, and installable on a clean machine?
Retake council	~Mar 2027	—	only if W13 or W15 fails

The dual-council naming. "Hội đồng 1.1 / 1.2" is the *Hội đồng kín* terminology, conveyed through the supervisor's outline and never published as an official document. It is **not** a separate pair of events, it maps onto the table above: **Hội đồng 1.1 = Faculty Council (W13)**, **Hội đồng 1.2 = Final Submission & Defense (W15)**. Use it in internal planning; cite only the SEP490 names in graded documents and slides.

Preparation loop. Every gate is preceded by the same four-step cycle, run three times in the term: Common Meeting → team self-check → Group Meeting → fix → readiness check → gate.

```
CM1 (W1)  -> self-check -> GM -> fix -> readiness -> (foundation for the term)
CM2 (W3)  -> self-check -> GM -> fix -> readiness -> REVIEW 1  (W4)
CM3 (W7)  -> self-check -> GM -> fix -> readiness -> REVIEW 2  (W8)
CM4 (W12) -> self-check -> Mock Council -> fix -> readiness -> COUNCIL (W13)
```

Meetings. Four **Common Meetings** (all groups together) at **W1, W3, W7, W12**. A **Group Meeting** every week, ours on **Sunday**, time set by the supervisor. In a Common Meeting week the Group Meeting follows the CM, it exists to handle this group's specific problems, not to repeat what was just briefed to everyone.

Feedback is closed-loop and tracked. Every comment from any gate is recorded as `Feedback → Required Action → Owner → Deadline → Evidence → Status`, in the Review Feedback Tracker. Repeating a Review 1 mistake at Review 2 is named as a direct cause of failure, and a comment the group chooses not to follow needs a stated, defensible reason, not silence.

---

3. Week-by-week calendar

Weeks run Mon–Sun from Sep 7, 2026. "Due" means end of that week unless stated.

Wk	Dates 2026	Common Mtg	Phase	Gate / event	Deliverable due
1	Sep 7–13	**CM1** Kick-off & Working Guideline	Initiation	Group kick-off	Project Introduction · Initial Scope · Team Working Plan
2	Sep 14–20	—	Planning	WBS / timeline / risk review	**PMP Draft · WBS · Feature Tree · Mainflow list · Gantt · Responsibility Matrix · Risk List**
3	Sep 21–27	**CM2** Review 1 Clinic	Requirement + Foundation Design	SRS draft / UC / BR review	**SRS Draft · Architecture Diagram · ERD · Package Design · prioritised Mainflow list** · demo MF-01
4	Sep 28–Oct 4	—	Review 1	**REVIEW 1, GATE 1**	**Registration Form · PMP Draft · SRS Draft · Review 1 slides**
5	Oct 5–11	—	System Design	Architecture + ERD approval	Figma/prototype per Main Flow · SDD update
6	Oct 12–18	—	Detailed Design	Sequence/Class/Workflow approval · **SCOPE LOCK**	**Amended registration form, GVHD-confirmed, FROZEN**
7	Oct 19–25	**CM3** Review 2 Clinic	Design Baseline	Baseline SRS/SDD, Test Plan, readiness	**MF-01 + MF-02 complete · MF-03 in progress · MF-04/05 have Figma + spec**
8	Oct 26–Nov 1	—	Review 2	**REVIEW 2, GATE 2, Tue 2026-10-27**; package complete Mon 2026-10-26 (D-058)	**PMP Updated · SRS Final · SDD Initial · Test Plan Draft · slides** · demo MF-01,02
9	Nov 2–8	—	Implementation I	Iteration 1 review · Review 2 closes Sat Nov 7	Product v0.1 · demo highest-priority Main Flow end-to-end · **registration form updated after Review 2**
10	Nov 9–15	—	Implementation II	Iteration 2 review · **registration form locked Mon Nov 9, 18:00** · **real device and payment checkpoint (D-093)**	All Main Flows demoable on real nodes and SePay sandbox payments, no unlisted stand-ins · Coverage Matrix updated
11	Nov 16–22	—	Implementation III	Iteration 3 review + readiness	**Feature complete · Product v0.9 / Release Candidate · Configuration Matrix updated · Report 5**
12	Nov 23–29	**CM4** Council Readiness	Testing & Council Prep	**Mock Council** + buffer sprint	**STD / Test Results · Deployment Package · Demo Script** · 100 % Coverage Matrix
13	Nov 30–Dec 6	—	Final Evaluation	**FACULTY COUNCIL, GATE 3**	**Final Product · PMP/SRS/SDD/STD · Software Package · Reports 1–5 · final slides**
14	Dec 7–13	—	Finalization	Feedback closure + consistency audit	**User Guide · Installation Guide · Reports 6–7 · Final Project Package**

Wk	Dates 2026	Common Mtg	Phase	Gate / event	Deliverable due
15	Dec 14–20	—	Submission	**FINAL SUBMISSION & DEFENSE**	**Final Report · final slides · Software Package installable on a clean machine**

> **Week ↔ date mapping** assumes Week 1 is the calendar week containing Sep 7, 2026, with no holiday gaps. No Vietnamese public holiday falls inside W1–W15. Exact gate dates, rooms and reviewer assignments are notified per group; this table fixes the windows.

3.1 Two contradictions inside the SEP490 source, and how we resolve them

Flagged rather than hidden, so nobody "corrects" this file back later.

Contradiction	Resolution
Review 1 at **W4** (Roadmap table, Master Schedule 5.2, quick guide) vs **W3** (§4 prose item 2)	**W4**, two sources to one
"Two Main Flows complete at **W7**" (§4, Master Schedule 5.1) vs "Sprint 1 (**W8**) → MF-01, MF-02" (Sprint Plan)	Plan to the **stricter W7**; W8 is the confirmation demo

3.2 Continuous obligations

Not one-off deliverables; checked at every gate.

- **Group Meeting every week**, all members attend. A member who misses reviews and contributes little **fails individually even if the group passes.**
- **Individual Contribution evidence** comes from the team's own records: daily reports (chapter 12), commits and PRs, and Jira. The Progress Log and Project Tracking workbooks are dropped (D-050); they are produced from those records only if the supervisor asks for them.
- **Mainflow Coverage Matrix**, the supervisor's progress instrument. Kept current weekly.
- **Review Feedback Tracker**, every gate comment carried to a closed status with evidence.
- **Evidence habit**, commits, documents, screenshots, test results, meeting minutes.

3.3 The weekly routine

`Plan → Execute → Team meeting → Evidence → Report to GVHD → Weekly close`, closing each week as DONE / IN PROGRESS / BLOCKED / NEXT WEEK. Anything that misses its Definition of Done carries into the next Group Meeting rather than quietly disappearing.

Our own cadence, inside that frame: asynchronous daily report via GitHub Issues; online team meetings **Monday** and **Thursday**; offline meeting **Sunday**; an offline retrospective and review at each two-week sprint boundary.

---

4. The five Main Flows

Redrawn after Review 1 by **D-033** (superseding D-016 and the supervisor's original image); identifiers and owners are unchanged. These are the units the Coverage Matrix tracks, the units demoed at each Iteration review, and the units the council evaluates. Full flows: `05-main-flows.md`.

MF	Name	Substance	Owner
MF-01	Organization onboarding → Rental contract → Handover	Self-registration → verification at the counter → Admin approval → plan request (monthly or day, variant, quantity ≥ MOQ) → approval reserves devices → first payment (SePay or counter) → provisioning with the organization key → signed handover	**TanNB**
MF-02	Field data → Field Station → Cloud synchronization	Device SOS/GPS/telemetry over LoRa mesh → Field Station SQLite priority queue while offline → MQTT → NestJS; P0–P3 with idempotency; priority-ordered flush on reconnect	**KhoaDD**
MF-03	SOS → Tiered alert → Escalation	SOS → one incident per episode → primary, backup, Manager tiers with timeouts → acknowledgement, status, outcome → escalation to TrekLink and the authority report when nobody answers (D-034)	**HoangTK**
MF-04	Live telemetry: web map and organization API	Device → Field Station → backend → organization-scoped map and REST/WebSocket API with a key per organization; the Field Station's local page offline	**LongNN**
MF-05	Term end → Return → Inspection → Billing → Maintenance	Notice or day-plan end → check-in at the counter → reset and inspection → term balance, late, damage and loss charges → payment → close; device restocked, serviced or retired (D-035)	**LongLP**

E7 (DevOps/CI-CD) and E8 (Research & Experimental Evaluation) are cross-cutting and deliberately are not Main Flows. State this wherever the Coverage Matrix is presented, so their absence does not read as an oversight.

4.1 How a Main Flow is built

Each one goes through the full cycle; the system is **not** designed end-to-end before coding starts. Architecture, the foundational ERD and the technology decisions are made **once** at W3 and serve every flow.

```
Prototype / Figma
  -> detailed functional spec  (input, output, validation, business rule, happy + unhappy path)
  -> sequence + class diagram, state diagram for anything with a lifecycle
  -> API / interface spec      (endpoint, request/response, DB or third-party call)
  -> implement
  -> test
  -> demo
```

A flow whose design finishes first may be implemented first, in parallel with the design of the others. No flow enters implementation (W9–W11) without Figma **and** a detailed spec.

Traceability must hold in both directions: Main Flow → Use Case → Sequence → Class/Service → Database → Code. A reviewer will pick a requirement and walk it to the implementation, or pick a diagram component and ask which code it is.

4.2 Sprint plan

Sprint boundaries align to gates, never to a fixed drumbeat.

Sprint	Weeks	Closes on	Carries
1	1–3	Review 1 readiness (W3)	Requirements, architecture + ERD foundation, MF-01 first cycle
2	4–6	**Scope lock (W6)**	Review 1 feedback closure, MF-01/MF-02 design, **form amendments**
3	7–8	**Review 2 (W8)**	MF-01 + MF-02 complete; MF-03 in progress; MF-04/05 spec'd; Test Plan
4	9–10	Iteration reviews	MF-03, MF-04 implemented, Product v0.1
5	11	Feature complete (W11)	MF-05 + full-system integration, Release Candidate
6	12	**Mock Council (W12)**	Buffer for anything outstanding, system testing, regression, deployment, demo rehearsal
7	13–15	Councils	Council, feedback closure, user/installation guides, final report, defence

The W12 buffer is a **safety net, not the plan**. The target is every Main Flow finished by the end of W11. The council expects all Main Flows working plus at least 80 % of use cases.

---

5. Deliverable ledger and ownership

Deliverable	Planned	Owner	Reviewer	Status
Report 1, Project Introduction	W1 → W4	KhoaDD	TanNB	Draft complete
Report 2, Project Management Plan (PMP)	**W2 draft → W4 → updated W8**	**KhoaDD**	LongLP	In progress; last rebuilt 2026-10-11, the W8 update is still open
Report 3, Software Requirement Specification (SRS)	**W3 draft → W4 → final W8**	**TanNB**	KhoaDD	Draft complete 2026-10-14 (65 use cases, 110 FRs); final due W8
Report 4, Software Design Document (SDD)	W3 draft → W8 initial → W13 final	KhoaDD + HoangTK	LongLP	Initial draft 2026-10-14, generated from the specs (D-044); rebuilt 2026-10-18 on the SEP490 Report 4 template (D-048) with the database screenshot and the IoT hardware view
Report 5, Test Plan → STD & Test Results	W7 plan → W11 → W12 complete	TanNB	HoangTK	Test plan and test cases drafted 2026-10-18 on the three SEP490 templates (198 cases from the SRS, 68 unit cases); TanNB studies, runs and owns it
Report 6, User Guide	W14	LongNN	TanNB	Not started
Report 7, Final Project Report	W15	KhoaDD	all	Not started
Installation Guide	W14	LongLP	KhoaDD	Not started
Software Package (v0.1 / v0.9 / final)	W9 / W11 / W13	whole team	—	In progress: Iteration 1 (D-058) ships at the `review-2` tag on 2026-10-25. Merged 2026-10-23 to 25: platform Phases 1 and 2, 3.1, 4.2, the module-graph check and the demo seed (treklink-web#44, #47, #57, #59); sign-in, the organization account context, CASL and global guards (#48, #53, #50, #59, D-060, D-061); password reset, invitation and change password (#61); node MQTT ingestion into field events and the device projection with the replay harness (#55); incidents 1.1, persistence foundation (#56); frontend router, guards, API client, Leaflet map with the overlay and the socket client with the alert banner (#54, #58, #60, #65); the Neon link (#62, D-062). Approved, waiting for merge: account and role administration (#63). In review: the account menu (#67), the incident lifecycle (#66, changes requested). Open: the live map page (frontend 9.1), the monitoring stream (monitoring has no task ticked), real-device fixture captures; `rentals` and `billing` have no code and `organizations` only its account context (1.3) (D-066 targets five flows by 2026-10-31)
Presentation / slides	W4, W8, W13, W15	KhoaDD	all	Review 1 done; Review 2 deck v2 built 2026-10-18 on the SEP490 template as new files (`Review2_Slides_TrekLink_v2.pptx`); the 2026-09-29 deck is kept unchanged

Deliverable	Planned	Owner	Reviewer	Status
Progress Log and Project Tracking workbooks	—	—	—	Dropped 2026-10-18 (D-050); evidence is daily reports, commits and Jira
Mainflow Coverage Matrix	weekly from W3	KhoaDD	supervisor	To create

Report 3 is split across two deadlines. W4 needs the draft, Product Overview, User Requirements, System Functional Overview, Context Diagram, Actors, Use Cases, initial Business Rules, Exception Scenarios. The full EARS SRS is W8. Write the W4 draft so the W8 version grows out of it rather than replacing it.

Two UML State Machine Diagrams are named, graded deliverables (register §f): Device Lifecycle (7 states) and Incident Lifecycle (5 states). They belong in Report 4 and in `specs/devices/design.md` / `specs/incidents/design.md`, and they are visible in MF-03 and MF-05.

5.1 Module lanes

Assigned against the enrolment framework codes. `BIT_SE_NJS_18D` is the Node.js track and is treated as covering NestJS; backend capability is **3 of 5**, not 1 of 5 as previously recorded.

Member	Track	Lane	Main Flow
KhoaDD, leader	IC 19A	Prisma schema, `devices`, `gateway-sync`, `platform`, firmware, UI layout, architecture	MF-02 owner, MF-05 support
LongLP, delegate	**NJS** 18D	`auth`, `rentals`, `billing`	MF-05 owner, MF-01 support
HoangTK	**NJS** 18D	`incidents`, the `incident.alert` push (monitoring task 2.3)	MF-03 owner, MF-04 secondary
LongNN	IC 19A	`monitoring` backend (stream, `LiveGateway`, read models, Organization API), `frontend` (FSD), map and monitoring UI	MF-04 owner, backend and UI (D-056)
TanNB, delegate	IC 18D	`organizations`, QA and test lead (Report 5); secondary Meshtastic knowledge	MF-01 owner

Lanes remapped 2026-10-18 (leader): `trips` and booking left the scope with D-033, so TanNB takes `organizations`, and `platform` is named under KhoaDD.

Lanes remapped again 2026-10-21 (D-056): MF-04 had its backend in HoangTK's lane and only its screens in LongNN's, so its owner could not answer for the flow end to end. LongNN now takes the `monitoring` backend (every task of `specs/monitoring/tasks.md` except 2.3, `incident.alert` publishing, which stays with HoangTK because it is the delivery leg of MF-03). HoangTK reviews LongNN's monitoring PRs as the secondary, since MF-03 consumes `LiveGateway`. Fallback (D-056 rule 5): if task 1.1 has no open PR two working days after `platform` Phase 1 merges, or 1.1 and 2.1 are not merged before the `review-2` tag, both go back to HoangTK.

Division of work. The leader writes the specs and the full task lists (`specs/{module}/tasks.md`); members implement their lane's tasks. **Emergency cover**: KhoaDD, LongLP and TanNB take the hard parts of a lane that falls behind. In an absolute emergency, where a lane delivers nothing, the leader owns everything; the plan keeps that case as rare as possible.

Lanes run as concurrent branches across decoupled NestJS modules rather than serialising on one branch. Ramp-up for the two IC-track members on `01-conventions/05-backend-conventions.md` (`05-backend-conventions.md`) during W2–W5 is budgeted work, not slack, and is a tracked risk in the register.

---

6. ⚠️ The Week-6 scope lock

SEP490 does not mention it; the SWP490 roadmap does, and it is real (D-013). After the end of W6 the registration form is frozen, and the Faculty Council grades the product against that frozen form. Note there are now **two** baselines and they are not the same: the **requirement** baseline is set at Review 1 (W4), the **form** freeze at W6.

6.1 Supervisor questions: all closed

#	Question	Decision	Outcome
1	Keep Stage B (the basecamp bridge, renamed Stage C by D-018) or drop it?	**D-005**	**Keep, permanently.** It is the substance of MF-02. Offline NFRs and RQ1/RQ2 stay binding
2	Do firmware commits earn graded credit?	**D-008 Q3**	**Yes**, with the caveat that code volume alone is not what is assessed
3	Are targeted firmware fixes read as out-of-scope "firmware redesign"?	**D-008 Q2**	**No**, firmware enhancement and integration are in scope; only a mesh-stack rearchitecture is excluded

The supervisor's position as given on 2026-09-13: the team may change tech stack, flows and scope as it judges best, then pitch and defend the result at the next meeting. His own outline is guidance, not a restriction. **Nothing is blocked on him.** What remains is our own obligation to put the amended form in front of him before W6.

6.2 Register text to amend in the Week-6 update

The submitted form contains statements later work proved wrong. Each must be amended, or the product will diverge from the document it is graded against.

Register says	Reality	Source
"Apply PostgreSQL migrations via **TypeORM**" (§e)	Prisma, locked as team mandate	**D-001**
`eventId = Device ID + Session ID + Sequence Number` (§b, §c)	Neither field exists in firmware; key is `sha256(nodeNum:packetId)` plus open-Incident correlation	**D-006**, `04-firmware-ground-truth.md` (`04-firmware-ground-truth.md`) §3
Firmware "version-locked to Summer 2026 release" (§b)	Editable, credited, and in scope for enhancement	**D-008**
Gateway is dedicated hardware with its own uplink (§b)	Staged: Stage A = node's own MQTT; Stage B = on-device durable queue; Stage C = basecamp bridge. All in scope	**D-005**, **D-016**, **D-018**
Frontend map library	**Leaflet + OpenStreetMap** with a Vietnamese sovereignty overlay; Goong Maps dormant in configuration	**D-031** (supersedes D-012)
—	v1 hardware compiles MQTT out and is **out of the demo set**	**D-005**, ground truth §5
Booking, trek packages, Customer, Guide, trip management (§3.1.2, §3.2, §e)	Enterprise rental platform: organizations rent devices by monthly or day plan; asset management replaces booking	**D-033**
Device lifecycle of seven states with `In-Field`	Eight states with `In Intake` and `Lost`; no `In-Field`	**D-035**
Incident lifecycle of five states	Tiered-alert lifecycle with escalation to TrekLink	**D-034**
Multi-tenancy out of scope	In scope: organizations, members, roster, API keys	**D-033**

The adjusted form, with every change highlighted for the supervisors, is `treklink-docs/topics/Phieu_FA26SE159_v2_2026-10-29.md`.

> The `eventId` amendment matters most. The register makes it a **named scientific contribution** (§3.3d, "a formally defined eventId scheme") and the duplicate-prevention NFR is written in terms of it. Changing the formula silently and presenting a different one at defence is exactly what the council exists to catch. Amend the wording to the constructible form and keep the intent.

---

7. Gate readiness checklists

Before Review 1 (W4)

- [ ] Problem, target users, objective and scope stated clearly
- [ ] **Context Diagram**, Actors, Use Case Diagram complete
- [ ] FR and NFR written at a verifiable level, no "Admin manages everything"
- [ ] **Feature Tree** complete
- [ ] **Business Rule Matrix** first version, `BR ID | Business Rule | Requirement | Implementation | Test Case`
- [ ] At least one **exception scenario per Main Flow**
- [ ] Main Flow list identified and prioritised; the slides show high-level steps only, never an activity diagram (swimlane diagrams stay in the SRS)
- [ ] Deck states system or platform and names the partners (chapter 15 §3)
- [ ] Registration Form, PMP Draft, SRS Draft submitted; slides consistent with the SRS
- [ ] Use cases are functions, not workflows; `include` / `extend` / generalization used correctly
- [ ] Every decision-register item either resolved or explicitly tabled

Before Review 2 (W8)

> **Course guide, 2026-10-20** (`capstone/Documents/course-material/SWP490_R2_Huong-dan-chuan-bi-Review-2_1.pdf` , forms BM01 to BM04 in `SWP490_R2_BM04_Review2-Document.zip`). Review 2 fixes the scope for good and is the only basis for Defense 1.1 and the Viva. Four PDFs are submitted, named `SWP490_<code>_R2_<name>.pdf` :
>
> 1. Registration form, proposed final version, with the Record of Changes (BM03).
> 2. Reports 1 to 5 and Project Tracking. **Iteration 1 source code, the database script, tests and CI are in the repository under the tag `review-2` ; Iteration 1 runs and CI runs the automated tests.**
> 3. Self-review (BM02): the course's standard prompt run unmodified by a coding agent on the `review-2` tag, its output kept verbatim, plus a team response per finding (Fixed, Kept or Planned).
> 4. Design Brief (BM01): sections 0 to 8, at most 4 A4 pages, plus Appendix A (Defense 1.1 targets).
>
> Report 4 must declare the third-party services, the stack with versions, source control and CI, the environments (dev, staging, production) with deployment and rollback, and **the AI tools, models and the stages they were used in** (guide §10). Main workflows: at least one per member, each owned by exactly one member and drawn as an activity diagram in the SDD. At the review, each member opens and explains the code they own. The Defense 1.1 demo runs on the staging environment declared in Report 4, with seed data from a script in the repository.

- [ ] Iteration 1 code, database script, tests and CI tagged `review-2` (guide §3)
- [ ] BM01 Design Brief, BM02 self-review, BM03 Record of Changes
- [ ] Report 4 technology declaration, including AI tools, models and stages (guide §10)

- [ ] Five main workflows, one owner each, each with an activity diagram (guide §9.1)
- [ ] SRS Final, SDD Initial, Test Plan Draft
- [ ] Architecture, ERD with PK / FK / relationships / cardinality, Package Design
- [ ] State / Sequence / Class diagrams for the main data objects
- [ ] Traceable Use Case → Design → Class/Service → Database
- [ ] Working prototype or workflow demo; **MF-01 and MF-02 demoed**
- [ ] Business parameters configurable, not hardcoded (**D-015**)
- [ ] Entity and attribute names consistent between ERD, SRS and code
- [ ] Every architecture and technology choice has a stated reason
- [ ] No component drawn that the team does not intend to implement
- [ ] Review 1 feedback closed with evidence, item by item against the Review 1 minutes (they are tracked)
- [ ] Deck says explicitly that multi-tenancy moved from out of scope (Review 1 minutes) to in scope, and why

Before the Faculty Council (W13)

- [ ] **Every Main Flow runs end-to-end**; ≥ 80 % of use cases working
- [ ] Coverage Matrix 100 % Implemented / Tested / Demo Ready
- [ ] Each important FR has at least one test case with evidence
- [ ] Product deploys outside a developer machine; demo data ready and realistic
- [ ] Demo rehearsed at least twice, with a backup video of each Main Flow
- [ ] Business parameters demonstrably configurable, expect to be asked live
- [ ] Documentation matches the software that will be demoed
- [ ] RQ1 / RQ2 / RQ3 results written up
- [ ] Every member can answer: *"what did you do, and where is it in the code?"*
- [ ] Review 1 and Review 2 feedback closed with evidence, tracker in hand

Before Final Submission (W15)

- [ ] Package complete and internally consistent; no template placeholders left
- [ ] Software Package installs on a clean machine
- [ ] User Guide and Installation Guide complete
- [ ] Every member can answer questions about the **whole** system, not only their own part
- [ ] Submitted build is the build that was demoed

---

8. Known failure modes to design against

From the faculty fault-prevention handbook. These are graded criteria.

The six causes of not passing, in order of frequency: a Main Flow that breaks during the demo or cannot be shown in the allotted time · hardcoded business parameters · documentation that is wrong, incomplete, or not on the official template · business logic detached from reality with no exception handling · Review feedback not acted on · not being approved to defend, or a member who contributed too little.

Specific to this project:

- **Demo failure is the single most common cause of failure.** Rehearse twice, keep a backup video, keep an IDE open on the repository, use short demo passwords, never build a special "demo version", and if something breaks, stop and explain the fault rather than skimming past it.
- **Hardcoding**, see **D-015**. The first question in the handbook's most-asked list is *"can this number be changed? show me now."*
- **The word "Smart" in our registered title.** The handbook devotes a section to projects whose name promises AI and whose demo is CRUD, and says plainly that a rule-based system must be called rule-based. TrekLink has no ML component. The honest answer, rehearsed, and known by every member, is that the intelligence is **device-level autonomy**: IMU fall detection, autonomous SOS broadcast, multi-hop mesh routing, priority-ordered store-and-forward. Never write "AI" for the platform in a graded document or slide.
- **AI-written documentation and fabricated test results** are called out as a fast-growing and serious failure. Every NFR and business rule must point at the code or test that implements it. Graded documents describe the work as **AI-assisted development with mandatory human review**.
- **Data, security and legal**, collect only what is used; no secrets in source; cite third-party data sources; keep a short Legal & Compliance section. The map-provider migration (**D-012**) sits here and is a legal obligation, not a preference.
- **Individual contribution**, commits and weekly minutes are the evidence. A repository where one or two people committed everything cannot demonstrate who did what.

Appendix A: TP1–TP6 (historical, no longer the planning unit)

The register (§g) organises work into six task packages. SEP490 organises delivery by Main Flow, and **the Main Flow model governs** (D-013). This table is retained so register cross-references resolve, and is mapped onto the current plan.

TP	Register scope	Now carried by
TP1	SRS, 2 UML state machines, architecture doc, inherited-component analysis, DB schema, RQ/experiment protocol, PoC parser	W2–W3 foundation work + Report 3/4
TP2	Gateway Bridge: serial parser, SQLite P0–P3 queue, MQTT publish, reconnect/flush, gateway dedup, health API	**MF-02**
TP3	NestJS auth/RBAC, device fleet FSM, rental lifecycle, idempotent ingestion, sync audit log, migrations	**MF-01**, **MF-02**, **MF-05**
TP4	Telemetry ingestion, live map + WebSocket, SOS→Incident pipeline, incident FSM, notifications	**MF-03**, **MF-04**
TP5	Trip/booking, reservation/assignment, check-out/in, agreements, billing, role-based views	**MF-01**, **MF-05**
TP6	LoRa experiments (RQ1/RQ2), RQ3 drills, dedup/concurrency results, evaluation report, Docker Compose, CI/CD, final docs	**E7 + E8**, cross-cutting; W11–W13

The one TP-era constraint that survives unchanged: **the message-schema freeze is a hard dependency for everything downstream.** Do not start Gateway or ingestion implementation before the schema is committed to `specs/gateway-sync/design.md`.

Appendix B: Superseded framings

Do not reintroduce these; they appear in older documents and in the SWP490 roadmap.

Superseded	Replaced by
Review 1 as a "Weeks 4–5 window with a Week-3 dossier"	Review 1 = **W4**
Review 2 as "Weeks 8–9 with a Week-7 dossier"	Review 2 = **W8**
Hội đồng 1.1 at W14 and 1.2 at W15 as separate extra events	**W13 Faculty Council** and **W15 Final Submission & Defense**
Iteration 1 / 2 / 3 completing at W7 / W11 / W13	Iteration reviews at **W9 / W10 / W11**, feature complete W11
Seven sprints on a fixed two-week drumbeat	The gate-aligned sprint plan in §4.2
"NestJS is a skill only for Khoa"	**3 of 5**, see §5.1
Leaflet.js as the map library	Kept, over OpenStreetMap with a sovereignty overlay (D-031)

TrekLink: Decisions Log & Risk Register

Use this file like a lightweight ADR index. Anything marked **OPEN** blocks the dependent work listed under it, resolve before starting that work, not during.

Decisions

D-000: Which register document is authoritative

- **Status**: ✅ Resolved
- **Context**: `Phieu_FA26SE159.docx` (individual registration form, detailed RQs/NFRs/TP1–TP6) and `Phieu_dang_ky_de_tai_TrekLink_FA26_FINAL.docx` (team draft, M1–M5 module framing) describe the same project at different fidelity, with minor differences (supervisor email domain `fe.edu.vn` vs `fpt.edu.vn`; module count 5 vs 5 core capabilities; TypeORM vs Prisma, see D-001).
- **Decision**: `Phieu_FA26SE159.docx` is authoritative for anything it specifies explicitly (RQs, NFRs, FSMs, task packages, experiment design). The FINAL draft is used only to fill gaps it doesn't cover.
- **Owner**: Team lead, confirm with supervisor at Review 1 kickoff that FA26SE159 is the version on file.

D-001: ORM: Prisma vs TypeORM

- **Status**: ✅ **Resolved** (Prisma ORM)
- **Decision**: Prisma ORM is locked as the team mandate for maximum productivity and type safety across backend services. PostgreSQL schema models and migrations are maintained in `backend/prisma/schema.prisma`.

D-002: Response envelope standard

- **Status**: ✅ Resolved
- **Decision**: All backend responses use the shape already defined in `API_Design_Template.md`: `{ "result": ... "isSuccess": bool, "statusCode": int, "message": string }`. This supersedes the raw-DTO / `errorDetails[]` pattern from the previously-used `dev-flow.zip` (a different, .NET-project convention), see `02-templates/04-api-endpoint-template.md` and `01-conventions/05-backend-conventions.md`.

D-003: GitLab → GitHub adaptation is cosmetic, not philosophical

- **Status**: ⛔ **SUPERSEDED by D-009** (2026-09-13). Kept verbatim below for history, do not follow it.
- **Decision** *(superseded)*: Branch topology (`main` / `develop` / `features/Implementation_*` / `features/Design_*` / `hotfix/*` / `release/sprint_x`), commit discipline, and the dual Design+Implementation branch pattern from `Git_Lab_Guide.pdf` carry over unchanged. Only the tool-specific mechanics change: GitLab Issues/Labels/Milestones → GitHub Issues/Labels/Milestones+Projects; GitLab MRs → GitHub PRs (multi-template via `.github/PULL_REQUEST_TEMPLATE/`); GitLab child tasks → GitHub sub-issues/tasklists. See `01-conventions/07-github-workflow-git-conventions.md`.

D-004: Monorepo vs. multi-repo

- **Status**: ✅ **Resolved** (updated Sep 7, Session 2, repos exist and this is what's actually cloned)
- **Context**: TrekLink has 4 codebases: firmware (inherited, read-only), gateway bridge (Node/TS), backend (NestJS), frontend (React). The org is `github.com/TrekLink-Team`. The original sketch (below, kept for history) considered 4 separate app repos.
- **Original options considered**: (a) 4 separate repos under the org (`treklink-firmware`, `treklink-gateway`, `treklink-backend`, `treklink-web`) with independent CI, or (b) one monorepo with workspaces (`apps/gateway`, `apps/backend`, `apps/web`, `firmware/` as a git submodule).
- **Decision actually taken**: a **hybrid**, 3 repos total under `TrekLink-Team`:

    - `treklink-docs`, this repo (SSOT, docs-only).
    - `treklink-firmware`, inherited SU26 firmware, frozen/read-only this term.
    - `treklink-web`, **one** active application repo containing the Gateway Bridge, NestJS backend, and React frontend as workspace packages (`gateway/`, `backend/`, `frontend/`), rather than 3 separate repos.

- **Rationale**: The firmware is a frozen, inherited dependency, keeping it fully separate avoids accidental edits being graded as "new" work, matching the register's note that firmware effort must be excluded from statistics. Splitting the *active* code further into 3 repos (original option a) was reconsidered: for a 5-person/13-week term, one repo with workspace packages keeps shared TypeScript types (e.g. the `eventId`/DTO shapes gateway and backend both touch), a single CI pipeline, and a single `npm install`, at the cost of coarser per-package branch protection, which `module:*` labels and path-scoped PR reviews (see `01-conventions/07-github-workflow-git-conventions.md`) substitute for.
- **Consequence**: `treklink-web/specs/{module}/` is the one spec root for gateway, backend, and frontend modules alike, see `01-conventions/02-spec-driven-development-workflow.md`. Update that doc's example paths if this ever splits back into separate repos.

D-005: Field-to-cloud bridge topology

- **Status**: ✅ **Resolved and closed** (2026-09-16, Session 6), staged rollout, **both stages in permanent scope**. Supersedes the earlier "Stage B is tradeable" framing.
- **Context**: The register describes the Gateway/Bridge as **dedicated TrekLink hardware with its own Wi-Fi/cellular uplink** (charter §2, FA26SE159 §b). Session 3 established the physical constraint that closes this: **the Gateway Bridge machine is not carried during the trek.** It sits at basecamp. The guide carries a node, not a laptop.
- **Options considered**:
    1. **Basecamp-fixed bridge**, a designated node USB-tethered to the basecamp machine running `gateway/src`; the SQLite P0–P3 queue buffers the machine's intermittent Wi-Fi uplink. Requires no firmware work.
    2. **Node's built-in MQTT uplink, no bridge**, the guide's node publishes to Mosquitto over its own Wi-Fi using the stock Meshtastic MQTT module already compiled into the frozen firmware. Simplest possible path; **has no buffer anywhere.**
    3. **Fork the Meshtastic mobile apps**, rejected outright. iOS requires Xcode on macOS, which the team does not have; an Android-only fork would split Guide/Customer behavior by platform, and mobile apps are explicitly out of charter scope.
- **Decision**: Build **Option 2 first (Stage A, TP1)**, then **add Option 1 on top (Stage B, TP2)** as an additional ingress adapter plus a hard-wired gateway node. Option 3 stays rejected.
- **Rationale**: Option 2 is the shortest path to an end-to-end demo and needs no serial parser, no hardware tether, and no protobuf decoding. It is only non-throwaway because of the ingress-adapter seam defined in **D-007**, Stage B reuses the entire normalizer and ingestion pipeline and contributes only a new adapter in front of it.
- ⚠️ **Known gap, deliberately accepted for Stage A**: Option 2 has **zero offline buffering**. Stock Meshtastic MQTT drops packets when the uplink is down (verified Session 2), and Store & Forward is a mesh-internal, PSRAM-only, ~30-packet chat replay, not a cloud-sync buffer. Therefore, **while only Stage A exists**, the following charter §5 NFRs are unmeasurable and RQ1/RQ2 are unanswerable:
    - Offline recovery delivery rate ≥99% after reconnection (30s–30min loss)
    - Priority-ordering compliance ≥99%, all P0 flushed before P2/P3 on reconnect
    - Gateway→cloud sync ≤5s *when uplink returns* (the ≤5s steady-state figure is still measurable)

  These are restored by Stage B, where the SQLite queue sits in the uplink path and loss is induced by killing the bridge's Wi-Fi.
- **Scoping note that makes Stage B sufficient**: every offline NFR in charter §5 is scoped to the **gateway→cloud** leg, not the **node→gateway** mesh leg. Charter §1 gap #1 reads *"no store-and-forward path to the cloud… there is no Gateway between the mesh and a backend."* Mesh-range loss (a node out of LoRa range of any relay) is an RF-coverage problem,

already carried as an RF-reliability caveat in the risk table below, and is **not** claimed as in scope. A basecamp-fixed bridge therefore exercises exactly the leg the research questions measure.

- **Hardware scope** (settled Session 3): **Stage A targets v2/v3/v4 only. v1 is out of the demo set.** v1 compiles MQTT out entirely (`-D MESHTASTIC_EXCLUDE_MQTT=1` , `variants/esp32/treklink_v1_0/platformio.ini:10`), the module is removed at build time, so no runtime configuration can enable it. v2/v3/v4 omit that flag and all carry Wi-Fi silicon, so any of them can serve as the uplink node. Were v1 ever needed, deleting the build flag is a one-line change now that D-008 permits firmware edits.
- ~~**Stage B is tradeable scope**~~, **struck (Session 6).** Stage B is permanent scope. Two independent reasons, either of which alone is sufficient:
  1. **The supervisor put it in the mainflow set.** `Documents/course-material/TrekLink-proposed-mainflow-ducndm.png` defines **MF-02, Field Data → Offline Gateway → Cloud Synchronization**, and draws the Gateway Bridge (Node.js) with its SQLite offline queue and priority-ordered reconnection flush as the substance of that flow. Dropping Stage B would delete a supervisor-specified mainflow. See **D-016**.
  2. **The scope constraint that motivated the trade is gone.** At the 2026-09-13 meeting the supervisor granted the team latitude to set its own scope and tech stack, subject to pitching and defending it. There is no longer a scope-reduction pressure to spend Stage B on.
- **Consequence**: charter §5's offline-recovery and priority-ordering NFRs and **RQ1/RQ2 stay binding and must be delivered.** Stage A remains the first increment, not a substitute, never present Stage A as satisfying the offline-recovery NFR.
- **Blocks**: nothing, `specs/gateway-sync/{requirements,design,tasks}.md` are written against this decision. Stage B's isolation in Phase 9 is retained as sequencing, no longer as a removal seam.

D-006: `eventId` redefinition: the charter's scheme is not constructible

- **Status**: ✅ **Resolved** (Session 3), supersedes charter §2 and `01-conventions/04-architecture-conventions.md` §3
- **Context**: Charter §2 and the architecture conventions both specify `eventId = DeviceID + SessionID + SequenceNumber` as the backend idempotency key. Direct inspection of the frozen firmware shows **neither `SessionID` nor `SequenceNumber` exists anywhere**, not in the TrekLink modules, not in the Meshtastic packet format. The only per-packet identifier transmitted is `MeshPacket.id` , and `Router.cpp:168` (`generatePacketId()`) shows it is a 10-bit rolling counter OR'd with 22 random high bits, re-seeded randomly at every boot. It is a flood-dedup token, **not** a monotonic sequence. The charter's key cannot be built from what the hardware actually sends.
- **Options considered**:
  1. **Split the key** into a packet-level dedup key and an episode-level correlation key.
  2. **Single content-addressed key**, `hash(from : rx_time : portnum : payload)` , rejected: the SOS beacon retransmits every 5s (then 30s) with a fresh `rx_time` , so one SOS episode would mint a new key per tick and create N Incidents from one fall.
  3. **Bridge synthesizes session + sequence**, rejected: the key would then describe the *bridge*, not the device. Restart the bridge, replay the same packets, and every key is new; deduplication becomes a silent no-op, which is precisely the failure the 10× replay NFR exists to catch.
- **Decision** (Option 1):
  - **Packet dedup key**, `GatewayEvent.eventId = sha256(nodeNum : packetId)` . Satisfies charter §5's *"0 duplicate Incidents for repeated eventId delivery (10× replay test)."* Enforced by a unique index; conflict is a no-op insert inside the ingestion transaction.
  - **Episode correlation**, *not* a hash. On SOS ingest, look up an open `Incident` for the same device whose `lastEventAt` falls inside the episode window; append if found, create if not. An earlier draft used `hash(nodeNum : timeBucket)` , which was discarded: a bucket boundary falling mid-episode splits one SOS into two Incidents, the exact failure the key exists to prevent.
- **Consequences**:

  - `backend/prisma/schema.prisma`: `Incident.eventId @unique` currently serves as *both* keys and must be split, `Incident` gains `lastEventAt` and an index on `(deviceId, status, lastEventAt)`, and references its originating `GatewayEvent` by FK rather than carrying a duplicate unique string.
  - **`01-conventions/04-architecture-conventions.md` §3 still states the old formula and is now contradicted by this decision. It must be updated before any `gateway-sync` implementation branch opens.**
  - Charter §2's wording stands as the *intent* (a natural, device-derived idempotency key); this decision records the constructible form of it.

- **Reopened by D-008** (firmware is editable): adding a boot-`sessionId` and a per-packet `sequenceNumber` firmware-side would make the charter's original formula constructible and would give a genuinely monotonic sequence, strictly better than hashing a randomized packet id, and it would let the platform *detect gaps* (a missing sequence number proves loss) rather than merely deduplicating what arrives. **The split key above remains correct and functional with or without it**; treat a firmware sequence as a layered upgrade to evaluate next session, not a prerequisite for TP1.

D-007: Canonical event envelope + Strategy-based normalizer (the ingress seam)

- **Status**: ✅ **Resolved** (Session 3)
- **Context**: Stage A (node MQTT) and Stage B (serial bridge) do **not** speak the same wire format. The node's MQTT module publishes to a hardcoded topic shape, `<root>/2/e/<channelId>/<nodeId>` carrying a `ServiceEnvelope` protobuf, or `<root>/2/json/<channelId>/<nodeId>` carrying JSON when `json_enabled` (`src/mqtt/MQTT.cpp:423–430`, `:798`). `<root>` is configurable; `/2/e/` and the payload type are not. Meanwhile `gateway/src/mqtt/mqtt-client.ts` publishes `treklink/events/priority/{0..3}` with a TrekLink-shaped payload. If the backend parses Stage A's format directly, Stage B's arrival forces a rewrite of the ingestion layer, and D-005's staged plan quietly becomes throwaway work.
- **Decision**: The backend ingests exactly one internal type, **`TrekLinkEvent`**. Between the wire and the domain sit two seams:
  1. **Ingress adapters** (`MeshIngressAdapter`), one per topology, responsible only for getting bytes off a transport and producing a `RawMeshPacket`. Stage A ships `MqttJsonIngressAdapter`; Stage B adds `SerialBridgeIngressAdapter`. Adapters hold no domain logic.
  2. **Normalizer** (`MeshNormalizerService`), the Strategy-pattern context. It resolves a `PacketNormalizationStrategy` by PortNum from an injected registry and delegates. Strategies are pure (no I/O, no Prisma) and each owns one PortNum's mapping to a domain event kind and priority tier. Adding a PortNum means adding a strategy class and registering it; the normalizer itself never changes (Open/Closed).
- **Rationale**: the normalizer holds ~all the genuinely hard logic (SOS prefix parsing, priority assignment, `eventId` derivation, episode correlation) and is 100% shared between stages. Purity makes it unit-testable without a broker, a device, or a database, which is what makes the charter's dedup/ordering/concurrency NFRs cheap to test rather than integration-only.
- **Stage A transport config, frozen**: `json_enabled = true`, `encryption_enabled = false`, `root = "treklink"`. JSON removes any protobuf dependency from NestJS, and the JSON serializer covers the three PortNums TrekLink actually emits, `TEXT_MESSAGE_APP`, `POSITION_APP`, `TELEMETRY_APP` (`src/serialization/MeshPacketSerializer.cpp:28`, `:208`, `:56`). `encryption_enabled = false` is required so the broker receives decrypted packets; the field's own comment in `module_config.pb.h` notes decrypted output exists for exactly this purpose. The alternative is reimplementing Meshtastic's AES-CTR channel crypto in NestJS.
- **Known limitation of the JSON path**: the JSON envelope (`MeshPacketSerializer.cpp:410–424`) carries `id`, `timestamp`, `to`, `from`, `channel`, `type`, `sender`, `payload`, `rssi`, `snr`, `hops_away`, but **not** **`MeshPacket.priority`**. The SOS position packet is sent with `priority = MAX` (`TrekLinkSOSHelper.cpp:119`) and is therefore indistinguishable from a routine position report on this path. Handled by backend episode correlation with a backward grace window (see `specs/gateway-sync/design.md` §2.4). Switching to the `/2/e/` protobuf topic would recover `priority` directly and is logged as the deferred precision upgrade.

D-008: The firmware is editable this term (supersedes the "frozen / read-only" framing)

- **Status**: ✅ **Resolved and closed** (2026-09-16, Session 6). All three sub-questions answered; no part of this decision remains open.

- **Context**: `README.md` §1, charter §2, and D-004's rationale all describe `treklink-firmware` as *"Frozen / read-only this term. Branch-protected. Not a deliverable."* Sessions 1–3 reasoned under that constraint and, on its strength, classified several firmware-rooted defects as unfixable-by-design. **The team lead has confirmed this is wrong**: the team owns the repo, can modify and build it, and can reflash the physical units.
- **Decision**: firmware modification is **technically available** and may be used to fix defects that cannot be worked around from the platform side. All prior "unfixable without touching frozen firmware" conclusions are void and must be re-derived.
- **The distinction that still matters**, three separate claims were bundled under one word:
  1. *Can we edit it?*, **Yes.** Settled.
  2. *Is firmware work in scope?*, **Yes** (answered 2026-09-13, supervisor). Firmware **enhancement and integration** is an accepted development path, not the out-of-scope "firmware redesign." Extending the firmware so the platform integrates with it more deeply, a custom PortNum, an explicit SOS discriminator, a boot `sessionId` + per-packet `sequenceNumber`, beacon priority, is treated as building the product, not rebuilding the inherited component. The charter's exclusion is read narrowly, as prohibiting a rearchitecture of the mesh stack.
  3. *Does firmware effort count toward graded deliverables?*, **Yes** (answered 2026-09-13, supervisor), with the caveat that assessment is not code volume alone. This supersedes D-004's rationale citing "the register's note that firmware effort must be excluded from statistics"; that note is treated as an accounting convention for source statistics, not as a bar on credit.
- **Working rule (Session 6)**: firmware changes are a **first-class option**, evaluated on merit against the platform-side alternative rather than treated as a last resort. Prefer whichever is more robust for the same cost; where the firmware fix is strictly better, as with the SOS discriminator and beacon priority, take it. Keep each change individually justified and logged here. Still excluded: rearchitecting the Meshtastic mesh stack.
- **Reopens**:
  - **D-006**, a firmware-side boot-`sessionId` + per-packet `sequenceNumber` would make the charter's original `eventId` formula constructible. The split key stays valid regardless; this would be a layered upgrade.
  - **The Critical SOS risk below**, the single-unacknowledged-text-frame failure is now firmware-fixable (custom PortNum, `want_ack`, or retransmitting the discriminator with each beacon) rather than mitigable only by heuristic.
  - **D-007's SOS discrimination**, a real custom PortNum would retire the `printf`-format string parser entirely.
  - **v1 MQTT exclusion**, a one-line build-flag removal, though v1 is now out of the demo set anyway (see D-005).
  - **New (Session 4), SOS beacon priority.** `TrekLinkSOSHelper::broadcastPosition()` retransmits via `PositionModule::sendOurPosition()`, which sets `priority = BACKGROUND` for a handheld role (`PositionModule.cpp:377–380`), only the very first position packet at trigger time is `MAX`. Every beacon for the rest of an episode is the *lowest*-priority traffic on the mesh. Candidate fix: have the beacon path set `priority = MAX` (or at least `RELIABLE`) explicitly instead of delegating to the generic broadcast method. See `04-firmware-ground-truth.md` §2.
- **Action** (owner: team lead): none outstanding, both questions answered. Continue to log every firmware change in this register, and carry the firmware work in the same backlog and Progress Log as platform work so the contribution evidence is uniform.

D-009: Git, tracking & review model v2 (supersedes D-003)

- **Status**: ✅ **Resolved** (2026-09-13, Session 5)
- **Context**: D-003 ratified the school's `Git_Lab_Guide.pdf` model wholesale. Auditing it against reality found it was never actually implemented and could not be: **no repository has ever had a `develop` branch**, yet `develop` appeared in 34 documentation files, making every documented git command broken. Three documents disagreed with each other on the branch model (`07-*.md` §3.2 and D-003 mandated dual Design/Implementation branches; `09-*.md` §1 said they were "not adopted"). The GitHub-Issues-as-tracker assumption conflicted with the team's actual use of Jira.
- **Options considered**:
  1. **Fix reality to match the docs**, create `develop`, adopt dual branches, drop Jira. Rejected: dual branches double PR overhead for a 5-person/13-week term, and the team already runs Jira.
  2. **Fix the docs to match reality, keeping GitLab's philosophy**, chosen.

3. Leave the contradiction and rely on tribal knowledge. Rejected: agents read the docs literally and will follow the broken commands.

- **Decision**:
  - Integration branch is `dev`. Branches: `main`, `dev`, `feat/*`, `fix/*`, `hotfix/*`, `docs/*`, `chore/*`.
  - `release/*` **dropped**, `main` is the release.
  - **Dual Design/Implementation branches killed.** One branch per unit of work; spec commits land before implementation commits on the same branch, which preserves review independence at half the overhead.
  - Branch naming: `{type}/{JIRA-KEY}-{short-kebab-desc}`, e.g. `feat/TK-45-device-registration`. The Jira key is what makes the org-level Jira↔GitHub integration auto-populate each card's Development panel.
  - Commits: **Conventional Commits**, all standard types, Jira key as scope, `feat(TK-45): ...`. Scope omitted when genuinely general. **Not CI-enforced**: commit hygiene must never block a delivery.
  - Merge: **Rebase & merge** default, **Squash & merge** when multi-commit, **merge commits prohibited**. Delete source branch except `dev` → `main`.
  - **No direct pushes to any branch, by anyone, including the leader.**
  - **Jira is the single work tracker.** GitHub Issues hold daily reports and standalone bugs only. GitHub Milestones retired; `points:*` labels retired in favour of Jira story points on the **Fibonacci** scale (1/2/3/5/8/13/21), corrected 2026-09-17; an earlier revision published a non-standard base-5 scale that the backlog was never estimated against.
  - Bugs route three ways: Jira `BUG` **status** (defect found reviewing an active story) / GitHub Issue `type:bug` (standalone, never enters Jira) / Jira `Bug` **work item** (only if >0.5 day or it changes a spec).
  - CI is an **indicator, not a gate**, red CI does not block merge, but the leader must approve any red merge and the reason goes in the PR.
  - PR self-approval permitted **only** for <50-line, non-behavioural housekeeping. The PO is not exempt and must run an independent AI review pass on their own non-trivial PRs.
  - **English only** in every repository artifact. Vietnamese permitted when prompting an AI agent, and by exception in daily reports.
- **Consequence**: `01-conventions/` rewritten as Conventions v2; `07-*.md` fully rewritten; new chapters `10` (Jira), `11` (AI-first), `12` (communication). Two PR templates collapsed into one. `treklink-web/docs/conventions/` deleted (D-011). The generated Developer Handbook PDF is built from these files.
- **Owner**: Team lead.

D-010: Neon as the shared managed Postgres

- **Status**: ✅ **Resolved** (2026-09-13)
- **Context**: `docker-compose.yml` provisions a local Postgres per developer, which is correct for isolated unit/integration work but gives the team no common database to co-develop against. Integration bugs that only appear with shared data (FK collisions, migration ordering, seed drift) surface late, typically during demo prep.
- **Decision**: Adopt **Neon** as the managed Postgres for shared **dev** and **prod/demo** environments. Local Docker Postgres remains the default for unit tests and CI (fast, hermetic, no network).
- **Consequence**: Each member installs the **Neon MCP connector** from the Claude skills store and authorises it under their own account. Connection strings live in each developer's `ignore/envs/` and are **never committed**. `DATABASE_URL` in CI continues to point at the ephemeral service container, not Neon.
- **Open**: branch-per-developer Neon databases vs. one shared dev database, decide before the first cross-module integration sprint.
  - **Update 2026-10-24**: provisioned. Shared development runs on the Neon branch `dev` of project `damp-queen-78476528`, Postgres only (D-062).
  - **Update 2026-10-04**: the Neon project has still never been provisioned, so no shared database holds applied migrations. The migration baseline is therefore rewritten in place for the rescope rather than migrated forward (D-036).
  - **Update 2026-09-29**: settled by `07-clarification-answers.md` §6 question 40, one shared dev database with migrations applied only from `dev`, by CI or the leader. The Neon project is **not provisioned yet**; until it is, every

member develops against local Docker Postgres from `.env.example`. The leader distributes the team `.env` privately (Zalo), never through a repository.

- **Owner**: Team lead + LongLP (data lane).

D-011: Single canonical convention set; vendored copies deleted

- **Status**: ✅ **Resolved** (2026-09-13)
- **Context**: `treklink-web/docs/conventions/` held a verbatim, unreconciled copy of the author's generic `dev-flow` template, 12 files with zero TrekLink-specific content, still teaching `develop`, bracket-tag commits, and the dual-branch model. `treklink-web/AGENTS.md` explicitly directed agents to **fall back to it**, so an agent opened on `treklink-web` alone would have been actively taught the wrong rules.
- **Decision**: **Delete it.** `treklink-docs/_docs/01-conventions/` is the single canonical convention set for all three repositories. No repo vendors a second copy. A single `AGENTS.md`, identical in content, is placed in `capstone/`, `treklink-docs/`, `treklink-web/`, and `treklink-firmware/`, and points at the canonical folder.
- **Rationale**: A duplicated convention set does not merely drift, it drifts *silently*, and the copy is what gets read when the sibling layout isn't present. The previous fallback was worse than having no fallback, because a wrong answer delivered confidently costs more than a missing one.
- **Consequence**: Agents must be opened on the `capstone/` parent folder. An agent opened on a single repo will find `AGENTS.md` pointing at a path it cannot resolve, and must say so rather than guessing, which is the intended failure mode.
- **Owner**: Team lead.

D-012: Map provider: Goong Maps over MapLibre GL; OpenStreetMap tiles prohibited

- **Status**: ⛔ **Superseded by D-031** (2026-09-29). Resolved 2026-09-16, Session 6
- **Context**: `frontend/src/widgets/LiveMapWidget/LiveMapWidget.tsx:18-19` renders the standard OpenStreetMap tile server (`https://{s}.tile.openstreetmap.org/{z}/{x}/{y}.png`). The team lead inspected every OSM base layer and confirmed each renders the Hoàng Sa and Trường Sa archipelagos under Chinese toponyms. Under Vietnamese law that makes the rendered product unlawful to publish.
- **Legal basis**: **Nghị định 174/2026/NĐ-CP, Điều 93 khoản 3 điểm a**, in force **1 July 2026**, fine **30–40 million VND** for *"Đăng, phát, sử dụng hình ảnh bản đồ Việt Nam không thể hiện đầy đủ hoặc thể hiện sai chủ quyền quốc gia."* It raises the 20–30M VND of Decree 15/2020/NĐ-CP Art. 99(3)(b). Ancillary sanctions include confiscation of the equipment used, forced takedown of the content and its links, and **forced removal of the application**. Note the wording penalises *failing to represent fully* as well as *misrepresenting*, omission is sufficient; a nine-dash line is not required for liability. Enforcement against software and devices is established practice (imported-vehicle GPS confiscations, Hải Phòng 2019; 25M VND fine to the Oceanman 2023 organiser under the predecessor article).
- **Options considered**:
  1. **Goong Maps via MapLibre GL**, chosen. Vietnamese provider (IMAP JSC), servers in VN and SG, free tier of $100 standing credit with 30,000 requests/month, 180 req/min and 1,000 map loads.
  2. **VietMap**, rejected on cost. Technically the closest fit (it publishes a documented `@vietmap/vietmap-gl-leaflet` wrapper that would have preserved the Leaflet API and a raster XYZ satellite endpoint), but it is not free.
  3. **Viettel Maps**, rejected on capability. Its public documentation exposes only a Static Map image endpoint, an `<iframe>` embed, Place and Routing. No XYZ tile layer and no GL style are documented, so it cannot back an interactive operations map.
  4. **Self-hosted sovereignty-corrected tiles**, rejected. Tile pipeline and storage cost far exceed a 13-week budget for no graded benefit.
- **Decision**: **Goong Maps rendered through MapLibre GL JS.** This replaces Leaflet as the map rendering library, Goong publishes GL styles, not an XYZ raster layer, so Leaflet is no longer the right host. Style URL form: `https://tiles.goong.io/assets/goong_map_web.json?api_key={MAP_KEY}`; variants `goong_map_web` (full icons), `goong_map_highlight` (minimal icons), `goong_satellite`. Integration is via the `maplibre-gl` CDN bundle, Goong documents no npm package of its own.

- **Two distinct credentials**: a **Map Key** authenticates style/tile URLs; a separate **API Key** authenticates Autocomplete, Direction, Geocoding, Distance Matrix and Place Detail. Do not conflate them.
- **Provider-agnostic by construction** (team lead, Session 6): the map layer must not hardcode Goong. Provider identity, style URL, key and default viewport are configuration, so a future swap to another GL-style provider is a config change and not a code change. See **D-015**.
- **Consequences**:
  - Leaflet is removed from the stack. Ten documents name it, `01-project-charter.md` (×2), `01-conventions/00-index.md`, `04-architecture-conventions.md`, `06-frontend-conventions.md`, `02-roadmap-and-milestones.md`, `AGENTS.md` (×4 copies), backlog story **US-055** via `build_backlog.py`, and `Documents/reports/Report1_Project_Introduction_DRAFT.md` §6.1, all must be updated in the same pass.
  - The API key is visible in the browser by design. Mitigate with an HTTP-referer allowlist and a per-IP rate limit on the key, and record that mitigation, it is the direct answer to the "API key exposed in source" failure mode in the faculty fault handbook §10.
  - **Acceptance test, mandatory before Review 1**: load the operations map over Hoàng Sa (~16.5°N, 112.0°E) and Trường Sa (~9.7°N, 114.0°E), confirm Vietnamese toponyms and correct sovereignty depiction, and file the screenshots as evidence. This is a team-performed check; it has **not** been carried out yet.
  - **Update 2026-09-25**: `07-clarification-answers.md` question 28 (Session 8, Confirmed) records that the team lead has performed the sovereignty check and found Goong compliant. Whether the screenshots are filed as evidence is not recorded (needs check).
  - **Update 2026-09-25, later**: the team lead confirms no screenshots are filed yet (`07-clarification-answers.md` §5 question 23). The acceptance test's evidence is outstanding.
  - **Update 2026-09-25, evidence filed**: the leader captured Goong Maps over Hoàng Sa and Trường Sa, both labelled in Vietnamese, and OpenStreetMap over the same area, labelled with foreign names and boundaries. Filed in `capstone/Documents/evidence/map-sovereignty/`. TC-24 passes for Goong; OpenStreetMap stays prohibited.
- **Owner**: Team lead (schema/UI layout lane) + LongNN (frontend lane).

D-013: Execution model: SEP490 2026 mainflow-incremental, retaining SWP490 practice

- **Status**: ✅ **Resolved** (2026-09-16, Session 6)
- **Context**: `02-roadmap-and-milestones.md` was derived from `SWP490_Lo-trinh-Capstone_v1.0.pdf`. The Fall 2026 course issues `SEP490_Student_Project_Execution_Schedule.pdf` (50pp) and `SEP490_Huong_dan_nhanh_cho_sinh_vien.pdf`, which describe a materially different model: gates at W4/W8/W13 plus final submission at W15, four Common Meetings (W1, W3, W7, W12), a weekly Group Meeting, and **incremental delivery per Mainflow** rather than by TP package or Iteration.
- **Decision**: the **SEP490 schedule is the spine**. TP1–TP6 and the Iteration 1/2/3 framing are demoted to a historical appendix and mapped onto mainflow ownership; they no longer drive planning. Practices from SWP490 that the SEP490 documents do not contradict are **retained deliberately** because they are good practice, the phase discipline, the deliverable ledger shape, and the Week-6 scope lock (which SEP490 does not mention but which remains real).
- **The dual council is real but informal** (team lead, Session 6): "Hội đồng 1.1 / 1.2" is the *Hội đồng kín* naming, never published as an official document and conveyed only through the supervisor's outline. It maps cleanly onto the SEP490 calendar and is **not** a separate pair of events: **Hội đồng 1.1 = Faculty Council, W13** (Gate 3, defence eligibility); **Hội đồng 1.2 = Final Submission & Defense, W15**. Record it in internal planning; cite only the SEP490 names in graded documents.
- **Retake path**: failure at either council moves the group to a council in the following term, ~March 2027. This is why the registration form's stated duration reads 09/2026 – 03/2027 while the working plan ends in December 2026. **Plan for December.**
- **Known contradictions inside the SEP490 source**, resolved as follows and flagged wherever cited:
  - Review 1 at **W4** (Roadmap table, Master Schedule 5.2, quick guide) vs W3 (§4 prose item 2) → **W4** adopted, two sources to one.
  - "Two mainflows complete at W7" (§4, Master Schedule 5.1) vs "Sprint 1 (W8) → MF-01, MF-02" (Sprint Plan) → the **stricter W7** reading adopted; W8 is the confirmation demo.

- **Owner**: Team lead.

D-014: Tracking artifacts: the SEP490 workbook and Progress Log

- **Status**: ✅ **Resolved** (2026-09-16, Session 6)
- **Context**: SEP490 §§27–37 name ten tracking artifacts and recommend consolidating them into one 8-sheet workbook. `Documents/tracking/Report3_Project Tracking.xlsx` (WBS / Issues / Defects / Q&A) is the 2021 artifact and covers a strict subset. The course also ships `templates/Mã nhóm_Progress_Log.xlsx`, named as **the** primary evidence for Individual Contribution, a dimension on which an individual member can fail even when the group passes.
- **Decision**: adopt both.
  1. `GFA26SE55_Progress_Log.xlsx`, one file for the whole term, from the course template. Updated **before every Group Meeting**. Per-member, per-week, tied to a named deliverable; "continued working on the project" is not an entry.
  2. **An 8-sheet tracking workbook**, `01_MASTER_SCHEDULE`, `02_WEEKLY_TASK_TRACKER`, `03_DELIVERABLE_TRACKER`, `04_TRACEABILITY_MATRIX`, `05_REVIEW_ACTION_TRACKER`, `06_RISK_ISSUE_CONFIG`, `07_FINAL_READINESS_CHECKLIST`, `08_INDIVIDUAL_CONTRIBUTION_LOG`.
  3. The **Mainflow Coverage Matrix** is the single sprint-tracking instrument the supervisor uses to confirm progress in the weekly Group Meeting. It is authoritative over any other view.
- **Risk register interface**: the Risk & Issue Log sheet adopts **the school's columns** (`ID · Risk/Issue · Impact · Probability · Mitigation/Action · Owner · Deadline · Status`) rather than a composite exposure score. The register below stays the engineering source of truth; the workbook sheet is its reporting projection and must be regenerated from it, never edited apart.
- **Consequence**: `Project Weekly Report_GroupName.xlsx` is retired. The old Project Tracking sheets fold into `02` and `06`.
- **Owner**: Team lead.

D-015: Business parameters are configuration, never constants

- **Status**: ✅ **Resolved** (2026-09-16, Session 6)
- **Context**: the faculty fault handbook ranks hardcoded business parameters the **#2 cause of failure**, and its list of most-asked council questions opens with *"can this number be changed? Demo it for me now."* SEP490's W11 Definition of Done requires "tham số nghiệp vụ cấu hình được" and a maintained **Configuration Matrix**.
- **Values already hardcoded** (found by inspection, Session 6): `gateway/src/queue/priority-queue.ts:50` peek limit `10` · `gateway/src/mqtt/mqtt-client.ts:20` `reconnectPeriod: 3000` · `:41` flush batch `20` · `:49` topic prefix `treklink/events/priority/` · `frontend/src/widgets/LiveMapWidget/LiveMapWidget.tsx:6` `DEFAULT_CENTER`.
- **Values that must be born configurable** (not yet written): SOS beacon cadence (5 s for the first minute, then 30 s), episode-correlation window and backward grace, cadence-anomaly threshold (N positions in window W), P0–P3 tier mapping, gateway→cloud sync target (≤5 s), battery warning thresholds, rental rate, deposit, late fee, damage fee, and the map provider/style/viewport (D-012).
- **Decision**: no business parameter appears as a literal in source. Each is registered in the Configuration Matrix with parameter, current value, location, configurable (Y/N), tested, and a demo path. A parameter that cannot be changed and shown changing during a demo is treated as a defect, not as a style preference.
- **Owner**: Team lead (schema) + each module owner for their own parameters.

D-016: The five Main Flows are supervisor-specified and binding

- **Status**: ✅ **Resolved** (2026-09-16, Session 6). ⛔ **Superseded by D-033 (2026-10-03)**: the five Main Flows are now the D-033 set. The flow identifiers and owners are kept; MF-01, MF-03, MF-04 and MF-05 change substance.
- **Context**: SEP490 organises all delivery from W3 to W12 around Mainflows, and the supervisor supplied the set for this project directly as `Documents/course-material/TrekLink-proposed-mainflow-ducndm.png`. They are not a format suggestion; they are the units the Mainflow Coverage Matrix tracks, the units demoed at each Iteration review, and the units the council evaluates.
- **Decision**: adopt exactly these five, with these identifiers.

MF	Name	Substance
MF-01	Booking → Rental → Trip Preparation	Customer browses package, submits booking, reserves device → Staff reviews, confirms, allocates device, assigns guide, generates rental agreement, checks out device → Guide receives device and prepares
MF-02	Field Data → Offline Gateway → Cloud Sync	Device (SOS/GPS/telemetry) over LoRa mesh → Gateway Bridge with SQLite priority queue while offline → MQTT → NestJS; P0–P3 processing with idempotency; priority-ordered flush on reconnection
MF-03	SOS → Incident → Emergency Response	SOS broadcast → gateway → idempotency check on `eventId` → Incident created if absent → FSM Detected → Acknowledged → In Progress → Resolved → Closed, each transition recording actor, timestamp and note → WebSocket notification to Staff and Guide
MF-04	Real-Time Trip Monitoring	Device → gateway → MQTT → backend → WebSocket → dashboard showing active trips, device positions, battery status, incident alerts, last-seen time, for Admin / Staff / Guide
MF-05	Return → Inspection → Billing → Maintenance	Check-in, return inspection, charge calculation, payment, rental close; device FSM Available → Reserved → Rented → In-Field → Returned → Maintenance → Retired

- **Backlog mapping**: MF-01 ← E3 + E2 + E1 · MF-02 ← E4 · MF-03 ← E5 · MF-04 ← E5 (frontend) · MF-05 ← E6 + E2. **E7 (DevOps) and E8 (Research & Evaluation) are cross-cutting and are deliberately not mainflows**, state this explicitly wherever the Coverage Matrix is presented, so the omission does not read as an oversight.
- **Consequences**:
  - MF-02 makes the offline buffer non-negotiable, see D-005.
  - MF-03 prints "idempotency check (using eventId)" on the supervisor's own diagram, which turns D-006's split key from an internal design note into a **demo obligation**: a replay must be shown producing exactly one Incident.
  - MF-05 and MF-01 together make the 7-state device lifecycle and the rental lifecycle demonstrable end-to-end, which is what the W13 council grades.
- **Owner**: Team lead.

D-017: Diagram and figure conventions; Mermaid pinned at 12.0.0

- **Status**: ✅ **Resolved** (2026-09-17, Session 6)
- **Context**: the Main Flow diagrams were authored as `flowchart` blocks with `subgraph` groupings. That *looks* like a swimlane and is not, the groups do not constrain layout, so the actor partition is decorative. The course supplies actor-partitioned swimlanes as its worked example (`Documents/templates/Main flows_ex02.jpg`) and the supervisor's own TrekLink diagram uses that form. Separately, nothing in the pipeline checked whether a diagram was *legible once printed*: the handbook carried figures that render at 1.58 pt on A4.
- **Decision**:
  1. **Multi-actor process flows are Mermaid `swimlane-beta`**, one `subgraph` per actor lane, orientation `TB`. Plain `flowchart` is reserved for structures with no actors, context diagrams, feature trees, architecture diagrams.
  2. **Mermaid is pinned at 12.0.0.** `swimlane-beta` requires ≥ 11.16.0 and did not exist in the previous pin of 10.9.1. All 12 pre-existing diagrams were re-rendered at 12.0.0 and none regressed.
  3. **Figure placement is computed, not authored.** `plan_figure` in `build_handbook.py` renders each diagram headless, measures its viewBox and smallest rendered label, and chooses inline or a counter-clockwise rotated plate, whichever affords the larger scale. Both axes are always constrained, so nothing clips.
  4. **A 7 pt legibility floor**, with the escape hatch that a figure below it is a note rather than a build failure; the fix is to re-source the diagram, and any carried exception is recorded in `01-conventions/13-diagram-and-figure-conventions.md`.
  5. **Monochrome.** No figure may depend on hue, these documents are printed and photocopied.

6. Every figure carries a number and a caption and is referenced before it appears. Numbering is per source document; the build renumbers continuously across the handbook and rewrites the in-text references.

- **Consequences**:
  - Diagrams are **pre-rendered to inline SVG** before pagination. Previously mermaid rendered in the browser during `--print-to-pdf`, which meant layout could not know a figure's size until after pagination had been decided, computed placement is impossible that way.
  - Rotation happens **inside the SVG coordinate system**, never as a CSS transform: a transformed box paints in one place and paginates in another, which prints content on the wrong page.
  - Three pre-existing figures were below the floor and were re-sourced by splitting: the session lifecycle sequence diagram, the Jira delivery loop, and the AI session workflow. The corpus is now **27 figures, all above the floor**, lowest 7.40 pt.
  - The CI "raw mermaid source" text check was removed. Its markers (`commit id:` , `[*] -->` , `-->|`) now all appear in the conventions prose that documents them, so they false-positive. CI validates figure numbering instead; an unrenderable diagram is already a hard build error.
- **Owner**: Team lead.

D-018: Three-tier buffering topology; the on-device durable queue is inserted as Stage B

- **Status**: ✅ **Resolved** (2026-09-17, Session 7), **refines D-005, does not supersede it.** D-005's staged-rollout principle and its permanent-scope conclusion both stand.
- **Context**: D-005 described two stages, node MQTT with no buffer (A), then a basecamp bridge holding the SQLite queue (B). Session 7 inspection of `src/mqtt/MQTT.{h,cpp}` found that **the node already has a queue**, and that it is actively harmful: 16 entries, RAM-only, strict FIFO, **discard-oldest** on overflow (`MQTT.cpp:821–823`). Because eviction takes the oldest entry, the single `"SOS - …"` text frame that identifies an episode is **the first thing dropped** during an outage, the exact inverse of MF-02's binding priority rule. Full evidence: `04-firmware-ground-truth.md` §4.1.
- **Decision**, three tiers, delivered in this order:

Stage	Where	Buffer	Status
A	Guide's node publishes direct to MQTT over its own Wi-Fi	the stock 16-entry RAM FIFO, i.e. effectively none	**already exists, pure configuration, nothing to build**
B	**On the device (firmware)**, RAM tier, then a flash tier	priority-ordered, reboot-proof, bounded, shed-aware	**built now; this term's focus**
C	Basecamp gateway, node tethered to a laptop or phone	the large central queue, aggregating the whole local mesh	built after B; form settled by **D-020**

- **Naming note, to stop a rename from creating drift**: what documents written before Session 7 call *"Stage B, the basecamp bridge with the SQLite queue"* is **now Stage C**. Stage B is the new on-device work. Every `[B]` -tagged requirement in `gateway-sync/requirements.md` predating this decision refers to Stage C and is retagged in the same pass.
- **Rationale**: Stage B is chosen ahead of Stage C on three independent grounds.
  1. **It fixes a defect rather than adding a layer.** Stage C buffers the gateway→cloud leg; it does nothing about a node that evicts its own SOS 80 seconds into an outage. Those are different failures and only Stage B addresses the second.
  2. **It needs no hardware the team does not already have.** Stage C needs a basecamp machine plus a tether; Stage B needs a node and a broker.
  3. **It is the strongest available answer to the council's individual-contribution question.** A cited before/after on inherited firmware is a materially better claim than new application code.

- **What Stage B does not do, stated so it is never overclaimed**: an on-device queue buffers only *that node's own* events. It cannot buffer for peer nodes that never reach Wi-Fi. Multi-node aggregation is Stage C's job and Stage B is not a substitute for it, the same relationship D-005 established between A and B.
- **Consequences**:
  - RQ1/RQ2 become answerable **this term, against a real baseline**, the unmodified firmware at its current commit (see D-019's preservation requirement, which is what makes the baseline reproducible).
  - The risk row *"Stage A has no offline buffer, so RQ1/RQ2 cannot be evaluated until Stage B lands"* is downgraded: Stage B lands first and is the smaller of the two.
  - `specs/gateway-sync/*` gains Stage-B requirements; `treklink-firmware/specs/onboard-queue/*` is created as the firmware-side spec suite, following the convention that specs live in `specs/{module}/` inside the repo that holds the code (`01-conventions/02-spec-driven-development-workflow.md` §2).
- **Owner**: KhoaDD (MF-02 owner).

D-019: Firmware changes are additive and non-destructive; stock behaviour is preserved and must keep working

- **Status**: ✅ **Resolved** (2026-09-17, Session 7)
- **Context**: D-008 established that the firmware is editable. It did not say *how*. The queue work in D-018 touches `src/mqtt/MQTT.{h,cpp}`, stock Meshtastic files on the critical path of the app-pairing and MQTT-uplink features the product depends on. Overwriting them in place would destroy the measurement baseline RQ1/RQ2 need, and would risk the two integrations the demo cannot lose.
- **Decision**, three binding constraints on every firmware change this term:
  1. **Never delete or overwrite stock logic. Preserve it and branch around it.** The replaced stock path is kept intact and reachable, either behind a compile-time flag defaulting to the TrekLink path or extracted verbatim into a clearly-named function that the new code can call. A reviewer must be able to read what upstream did without consulting git history.
  2. **Stock Meshtastic mobile-app compatibility is a hard requirement.** The phone app pairs over BLE and, with `proxy_to_client_enabled`, carries the MQTT uplink itself (`MQTT.cpp:800` , `:607`). That path must keep working unmodified, it is how a guide with a phone and no laptop reaches the backend at all, and it is Stage C's mobile ingress.
  3. **The stock MQTT endpoint stays the publish target.** TrekLink does not invent a wire format here. Events still leave as `ServiceEnvelope` on `<root>/2/e/<channelId>/<nodeId>` and JSON on `<root>/2/json/...` (`MQTT.cpp:423–430`). The queue changes *which event leaves next and whether it survives a reboot*, never what it looks like on the wire. This keeps `gateway-sync` 's normalizer (D-007) unchanged and keeps the units legible to any stock Meshtastic tooling.
- **Rationale**: constraint 1 is what makes the D-018 baseline reproducible, "unmodified firmware" must be a build the team can still produce on demand, not a git tag nobody can flash. Constraints 2 and 3 protect the two integrations whose loss would cost the demo, for no benefit: nothing about a durable queue requires a new wire format or a forked app protocol.
- **Consequence**: a firmware PR that deletes stock code, changes a published topic shape, or breaks app pairing is rejected on this decision regardless of how well the queue works.
- **Owner**: KhoaDD.

D-020: Basecamp gateway (Stage C) delivery form: browser-first, native desktop as fallback, no iOS

- **Status**: 🟡 **Decided in principle, build deferred** (2026-09-17, Session 7). Stage C is scheduled after Stage B; this records the form so Stage B's interfaces do not foreclose it. **Form superseded by D-033 (2026-10-03)**: Stage C ships as the Field Station, a single bundled executable on the renter's own laptop with a local browser UI.
- **Context**: Stage C needs a machine at basecamp with more storage than a node and an intermittent internet uplink. Three delivery forms were considered, against a guide who is not a technician.
- **Options considered**:
  1. **Purely web-based**, the guide opens a tab. The page reaches the node over **Web Serial** (tethered laptop) or **Web Bluetooth** (phone or laptop), holds the queue in browser-local storage (IndexedDB), and forwards upstream when the

network returns. No install, cross-platform by construction, one artifact to maintain.

2. **Native cross-platform desktop app** (Windows/Linux/macOS), or the `server.sh` / `server.bat` one-click equivalent over the existing `gateway/src`. Full serial access, no browser-permission friction, real filesystem storage. Three build targets and a signing/distribution problem.
3. **A second Android app running alongside Meshtastic**, rejected. iOS is unviable without macOS/Xcode (already established in D-005), so this splits guide behaviour by platform, and it duplicates the pairing the stock app already does.

- **Decision**: **Option 1 is the target form**, with Option 2 retained as the documented fallback for any venue where browser device APIs are unavailable. Option 3 stays rejected, consistent with D-005.
- **Rationale**: Option 1's install cost is zero, which is the only property a non-technical guide actually experiences. `gateway/src` is not wasted under it, the queue policy, priority tiers and flush ordering are the substance and port directly; only the transport and storage adapters differ, which is the same ingress-adapter seam D-007 already defines.
- ⚠️ **Known risks, accepted and carried** (see the risk table):
  - **Web Serial and Web Bluetooth are Chromium-only**, no Safari, no Firefox. On iOS this means *no browser at all* can reach the node, so an iPhone guide is served only by the stock Meshtastic app path (D-019 constraint 2), not by Stage C.
  - **A tab is a fragile host for a durable queue.** Backgrounded tabs get throttled, and a closed tab stops forwarding. IndexedDB survives the close, so nothing is lost, but delivery stalls until the tab is reopened. This must be surfaced in the UI and stated honestly at the council, not presented as an always-on service.
  - **WebRTC is not the mechanism.** It was raised as a candidate; it addresses peer-to-peer transport, not device access or storage, and is not required by Option 1. Recorded here so it is not reintroduced as an assumption.
- **Owner**: KhoaDD; revisit at Stage C kick-off.

D-021: Encryption: provision a custom channel PSK; keep the MQTT hop plaintext behind TLS

- **Status**: ✅ **Resolved** (2026-09-17, Session 7)
- **Context**: "turn on end-to-end encryption" was raised as a requirement. Inspection shows the premise needs splitting, because two independent switches were being treated as one.
  - **LoRa channel PSK.** `Channels::initDefaultChannel()` (`Channels.cpp:128–134`) already sets `psk.bytes[0] = 1`, which `:238` documents as *"no change vs defaultPSK"*. So RF traffic **is** AES-encrypted out of the box, with **Meshtastic's published default key**. Any stock client in range decrypts it, SOS positions included. Encryption is present; confidentiality is not.
  - **`moduleConfig.mqtt.encryption_enabled`.** Controls only whether the packet handed to the broker stays encrypted. D-007 froze it `false` so the backend receives decoded payloads.
- **Decision**:
  1. **Provision a custom per-fleet PSK on the primary channel**, replacing the default key, as part of device provisioning in MF-01. This is the change that delivers actual confidentiality on the RF hop, and it is configuration, not code.
  2. **`encryption_enabled` stays `false`** (D-007 unchanged). The gateway→cloud hop is secured by **TLS plus a per-gateway API key** instead.
- **Rationale**: setting `encryption_enabled = true` would force reimplementing Meshtastic's AES-CTR channel crypto inside NestJS *and* would eliminate the JSON topic entirely (`MeshPacketSerializer` needs a decoded payload), taking out the whole Stage A ingress path, to protect a hop that TLS already protects. The real exposure was never the broker hop; it was the well-known RF key, which item 1 closes for the cost of a provisioning step.
- **Consequences**:
  - Device provisioning acquires a new mandatory step, and the PSK becomes a managed secret, never committed, never printed in a graded document, distributed per D-015 as configuration.
  - A custom PSK means a **stock Meshtastic app must be given the channel** to pair usefully. This does not violate D-019 constraint 2, the app path still works, it just needs the channel QR like any Meshtastic channel.

    - Losing the PSK bricks the fleet's interoperability until every unit is re-provisioned. Treat it as a recovery-critical secret with an escrowed copy.

- **Owner**: KhoaDD; provisioning step to be written into `specs/devices/`.
- **Amended by D-082** (2026-10-30): the escrowed secret is one master; per-organization channel keys are derived from it on the server and never stored.

D-022: `capstone` is a live auto-sync repository; the no-direct-push rule is scoped to the code repos

- **Status**: ✅ **Resolved** (2026-09-17, Session 7)
- **Context**: `capstone/` was already a local git repository with no remote, tracking `AGENTS.md`, `CLAUDE.md` and `Documents/`, the three sibling repos are gitignored. The team needs graded paperwork (progress log, reports, diagrams, meeting notes) to move between members continuously, edited from Obsidian. That is incompatible with `01-conventions/07-github-workflow-git-conventions.md` §3, which requires every change to arrive by PR and forbids direct pushes to any branch.
- **Options considered**:
    1. Fold `Documents/` into `treklink-docs`, one repo, but every progress-log edit becomes a PR, which defeats the purpose and would make the workbook a merge-conflict generator.
    2. `capstone` with the three siblings as submodules, rejected: detached HEADs and stale checkouts are a known failure mode for a team under deadline, and it solves nothing here.
    3. Give the existing `capstone` repo a remote and let it auto-sync.
- **Decision** (Option 3): `capstone` is published as a **private** repository and runs **auto-commit / auto-push to `main`**. The no-direct-push rule is explicitly **scoped to `treklink-docs`, `treklink-web` and `treklink-firmware`**, which keep full PR discipline.
- **Rationale**: PR review exists to gate code that can break a build or a contract. Meeting notes and a progress log cannot. Applying the same ceremony to both makes the ceremony get skipped for the thing that actually needs it. Separating them keeps the gate credible where it matters.
- **Scope limits, all three are load-bearing**:
    1. **`capstone` only.** A change to a sibling repo is still a PR, always.
    2. **`_docs/` stays read-only in the vault.** `treklink-docs` is a nested repository that `capstone/.gitignore` excludes, so Obsidian can read and link conventions while edits to them still go through a PR. This is a feature, not a limitation.
    3. **History stays linear.** `pull.rebase = true` is set in the repo config; merge commits remain prohibited everywhere (§3).
- **Consequences**: the repo is private, because `Documents/` holds supervisor meeting notes and course-issued PDFs. Auto-commit intervals must exceed a typical agent session, or in-progress edits get committed mid-work.
- **Owner**: KhoaDD.

D-023: A Main Flow owner is not the assignee of every story in that flow

- **Status**: ✅ **Resolved** (2026-09-17, Session 7)
- **Context**: raised by LongLP, the charter (`01-project-charter.md:14`) and roadmap (`02-roadmap-and-milestones.md:164`, `:249`) name **LongNN** as the frontend/FSD, map-and-monitoring-UI member and **MF-04 owner**, while the generated backlog assigned every `module:monitoring` story to TanNB. Verified by inspection, and the report was correct on MF-04 and over-generalised beyond it.
- **What the audit actually found**:
    - LongNN held **zero** monitoring and **zero** frontend stories, his nine were devices ×4, trips ×3, auth ×1, billing ×1. He did not own `TK-63`, the MapLibre/Goong live map, despite being the designated map member.
    - Load was skewed: TanNB 28 stories across nine modules, LongNN 9.
    - Cross-tabulating all 75 MF-tagged stories showed 66 "mismatches" *if* one assumes the flow owner owns every story in it. **That assumption is wrong**, MF-01's stories are spread across all five members by design.

    - **MF-04 was the only flow whose named owner held none of its stories.** That is what made it a real defect rather than a naming artifact.
    - It was **not a generator bug**: `build_backlog.py` documented a deliberate Session-2 rearrangement that was never reflected back into the charter.

- **Decision**, two parts:
    1. **The roles are distinct and both are kept.** A **Main Flow owner** (D-016) is accountable for that flow reaching Demo Ready on the Mainflow Coverage Matrix. A **story owner** implements one story. A flow legitimately spans several implementers. Do not reassign a whole flow to its owner.
    2. **MF-04 is corrected by layer, not by flow.** UI stories → **LongNN** (`TK-63` live map, `TK-64` telemetry display, `TK-73` gateway connectivity indicator, exactly the "map and monitoring UI" the charter names). Backend infrastructure stays with **TanNB** (`TK-61` Socket.io gateway, `TK-46` monitoring read API). Session 2's reasoning for placing infrastructure there is unchanged.

- **Rationale**: this satisfies the charter's *skill* basis and the Session-2 risk weighting simultaneously, the frontend member gets the frontend work, the riskiest backend infrastructure stays where it was deliberately put. No charter or roadmap edit is needed, because the charter was already right.
- **Consequence, individual contribution**: the register already carries the risk that a member with thin visible contribution fails individually even when the group passes. LongNN listed as MF-04 owner while another member demos MF-04 is exactly the *"which part did you do?"* failure the faculty handbook describes. This correction is as much about defensible individual evidence as about tidy assignment. New balance: TanNB 25, LongLP 20, Khoa 18, HoangTK 13, LongNN 12.
- **Also corrected in the same pass**: `build_backlog.py` carried an assignment rationale naming a teammate as unreliable. That file is tracked and forms part of the graded documentation set. The rationale is rewritten in terms of layer and track record; person-level judgements belong in `ignore/`, not in a graded repository.
- **Follow-up**: Jira must be re-synced for `TK-63`, `TK-64`, `TK-73` before implementation starts.
- **Owner**: KhoaDD.

D-024: Prose conventions are binding, and Jira keys are scoped to Epics and User Stories

- **Status**: ✅ **Resolved** (2026-09-22, Session 8). Two rulings recorded together because both were issued in the same instruction and both touch `01-conventions/07`.
- **Context**: two separate wording and tracking defects were raised by the leader.
    1. Every tracked document, and every AI chat reply, was using the em dash as a general-purpose clause separator. At volume it reads as machine-generated, it is inconsistent with the graded reports' register, and it hides the sentence boundary a reader under time pressure needs.
    2. `07-github-workflow-git-conventions.md` §2.2 said a branch without a Jira key was *"rare, prefer creating the card."* Followed literally, that mints a Jira card for every CI fix, tooling change and conventions edit, which pollutes the backlog, the Mainflow Coverage Matrix and the burndown. Those three are exactly what the supervisor reads at the weekly Group Meeting.

- **Decision**, two parts:
    1. **Prose conventions are binding**, published as `01-conventions/14-prose-and-wording.md` (`14-prose-and-wording.md`). No em dash in prose anywhere, no en dash as a clause separator, no banned openers, no aphorism formulas, no two-beat antithesis, no unverified claims, no fabricated precision. Code fences, inline code spans, "not applicable" table cells and verbatim quotations are exempt as data. Every AI assistant loads the `prose-and-wording` skill and `caveman` level `full` at session start, without being asked; chat is compressed, anything persisted to a repository stays normal prose. *(The `caveman` clause is superseded by D-043.)*
    2. **A Jira key belongs to an Epic or a User Story and to nothing else.** A branch and a commit scope carry a key only when the unit of work is one of those cards. Housekeeping, CI, automation, tooling, conventions and non-deliverable documentation carry no key and use a plain descriptive branch. Task and Subtask breakdown is tracked inside the parent story card, not as its own keyed branch. Do not create a card so that a branch can have a key.

- **Rationale**: part 1 is a register decision, and the register of a graded artifact is not cosmetic, because the Faculty Council reads the reports. Part 2 restores the backlog's meaning: a card should represent delivered product scope, so that the

Coverage Matrix stays an honest instrument.

- **Consequences**:
  - `07-github-workflow-git-conventions.md` §2.2 and §3.1 are amended in the same pass.
  - `00-index.md` gains row 14.
  - The four canonical `AGENTS.md` copies gain §2.7 and a line in §6.
  - A **mechanical sweep ran on 2026-09-22** across `treklink-docs`, replacing 1230 em dashes in 54 files. It was verified by diff sampling, `git diff --check` for the trailing whitespace a blind join leaves behind, and the new checker, per chapter 14 §6.2. `treklink-web` and `treklink-firmware` are **not** swept; chapter 14 §6 corrects a file when it is next edited for another reason.
  - **`.github/scripts/check_prose.py` and `.github/workflows/prose-check.yml` are built and green.** They enforce the two regex-detectable rules, the em dash in prose and a banned opener at the start of a sentence, on every pull request and push to `dev` and `main`. The rest of chapter 14 stays review-enforced, because a checker that guesses at aphorism formulas or unverified claims produces false positives.
  - **Never swept, and skipped by the checker**: `topics/`, `ignore/`, and the two generated backlog files. Chapter 14 §6.1 carries the list.
- **Incident recorded in the same pass**: the first run of the sweep had an exclusion filter for `topics/` that silently failed. It reworded the **registered capstone project title**, in English and in Vietnamese, in both `topics/Phieu_FA26SE159.md` and `topics/Phieu_dang_ky_de_tai_TrekLink_FA26_FINAL.md`. Caught by sampling the diff, reverted with `git checkout` before any commit, net change zero. Those forms are the version the school holds and the title is frozen until the Week 6 scope lock. The rule that came out of it is `08-ai-agent-steering-and-discipline.md` Stage 2.7: print the file list a sweep will touch and confirm the exclusion held, do not assume the filter worked.
- **Two further standing rules were issued in the same instruction** and are recorded as `08-ai-agent-steering-and-discipline.md` Stages 2.6 and 2.7:
  - **Stage 2.6**: a standing instruction from the leader is written into the conventions in the same pass, routed by kind. An instruction that lives only in a chat transcript is lost at the next session boundary.
  - **Stage 2.7**: correct before polished. A document that is factually right, cites its evidence and contradicts nothing is done, even if its wording is plain. This does not license an unverified claim; Evidence Completeness still outranks Resource Efficiency.
- **Owner**: KhoaDD.

D-025: `dev` reaches `main` by fast-forward push, and the handbook PDF is committed on the PR branch

- **Status**: ✅ **Resolved** (2026-09-25). Leader-approved.
- **Context**: `main` and `dev` diverged in `TrekLink-Team.github.io` and in this repository, although neither held content the other lacked. Three mechanisms caused it. (1) GitHub's "Rebase and merge" re-creates each commit with a new SHA, even when a fast-forward is possible, so after landing landing-site PR #12 `main` and `dev` each held 9 commits the other lacked, with byte-identical trees. (2) "Squash and merge" of a `dev` → `main` PR creates one new commit on `main`. (3) `.github/workflows/handbook.yml` tried to commit the rebuilt PDF to whichever of `dev` or `main` it ran on, so every push to `main` could add a bot commit that existed on `main` alone. Since branch protection was applied on 2026-09-22 that push has been rejected on both branches (the workflow token cannot bypass protection), so every handbook run on `dev` failed and the committed PDF stopped at `eb033a7`. In this repository `main` carried 6 such commits: resync copies of older `dev` states, a PDF rebuild, and the retired `mermaid-10.9.1.min.js` cache. Every file they changed has a newer version on `dev`.
- **Decision**:
  1. The `dev` → `main` release PR is opened and approved as before, then landed by the leader with `git push origin origin/dev:main` after `git merge-base --is-ancestor origin/main origin/dev` succeeds. Never with the merge button. `07-github-workflow-git-conventions.md` §5.7 carries the command.
  2. `handbook.yml` commits the rebuilt PDF to the head branch of a same-repository pull request, so the PDF reaches `dev` inside the reviewed PR and `main` through the release fast-forward. On pushes to `dev` and `main` it only validates. `_docs/handbook/README.md` describes the flow.

3. Existing divergence is repaired once per repository. Where `dev` already contains all of `main`'s content, `main` is moved to `dev`'s tip. Where `main` holds content `dev` lacks, `dev`'s own commits are replayed onto `main` and `dev` is pointed at the result. Both need a temporary `allow_force_pushes` on the target branch, restored immediately after a push leased on the old SHA.

- **Rejected**: (c) commit the PDF on pushes to `dev` only. It fails for the same protection reason. (d) Give the workflow a token that bypasses protection. It reopens the direct-push path that protection exists to close. (a) keep releasing with "Rebase and merge" and realign after each release. It needs a force-push on a protected branch every time. (b) Allow merge commits for `dev` → `main` only. It breaks the linear-history rule in §5.7 for the one PR where traceability matters most.
- **Consequences**: a hotfix landed on `main` (§2.4) is the only way `main` gains a commit `dev` lacks, and §2.4 already requires syncing it into `dev`. Everyone with a local `dev` or `main` in a realigned repository runs `git reset --hard origin/<branch>`, announced in Zalo.
- **Owner**: KhoaDD.

D-026: A failure response carries its error code in `result`

- **Status**: ✅ **Resolved** (2026-09-25). Leader-approved (treklink-web C-003 item 2).
- **Decision**: on failure the D-002 envelope keeps its four keys and sets `result` to `{ "errorCode": "..." }`, a stable machine-readable code such as `DEVICE_NOT_AVAILABLE`; `message` stays human text.
- **Rejected**: `result: null` with the code prefixed in `message` (parsing text is fragile); a fifth key (breaks D-002).
- **Consequence (2026-09-29, TK-90, `07-clarification-answers.md` §7 questions 1 and 7)**: from TK-90 on, the global exception filter sets `result.errorCode` on every failure. A `DomainException` carries its own code; a Nest `HttpException` maps by status to the catalogue code for 400, 401, 403, 404, 413 and 503, and any other 4xx keeps its status with the generic `CLIENT_ERROR`; an unhandled exception is a 500 with `INTERNAL_ERROR`, which is never used for a client error.
- **Owner**: KhoaDD.

D-027: One-endpoint operation dispatch is limited to `gateway-sync`

- **Status**: ✅ **Resolved** (2026-09-25). Leader-approved (C-003 item 3).
- **Decision**: `gateway-sync` keeps its single `POST /api/gateway-sync` route with an `op` discriminator (Session 7). Every other module uses REST routes as in `05-backend-conventions.md` §5.
- **Rejected**: reverting `gateway-sync` to REST (its design already relies on the dispatch); extending dispatch to all modules (loses per-route policy and HTTP caching).
- **Owner**: KhoaDD.

D-028: A cross-cutting `platform` module

- **Status**: ✅ **Resolved** (2026-09-25). Leader-approved (C-003 item 1).
- **Decision**: `backend/src/modules/platform/` and `specs/platform/` hold the response envelope, configuration, runtime parameters (UC-19), the audit sink and viewer (UC-20), the scheduler and health.
- **Rejected**: folding them into `auth`, which would make every module import `auth` for reasons unrelated to identity.
- **Owner**: KhoaDD.

D-029: Backlog Jira keys follow the keys Jira issued, offset by five

- **Status**: ✅ **Resolved** (2026-09-25).
- **Context**: the first `jira_sync.py --apply` run found `TK-1` to `TK-5` already in the project. The epics were issued `TK-6` to `TK-13` and the stories `TK-14` to `TK-103`, five above every key the backlog had predicted.
- **Decision**: `build_backlog.py` sets `JIRA_EPIC_BASE = 6` and `JIRA_STORY_BASE = 14`, and the backlog is regenerated. Every `TK-nn` cited before this entry, for example `TK-63`, `TK-64` and `TK-73` in the MF-04 correction above, refers to the old prediction; add five to find the live card. `TK-45` in branch and commit examples is illustrative and unchanged.

- **Rejected**: deleting and recreating the cards to reach `TK-1`, because Jira never reuses an issue number.
- **Owner**: KhoaDD.

D-030: The module specs govern the device, incident and rental state machines

- **Status**: ✅ **Resolved** (2026-09-26). **Superseded by D-034 and D-035 (2026-10-03)**: the booking, trip and rental machines it reconciled no longer exist after the D-033 rescope.
- **Context**: the Report 4 SDD draft (capstone PR 1) follows `treklink-web` specs and `schema.prisma`, which disagree with the SRS state machines drawn from `07-clarification-answers.md` §5. Incident: §5 question 6 reopens `Resolved` to `In Progress` and dismisses only from `Detected`; `specs/incidents/design.md` §2 reopens to `DETECTED` and dismisses from `DETECTED` or `ACKNOWLEDGED`. Rental: §5 question 27 has `Created`, `Active`, `Returned`, `Closed`, `Escalated`; `specs/rentals/design.md` has `DRAFT`, `READY`, `CHECKED_OUT`, `OVERDUE`, `RETURNED`, `CLOSED`, `CANCELLED`. Device: SRS Figure 22 failed the handover check from `Reserved`, while §6 question 12 already made `specs/devices/design.md` §2.1 authoritative (`RENTED` to `MAINTENANCE`). Trip: the same eight states under different names (§5 question 26 `On Prepare`, `On Booking`, `On Start`, `Ongoing`; the schema `PREPARING`, `BOOKING_OPEN`, `READY`, `IN_PROGRESS`).
- **Decision**: the specs and the schema govern the device, incident and rental machines. The SRS is amended to match (Record of Changes 2026-09-26): rental `Overdue` replaces `Escalated` and is entered at the return time plus the late-fee grace; a device still out after `rentals.nonReturnGraceDays` is flagged loss-suspected (§6 question 14). §5 questions 6 and 27 are superseded. Trip names stay as they are on both sides: the SRS keeps the display names of §5 question 26, and the SDD maps each to its stored value. Booking names are unchanged by this entry; §6 question 23 still governs them.
- **Rejected**: renaming the specs and the schema to the §5 answers, because the seven-state rental covers cancellation before check-out and the late state that merged code already uses, and it would need a forward migration of three enums. Renaming the trip enum, because a mapping costs no code.
- **Owner**: KhoaDD.

D-031: The map reverts to Leaflet over OpenStreetMap, with a Vietnamese sovereignty overlay (supersedes D-012)

- **Status**: ✅ **Resolved** (2026-09-29).
- **Context**: D-012 moved the map to Goong Maps over MapLibre GL because every OpenStreetMap base layer labels Hoàng Sa and Trường Sa with foreign toponyms; the leader's screenshots in `capstone/Documents/evidence/map-sovereignty/` confirm it. The leader asked the supervisor, who accepts OpenStreetMap for this university project as an educational use.
- **Decision**: Leaflet renders OpenStreetMap raster tiles. Goong stays dormant: its configuration keys and the D-012 integration notes are kept, no code path calls Goong, and no Goong key is required. A small Leaflet overlay labels Hoàng Sa and Trường Sa in Vietnamese as Vietnamese territory, because Nghị định 174/2026/NĐ-CP Art. 93(3)(a) penalises failing to depict sovereignty fully as well as depicting it wrongly. Provider, tile URL, attribution and default viewport stay configuration (**D-015**), so a return to Goong is a configuration and renderer change.
- **Residual risk**: OpenStreetMap's own foreign labels still render beneath the overlay. The supervisor's acceptance covers the course; it does not change the decree. R11 is reopened as an accepted risk within educational scope: nothing built on OpenStreetMap tiles is deployed publicly beyond the course, and any such deployment first switches the provider back to Goong and re-runs TC-24.
- **OpenStreetMap tile usage policy** (https://operations.osmfoundation.org/policies/tiles/): attribution visible on the map, a named User-Agent and a valid Referer, no cache bypass, and no bulk prefetch. The last rule means OpenStreetMap tiles cannot be cached for offline field use by the Basecamp gateway (D-020).
- **Rejected**: keeping Goong as the renderer (leader decision); OpenStreetMap without the overlay, because it leaves the omission clause open for the cost of one layer; a viewport that excludes the archipelagos, because the user can still pan to them.
- **Consequences**: D-012 is superseded. The conventions, charter, roadmap, Main Flows, requirements foundation and the canonical `AGENTS.md` are updated in this pass. Queued: the graded reports and their generators in `capstone`, and the `treklink-web` specs (`frontend`, `monitoring`, `platform`) and code (`shared/config/map.ts`,

`widgets/LiveMapWidget`, the `maplibre-gl` dependency), which go to the frontend lane as a spec change first. TC-24 now tests the overlay.

- **Owner**: KhoaDD; LongNN (frontend lane).

D-032: The health endpoint reads MQTT state through an optional probe that `gateway-sync` registers

- **Status**: ✅ **Resolved** (2026-09-29). Leader-approved in TrekLink-Team/treklink-web#15, recorded in `07-clarification-answers.md` §7 questions 2 and 9.
- **Context**: `specs/platform/api-design/01-get-health.md` reports MQTT broker reachability by calling `MqttIngressAdapter.isConnected()` (REQ-EVT-04, US-077). `specs/gateway-sync/design.md` §2.1 defines `MeshIngressAdapter` with only `path`, `start()` and `stop()`, and the adapter (gateway-sync task 5.1) is not built. `platform` depends on no other module (`treklink-web` `specs/platform/requirements.md:28`, "Depends on: nothing"; the module itself is D-028), so the health service cannot import `gateway-sync`.
- **Decision**: `platform` defines an optional `MqttHealthProbe` interface, `isConnected(): boolean`, and the injection token `MQTT_HEALTH_PROBE`. The health service injects it as optional. While no implementation is registered, `components.mqtt` is `unknown` and does not change `status`. A registered probe reporting a lost connection makes `status` `degraded`. `MqttJsonIngressAdapter` implements the probe and registers the token when `gateway-sync` builds it.
- **Rejected**: omitting `mqtt` from the response until `gateway-sync` Phase 5, because the response shape would change later and clients would code against both shapes; a broker connection owned by `platform`, because it duplicates the ingress connection and reports the reachability of a second client, not of the path events actually arrive on.
- **Consequences**: TK-90 amends `api-design/01-get-health.md` (the `mqtt` value set and the `status` rule), `specs/platform/requirements.md` REQ-EVT-04 and `specs/gateway-sync/design.md` §2.1.
- **Owner**: KhoaDD; LongLP (TK-90).

D-033: TrekLink is an enterprise device-rental platform built on asset management (rescope after Review 1)

- **Status**: ✅ **Resolved by the leader** (2026-10-03). Supervisor sign-off of the adjusted registration form is pending (co-supervisor Bùi Văn Phúc, 2026-10-04; then Đặng Ngọc Minh Đức). Supersedes the booking scope of **D-016**, the Stage C form of **D-020** and the state machines of **D-030**. Rule 3 amended by **D-074** (generic device groups) and rule 8 by **D-073** (device first) on 2026-10-28.
- **Context**: at Review 1 (2026-10-01) the reviewers held that the registered title, "Smart Device Rental Management **Platform for Trekking Agencies**", contradicts the presented scope, which worked like one tour agency taking customer bookings. Report 3 SRS §1 called the product "a single-tenant operations system for one trekking agency". The registered form body (`treklink-docs/topics/Phieu_FA26SE159.md:111-153`, `:285`, `:305`) and the supervisor's flow image (`Documents/course-material/TrekLink-proposed-mainflow-ducndm.png`, MF-1 "Booking → Rental → Trip Preparation") both carry the booking flow, so the contradiction sits inside the registration, between its title and its body. Reviewer Lâm Hữu Khánh Phương asked for an IoT solution provider renting equipment with a management platform by package and monthly payment; the Review 1 minutes listed multi-tenancy as out of scope. At the 2026-10-02 meeting the supervisor ruled that the title cannot change, that the registration form may be adjusted one last time with changes highlighted, and that the product must be a platform, renting to a single company being a system (`capstone/Documents/meetings/2026-10-02_Rescope_Meeting_and_Review_Guidance_Summary.md`). The course defines a platform as one whose services come partly from the operator and partly from partners.
- **Decision**:
  1. **TrekLink is the sole provider** of the devices, the firmware, the Field Station software and the cloud platform, and it is the **asset manager** of every device. There are no third-party device providers.
  2. **Renters are corporate organizations only.** An organization self-registers, is verified in person or by phone at TrekLink, signs a master contract and is approved by a TrekLink Admin. Many organizations use one platform and each manages its own members, on-duty roster, rented devices, alerts and API keys: that is the platform. **The partners' part stays outside the system**: each organization's trips, customers and emergency response are its own business and are not modelled. Inside the system it has only what alert routing needs.

3. **No individual renters, no bookings, no trips, no trek packages.** The website sells rental plans, nothing else.
4. **Plans**, priced per device by hardware variant, with a minimum order quantity per contract that TrekLink sets:
    - **Monthly plan**: the term is one month and renews until the organization gives notice during a running term. Each term opens with a holding fee of half the term fee, which is part of the fee and not refundable, and closes with the other half. Mid-contract, a month boundary therefore carries a full term fee; the final term ends with only the second half.
    - **Day plan**: a fixed length from a configurable list (3, 4, 7 days); the per-day rate is the monthly rate divided by 30 times a premium of at least 1, so a day plan always costs more per day. Paid in full at handover. Never renewed or extended.
    - **No change once a contract is running**: no added or removed devices, no variant change. An organization that needs more opens an additional contract. A device never passes from one contract to the next without being returned and inspected.
    - **Charges outside the plan**: late return per device per day after a grace period; damage from inspection, with charges above a threshold approved by a TrekLink Admin; loss at the device's remaining value.
5. **Handover and return happen in person at the TrekLink counter**, with identity, signature and payment checked there. No shipping.
6. **Monitoring is always on** for every rented device; it is what the organization rents. Alerts go first to the organization's on-duty member, then its backup member, then its Manager; if nobody acknowledges, TrekLink logs it and reports to the authorities (**D-034**). TrekLink never coordinates a rescue.
7. **Live telemetry reaches the organization** on the TrekLink web platform and through a REST plus WebSocket API with one key per organization, on every plan.
8. **Field side**: device holders use the stock Meshtastic app only and need no TrekLink account. The organization runs the **Field Station**, a single bundled executable on its own laptop, with one of its rented nodes on a USB serial port and a local browser UI (for example `localhost:4321`). It shows everything locally while offline, queues events durably, and uploads when the laptop has internet. Organization operators are trained from the TrekLink manuals and handbook before deployment. The Field Station is Stage C of **D-018**.
9. **Payments** are recorded in the platform. SePay (VietQR with a confirming webhook, sandbox environment) is the third-party payment gateway; cash and bank transfer at the counter are recorded by Staff.
10. **The five Main Flows**, numbered so that each owner keeps their flow:

MF	Name	Owner
MF-01	Organization onboarding → Rental contract → Handover	TanNB
MF-02	Field data → Field Station → Cloud synchronization	KhoaDD
MF-03	SOS → Tiered alert → Escalation	HoangTK
MF-04	Live telemetry: web map and organization API	LongNN
MF-05	Term end → Return → Inspection → Billing → Maintenance	LongLP

    Device intake and provisioning are supporting use cases that feed MF-01 and close MF-05's loop.

- **Rejected**: (a) keep the single-agency booking system and argue the title; the supervisor ruled the title fixed and the reviewers rejected the scope. (b) Third-party device providers listing fleets on the platform, the supervisor's reading of "platform"; it would reduce TrekLink's own hardware, firmware and gateway work to one listing among many and invite the reviewer's "what is unique here" objection. (c) Selling device packages with a maintenance fee; it drops "Rental Management" from a fixed title. (d) Individual renters; they force TrekLink to coordinate rescues and add a second payment model, and the title names trekking agencies. (e) Organization-created groups or trips inside the platform (create a group, add people and devices, pair them, export), raised by the supervisor at Review 1 (`ignore/khoa/docs/rescope/review-1-panel-transcript.md`); the leader ruled on 2026-10-04 that it contradicts the

supervisor's own "device management platform, not a trekking management platform" in the same review. A device carries a holder label for alert routing; trips stay in the organization's own systems.

- **Consequences**: Report 1 background and vision, Report 2 scope, Report 3 SRS, Report 4 SDD, `05-main-flows.md`, `06-requirements-foundation.md`, the adjusted registration form (`treklink-docs/topics/`), the backlog, and the `treklink-web` specs and schema for `rentals`, `trips`, `billing`, `auth`, `incidents`, `monitoring` and `frontend`. Multi-tenancy moves from out of scope to in scope; Review 2 must say so against the Review 1 minutes.
- **Owner**: KhoaDD.

D-034: Incident lifecycle with tiered notification and escalation

- **Status**: ✅ **Resolved by the leader** (2026-10-03; the leader delegated the design to the orchestrator with "multiple states, transient and atomic, a fallback for every edge case"). Replaces the five-state incident machine of the registration form and of `specs/incidents/design.md` §2.
- **States**:

State	Kind	Meaning
`DETECTED`	transient	Created from a confirmed SOS, a fall SOS or a suspected cadence episode; routed inside the same transaction, never observed at rest
`NOTIFY_PRIMARY`	timed	The on-duty member is alerted
`NOTIFY_BACKUP`	timed	The primary did not acknowledge in time; the backup member is alerted
`NOTIFY_MANAGER`	timed	The backup did not acknowledge in time; the organization Manager is alerted
`UNROUTED`	stable	No organization to route to (device not on a running or overdue contract, or the organization has no reachable member); TrekLink Staff own it
`ESCALATED`	stable	Nobody acknowledged, or an acknowledged response went silent too long; TrekLink Staff own it
`REPORTED`	stable	TrekLink Staff recorded a report to the authorities (agency, reference, time)
`ACKNOWLEDGED`	timed	An organization member owns the response
`RESPONDING`	timed	The organization reported a response under way; status updates are due on a cadence
`RESOLVED`	timed	The organization reported the outcome
`FALSE_ALARM`	timed	The organization, or Staff for an unrouted incident, declared it false with a reason
`CLOSED`	terminal	Nothing further is accepted

- **Transitions**:

From	Event	To
(none)	SOS, fall or suspected episode with no open incident for the device	`DETECTED`
`DETECTED`	routed to a running or overdue contract with a reachable primary	`NOTIFY_PRIMARY`
`DETECTED`	no contract, or no reachable member	`UNROUTED`
`NOTIFY_PRIMARY`	acknowledge timeout; or no primary on the roster	`NOTIFY_BACKUP`
`NOTIFY_BACKUP`	acknowledge timeout; or no backup	`NOTIFY_MANAGER`
`NOTIFY_MANAGER`	acknowledge timeout	`ESCALATED`
`NOTIFY_*`, `ESCALATED`, `REPORTED`	a member acknowledges	`ACKNOWLEDGED`
`ACKNOWLEDGED`	the owner reports a response under way	`RESPONDING`
`ACKNOWLEDGED`, `RESPONDING`	no status update within the stale limit	`ESCALATED` (owner kept, Manager notified)
`ACKNOWLEDGED`, `RESPONDING`	the owner is deactivated or leaves the organization	`NOTIFY_BACKUP`
`ACKNOWLEDGED`, `RESPONDING`	the owner reports the outcome	`RESOLVED`
`NOTIFY_*`, `ACKNOWLEDGED`, `RESPONDING`	a member declares a false alarm with a reason	`FALSE_ALARM`
`UNROUTED`, `ESCALATED`	Staff record an authority report	`REPORTED`
`UNROUTED`	Staff declare a false alarm with a reason	`FALSE_ALARM`
`REPORTED`	Staff record that the authority case is closed	`CLOSED`
`RESOLVED`, `FALSE_ALARM`	a new SOS episode from the same device within the reopen window	`NOTIFY_PRIMARY` (reopen count + 1)
`RESOLVED`, `FALSE_ALARM`	the reopen window elapses	`CLOSED`

- **Rules**:

  1. **Atomic.** Each transition is one database transaction: a compare-and-set on the incident's state and version, plus one append-only audit row (actor or `SYSTEM`, from, to, reason, UTC time). A losing concurrent writer reads the current state and the actor who won.
  2. **Idempotent timers.** Timeout jobs re-read state and deadline inside the transaction and do nothing when the incident has moved on, so a retried or duplicated job cannot double-escalate.
  3. **Notification never gates state.** Alerts are written to an outbox in the same transaction and delivered after commit (web, WebSocket, email, API event); a failed delivery is retried and logged, and the state machine continues on its timers.
  4. **Safety first.** An incident is created and routed even when the contract is overdue or the organization is suspended. An episode is one incident (correlation window, `gateway-sync`); ~~a device's cancel gesture is recorded on the incident and prompts the owner to confirm a false alarm~~ (withdrawn by D-038: the device never changes an incident).
  5. **Device silent during an incident**: the incident keeps its state and is flagged stale with the last position; the owner is notified.
  6. **A contract cannot be settled while one of its devices has an incident that is not `CLOSED`.**
  7. Timeouts, the stale limit and the reopen window are business parameters (D-015).

- **Owner**: HoangTK; KhoaDD.

D-035: Device, organization and rental-contract lifecycles

- **Status**: ✅ **Resolved by the leader** (2026-10-03). Replaces the seven-state device machine of the registration form and the booking, trip and rental machines of D-030. *The device lifecycle is amended by D-045 (loss from any in-service state, `DISPOSED`) and D-047 (a passed inspection of a unit due for service or firmware goes to `MAINTENANCE`; the weekly scan opens scheduled service).*
- **Device** (asset): `IN_INTAKE → AVAILABLE` (quality check passed) `→ RESERVED` (allocated to an approved contract) `→ RENTED` (handover signed) `→ RETURNED` (checked in) `→ AVAILABLE` (reset and inspection passed) or `MAINTENANCE` (inspection failed). Also `RESERVED → AVAILABLE` (contract cancelled before handover), `RESERVED → MAINTENANCE` (fails its check at the counter and is swapped, E01-5; edge added 2026-10-04 when the devices spec found it missing), `RENTED → LOST` (reported lost on a `RETURN_DUE`, `OVERDUE` or `DEFAULTED` contract, or unrecovered after default; amended by D-038), `LOST → RETURNED` (recovered), `LOST → RETIRED` (written off), `AVAILABLE → MAINTENANCE` (scheduled service), `MAINTENANCE → AVAILABLE` or `RETIRED`. `IN_FIELD` is dropped: telemetry gives last seen, not trail versus storage. Every device carries two identities registered at intake, a printed asset tag and the radio `nodeNum`, never reused. A returned device is reset (channel key, node database, owner name) before it can be `AVAILABLE` again, and the reset is logged.
- **Organization**: `PENDING` (self-registered) `→ ACTIVE` (verified at the counter, master contract signed, Admin approved) or `REJECTED`; `ACTIVE → SUSPENDED` (a contract defaulted, or Admin action) `→ ACTIVE` (settled); `ACTIVE → CLOSED` (no open contract). A `SUSPENDED` organization cannot open a contract; its running devices stay monitored.
- **Rental contract**: `REQUESTED` (the Manager submits plan, variant, quantity, start date) `→ APPROVED` (Staff confirm stock; devices `RESERVED`) or `REJECTED`; `APPROVED → ACTIVE` (first payment recorded and handover signed at the counter) or `CANCELLED` (before handover; devices released); `ACTIVE → ENDING` (monthly: notice given, ends at the current term end) `→ RETURN_DUE`; a day plan goes `ACTIVE → RETURN_DUE` at its end date; `RETURN_DUE → RETURNED` (every device checked in or recorded lost) `→ CLOSED` (every charge paid, no open incident); `RETURN_DUE → OVERDUE` (grace not yet elapsed, late fees accrue) `→ DEFAULTED` (grace elapsed: the organization is suspended, devices are tracked, Staff report to the authorities with the audit log as evidence) `→ RETURNED` once devices are recovered or recorded lost.
- **Monthly terms** are child records of a monthly contract: each term holds its holding-fee and balance payments and its due dates; a term's balance is due at its end, the next term's holding fee at the same boundary.
- **Owner**: TanNB (contract), LongLP (device, billing), KhoaDD (organization).

D-036: Stale artefacts move to `.deprecated/`; the specs and the schema are rewritten from the SRS

- **Status**: ✅ **Resolved by the leader** (2026-10-04).
- **Context**: after D-033 to D-035 every `treklink-web` spec suite and `schema.prisma` describe the booking scope. The specs index marked them stale (treklink-web PR 26), but stale files left in place are what an agent or a member builds against by mistake, and deleting them loses the reference that the rewrite reuses (gateway-sync, platform). The Neon database was never provisioned (D-010), and only `platform` holds code.
- **Decision**:
  1. **A stale artefact moves, whole, into a `.deprecated/` folder at the root of its own repository, keeping its original path** (`treklink-web/specs/rentals/` becomes `treklink-web/.deprecated/specs/rentals/`). Nothing under `.deprecated/` is built, linked from a live document, or cited as a requirement. Each `.deprecated/README.md` states what moved, when, and why.
  2. **Every `treklink-web` spec suite is rewritten** from Report 3 SRS (2026-10-04) and D-033 to D-035, in the full form: `requirements.md` in EARS traced to SRS FR, UC and BR identifiers, `design.md`, `tasks.md`, and one `api-design/` file per endpoint. `trips` is not rewritten; `organizations` is new.
  3. **The state machines are D-034 (incident) and D-035 (device, organization, rental contract).** Where an old spec or the old schema disagrees, the decision wins.
  4. **The migration baseline is rewritten**, not migrated forward: a new initial migration and seed replace the 2026-09-25 pair, which move to `.deprecated/`. Every member drops and recreates the local database once.

- **Rejected**: deleting the stale suites (loses the reuse source; history is a poor reading surface); a forward migration with drops (protects data that does not exist).
- **Consequences**: unmerged branches built on the old schema (the booking-state rename, `feat/TK-22-admin-manage-user-account`) rebase onto the new baseline. Spec approval per module still goes through its owner's review before implementation (AGENTS.md §2.1).
- **Owner**: KhoaDD.

D-037: Field Station credentials are self-service; one invoice per term; handover notes are signed on screen

- **Status**: ✅ **Resolved by the leader** (2026-10-04), during the spec rewrite of D-036.
- **Decision**:
  1. **Field Station credentials are self-service.** An Org Manager creates, names and revokes the organization's Field Station credentials in the portal, the way API keys work (UC-06); each credential is shown once and stored only as a hash. TrekLink Staff and Admin may revoke one for support but never see it. TrekLink provides the service; how the organization deploys its stations is its own business.
  2. **One invoice per monthly term with two dated lines**: the holding fee due at the term start and the balance due at the term end (FR-BILL-01, FR-BILL-06). Payments apply line by line.
  3. **The handover note is signed on screen** at the counter; the drawn signature is stamped into the generated PDF and the PDF's hash is stored (FR-CON-06).
- **Rejected**: Staff-issued Field Station credentials only (puts routine operations on TrekLink); two invoices per term (contradicts FR-BILL-06); a scanned paper signature (needs document storage and is weaker evidence of what was signed).
- **Owner**: KhoaDD.

D-038: SePay webhook answers SePay's own body; no on-device SOS cancel; a device may be recorded lost from RETURN_DUE

- **Status**: ✅ **Resolved by the leader** (2026-10-04), during the spec rewrite of D-036. *Rule 3 is superseded by D-045: a loss may be reported from any in-service state.*
- **Decision**:
  1. **`POST /api/payments/sepay/webhook` is the one exception to D-002.** It answers HTTP 200 with the bare body `{"success": true}`, because SePay treats any other body as a failure and retries up to 7 times over 5 hours (https://docs.sepay.vn/tich-hop-webhooks.html, read 2026-10-04). Every other endpoint keeps the envelope.
  2. **An incident is never ended or changed by the device.** The firmware transmits nothing on cancel (`04-firmware-ground-truth.md` §2, `TrekLinkSOSHelper.cpp:49-53`), and even if it did, a cancel pressed on the device cannot be told apart from one pressed under duress. FR-INC-09 and exception E03-8 are withdrawn from the SRS; D-034 rule 4's sentence on the cancel gesture is withdrawn with them. A false alarm is declared only by a person (FR-INC-08).
  3. **D-035 amended**: Staff may record a device `LOST` on a contract in `RETURN_DUE`, `OVERDUE` or `DEFAULTED` when the organization reports the loss or the device is unrecovered after default. The loss is charged at the device's remaining value (FR-BILL-05) and counts as returned for closing the contract.
- **Rule 2 confirmed** (2026-10-29, leader ruling on treklink-web PR 114): a person ends every incident, the organization's staff, TrekLink Staff or the primary responder, never a device packet. An SOS that arrives after the reopen window of a `RESOLVED` or `FALSE_ALARM` episode closes that episode as `SYSTEM` under the normal window guard, the same close the timer of incidents task 3.1 makes, and opens a new incident. Inside the window, an SOS, attributed or not, reopens the episode, routed as at creation. REQ-UBI-05 and REQ-EVT-10 stand unchanged.
- **Rejected**: the envelope on the webhook (relies on undocumented SePay behaviour); a firmware cancel text that only logs (no consumer, and it still invites trusting the device over a person); inferring cancel from beacons stopping (indistinguishable from a dead battery); keeping `LOST` after default only (an honest report would suspend the organization and trigger an authority report).
- **Owner**: KhoaDD.

D-039: Where the platform runs, and how software on the organization's side is updated

- **Status**: ✅ **Resolved by the leader** (2026-10-13): (a) option 1, (b) option 2. Raised 2026-10-11.
- **Context**: D-033 rule 1 makes TrekLink the sole provider of the devices, the firmware, the Field Station software and the cloud platform; rule 2 has many organizations on one platform; rule 8 puts the Field Station on the organization's own laptop. D-010 hosts the database on Neon. Nothing records whether the backend could also run on an organization's own infrastructure (the self-hosted GitLab model), and nothing records how the Field Station, which runs at the customer end, receives new versions. That answer decides whether TrekLink has to ship over-the-air updates to customer infrastructure at all.
- **Options**, two independent parts (split 2026-10-13 after review of PR 60):
  - **(a) Where the backend runs**
    1. **One TrekLink-hosted, multi-organization backend; organizations integrate only through the web platform and their API key.** The only TrekLink software on the organization's side is the Field Station.
    2. **Self-hosted backend option**: an organization may run the TrekLink backend on its own infrastructure, with TrekLink shipping versioned backend releases and updates to it, alongside the Field Station.
    3. **Hybrid**: hosted by default, with a self-hosted tier for organizations that require data residency.
  - **(b) How the Field Station receives new versions**, needed under every option of (a), because the Field Station always runs on the organization's laptop (D-033 rule 8)
    1. **Self-update**: the Field Station checks a TrekLink release endpoint and installs a new version itself.
    2. **Re-download**: the organization downloads the new version from the portal and replaces the executable by hand.
  - **Device firmware**, the same under every option: updated at the counter during intake, reset or inspection, because every device passes through the counter between contracts (D-033 rules 4 and 5).
- **Recommendation (not a decision)**: (a) option 1. No recommendation yet for (b). Tier 3 of D-034 escalates unacknowledged alerts to TrekLink Staff, which needs every organization's incidents in TrekLink's own backend; the platform definition the supervisor accepted (many organizations on one platform) is a single deployment; options 2 and 3 add release management, version skew between installations and remote support of customer infrastructure inside a capstone schedule. Option 1 keeps the update problem to one artefact, the Field Station executable.
- **Decision**:
  - **(a)** The leader preferred the hybrid model (hosted by default, fully self-hostable, as GitLab offers) on condition that it fits the four implementation weeks (W9 to W12), and option 1 otherwise. It does not fit, so **(a) is option 1: one TrekLink-hosted backend for every organization.** Evidence: on 2026-10-13 the backend holds 17 TypeScript files with only the health and Prisma services written (`treklink-web/backend/src`). Hybrid would add, on top of option 1: two deployment profiles of one codebase, because assets, contracts and billing are TrekLink's own records and cannot move to a customer server; a synchronization channel between installations for contracts and devices one way and D-034 tier-3 escalations the other; D-040 attribution across installations; and every flow tested under both profiles.
  - **(b) Option 2, re-download.** The portal offers the current Field Station release with its version; the Field Station reports its version in every health message, and an older version is shown as outdated to the Manager and TrekLink Staff (SRS FR-EVT-13, FR-EVT-18, constraint 6).
- **Rejected**: (a) 2 and 3, for the scope above; hybrid is recorded as future work, not a capstone deliverable. (b) 1, self-update, which adds a release endpoint, signed binaries and a rollback path to design and test in W7 and W8.
- **Consequences**: SRS constraint 6, FR-EVT-13 and FR-EVT-18, out of scope widened, all 2026-10-13. The Report 4 SDD deployment view shows one cloud deployment plus a Field Station per organization. `treklink-web` specs gain the release download and the version in the health report.
- **Owner**: KhoaDD.

D-040: A field event belongs to the custody interval that contains its occurrence time

- **Status**: ✅ **Resolved by the leader** (2026-10-13). SRS edited 2026-10-13: FR-EVT-15 to FR-EVT-17, BR-36, E02-7, E02-8, FR-EVT-14, FR-INC-03, FR-MON-02, FR-MON-06 and FR-MON-08, ERD attributes. Adjusted form edited 2026-10-13: §3.2 b states time-based attribution. `treklink-web` edited 2026-10-13: `gateway-sync` , `incidents` , `monitoring` ,

`rentals` (`custodyAt` replaces `contractHolding`) and the Configuration Matrix (late-upload grace, attribution margin, device-time skew); `schema.prisma` gains `FieldEvent.capturedAt`, `occurredAt`, `timeSource`, `attribution` and `contractDeviceId`, with migration `20261013120000_field_event_attribution`.

- **Context**: co-supervisor Bùi Văn Phúc, reviewing the adjusted form and the SRS (Discord, 2026-10-12): organization A rents a device on 10/10 and raises an SOS at 16:00 while its Field Station is offline; the device is returned on 11/10 and rented to B; on 12/10 A's old SOS syncs. Routing by the device's current holder would send A's data to B. He asks for an assignment history over time linking Device, contract, Organization and FieldEvent, and for a rule when the device clock is unreliable or the timestamp is missing. Verified: the history exists (`ContractDevice.handedOverAt`, `checkedInAt`, `lostAt`), but FR-INC-03 routes to "the contract holding the device" at creation and FR-MON-02 and FR-MON-06 scope by what the organization rents now, so his scenario leaks. FR-EVT-14 accepts a Field Station's publishes only for devices its organization rents now, so after the return A's late SOS is refused and lost. The device `rx_time` is 0 without a valid RTC (`04-firmware-ground-truth.md`). Every device is reset and re-keyed at the counter between contracts (D-033 rule 5), so a late event for a returned device can only come from the previous renter's Field Station queue.
- **Decision**:
  1. **Occurrence time** is derived per event with its source recorded: the Field Station's capture time, corrected by the clock offset the station reports at each sync; the device `rx_time` only when non-zero and plausible; the server `receivedAt` always, as the upper bound.
  2. **Attribution**: the event belongs to the `ContractDevice` custody interval (handover to check-in or loss) that contains its occurrence time, and the uploading Field Station's organization must match that interval's organization. Incidents route, and telemetry streams, by the attributed contract and organization, never by the current holder.
  3. **No match**, or an occurrence time too close to a handover boundary to decide: the event is `UNATTRIBUTED` and goes to TrekLink Staff only.
  4. **Late uploads** from a Field Station are accepted for a configurable grace period after the device's return (D-015).
- **Rejected**: (b) attribution by the uploading credential alone, which checks no clock and cannot tell two contracts of one organization apart; (c) rejecting events older than the current custody, which drops SOS messages; (d) attribution by channel-key version, kept as a later hardening because whether the key version reaches the cloud is unverified (needs check against the firmware).
- **Consequences**: SRS: occurrence-time and attribution requirements, FR-INC-03, FR-MON-02, FR-MON-06 and FR-EVT-14 rewritten, exception E02-7 (the supervisor's scenario), a business rule for `UNATTRIBUTED`, ERD attributes. Form §3.2 b: one sentence. Schema: `FieldEvent` gains a capture time, a time source and an attribution state. Evaluation: the scenario becomes an isolation test (D-042).
- **Owner**: KhoaDD.

D-041: The device lifecycle is a state graph; the form lists states and transitions

- **Status**: ✅ **Resolved by the leader** (2026-10-13). Adjusted form edited 2026-10-13: the asset management item and the functional requirement list the eight states and the main transitions. *The state list grows to nine with `DISPOSED`, and `LOST` is reachable from every in-service state (D-045).*
- **Context**: Bùi Văn Phúc (2026-10-12) read the form's "In Intake → Available → Reserved → Rented → Returned → Maintenance → Lost → Retired" as one sequential path, and noted that a returned device that passes inspection goes back to Available and that a rented device can be lost. The SRS state machine (Figure 22) already has those transitions; the arrow chain in the adjusted form (§3.2 b and the products list) causes the misreading.
- **Decision**: keep the eight states and transitions of D-035 and the SRS. The form lists the states and names the main transitions instead of chaining them. The whiteboard names of 2026-10-11 (`08-whiteboard-target-flows.md` §1) are mapped in the SDD: Registered is In Intake, Liquidate is the disposal step after Retired.
- **Rejected**: adopting the whiteboard states in the SRS one week before Review 2 (requirements, ERD enum, specs and schema all change); replacing the arrows with commas only (the transitions stay unstated).
- **Owner**: KhoaDD.

D-042: Multi-organization isolation and load are evaluated by a separate test suite

- **Status**: ✅ **Resolved by the leader** (2026-10-13). SRS edited 2026-10-13: NFR-SEC-04 names at least two organizations per module and the late-event test, NFR-PERF-02 and NFR-PERF-03 name a simulated load test. Adjusted form edited 2026-10-13: TP6, Experiment 2 (two organizations at once, at least 4 participants, cross-organization leakage measured) and Integration & System Testing (isolation suite and simulated load test).
- **Context**: Bùi Văn Phúc (2026-10-12): the RQ3 drill uses one organization, which fits the incident workflow but does not test the many-organization requirement. He asks for integration and security tests with at least two tenants and a load test matching the multi-organization, multi-device NFRs. NFR-SEC-04 asks for a cross-organization test per module without a tenant count; NFR-PERF-02 and NFR-PERF-03 have no planned test.
- **Decision**:
  1. An isolation test suite with **at least two tenants** for every module, including the late-event scenario of D-040.
  2. A **load test** with simulated devices and Field Stations at the NFR-PERF-02 and NFR-PERF-03 levels, stated as simulated because only 3 to 5 physical devices exist.
  3. The **RQ3 drill runs with two organizations** at once. RQ1 to RQ3 stay unchanged in substance.
- **Rejected**: a new RQ4 (breaks the stated stability of the research questions); rewording NFR-SEC-04 only (no load test).
- **Owner**: KhoaDD.

D-043: Chat register follows `communication-tone`; the `caveman` skill is retired

- **Status**: ✅ **Resolved by the leader** (2026-10-13). Supersedes the `caveman` clause of D-024 part 1; the rest of D-024 stands.
- **Context**: D-024 made every AI assistant load `caveman` level `full` at session start to compress chat replies. The leader's prompt-orchestrator has since made `communication-tone` the single communication rule (`system-prompts/prompt-orchestrator/skills/communication-tone.md`, commit `a587916`, 2026-10-08). Its writing register forbids the compression `caveman` produces: "Do not invent abbreviations or arrows to save tokens" (§8). The skill is uninstalled on the leader's machine, so the conventions told every agent to load a skill that does not exist and contradicts the governing rule.
- **Decision**: every AI assistant loads `prose-and-wording`, `communication-tone` and `human` at session start, without being asked.
  1. `prose-and-wording` governs what any written text may contain (chapter 14).
  2. `communication-tone` governs chat replies: the four-part status (asked, done, state, next), settle scope then execute in one pass, and a plain technical register.
  3. `human` is the pass every submitted document goes through (chapter 15 §4). `caveman` is not loaded, and no chat reply is written in a compressed register.
- **Rejected**: keeping `caveman` for chat only (conflicts with `communication-tone` §8, which wins over any other file); dropping a named chat rule altogether (the four-part status would then be unenforced).
- **Consequences**: chapter 14 §5, the 00-index row 14 and §2.7 and §6 of the five canonical `AGENTS.md` copies are amended in the same pass.
- **Owner**: KhoaDD.

D-044: Report 4 SDD is generated from the specs; SRS lifecycles are authoritative

- **Status**: ✅ **Resolved by the leader** (2026-10-13).
- **Context**: `Documents/reports/Report4_SDD_DRAFT.md` predates the rescope (D-033): its detailed design covers booking, trips and customer billing, and its 20 diagrams under `sdd-diagrams/` were copied by hand from specs that have since been rewritten (D-036). The whiteboard flows of 2026-10-11 (`08-whiteboard-target-flows.md`) name some states differently from the SRS. Chapter 15 §2 requires numbered sequence diagrams across page, controller, service and repository, labelled state machines inside the design section, an architecture diagram that matches the repository and a physical schema.
- **Decision**:

1. **Lifecycles**: the SDD state machines are the SRS ones (D-034, D-035, SRS Figures 22 to 24). The whiteboard names are mapped in a table: Registered is In Intake, Liquidate is the disposal step after Retired. This extends D-041 to every lifecycle.
2. **Build**: a generator, `capstone/scripts/srs/build_sdd.py`, on the SRS pipeline (figure sizing, captions, table styling). Diagrams are read from `treklink-web/specs/*/design.md` and `schema.prisma`, never copied, so the SDD cannot drift from the specs. The old draft and `sdd-diagrams/` move to `.deprecated/` (D-036).
3. **Depth**: per Main Flow, the class diagrams of the modules it touches, the state machine where the flow owns one, and three to five sequence diagrams for the key use cases that cross page, controller, service and repository. Each new diagram is written into the owning module's `design.md` first, marked `<!-- sdd: ... -->`, so the specs stay the source.
4. **Layering**: every module gains a `*.repository.ts`, the only class that touches Prisma; the call order is controller, service, repository (`04-architecture-conventions.md` §1).

- **Rejected**: merging the whiteboard extras into the SRS a week before Review 2; a hand-written SDD (diagrams drift from the specs, captions and sizing by hand); one sequence diagram per swimlane step (40 or more diagrams, several sessions); one per Main Flow (too thin to code from).
- **Consequences** (2026-10-13, counts as of 2026-10-14 after D-045 and D-046): sequence diagrams for 29 use cases in 38 figures (UC-27 existed; long ones split for legibility) and 9 class diagrams in the `treklink-web` module designs; the platform design gains the third-party services and a deployment view; `capstone/scripts/srs/build_sdd.py` builds `Report4_SDD_DRAFT.md` and `Report4_SDD_TrekLink.docx`, 66 figures and 62 tables; 25 figures carried below 7 pt are recorded in `13-diagram-and-figure-conventions.md`. (needs check) No Report 4 template exists in `capstone/Documents/templates/`; the SDD is built on the Report 3 template with its cover title replaced until FLM's Report 4 template is found.
- **Owner**: KhoaDD (with HoangTK, reviewer LongLP, per the roadmap).

D-045: Device asset management: a lost device opens a loss case from any in-service state; replacement and disposal

- **Status**: ✅ **Resolved by the leader** (2026-10-14). *Design corrected 2026-10-18: `devices` reaches custody and loss charges through the ports `CUSTODY_RESOLVER` (provided by `rentals`) and `LOSS_CASE_LISTENERS` (provided by `billing` and `rentals`), because both modules import `devices` and direct calls would form import cycles (`platform` design §2.1).* Amends D-035, D-038 rule 3 and D-041. Applied 2026-10-14: SRS (UC-49 rewritten, UC-60 to UC-62, FR-DEV-12 to FR-DEV-16, FR-CON-15, FR-BILL-05 and FR-BILL-11, BR-25 and BR-37 to BR-42, E05-3 and E05-8 to E05-10, Figures 23 and 24, ERD), adjusted form, `devices`, `rentals`, `billing`, `organizations` specs and API catalog, `schema.prisma` with migration `20261014090000_asset_loss_and_compliance`, Report 4.
- **Context**: the leader compared the device lifecycle with an enterprise asset management practice (FSOFT Guideline_Physical Asset Management v1.6 and the Regulation on compensation for damaged or lost company assets, summarised in the leader's `ignore/khoa/docs/FSOFT_Asset_Management_Flows.md`). Verified gaps in the current design:
  1. A renter cannot report a loss during a running contract: `LOST` is reachable only from `RENTED` on a `RETURN_DUE`, `OVERDUE` or `DEFAULTED` contract (D-035 as amended by D-038; SRS UC-49 precondition; SRS Figure 22).
  2. A loss in TrekLink's own custody, a theft from the depot or a unit missing at stock-take, has no transition; UC-54 lists unconfirmed units and stops (FR-DEV-10).
  3. A loss is one state change with an immediate charge (UC-49, FR-BILL-05, BR-25): no case record, search window, police reference, waiver or recovery path.
  4. A lost renter device still holds the organization's channel key (D-021), and devices keep the key version they were given until the next handover (`organizations` design §1), so whoever finds the device can read that organization's mesh.
  5. The charge does not depend on custody: BR-25 charges the renter even for a loss in TrekLink's custody.
  6. There is no disposal after `RETIRED`; the whiteboard of 2026-10-11 shows "Liquidate".
  7. A faulty or lost unit cannot be replaced during a running contract; the only swap is at handover (E01-5).

- **Decision**:
  1. **Device lifecycle as a composite.** `IN_INTAKE`, `AVAILABLE`, `RESERVED`, `RENTED`, `RETURNED` and `MAINTENANCE` form the superstate **In service**. From any of them a reported loss moves the device to `LOST` and opens a loss case. `LOST` goes to `RETURNED` when the device is recovered at the counter, never straight back into use, because a device out of custody may have been altered and holds a channel key; it is reset and inspected like any return (BR-28). `LOST` goes to `RETIRED` when the loss is confirmed. A new terminal state **`DISPOSED`** follows `RETIRED` once the device is verified wiped (key, node database, owner name), matching the whiteboard's "Liquidate". Device states: nine.
  2. **Loss case**, an entity of the `devices` module, separate from the SOS incident of D-034, whose tiers and timers serve safety alerts. States: `REPORTED` (by the Org Manager for a rented device, or by Staff for any device, including a unit missing at stock-take) to `SEARCHING` (Staff triage: custody decided, last seen time and position recorded from telemetry, key exposure flagged) to `RECOVERED` (device back at the counter) or `CONFIRMED` (Staff confirm, or the search window `devices.lossSearchDays` elapses) to `SETTLED` (charge applied, reduced, waived or written off; device `RETIRED`).
  3. **Liability by custody.** The custody interval of D-040 that contains the time the device was last seen decides who bears the loss: renter custody charges the device's remaining value to that contract on confirmation (amends BR-25); TrekLink custody is an internal write-off with no charge.
  4. **Waiver**: an Admin other than the Staff member who triaged the case may reduce or waive the charge, with a reason, as for damage charges (BR-24).
  5. **Key exposure**: a loss in renter custody marks the organization's channel key as exposed and notifies the Manager; the key is rotated and the organization's devices re-provisioned at their next counter visit. The platform cannot revoke a key on a device it cannot reach, and the documents say so.
  6. **Police reference**: optional on every loss case; required when the case is flagged as suspected theft or fraud (D-046).
  7. **Mid-contract replacement**: at the counter Staff replace a faulty unit, or a unit with an open loss case, on an `ACTIVE` or `ENDING` contract with an `AVAILABLE` unit of the same variant. The quantity, plan and variant stay unchanged (BR-05 holds); the replacement gets its own `ContractDevice` row, so its own custody interval; it is provisioned and the replacement is signed on screen like a handover. The faulty unit is checked in and inspected (damage charge rules apply).
- **Rejected**: widening `RENTED` to `LOST` only (leaves gaps 2 to 7); asset loss as a type of the SOS incident (D-034 routes to on-duty members with tier timeouts, which an asset case does not need); recovering a lost device straight into use (key and tamper risk); charging every loss to the renter (contradicts custody).
- **Consequences**: SRS device state machine redrawn as a composite with `DISPOSED`; a loss-case state machine; UC-49 rewritten as Report Lost Device, new use cases for resolving a loss case, replacing a device and disposing of a device; FR-DEV, FR-CON and FR-BILL requirements, BR-25 amended and new business rules; exception scenarios for a mid-term loss, a unit missing at stock-take and a recovery after settlement; ERD gains `LOSS_CASE`. Adjusted form: the lifecycle sentence. Specs and schema: `LossCase`, `DeviceStatus.DISPOSED`, replacement in `rentals`, charge by custody and waiver in `billing`, `channelKeyExposedAt` in `organizations`. Report 4: the new state machines and sequences.
- **Owner**: KhoaDD (device and billing lane: LongLP).

D-046: Contractual compliance: NDA and software licence in the master contract; a compliance case for fraud, theft and IP or NDA breaches

- **Status**: ✅ **Resolved by the leader** (2026-10-14). Applied 2026-10-14: SRS (UC-63, FR-ORG-02, FR-ORG-08, FR-ORG-09, BR-40, BR-43, E05-11, ERD), adjusted form, `organizations` spec and API catalog (verification terms, compliance cases, key rotation), `schema.prisma`, Report 4.
- **Context**: TrekLink installs proprietary software on the customer's premises, the Field Station executable on the organization's laptop (D-033 rule 8, D-039), and rents physical devices that hold its firmware. The design records the master contract only as a reference at verification (UC-02) and has no record for a suspected fraud, scam or theft of devices, for an intellectual-property violation such as copying or leaking the Field Station's code, or for a breach of a non-disclosure agreement. The leader ruled these in scope (2026-10-14).
- **Decision**:

1. **Master contract terms**: verification (UC-02) records that the master contract includes a non-disclosure agreement and the Field Station software licence (no copying, redistribution, reverse engineering or disclosure of the software or the firmware). An organization cannot be approved without them.
2. **Compliance case**, an entity of the `organizations` module, opened by TrekLink Staff or an Admin against an organization, with a type: `SUSPECTED_FRAUD`, `SUSPECTED_THEFT`, `IP_VIOLATION`, `NDA_BREACH` or `OTHER_BREACH`; evidence notes; linked loss cases or contracts; an authority reference. States: `OPEN` to `CLOSED` with an outcome; every action is audited.
3. **Police report**: a case of type `SUSPECTED_FRAUD` or `SUSPECTED_THEFT` (signs of fraud, scams or theft of TrekLink devices) cannot close without a police report reference. A loss case flagged as suspected theft or fraud opens or links such a case.
4. **Actions** available from a case are the existing ones, recorded on the case: an Admin suspends the organization (FR-ORG-07), and Staff or an Admin revoke its Field Station credentials and API keys.

- **Rejected**: handling breaches outside the platform (no audit trail, and a suspended organization would have no recorded reason); a separate legal module (the actions are the existing suspension and revocations).
- **Consequences**: SRS: FR-ORG requirements for the contract terms and the compliance case, business rules for the NDA and licence precondition and the police reference, a use case for handling a compliance case, ERD gains `COMPLIANCE_CASE`. `organizations` spec and schema. Report 4.
- **Owner**: KhoaDD.

D-047: Periodic maintenance: a service plan per hardware variant, a weekly scan, cost approval and firmware updates

- **Status**: ✅ **Resolved by the leader** (2026-10-14). Amends D-035 (device lifecycle labels) and D-045 rule 1 (the In service superstate is unchanged). Applied 2026-10-14: SRS (UC-13 and UC-52 rewritten, UC-64, UC-65, FR-DEV-04, FR-DEV-08, FR-DEV-17 to FR-DEV-21, BR-44, BR-45, E05-12, E05-13, Figures 23 and 25, ERD), adjusted form, `devices` spec and API catalog, `platform` configuration matrix and scheduler, `schema.prisma` with migration `20261014150000_periodic_maintenance`, Report 4.
- **Context**: the leader compared maintenance with FSOFT Guideline_Physical Asset Management v1.6 section 2.6, periodic maintenance (summarised in `ignore/khoa/docs/FSOFT_Periodic_Maintenance_Flow.md`), and section 2.5, repair, replace or upgrade. Verified gaps in the current design:
  1. A scheduled service exists only as the reason string `SCHEDULED` on `MaintenanceRecord` (`schema.prisma`); there is no interval, no due date and nothing that opens a scheduled record (SRS UC-52, FR-DEV-08).
  2. No advance notice before a service falls due (FSOFT step 1, five days ahead).
  3. A maintenance record carries no cost, no in-house or vendor distinction, no warranty and no approval (FSOFT steps 3, 4.1, 4.2 and form 23v).
  4. The firmware version is recorded only at registration (FR-DEV-02), although D-039 updates device firmware at the counter, so the device record drifts from the hardware.
  5. SRS UC-52 asks for "an expected date" that the schema does not hold. FSOFT step 5, the acceptance test after the work, is already the intake check that every maintained device must pass again (UC-12, FR-DEV-08). FSOFT step 6, the payment to the supplier, stays outside the platform.
- **Decision**:
  1. **Service plan per hardware variant.** An Admin sets a service interval in days and a service checklist on each hardware variant (UC-13). A variant without an interval has no periodic service. Each device holds a service due date: set from the variant interval when it first passes the intake check, and moved forward by the interval each time a `SCHEDULED` record is completed. Unscheduled repairs do not move it.
  2. **Weekly scan.** A scheduled job runs once a week. It selects every device whose service is due before the next run plus `devices.maintenanceLeadDays` (default 5, FSOFT's lead time), and every device whose firmware version differs from its variant's firmware baseline. For an `AVAILABLE` device it opens a maintenance record with reason `SCHEDULED` or `FIRMWARE_UPDATE` and moves the device to `MAINTENANCE`. A `RESERVED` or `RENTED` device is never

pulled from a contract; at check-in, an inspection that passes routes it to `MAINTENANCE` with that record instead of `AVAILABLE`. Staff receive the week's list.

3. **Record contents.** A record carries an expected completion date, whether the work is in-house or by a vendor (with the vendor's name), the estimated and the actual cost in VND, a warranty-until date for vendor work, and, for `SCHEDULED`, a result for each checklist item of the variant.
4. **Cost approval.** IF the estimate exceeds `devices.maintenanceApprovalThresholdVnd`, THEN the record is `PENDING_APPROVAL` and cannot be completed until an Admin other than the person who recorded the estimate approves it or rejects it with a reason. A rejected record returns to `OPEN`, to be re-estimated or closed `UNREPAIRABLE`. An actual cost above the approved amount returns the record to `PENDING_APPROVAL`. Paying the vendor happens outside the platform; the cost is recorded, never invoiced to an organization, and the renter's share of a repair remains the damage charge of BR-24.
5. **Firmware update.** Any record may record a new firmware version on completion; a `FIRMWARE_UPDATE` record must. Completion updates the device's firmware version; the intake check then accepts the unit as for any maintenance.
6. **Maintenance record lifecycle**: `OPEN` to `PENDING_APPROVAL` and back, `OPEN` to `COMPLETED` or `UNREPAIRABLE`.

- **Rejected**: manual scheduling only (a "scheduled service" with no schedule behind it); an annual calendar of maintenance campaigns as in FSOFT (built for a multi-site office estate, too heavy for one depot in four build weeks); pulling a rented device mid-contract when it falls due (breaks the contract for a non-urgent service; a faulty unit already has replacement, D-045 rule 7); a daily scan (the leader prefers weekly; the look-ahead of the run period plus the lead days keeps a weekly run from missing a due date); recording cost without approval (FSOFT's authority level is the step a council is most likely to ask about); firmware version left as registered.
- **Consequences**: SRS: UC-13 and UC-52 rewritten, new use cases for the weekly scan and for approving a maintenance cost, FR-DEV requirements for the plan, scan, cost approval and firmware update, new business rules, an exception scenario for a rented unit falling due, the device state machine labels and a maintenance record state machine. Adjusted form: the maintenance sentence. `devices` spec, API catalog and `schema.prisma` (variant interval and checklist, device service due date, record fields and `PENDING_APPROVAL`) with a migration; `platform` scheduler registration; Report 4.
- **Owner**: KhoaDD (device lane: LongLP).

D-048: The subject is SEP490; its syllabus, Student Guide and templates are the governing sources

- **Status**: ✅ **Resolved by the leader** (2026-10-18).
- **Context**: the team's planning drew on several course documents with different subject codes. The roadmap was first derived from `SWP490_Lo-trinh-Capstone_v1.0.pdf` (D-013), and Report 4 was built on the Report 3 template because no Report 4 template was in `Documents/templates/` (session 2026-10-14, needs check). The leader's local course folder (`/mnt/DATA/DATA/FPTU/Subjects/KLTN/SEP490/`) holds the SEP490 Student Guide (Fall 2023) and the official templates for Reports 1 to 7, Project Tracking, Test Report and Unit Test. The FLM syllabus 14065 (decision 377/QĐ-ĐHFPT, 2026-09-04) names SEP490 and lists the Student Guide and the project templates as its main materials.
- **Decision**:
  1. TrekLink's subject is **SEP490**, SE Capstone Project. It is not SWP490, SET or any other code. Documents of other codes are background only and never override SEP490.
  2. The governing sources, in order: the FLM syllabus 14065 (copy `capstone/Documents/course-material/SEP490_Syllabus_FLM_14065.md`), the SEP490 Student Guide (`capstone/Documents/course-material/SEP490 StudentGuide_Fall 2023.docx`), the SEP490 execution schedule and quick guide already listed in D-013, and the templates in `capstone/Documents/templates/`.
  3. Every graded report uses its own SEP490 template. Report 4 moves to `Report4_Software Design Document.docx`; Report 5 uses `Report5_Test Documentation.docx`, `Report5_Test Report.xlsx` and `Report5_Unit Test.xls`; tracking uses `Report3_Project Tracking.xlsx` (WBS, Issues, Defects, Q&A).
  4. D-013 stands: SWP490 practices that SEP490 does not contradict stay as practice, never as a source of requirements.
- **Rejected**: keeping the Report 3 template for Report 4 (a template mismatch is visible to the supervisor, and Report 4 carries 18% of OGA); treating the SWP490 roadmap as co-equal (the cause of the D-013 rework).

- **Consequences**: Report 4 is re-skinned onto its template; Report 5 is built on its three templates. The syllabus eligibility rule (at least 75% of the use cases submitted in Report 3 completed, and at least 20 medium use cases) is recorded as a risk row below. Roadmap and chapter 15 references to course sources cite SEP490.
- **Owner**: KhoaDD.

D-049: No AI co-author, author or contributor in any TrekLink repository

- **Status**: ✅ **Resolved by the leader** (2026-10-18). Scope widened the same day from `treklink-web` to all four code repositories and `capstone`, going forward. History cleanup: `treklink-web` `dev` is rewritten (rule 5); history in the other repositories stays as it is.
- **Context**: the SEP490 syllabus (D-048) fails a member who cannot prove they built the software, and sends the team to the second defence round if it cannot prove it prepared the software package itself. `treklink-web` is the graded software package. On 2026-10-18 `origin/dev` held 53 `Co-Authored-By: Claude` trailers and 15 commits authored as `Claude <noreply@anthropic.com>`; `origin/main` held none, and the GitHub contributor list (default branch) showed only `ruskicoder`. The next `dev` to `main` merge would add an AI account to the contributors.
- **Decision**:
  1. No commit in `treklink-web` carries a `Co-Authored-By` trailer naming an AI model.
  2. No commit in `treklink-web` is authored by an AI identity. The member who owns the work is the author.
  3. No AI account appears among the repository's contributors.
  4. Rules 1 to 3 apply to `treklink-web`, `treklink-docs`, `treklink-firmware`, `TrekLink-Team.github.io` and `capstone` for every new commit. Agents strip their default attribution lines before committing. Conventions chapter 07 §3.4 rule 7.
  5. `treklink-web` `dev` is rewritten before it next reaches `main`: on a backup clone, `git filter-repo` drops the AI trailers and re-authors the AI-authored commits to their human owner (the leader by default); `dev` and the open feature branches are force-pushed and members re-clone or reset. The force-push runs only on the leader's explicit go at execution time.
  6. The PR template's `Model used:` field (chapter 11 §2) stays. It declares a tool; it does not make a contributor.
  7. *(Amendment of 2026-10-31, proposed by LongLP; in force when the leader merges it.)* Rules 1 to 4 extend to what is posted on GitHub for these repositories: pull request titles and descriptions, issues, comments, review comments and review summaries carry no AI attribution line, such as "Generated with Claude Code", "Generated by Claude Code", a robot-emoji footer or an AI co-author line. Some agent tools add such a footer on the server when they post. The agent reads every post back and edits the footer out; if it cannot, it tells the member, who removes it. The AI Disclosure section of a pull request still names the model, because it declares a tool and does not make a contributor.
- **Rejected**: keeping attribution for transparency (it becomes evidence against authorship at the defence); relying on squash merges alone (a squash commit lists every co-author unless the message is edited).
- **Amendment context (2026-10-31)**: rules 1 to 4 named commits only. On 2026-10-31 the GitHub tool of a cloud Claude Code session appended "Generated by Claude Code" to the description of capstone#4 and to a comment on it, both posted under LongLP's account, and the member had to ask for each removal.
- **Consequences**: chapter 07 §3.4 rule 7; the `treklink-web` history rewrite of rule 5, announced in Zalo before the force-push. Rejected for the cleanup: squashing at release only, which leaves the AI history visible on `dev` to anyone browsing branches.
- **Owner**: KhoaDD.

D-050: The Progress Log and Project Tracking workbooks are dropped; contribution evidence is daily reports, commits and Jira

- **Status**: ✅ **Resolved by the leader** (2026-10-18).
- **Context**: the roadmap (§3.2) named `GFA26SE55_Progress_Log.xlsx` the primary evidence of individual contribution, taken from the SEP490 execution schedule, and the Student Guide (D-048) suggests a tracking database with WBS, Issues, Defects and Q&A sheets (`Report3_Project Tracking.xlsx`), adding that any team-convenient tool may be used

instead. Both workbooks were last committed on 2026-09-17. The team already records the same facts in daily reports (chapter 12), commits and PRs, and Jira (chapter 10).

- **Decision**: the two workbooks are no longer maintained. Contribution and progress evidence is the daily reports, the git history and Jira. If the supervisor or a council asks for a workbook, it is produced from those records at that time.
- **Rejected**: rebuilding both workbooks for W1 to W7 before Review 2 (duplicate bookkeeping of facts already recorded elsewhere).
- **Consequences**: roadmap §3.2, §3.3 and the deliverable ledger updated. Risk: the SEP490 execution schedule names the Progress Log as evidence; if a reviewer asks for it at Review 2, it must be generated on short notice.
- **Owner**: KhoaDD.

D-051: The backlog is one story per SRS use case, generated from the SRS data, with new IDs

- **Status**: ✅ **Resolved by the leader** (2026-10-18).
- **Context**: `build_backlog.py` still modelled the pre-D-033 scope (8 epics, 87 stories on trips, bookings, the seven-state rental machine, `device_types` and `maintenance_logs`). The SEP490 syllabus counts use cases (D-048), and Jira already holds the old cards with labels `backlog-E1` to `backlog-E8` and `backlog-US-001` to `backlog-US-087`, which `jira_sync.py` skips on sight.
- **Decision**:
  1. One story per SRS use case, generated from `capstone/scripts/srs/srs_data.py`; the acceptance criteria are the FRs that cite the use case, plus its business rules and exceptions. Four delivery stories cover work with no use case (local stack and CI, seed data, Neon deployment, the D-042 suite). The generator stops if an FR has no story.
  2. IDs: epics `EP01` to `EP10`, stories `US-UCnn` and `US-Xnn`. The old cards are retired (`jira_sync.py --retire`, label `retired-d033`, Done transition); new Jira keys are recorded after the sync in `JIRA_KEYS`.
  3. The week 3 baseline is `srs_data.W3_MAP`: 51 of the 58 week 3 use cases map onto 44 current use cases (flag `baseline`); 7 were removed by D-033. Completing the 44 completes 51 of 58 (88%); the floor is 44 of 58.
  4. Owners follow the lanes of roadmap §5.1; LongNN owns the read-only screen use cases (UC-38, UC-42, UC-55, UC-59), split by layer as in D-023, and is secondary on every other story with a human actor. Sprints follow roadmap §4.2, and `jira_sync.py` now dates Jira sprints from that table.
- **Rejected**: one story per FR (110 stories, and the 75% rule counts use cases); hand-written stories (they drifted from the SRS once already); reusing `US-001` (collides with the stale Jira cards); continuing at `US-088` (the ID no longer names its use case).
- **Consequences**: `03-backlog/` regenerated (10 epics, 69 stories, 192 points), `User_Story_Agile_TrekLink.xlsx` rebuilt, chapter 10 §2.1 table, §7.1a and §9 updated, `_docs/README.md` updated. Jira sync and retirement wait for the leader's review (outward action).
- **Owner**: KhoaDD.

D-052: The leader writes every spec; members study, own, defend and implement their lane

- **Status**: ✅ **Resolved by the leader** (2026-10-19).
- **Context**: on 2026-10-18 the leader asked whether the specs were ready for members to design. Every `design.md`, `api-design` source and `tasks.md` in `treklink-web/specs/` was written by the leader with an agent; members appear only as small edits. The SEP490 syllabus fails a member who cannot prove they built the software (D-048, D-049). Report 4 (SDD) is generated from the `design.md` files (D-044), and the Review 2 package is due 2026-10-25. SRS §3.1.2 Screens Flow and §3.1.3 Screen Descriptions are still empty.
- **Decision**:
  1. The leader decides scope, FRs and stories, and writes `requirements.md`, `design.md`, the `api-design` sources and `tasks.md` of every module, kept in sync with the SRS data (`capstone/scripts/srs/srs_data.py`).
  2. Each member takes the suites of their lane (roadmap §5.1), studies them, owns them and must defend their domain at every review, then implements from `tasks.md`. A member who finds a defect raises it; the leader decides the change.
  3. Screen layouts are delegated to members by the leader, each assignment with a deadline of 2 to 3 days. The leader finishes whatever is not done by the deadline, in about 2 to 3 further days.

4. A spec change is a pull request to `dev` reviewed by the leader; the merge is the approval. Each `design.md` carries a `Status` line.
5. No design stories are added. A story is ready when its suite is approved and its owner has studied it (chapter 10 §2.1, Definition of Ready); in Jira this is a subtask of the `US-UCnn` card.

- **Rejected**: members design the backend from `requirements.md` alone (cannot meet 2026-10-25, and the SDD would be rebuilt from new designs); one design story per module (breaks D-051, one story per use case); approval recorded in Jira only (leaves no evidence in git).
- **Consequences**: `treklink-web/specs/README.md` §6, chapter 02 tenet 7, chapter 10 §2 and §2.1 updated; `Status` line added to every `design.md`. Supersedes the wording of D-051 rule 4 only where it implied members design.
- **Owner**: KhoaDD.

D-053: Every story runs SD, CO, UT and RV in one pull request; pages belong to their module's lane

- **Status**: ✅ **Resolved by the leader** (2026-10-19).
- **Context**: a review after each phase (V-model style) costs the leader a review per phase per story. Members must design, code and test reliably on their own. The frontend task list gave all 39 page tasks to LongNN while LongLP held 58 tasks.
- **Decision**:
  1. A story runs four mini-phases, SD (specification and design), CO (code), UT (unit test) and RV (review), all in one pull request; the leader reviews the whole PR once. A finding reopens the phase it belongs to, on the same PR (chapter 10 §7.1b).
  2. UT is done at **at least 80% branch coverage and 100% line coverage** of the files the PR changes, by the CI coverage report.
  3. Effort is story points, a measure of complexity, never lines of code.
  4. Each module's pages are built by that module's lane owner. LongNN owns the shell, shared components, maps, plans, administration, monitoring pages and the journeys, and reviews every page PR for consistency. Screens are designed in `specs/frontend/ui-design/` against chapter 06 §7 (checklist) and §8 (practices).
  5. `requirements.md` holds requirements only, in EARS (functional, including endpoint behaviour and error codes, and NFRs); detail lives in `api-design/`, `ui-design/` and `design.md` (chapter 02 tenet 8).
  6. Software Package 1 runs on local Docker Postgres; Neon waits for Sprint 4 (D-010). *Superseded by D-062 on 2026-10-24: shared development runs on the Neon `dev` branch.*
- **Rejected**: a review per phase (leader effort); counting lines of code; LongNN building every page; a separate "requirement details" file.
- **Owner**: KhoaDD.

D-054: Every member commit carries a sealed Checksum trailer declaring the model and stage

- **Status**: ✅ **Resolved by the leader** (2026-10-20). Rules 4 and 5 amended by D-070 (2026-10-25): an explicit model allowlist with the variant sealed; an unsealed commit stays a label.
- **Context**: the PR template's free-text `Model used:` line (chapter 11 §2.4) can be edited after the fact and says nothing per commit. The Review 2 guide asks for the AI tools, models and stages to be declared in Report 4 (risk row of 2026-10-20), and D-049 removes AI attribution from commits. The leader wants a per-commit declaration that cannot be altered after it is written.
- **Decision**:
  1. Every commit a member makes in `treklink-docs`, `treklink-web`, `treklink-firmware` and `TrekLink-Team.github.io` carries one trailer, `Checksum: <64 hex>`, written by a commit-msg hook (`treklink-docs/.github/scripts/tk_checksum.py install`).
  2. The token is AES-256-GCM under the member's own key. It holds the model family and version and the stage (SD, CO, UT, RV, DOC or CHORE), bound to the member code and the commit subject. The model is readable only with the keys.

3. All member keys live in `capstone/.provenance/keys.json`, committed to the private `capstone` repository, and in the organisation secret `TK_CHECKSUM_KEYS` for CI. Any member can read every key. Forgery is prevented by rule: an AI agent refuses to seal with another member's key or to write a token by any means other than the hook (AGENTS.md §6, chapter 08 §3.1).
4. CI (`checksum.yml` on `pull_request`, calling the reusable `checksum-verify.yml` at treklink-docs `dev`) fails on a token no key opens, a token sealed by another member than the commit's GitHub author, a model outside chapter 11 §2.1, or a restricted model on a feat or fix commit. An unsealed commit is a hand-typed commit: it gets the `provenance-review` label and a manual review, no failure. AI attribution (D-049) gets the same label.
5. Approved for sealing: Claude Opus and Sonnet from 4.8, Claude Fable from 5.1, GPT from 5.6. Restricted (chores only): Gemini and Claude Haiku. `human` declares a hand-written commit.
6. The `Model used:` line is removed from AGENTS.md and the PR templates; the trailer replaces it.
7. The mechanism is documented in chapter 07 §3.6, visible to every member. Report 4 declares it with the AI tools, models and stages.

- **Rejected**: a `pull_request_target` trigger (GitHub reads it from the default branch `main`, and disables it on public repositories from 2026-11-02; it shielded only a secret members can already read); keys held by the leader only with one private key per member (more distribution work; the leader accepted the forgery risk under rule 3); failing CI on an unsealed commit (a hand-typed commit is legitimate and is reviewed instead); a plaintext model trailer (the leader keeps the model inside the token); a manual seal command (easy to forget).
- **Consequences**: chapter 07 §3.4 rule 7 and new §3.6; chapter 08 §3.1; chapter 11 §2.1 and §2.4; the five AGENTS.md copies §6; the PR templates of treklink-docs, treklink-web and TrekLink-Team.github.io. The token proves who sealed it and that the declaration is unchanged; it does not prove which model wrote the code.
- **Owner**: KhoaDD.

D-055: Review 2 package: no registration change, grouped features, AWS staging, one decision per member

- **Status**: ✅ **Resolved by the leader** (2026-10-20).
- **Context**: the course's Review 2 guide (`capstone/Documents/course-material/SWP490_R2_Huong-dan-chuan-bi-Review-2_1.pdf`) asks for the final registration form with a Record of Changes (BM03), Reports 1 to 5 and Project Tracking, a self-review (BM02) on tag `review-2`, and a Design Brief (BM01) with Defense 1.1 targets. A main workflow must change the state of a main entity; mandatory features set the committed test count (3 per feature, 1 per workflow, per state transition and per NFR); demos run on a staging environment declared in Report 4.
- **Decision**:
  1. The adjusted registration form submitted to F-CAPS after Review 1 is the approved current version. BM03 records "No changes".
  2. MF-04 stays as defined. Ingested telemetry updates the device's battery and last-seen time (FR-DEV-06), and UC-41 flags a device stale when silent beyond its threshold and clears the flag when it reports (FR-MON-03). Report 4 draws this as a Device connectivity state machine (Reporting, Stale) so the workflow's state change is traceable.
  3. Mandatory features group the 44 baseline use cases (D-051) into about 20 features, each with measurable acceptance criteria. Every baseline use case still ships (D-048).
  4. Environments: development on local Docker Postgres (D-053); staging and production on AWS for the backend and an MQTT broker, with Neon Postgres (D-010), ready by Sprint 4. Iteration 1 at Review 2 runs locally. *Development superseded by D-062 on 2026-10-24.*
  5. Report 4 declares the AI tools, models and stages, and states that every commit declares its model and stage (D-054), without the sealing detail.
  6. Design Brief section 3, one key decision per member: three-tier field buffering with event idempotency (D-018, D-006, D-040), KhoaDD; organization-scoped isolation of every request and API key (FR-AUTH-11, D-042), TanNB; tiered incident notification and escalation (D-034), HoangTK; Leaflet over OpenStreetMap with the sovereignty overlay and one live WebSocket stream (D-031), LongNN; device and contract lifecycles as state graphs with custody intervals and loss cases (D-035, D-040, D-045), LongLP.

7. Twenty mandatory features cover the 44 baseline use cases plus the six flow-path use cases (2, 3, 12, 23, 24, 51). Feature owners: LongLP 7, KhoaDD 4, HoangTK 3, LongNN 4 (platform accounts, device holder labels, system health, administration), TanNB 2. A feature owner answers for it at review; others may code parts of it.
8. Every transition of all eight lifecycles is a main-entity transition with one test: 80 tests. With 60 feature tests, 5 workflow tests and 6 NFR tests the Defense 1.1 commitment is 151 test cases, at least 76 automated in CI.
9. Design Brief section 7 NFRs: NFR-REL-01, NFR-REL-03, NFR-REL-04, NFR-PERF-01, NFR-PERF-04, NFR-SEC-04.

- **Rejected**: one feature per use case (132 to 195 feature tests, a commitment the Defense 1.1 count check could fail); Render or Vercel for the backend (the leader chose AWS; Vercel functions cannot hold the WebSocket and MQTT connections); a plaintext account of the commit seal in Report 4.
- **Owner**: KhoaDD.

D-056: The MF-04 owner takes the monitoring backend; HoangTK keeps incidents

- **Status**: ✅ **Resolved by the leader**. LongNN drafted it at his own request (PR #78, merged 2026-10-22); the leader reviewed the content and confirmed it on 2026-10-22, adding rules 5 and 6 and the task 2.3 wording of rule 2.
- **Context**: roadmap §5.1 gave LongNN MF-04 but only its screens (`frontend` tasks 9.1 to 9.4), while every `specs/monitoring/tasks.md` task except 5.1 was HoangTK's. LongNN's lane was thin (14 tagged tasks, all frontend, against HoangTK's 30), and Review 2 requires each member to own two to three parts and at least one main workflow they can defend (Design Brief section 8, D-052 rule 2); at the review each member opens and explains the code they own (roadmap, "Before Review 2"). An owner who builds no part of the flow's backend cannot defend the Organization API or the tenancy tests. The page rule of D-053 rule 4 also had an exception here: the monitoring pages were LongNN's while the module was HoangTK's.
- **Decision**:
  1. LongNN owns the `monitoring` backend: tasks 1.1, 2.1, 2.2, 2.4, 3.1, 3.2, 3.3, 3.4, 4.1, 4.2 and 6.1 of `specs/monitoring/tasks.md`, plus the screens of `specs/frontend/tasks.md` 9.1 to 9.4. MF-04 is therefore LongNN's end to end, backend and UI.
  2. HoangTK keeps the `incidents` module. Task 2.3 (`incident.alert` publishing) is the one task of `monitoring` with another owner: it is a single synchronous listener that delivers an MF-03 alert, and it sits in `monitoring` only because the `user:<id>` rooms of `LiveGateway` do, so HoangTK owns it and answers for alert delivery. LongNN answers for the stream, the rooms and every other task of the module. HoangTK is the secondary reviewer of LongNN's monitoring PRs because MF-03 consumes `LiveGateway` .
  3. D-053 rule 4 is unchanged: each module's pages belong to that module's lane owner, and LongNN owns the shell, shared components, maps, plans, administration, monitoring pages and the journeys. The monitoring pages now follow that rule with no exception.
  4. Feature owners of D-055 rule 7 are unchanged (LongNN 4, HoangTK 3).
  5. **Fallback**: tasks 1.1 and 2.1 are the ones Review 2 needs (MF-02 events on a map). If task 1.1 has no open pull request two working days after `platform` Phase 1 merges to `dev` , or 1.1 and 2.1 are not merged before the `review-2` tag is cut, the leader moves 1.1 and 2.1 back to HoangTK and LongNN keeps the rest. The clock starts at the platform merge, so a delay in the leader's lane does not count against LongNN.
  6. HoangTK acknowledges the change on `treklink-web` PR #37, which moves the owner tags, before Sprint 4 starts. The acknowledgement does not block the merge (leader, 2026-10-23).
- **Rejected**: splitting the monitoring tasks half and half (two owners in one module, no one answers for the stream); moving MF-04 to HoangTK (LongNN would lose the flow presented at Review 1); adding backend work from another lane (LongLP already holds `auth` , `rentals` and `billing`).
- **Consequences**: roadmap §5.1 and the charter team matrix updated (PR #78). Follow-ups done on 2026-10-22: `build_backlog.py` sets `LANE["monitoring"] = "LongNN"` with HoangTK as the secondary owner of monitoring stories, and the backlog is regenerated; `treklink-web/specs/monitoring/tasks.md` and `specs/README.md` carry the new owners; the Report 2 RACI and the Design Brief Ownership Map are updated and rebuilt; the lane table of chapter 11 §3.4 is brought in line with roadmap §5.1. Jira assignees follow on the next `jira_sync.py` run by the leader. Residual exposure: LongNN is IC-track, so the backend ramp-up of register row "NestJS is a skill only for Khoa" applies to monitoring; the reviewer is KhoaDD.

- **Owner**: KhoaDD.

D-057: Rulings on the LongNN screen designs: permission catalog, audit routes, telemetry routes, health rows, report shapes, messages

- **Status**: ✅ **Resolved by the leader** (2026-10-23), from the open items O-1 to O-10 of `treklink-web` PR #36 and its notes for the SRS owner.
- **Context**: the nine screen designs of the LongNN lane found gaps in the endpoint catalogs, the route table of `specs/frontend/design.md` §2 and the SRS message list. A screen cannot be built against an endpoint that does not return what it shows.
- **Decision**:
  1. **Accounts (O-1)**: `GET /api/accounts` returns `phoneNumber`. "Invitation pending" is `lastLoginAt` null; no new field.
  2. **Permission catalog (O-2)**: new `GET /api/permissions`, gated by `role.manage`. Each item: `key`, `action`, `subject`, `scope` (`own` or `any`), `accountType` (`TREKLINK` or `ORGANIZATION`), `description`, `protected` (ADMIN cannot lose it). Raw CASL `conditions`, `fields` and `inverted` are not returned. The catalog is read-only and comes from the seed only. `PUT /api/roles/:id/permissions` keeps rejecting a key not in the catalog (400 `UNKNOWN_PERMISSION`) and also rejects a permission whose account type differs from the role's (400 `PERMISSION_SCOPE_MISMATCH`), so an organization role can never receive a platform permission. `GET /api/roles` returns permission keys only, joined to the catalog on screen. `Permission` gains a non-null `accountType` column, filled by a new migration from the role grants of `scripts/specs/catalog.py`; `build_seed.py` refuses a permission granted to no role or to roles of two account types. That check split the three permissions shared by Staff and Org Manager into a TrekLink key and an organization key with the suffix `.org` (organization data no tenant owns): `hardwareVariant.read` and `hardwareVariant.read.org` (active variants, no counts), `device.availability` and `device.availability.org`, `plan.quote` and `plan.quote.org` (formerly `plan.quote.own`, which carried no condition).
  3. **Audit routes (O-3)**: two sub-routes, `/t/admin/audit/changes` (`AuditLog`, `auditLog.read`) and `/t/admin/audit/sign-ins` (`AuthEvent`, `authEvent.read`); `/t/admin/audit` redirects to the first. Each tab checks its own permission and is hidden without it; filters live in the URL query. The parameters page links to the change log filtered to the parameter.
  4. **Sign-in filter (O-4)**: `GET /api/auth-events?organizationId=<uuid>`, a query filter, never an authorization input (`authEvent.read` decides access). The server resolves the organization through the user's membership; an attempt that matched no account never matches the filter. A malformed UUID is 400 `VALIDATION_FAILED`, an unknown organization an empty page. Each row returns `organization {id, name}` or null.
  5. **Messages**: MSG35 for an invalid period (O-5), MSG36 for `STALE_VERSION` (a dialog with Reload that keeps the user's input), MSG37 `LAST_ADMIN`, MSG38 `ADMIN_LOCKOUT`, MSG39 `SELF_DEMOTION`. Success of account, role and parameter actions is MSG03. The client maps `errorCode` to a message; the server `message` is a fallback only.
  6. **Empty states (O-6)**: screen copy, no MSG code. 9.3 keeps "No Field Stations are registered yet." 2.3 reads "No plans are available right now. Contact TrekLink to ask about renting." with the footer contact link.
  7. **Admin routes (O-7)**: TrekLink Admin inherits every TrekLink Staff route (FR-AUTH-10, auth REQ-UBI-05); `design.md` §2 states it once.
  8. **Telemetry routes (O-8)**: `/o/devices/:id/telemetry` and `/t/devices/:id/telemetry`, period in the query. Named telemetry so it never collides with the lifecycle history of `/t/devices/:id` (monitoring api-design 07).
  9. **Health rows (O-9)**: `GET /api/system-health` returns `fieldStations.items[]` (`id`, `name`, `organization`, `lastSyncAt`, `stale`, `queueDepth`, `oldestRetryCount`, `version`, `outdated`), excluding revoked stations, plus `fieldStations.currentRelease`. Queue depths are named objects `{p0, p1, p2, p3}`; the column stays `Int[]`.
  10. **Reports (O-10)**: a row shape per kind (`utilization`, `revenue`, `overdue`, `lost`, `incident-times`); a period of at most 366 days (`monitoring.reportMaxRangeDays`), 400 `VALIDATION_FAILED` beyond it or when reversed.
  11. **Who changes what**: the leader edits the catalogs, schema, `design.md` and the SRS (D-052 rule 2); LongNN updates his screen files in PR #36.
- **Rejected**: the union of role permissions as the checkbox universe (a permission removed from every role could never be granted again); inferring a permission's account type from its condition (a security check must not rest on an inference);

one audit route with client-only tabs (no deep link, one permission for two data sets); a path segment `/auth-events/<organizationId>` (a filter, not a resource); "history" for the telemetry route; MSG28 for the three Admin lockout rules (its text explains none of them).

- **Consequences**: `treklink-web` spec PR (catalogs, schema and migration, `design.md` §2, regenerated api-design and permission matrix); SRS messages MSG35 to MSG39 and Report 3 rebuilt; PR #36 changes requested.
- **Owner**: KhoaDD.

D-058: Review 2 on Tue 2026-10-27; Iteration 1 is the platform slice with MF-02 by fixture replay; fixed cutoffs

- **Status**: ✅ **Resolved by the leader** (2026-10-23), in a question round on Software Package 1.
- **Context**: the official Review 2 session is Tue 2026-10-27, not the end of W8, and the leader wants every deliverable done one day earlier. That leaves Fri 2026-10-23 to Mon 2026-10-26. The working-day clocks of D-056 rule 5 and of the auth cover would expire after the review.
- **Decision**:
  1. **Dates**: tag `review-2` on Sun 2026-10-25 at 22:00 ICT; BM02, the team response per finding, Design Brief §5 and the PDF rebuild on Mon 2026-10-26; review Tue 2026-10-27.
  2. **Iteration 1 scope**: `platform` Phases 1 and 2 with the demo seed (1.12), sign-in, CI, and MF-02 shown by replaying the golden fixtures through the local Mosquitto into `gateway-sync` and onto the TrekLink fleet map. Events land `UNATTRIBUTED` (no `rentals` yet), so they reach the `fleet` room only. Iteration 1 runs locally (D-055 rule 4). The Field Station executable (`gateway-sync` 5.1) and live hardware move to Sprint 4. MF-01 is shown from the specs and the screen designs.
  3. **LongLP, sign-in**: `auth` 1.1 to 1.4, 2.1 to 2.4, the login, refresh, logout and me endpoints of 6.1 (api-design 01 to 04) and the sign-in page of `frontend` 2.1, in a PR by Sat 2026-10-24 20:00 ICT; `auth` 4.1 and 4.2 (CASL guards) by Sun 2026-10-25 12:00 ICT. Missed, the leader covers (roadmap §5.1 emergency cover).
  4. **LongNN, map**: `frontend` 1.1 to 1.4 (shell, `apiClient` , Leaflet with the overlay, `socketClient`), `monitoring` 1.1, 2.1 and 3.1, and `frontend` 9.1, in PRs by Sun 2026-10-25 12:00 ICT. Missed, HoangTK takes `monitoring` 1.1 and 2.1 and the leader takes 9.1. This replaces the clock of D-056 rule 5 for Iteration 1; D-056 rule 5 applies again from Sprint 4.
  5. **Leader lane**: `platform` 1.7, 1.11, 1.12 and 2.2 to 2.10; the `devices` reads that ingestion needs; `gateway-sync` 1.1, 1.2, 2.1 to 2.3 and the replay harness of 4.2.
  6. **TanNB** (QA lead) runs the demo on the seed on Sun 2026-10-25 from 18:00 ICT and logs defects as issues. **HoangTK** stands by for the rule 4 fallback.
  7. **Release**: `dev` was released to `main` in all four repositories on 2026-10-23 and is released again at the tag.
  8. The study's open questions (credentials with queued SOS, Socket.io or WebSocket for the organization API, the two graces, the broker host, invoice lines, organization closing, partial handover, the lifecycle count) are deferred to Sprint 4; none of them shapes the Iteration 1 slice.
- **Rejected**: the full MF-01 and MF-02 build (needs every member coding at once in three days); the live Field Station path for the review (every leg would have to land by Sunday); the leader building every lane (destroys the commit evidence the register already flags); working-day clocks (they expire after the review).
- **Consequences**: `.github/schedule.yml` and roadmap rows updated; notice issue to the team; the W7 milestone "MF-01 complete" is not met and is stated at the review.
- **Owner**: KhoaDD.

D-059: Rulings on the LongLP, LongNN and HoangTK screen designs: landing routes, uncoded messages, report row ids, incident order

- **Status**: ✅ **Resolved by the leader** (2026-10-23), in a live question round on the reviews of `treklink-web` #42 (LongLP), #43 (LongNN, D-057 follow-up) and #45 (HoangTK).
- **Context**: the three screen-design PRs raised open questions under D-052 rule 2. The review confirmed several against the specs: `auth` api-design 05 names `auth.otpResendCooldownSeconds` while the catalog and auth REQ-ERR-08

name `auth.codeResendCooldownSeconds`; `billing` 15 does not return the VietQR block, so the payment page cannot redraw the QR after a reload; `billing` 02 samples only a day-plan quote; an organization member whose invitation code expired has no way to get a new one; `monitoring` 08 report rows carry codes but no ids; per-organization percentiles cannot be combined into a platform figure; `incidents` 01 and 11 page without a documented order; `incidents` 02 samples `statusUpdates[]` and `authorityReports[]` only as empty arrays; `incidents` 03 requires `expectedVersion` but lists no `STALE_VERSION`. LongLP's question 11 was withdrawn: `billing` 17 has listed 403 `SEPARATION_OF_DUTY` since the rescoped specs.

- **Decision**:
  1. **Landing after sign-in**: a same-origin `?next=` path wins. Otherwise the Org Manager lands on a new organization home dashboard at `/o` (contract summary, balance due, open incidents, devices out), the Org Operator on `/o/map`, TrekLink Staff and Admin on `/t/map`. The dashboard is designed and built by LongLP in Sprint 4; until it exists the Org Manager lands on `/o/contracts`.
  2. **Closed organizations**: a member of a `CLOSED` or `REJECTED` organization who signs in gets 401 `INVALID_CREDENTIALS` (MSG09), the same answer as an unknown account, so closed organizations cannot be probed (auth REQ-STA-03).
  3. **Errors without an SRS message code** (`ACCOUNT_LOCKED`, `OTP_COOLDOWN`, `BEFORE_START_DATE`, `SIGNER_NOT_MANAGER`, `RESET_REQUIRED`, `VARIANT_MISMATCH`, `UNKNOWN_DAMAGE_CODE`, `NOTHING_DUE`, `PAYMENT_PENDING`, `EFFECTIVE_IN_PAST`, and the browser-only "Passwords do not match."): the screen shows the server `message`, the SRS §5.3 fallback, through Iteration 1. New MSG codes come with the Sprint 4 SRS revision.
  4. **Contract approval**: the server picks the reserved units; screen 5.3 does not offer `deviceIds`. The counter swaps a unit at handover when needed.
  5. **Placement**: the account menu is a header menu with a change-password dialog and has no route; damage rates are a section of `/t/admin/prices`.
  6. **Spec additions, generated from the catalogs**: `auth` 05 uses `auth.codeResendCooldownSeconds`, and a forgot-password request for an active account that never set a password sends a `SET_PASSWORD` code, which renews an expired invitation through `/forgot` without a new endpoint; `auth` 01 states the rule 2 answer; `billing` 02 adds a `MONTHLY` sample with `termFeeVnd` and `firstPaymentVnd`; `billing` 15 returns `vietQr` while the payment is `PENDING`; `billing` 08 and 09 return `organization { id, code }`; `monitoring` 08 adds `contractId` to `overdue` rows, `contractId` and `lossCaseId` to `lost` rows, and one `incident-times` row with `organization` null computed over all incidents of the period.
  7. **Incidents**: `incidents` 01 returns rows by `tierDeadlineAt` ascending with nulls last, then `firstEventAt` newest first; `incidents` 11 keeps open cases first, then `reportedAt` newest first; neither takes a sort parameter. `incidents` 02 samples non-empty `statusUpdates[]` and `authorityReports[]`. `incidents` 03 adds 409 `STALE_VERSION` (MSG36); `ALREADY_OWNED` (MSG27) is checked first, so a second member acknowledging still learns who owns the incident.
  8. **Study fixes** from HoangTK's result on issue 59: MF-03 and MF-04 step 2 route and scope by the custody interval of the occurrence time (D-040); E03-1 states that a fall SOS sends no beacons, so cadence detection cannot recover it; the study brief records that issue 59 is open.
- **Rejected**: a sort parameter on the incident lists (more backend and test work for no demo gain); new MSG codes before Review 2 (reopens Report 3 two days before the review); landing every organization account on the map (not the control view the leader wants for the Org Manager); building the dashboard inside Iteration 1 (D-058 fixed the scope); a dedicated `ORGANIZATION_CLOSED` code (confirms the email exists); dropping `expectedVersion` from acknowledge (the other incident mutations all carry it).
- **Consequences**: `treklink-web` #46 edits the catalogs, regenerates the api-design files and updates `specs/frontend/design.md` §2 (landing rules, the Sprint 4 `/o` route) and `specs/frontend/tasks.md` (task 5.6, the dashboard, for LongLP). Reviews: #43 approved, #42 changes requested for the `billing` 17 error and the 6.1 error placement, #45 commented with these rulings.
- **Owner**: KhoaDD.
- **Amendment (2026-11-05, leader)**: rule 7's "neither takes a sort parameter" and the rejected alternative "a sort parameter on the incident lists" are withdrawn. Chapter 06 §11.2 (2026-11-05) makes every sortable column header cycle ascending, descending and the default order, so `incidents` 01 and 11 take `sort` (one field from an allowlist: code, state, latest

event) and `order` (`asc` or `desc`), like the other paged lists; a field off the allowlist, or `order` without `sort`, answers 400 `VALIDATION_FAILED`. Without `sort`, both lists keep the rule 7 order above. Built in `treklink-web` #399 (task W26), with the screen specs 8-1 and 8-2 updated there.

D-060: Sign-in rulings for Iteration 1: organization sign-in through a real provider, the port carries the organization name, 14-day refresh, strict rotation

- **Status**: ✅ **Resolved by the leader** (2026-10-23), in a question round on the review of `treklink-web` #48 (LongLP, TK-121) and the three questions of treklink-docs#87.
- **Context**: #48 delivers the D-058 sign-in slice. The review ran it against Postgres 16 with the demo seed: every flow matches the specs, with these gaps. `ACCOUNT_CONTEXT_PROVIDER` has no provider, so organization accounts are refused; the spec cited `organizations` 2.9 as the provider, but the provider task is `organizations` 1.3 (2.9 is channel key rotation). `auth` api-design 01 and 04 show `organization.code` and `legalName`, which the port does not return. `JWT_REFRESH_TTL` defaults to `7d` in `environment-variables.ts` while `auth` requirements §4 and api-design 01 say `14d`. `JWT_REFRESH_SECRET` is validated but unused, because the refresh token is opaque and stored as SHA-256. Refresh returns `user`, which api-design 02 does not show. A concurrent rotation of one refresh token is treated as reuse and revokes the family.
- **Decision**:
  1. **Organization sign-in**: the leader builds the `ACCOUNT_CONTEXT_PROVIDER` half of `organizations` 1.3 now, in the `organizations` module, so the seeded Manager and Operator sign in for Iteration 1. `API_KEY_RESOLVER` and the exit-check port of 1.3 stay with TanNB. Until the provider merges, `auth` refuses organization accounts with MSG09.
  2. **Environment**: `BCRYPT_COST`, `MAIL_TRANSPORT`, `MAIL_FROM` and `SMTP_URL` are validated in `platform/config/environment-variables.ts` next to `JWT_*` (#87 item 2).
  3. **Sign-in page** on the existing router and `apiClient`, tokens in memory only; `frontend` 1.1 and 1.2 build the auth context and silent refresh on top (#87 item 3).
  4. **`JWT_REFRESH_TTL` defaults to `14d`**, as the spec says; the code default is corrected.
  5. **The port carries the organization name**: `AccountMembership` gains `organizationCode` and `legalName`, and login and `me` return them as api-design 01 and 04 show.
  6. **`JWT_REFRESH_SECRET` stays, optional and unused**, reserved in case refresh tokens become signed tokens.
  7. **Refresh returns tokens only**, as api-design 02 shows, the shape of a standard token response; a client reads `GET /api/auth/me` for fresh roles and membership.
  8. **Strict rotation**: two rotations of one refresh token at once count as reuse and revoke the family (REQ-ERR-02). `frontend` 1.2 runs one refresh at a time and shares its result between callers.
  9. **Lockout counting**: `LOGIN_FAILED` events count inside `auth.loginFailureWindowMinutes`, excluding events before the last successful sign-in and before the end of the last lock. The failure that reaches `auth.loginMaxFailures` already answers 423 `ACCOUNT_LOCKED`.
- **Rejected**: a stub provider inside `auth` (it would read `OrganizationMember`, a table `organizations` owns, and the module-boundary check rejects it); refusing organization accounts until Sprint 4; TanNB coding 1.3 before the Sunday demo run; dropping the organization name from the API; removing `JWT_REFRESH_SECRET`; a grace window for concurrent refresh (a requirements change, a new parameter and weaker reuse detection); adding `user` to api-design 02.
- **Consequences**: #48 is sent back for items 5 and 7, the `organizations` 1.3 comment and a backslash guard on `?next=`; `auth` design §2 and the lockout rule, `auth` tasks 1.2, `organizations` 1.3 ownership, `frontend` 1.2 and `platform` configuration are updated in `treklink-web`.
- **Owner**: KhoaDD.

D-061: Every route is guarded globally; `@Public()` opts out and `@CheckPolicies` lives in `common`

- **Status**: ✅ **Resolved by the leader** (2026-10-24), in a question round while building `platform` task 4.2.
- **Context**: `platform` task 4.2 told `ParametersController` and `AuditLogController` to use `auth`'s `JwtAuthGuard` and `PoliciesGuard`, but `platform` may not import `auth` (`platform` design Figure 3, enforced by the module-graph

check of `platform` 1.11). Every module below `auth` in Figure 3 has the same problem, and a route that forgets `@UseGuards` is open.

- **Decision**:
  1. `auth` registers `JwtAuthGuard` and then `PoliciesGuard` as global guards (`APP_GUARD`). Every route requires a valid access token and a passing policy unless it opts out.
  2. `@Public()` opts a route out of both guards: sign-in, refresh, health, the SePay webhook and the broker hooks. `@Authenticated()` requires a token but no permission: sign-out and `GET /api/auth/me` .
  3. A route with neither `@Public()` , `@Authenticated()` nor `@CheckPolicies` is refused with 403, so a forgotten policy fails closed.
  4. `@Public()` , `@Authenticated()` , `@CheckPolicies` and `@Caller()` live in `backend/src/common/decorators` , which every module may import; `auth` re-exports `CheckPolicies` so existing imports keep working. The CASL ability, the guards and `scopeWhere` stay in `auth` .
- **Rejected**: hosting `platform` 's controllers in `monitoring` (endpoints in another module's folder, ownership of api-design 02 to 05 unclear); deferring 4.2 to Sprint 4; a guard port declared by `platform` (a second mechanism for what `APP_GUARD` does natively); per-controller `@UseGuards` (open by default).
- **Consequences**: the `auth` controller drops its `@UseGuards` and gains `@Public()` and `@Authenticated()` ; `HealthController` gains `@Public()` ; `platform` 4.2 is built on this. `auth` design §3 and `platform` design §2.1 record the rule.
- **Owner**: KhoaDD.

D-062: Shared development moves to Neon now, on a `dev` branch, Postgres only

- **Status**: ✅ **Resolved by the leader** (2026-10-24), in a question round before the CO phase.
- **Context**: the team starts the CO phase of D-053 for Iteration 1 (D-058). D-053 rule 6 and D-055 rule 4 kept development on local Docker Postgres until Sprint 4, so every member codes against a private database with a private seed, and a cross-module integration fault surfaces only on the leader's machine. The Neon project of D-010 had never been provisioned. `neon init` offers Postgres, Neon Auth, the Data API, functions, object storage, an AI gateway and realtime, and its starter `neon.ts` expires every new branch after 7 days.
- **Decision**:
  1. Shared development runs on Neon from 2026-10-24, project `damp-queen-78476528` . This supersedes D-053 rule 6 and the development half of D-055 rule 4. **[Amended 2026-10-24]** The project is named `Treklink-web_001` . When a free-plan limit is reached, the leader duplicates the project under the next number (`Treklink-web_002` , then `_003`), applies the migrations and the demo seed to its `dev` branch, and sends a new team env zip; the connection strings change with each project. Each member replaces `.env` from the new zip and changes nothing else. Members receive only the `dev` strings; the `production` string stays with the leader and CI (rule 2).
  2. The team codes against the Neon branch `dev` , a child of `production` . `production` is kept for staging and production. `treklink-web/neon.ts` exempts `dev` from the 7-day expiry; any other new branch is a personal scratch branch and expires.
  3. Postgres only. Neon Auth is not used, because identity is JWT, bcrypt and CASL by the architecture contract (chapter 04). No other Neon service is provisioned; one is added only through a spec and a decision.
  4. Migrations reach the Neon `dev` branch only from the git `dev` branch, by CI or the leader (D-010, question 40, unchanged).
  5. Local Docker Postgres stays the database of unit tests, `test:db` and CI.
  6. The leader sends the team env file privately in Zalo as a zip. Each member keeps it in `ignore/{name}/envs/` and copies it to `.env` ; it is never committed. `DATABASE_URL` is the pooled string and `DATABASE_DIRECT_URL` the direct one (`treklink-web/.env.example`).
- **Rejected**: local Docker until Sprint 4 (no shared data during the CO phase); coding against `production` (member migrations and seed rows would land in what becomes production); provisioning every offered service (Neon Auth duplicates the auth module, the rest has no spec); one Neon branch per member (question 40 settled one shared database).

- **Consequences**: `treklink-web` gains `neon.ts`, the `@neon/config` and `@neon/env` packages and a `.neon` ignore line; D-053 rule 6 and D-055 rule 4 carry a superseded note; the demo seed runs on the Neon `dev` branch. Verified 2026-10-24: the 8 migrations and the demo seed applied to `dev`; the backend reported the database up, signed in a seeded account and ingested 12 replayed MQTT fixtures as 12 `field_events` rows. Neon runs Postgres 18.6 while local Docker and CI run 16, so a migration that passes CI is applied to a newer server.
- **Owner**: KhoaDD.

D-063: Password-flow rulings for US-UC09: one session rule, silent forgot cooldown, SMTP now, cooldown on the Staff trigger

- **Status**: ✅ **Resolved by the leader** (2026-10-24), in a question round on the seven defaults of treklink-docs#96 and the review of treklink-web#61.
- **Context**: LongLP built `auth` 3.1, 3.2 and the password routes of 6.1 (treklink-web#61) on seven stated defaults where the specs were silent or contradicted each other (treklink-docs#96), and added an eighth after review. The review reproduced a race: 40 concurrent wrong codes and the right one, with `auth.codeMaxAttempts` 5, ended in "Password changed" and 40 counted attempts. The backend has no request throttling; `@nestjs/throttler` was approved on 2026-09-25 and never installed.
- **Decision**:
  1. Changing the password ends every session of the account, the caller's included. api-design 08 says "every session" instead of "other sessions".
  2. Inside `auth.codeResendCooldownSeconds`, `forgot` answers 200 with the usual message and sends nothing, so a registered email cannot be told from an unknown one (FR-AUTH-05; OWASP Forgot Password Cheat Sheet, "Return a consistent message for both existent and non-existent accounts"). REQ-ERR-08 and api-design 05 drop the 429 for `forgot`.
  3. `nodemailer` is approved. LongLP builds the `smtp` transport of `auth` 1.3 before the `review-2` tag, configured by `SMTP_URL` and `MAIL_FROM`.
  4. The `console` transport is exempt from AC-06 (REQ-OPT-01). The backend refuses to start when `MAIL_TRANSPORT` is `console` and `NODE_ENV` is `production`, with a test; AC-06 carries the note.
  5. An invited member of a `CLOSED` or `REJECTED` organization who sets a password keeps it, the code is spent, and the answer is 401 `INVALID_CREDENTIALS` (D-059 rule 2).
  6. Sending a code spends the account's earlier live codes of the same purpose; only the newest works.
  7. The Staff-triggered reset (api-design 14) respects the same cooldown and answers 429 `OTP_COOLDOWN`.
  8. The Staff-triggered reset refuses a deactivated account with 409 `INVALID_STATE_TRANSITION`, because `reset` would refuse its code.
  9. The attempt limit is enforced by the database: an attempt is counted with a conditional update before the code is compared, and a `test:db` case fires more than `auth.codeMaxAttempts` concurrent wrong codes and the right one.
  10. The team SMTP account is `treklink.team@gmail.com`, authenticated by a Google app password. **[Amended 2026-10-24]** Google issues an app password only after 2-Step Verification is on (support.google.com/accounts/answer/185833), so the leader turns on 2-Step Verification with the leader's own authenticator app, holds that device alone, and creates the app password; no member signs in to the inbox. The app password reaches the team only through the team env zip (`SMTP_URL`, `MAIL_FROM`), the D-062 path, and is never committed. The account's own sign-in password is never placed in an env file. The shared team env keeps `MAIL_TRANSPORT=console`; a member switches to `smtp` locally to test delivery.
  11. Request throttling is a `platform` task for Sprint 4: a global `@nestjs/throttler` with stricter limits on the `@Public` auth routes, answering 429 `RATE_LIMITED`.
- **Rejected**: an optional `refreshToken` in the change-password body (catalog change for little gain); the 429 on `forgot` as specified (it reveals registered emails); SMTP in Sprint 4 (the leader wants real delivery in Iteration 1); masking the code in the console transport (local development could not finish a reset); refusing set-password for a closed organization (the member would need a new invitation after a reopen); several live codes (wider guessing space); no cooldown on the Staff trigger (repeated clicks flood the inbox and spend the code the user is typing); sending a code to a deactivated account; a sandbox inbox or a transactional provider for SMTP; `treklink.dev@gmail.com` as the sender (it reads as a

test account); a shared authenticator key (a team password that cannot be taken back from one member); console-only delivery until Sprint 4 (the leader wants real delivery in Iteration 1); throttling inside treklink-web#61 (three items for one member before the tag).

- **Consequences**: in treklink-web#61, per D-053 rule 1, LongLP updates `specs/auth/requirements.md` (REQ-ERR-08, REQ-OPT-01 with the production guard, AC-06), `scripts/specs/endpoints/auth.py` and the regenerated api-design 05, 08 and 14. The dependency row of 2026-09-25 adds `nodemailer`. A risk row tracks the missing throttling until Sprint 4.
- **Owner**: KhoaDD.

D-064: Account administration defaults for US-UC10 (treklink-docs#98)

- **Status**: ✅ **Resolved by the leader** (2026-10-24), accepting all six defaults LongLP stated in treklink-docs#98 for treklink-web#63.
- **Context**: `auth` 5.1 and 5.3 (TK-123) left six points open: two fields api-design 18 returns without a column, self-deactivation, repeated state changes, a missing error row, organization accounts on the account routes, and the auth-event route.
- **Decision**:
  1. `protected` in api-design 18 comes from a code constant holding `role.manage`, the only key the permission matrix marks protected; `description` is `null` until a migration adds both columns.
  2. An Admin may deactivate their own account while another Admin stays active; only `LAST_ADMIN` applies.
  3. Deactivating an inactive account or reactivating an active one answers 200 with the account unchanged, and writes no auth event and no audit row.
  4. `PERMISSION_SCOPE_MISMATCH` (api-design 16, D-057 rule 2) gets its row in auth design §4.
  5. `PATCH`, `deactivate` and `reactivate` on the account routes answer 404 for an organization account; its Manager handles it through `organizations`.
  6. `GET /api/auth-events` (api-design 17, UC-58) is not part of treklink-web#63.
- **Rejected**: a migration adding `description` and `protected` before the `review-2` tag (schema churn for a read-only field); forbidding self-deactivation (no rule needs it while `LAST_ADMIN` holds); 409 on a repeated state change (a retried click would show an error for a state the user wanted).
- **Consequences**: in treklink-web#63, per D-053 rule 1, LongLP adds the §4 row and states rules 2, 3 and 5 in api-design 11 and 12. A later migration adds the two `Permission` columns, filled by `build_seed.py`.
- **Owner**: KhoaDD.

D-065: Graded reports draw their diagrams in PlantUML; Mermaid stays for repository specs

- **Status**: ✅ **Resolved by the leader** (2026-10-24), after the supervisor meeting of 2026-10-24 (`capstone/Documents/meetings/Supervisor Meeting 2026 10 24 091511.txt`).
- **Context**: Mr. Duc rejected the report diagrams as not following notation: the context diagram merges each actor's inflow and outflow into one bidirectional arrow, the use case model is split over about ten figures instead of one overview on an A4 page, the architecture diagram does not separate frontend, backend and third parties, and the ERD's crow's-foot style was unfamiliar. The course handbook `Documents/templates/Cam-nang-tranh-loi-Capstone-SE.pdf` §2 grades eight diagram types on notation. The SRS use case figures are Mermaid `flowchart`s with rectangles for actors, and the context diagram merges two entities into one box, which §2.6 forbids.
- **Decision**:
  1. Every diagram in a graded report (Reports 1 to 7, the Design Brief, review decks) is PlantUML source rendered by the PlantUML jar, kept next to the report as `.puml`. **[Amended 2026-10-25]** Except activity (swimlane) and state machine diagrams, which are Mermaid first (`swimlane-beta`, `stateDiagram-v2`), rendered by the pinned `mmdc` with Mermaid 12.0.0 (`capstone/scripts/srs/render_figures.sh`). An activity diagram may also be PlantUML; a state machine falls back to PlantUML only when Mermaid cannot draw it. The leader ruled after comparing ten demo figures drawn in both tools (`capstone/Documents/reports/assets/puml/review/`): Mermaid drew the ERD crow's foot as the curved leaf the supervisor rejected, put filled heads on `include` arrows and tangled the architecture, so use case,

class, sequence, ERD, context and architecture stay PlantUML. **[Amended 2026-10-26]** The tool per diagram type, ruled by the leader after the 2026-10-25 grill on the comparison renders (`capstone/Documents/reports/assets/puml/review/compare/`): **PlantUML** for context, use case, class, ERD and physical schema, activity (swimlane), architecture, deployment, IoT hardware and package diagrams; **Mermaid** for state machines. **Sequence diagrams stay Mermaid for now**: every SDD sequence is also rendered in PlantUML (`capstone/Documents/reports/assets/puml/review/sequence-trial/`), and the leader picks one tool for all of them at final delivery. The context diagram stays PlantUML because its process now renders as a true circle (`capstone/scripts/srs/render_puml.py` redraws the ellipse PlantUML 1.2026.9 always draws for a `usecase`). Large figures may use `!pragma layout elk`, which needs Java 21, except an ERD. **ERDs are not drawn by PlantUML** (leader review 2026-10-26): the leader requires straight orthogonal lines, no curves or diagonals, and a jump where two lines cross. Graphviz `ortho` shares tracks and drifts labels, PlantUML's ELK adapter exposes no spacing, and neither draws jumps, so an ERD keeps PlantUML's entity syntax and is drawn by `capstone/scripts/srs/render_erd.py` (elkjs layered layout, orthogonal routing, one port per line end, SVG and jumps drawn by the script). Rejected: Graphviz polyline (diagonal lines). The leader vets each ELK render. No figure carries a legend or an explanatory note; the document's text or notation table explains the notation. The shared style's fonts rise to 16 px (labels 15 px) so wide figures stay closer to the 7 pt floor of chapter 13 §4.1. Visual Paradigm is not used. **[Amended 2026-11-06]** Report 4 Figures 1, 2, 3 and 5 are a scoped draw.io exception: context candidate A4; system architecture candidate B10, with one abstract backend in two tiers, SePay and generic Map tiles; deployment candidate C7, with the planned D-098 hosting; and package candidate E8, with one line per module pair and organizations, auth and platform as bars. Their sources are `capstone/Documents/reports/assets/drawio/sdd-fig1-context.drawio`, `sdd-fig2-architecture.drawio`, `sdd-fig3-deployment.drawio` and `sdd-fig5-packages.drawio`; draw.io desktop 31.7.0 exports each to PNG at scale 2 with `drawio -x -f png -s 2`. The leader approved the colour redraw on 2026-10-30 after the supervisor's 2026-10-24 notation critique, then selected these candidates on 2026-11-05 and the night of 2026-11-06 because PlantUML could not draw the approved icons, nested tiers, colour lanes and fixed orthogonal routing with jumps legibly at print size, and the leader judged its versions weaker. Each figure passed the D-067 gate against handbook §§1.3, 1.5, 1.6 and 2.3 to 2.6 and code on `dev` 340036f; Figure 4 and every other figure remain under rule 1.

2. Mermaid stays the diagram language of `treklink-docs` and `treklink-web/specs` (chapter 13); a spec diagram is not copied into a report as Mermaid.
3. Before the Review 2 package (2026-10-26), every report figure is redrawn and checked against handbook §2 for its type: the context diagram with one arrow per direction per entity, nouns as flow labels and no merged entities; one use case overview with CRUD folded into `Manage X`, the per-flow diagrams kept as detail; the architecture with frontend, backend and every third party as separate blocks and both request and response paths, plus the IoT hardware diagram with specifications and protocols; one overall ERD in one notation with its legend; sequences numbered, with activation bars, `:Object` names, named pages and two-lane `alt` boxes.

- **Rejected**: keeping Mermaid and fixing content only (no stick-figure actors, `include` and `extend` or activation styling the reviewers recognise); Modelio or Umbrello (hand-drawn binary models, not regenerable); Enterprise Architect under Wine (paid after the trial, hand-drawn); fixing only the three figures named in the meeting (the ERD and sequences would carry known handbook violations into the review).
- **Consequences**: chapter 13 §1 carries the exception. The SRS and SDD figure build moves from `.mmd` to `.puml`. **[2026-10-26]** Report 4 is rebuilt: 30 figures in PlantUML (context, architecture, deployment, IoT hardware, package, overall ERD, nine physical schema parts, five activity diagrams, ten class diagrams), 8 state machines and 42 sequences in Mermaid. Chapter 16 §2, §6 and §7 and `AGENTS.md` §2.8 and §4 follow the amendment. Report 3's figure swap reuses the same `.puml` sources. Report 4 Figures 1, 2, 3 and 5 use draw.io under the 2026-11-06 amendment.
- **Owner**: KhoaDD.

D-066: Five main flows run their happy path end to end by Saturday 2026-10-31

- **Status**: ✅ **Resolved by the leader** (2026-10-24), on the supervisor's demand of 2026-10-24.
- **Context**: at the 2026-10-24 meeting the team could not demo anything; Mr. Duc required all five main flows runnable by the weekend of 2026-10-31. On 2026-10-24, 44 of 209 tasks were ticked and `organizations`, `rentals` and `billing` had no code.
- **Decision**:

1. By Saturday 2026-10-31 each of MF-01 to MF-05 runs its main success scenario through the real screens and the real API on the seed data. Alternate and exception paths wait.
2. The leader and the agent own the documents and diagrams (D-065) and review every PR the day it opens; the four members own the code, one or more flows each, end to end.
3. The per-flow cut list and lane plan are published as a session file before Monday 2026-10-26.

- **Rejected**: every step and alternate of each drawn flow by 2026-10-31 (not reachable with 165 tasks open); asking the supervisor to restate the bar first (costs a day).
- **Owner**: KhoaDD.

D-067: Every diagram and spec passes the handbook gate: check, look, cross-check

- **Status**: ✅ **Resolved by the leader** (2026-10-24), a standing instruction after the supervisor meeting of 2026-10-24.
- **Context**: the diagrams the supervisor rejected broke rules the course handbook `capstone/Documents/templates/Cam-nang-tranh-loi-Capstone-SE.pdf` states plainly (§2.1, §2.6). Agents generated report figures and specs without re-reading it, checked the source but rarely the rendered image, and did not compare figures with each other, so notation and naming drifted between documents.
- **Decision**:
  1. Before writing or editing a diagram, or a spec or report section a diagram is drawn from, the author re-reads the handbook sections for that artifact (chapter 13 §1.1 table), from the PDF, every time.
  2. The rendered image is looked at before the figure is done: by the agent when it has image input, otherwise by a member.
  3. The figure is cross-checked against the other figures, the SRS and SDD text, `schema.prisma`, the module `design.md` and the code paths it claims.
  4. The PR body or session file records, per figure, the sections re-read, who looked at the render and what it was cross-checked against. A figure without that record is sent back in review.
  5. The rule is in `AGENTS.md` §2.8 in all five copies, so every agent loads it at session start.
- **Rejected**: a one-time audit before Review 2 only (the drift returns with the next generated figure); relying on source review (layout faults exist only in the render); copying the handbook into the repository (it is course material; the PDF stays the source and chapter 13 keeps a short paraphrase).
- **Owner**: KhoaDD.

D-068: The Field Station is part of the system, not an actor

- **Status**: ✅ **Resolved by the leader** (2026-10-25), during the D-065 redraw.
- **Context**: the SRS said the Field Station is TrekLink software "inside the boundary", but Table 11 listed it as an actor and UC-26 and UC-27 named it as their actor; the old context diagram drew it outside the system process. A UML actor is outside the system by definition, so the three statements could not all hold, and handbook §2.6 and §1.5 grade diagrams that disagree with each other.
- **Decision**:
  1. The Field Station and the MQTT broker are inside the system boundary. Neither is an actor or an external entity.
  2. The TrekLink Device is the external actor of UC-26 Ingest Field Event and UC-27 Flush Offline Queue; UC-28 keeps the Org Operator.
  3. SRS Table 11 drops the Field Station row and renumbers; Table 12 and the UC-26 and UC-27 specifications name the TrekLink Device; §2.1 explains why the Field Station is not an actor.
- **Rejected**: the Field Station as an external secondary actor (it is TrekLink's own executable, shipped and versioned with the platform, and the context diagram would show part of the system as outside it).
- **Owner**: KhoaDD.

D-069: UML modeling rules for every PlantUML diagram (chapter 16)

- **Status**: ✅ **Resolved by the leader** (2026-10-25), after rejecting the first PlantUML use case overview.
- **Context**: the first PlantUML use case overview had no actor generalization and put actors above and below the system boundary. The agent had drawn without a rule set saying what each diagram type may contain and where each element goes, so layout was decided by trial renders. D-067 checks a figure against the handbook, but the handbook lists mistakes, not a full notation and layout standard.
- **Decision**:
  1. Chapter 16 is the rule set for every PlantUML diagram: each rule tagged with its source (course handbook, the UML 2.5 specification, Ambler's *The Elements of UML 2.0 Style*, Wiegers and Beatty, the PlantUML reference, or a TrekLink choice), and a skeleton per diagram type in `_docs/02-templates/puml/` with a shared monochrome style. Each skeleton was rendered and inspected on 2026-10-25.
  2. The actor tree is `User` (abstract) with `Organization Member` (abstract) above `Org Operator` above `Org Manager`, and `TrekLink Employee` (abstract) above `TrekLink Staff` above `TrekLink Admin`. `Guest` stays outside the tree. Actors have no aggregation; organization membership is shown in the class diagram and the ERD.
  3. A sequence diagram shows one use case's main success path plus at most one `alt` for the failure its specification names; every other branch is in the activity diagram. (Briefly superseded by D-083 on 2026-10-30, which the leader withdrew the same evening; this rule stands.)
  4. The ERD notation is crow's foot (IE), drawn with orthogonal lines and square corners so each foot is three straight strokes ending on the entity border.
  5. Training material the leader holds in confidence informed some rules; it is not cited, quoted or stored in any repository, and the rules it alone supports are stated as TrekLink choices.
- **Rejected**: Chen notation for the ERD (PlantUML's Chen syntax not verified, and the course accepts either); every exception as an `alt` in the sequence (unreadable, and the activity diagram already carries the branches); no `alt` at all (the handbook asks for exception paths); a section of chapter 13 instead of a new chapter (mixes notation with print layout).
- **Owner**: KhoaDD.

D-070: The commit model check is an explicit allowlist with the variant sealed

- **Status**: ✅ **Resolved by the leader** (2026-10-25). Amends D-054 rules 4 and 5.
- **Context**: the leader saw every pull request pass the Commit Checksum check and asked whether it compares values. An audit of `tk_checksum.py` on 2026-10-25 confirmed the AES-GCM seal works (a token edited, moved to another subject or pushed by another member fails), and found the model check unsafe: approval was `(major, minor) >= floor` per family, so `claude-opus-9-9`, `claude-fable-7`, `gpt-9-9` and `gpt-5-7` passed; the token stored no variant, so `gpt-5-6-luna` and `gpt-5-6-terra` were sealed as plain `gpt-5.6` and passed, and Gemini 4 Argon was sealed as "gemini-flash 4.0"; a restricted model failed only on `feat`, `fix` and `hotfix`, so it passed on `refactor` and `test`. Every commit then on `dev` and in open pull requests declared Claude Opus 5.5, Claude Sonnet 5.5 or 5, or GPT 6, all approved under either rule, which is why everything passed.
- **Decision**:
  1. The allowlist names each model: Claude Opus 4.6, 4.7, 4.8, 5, 5.5; Claude Sonnet 4.6, 4.8, 5, 5.5; Claude Haiku 5, 5.5; GPT 5.6 Sol, 5.6 Cyber, 6, 6 Sol, 6 Luna, 6 Astra, 6.1 Sol; Gemini 4 Argon. It lives in chapter 11 §2.1 and in `ALLOWLIST` of `tk_checksum.py`, edited together. No version comparison: a later model fails until it is added.
  2. Ingest only, failing on every commit whatever its type: Gemini 3.8 Flash, GPT 5.6 Luna, GPT 5.6 Terra. Every model not listed fails as well.
  3. Claude Fable is approved at every version, the one family-wide entry, by the leader's choice.
  4. A commit with no `Checksum` trailer, or an empty one, is a manual commit: a member typing by hand never sets a model. It gets the `provenance-review` label for a review by hand, and the check passes, as D-054 rule 4 already said. Bot and merge commits stay exempt. AI attribution (D-049) stays a label.
  5. The hook writes token format tk2 (66 hex), which seals the variant with the model. A tk1 token (64 hex) still verifies; when its family and version need a variant to decide (today only `gpt-5.6`), it is labelled for a manual audit instead of

failing.

6. `tk_checksum.py selftest` checks every list entry, the near misses and the token rules offline; run it after any change to the list.

- **Rejected**: keeping the version floors (a future or unvetted model passes silently); listing Fable versions one by one (the leader allows the whole family); failing a commit with no trailer (a manual commit carries none, and members do not set a model by hand); failing every tk1 token (forces every member onto the new hook at once, for no gain on the models in use); passing a tk1 `gpt-5.6` token (reopens the Luna and Terra hole).
- **Consequences**: `treklink-docs/.github/scripts/tk_checksum.py`; chapter 07 §3.6; chapter 08 §3.1; chapter 11 §2.1, §2.2 and §2.4; the five AGENTS.md copies §6. Members pull `treklink-docs` `dev` so their hook writes tk2. The check's member-key and subject binding is unchanged; a commit with the identical subject would accept the same token, because the seal does not cover the diff.
- **Owner**: KhoaDD.

D-071: The live map uses the CyclOSM style, for terrain (amends D-031)

- **Status**: ⛔ **Superseded by D-072** (2026-10-27). Resolved by the leader 2026-10-26.
- **Context**: the plain OpenStreetMap style draws no contour lines or hillshading, and trekking staff read slope, ridges and valleys from the map. The leader asked for a terrain map before Review 2 and pointed at the CyclOSM style. A tile comparison over the default viewport (11.6°N 108.5°E, zoom 13) confirmed it: CyclOSM draws contours, hillshading, streams and forest cover.
- **Decision**: the three map parameters change to provider `cyclosm`, tiles `https://{s}.tile-cyclosm.openstreetmap.fr/cyclosm/{z}/{x}/{y}.png` and attribution `© OpenStreetMap contributors, style CyclOSM, tiles by OpenStreetMap France` (treklink-web `scripts/specs/catalog.py` and a forward migration, because the seed is already applied, D-036). Leaflet, the endpoint and the sovereignty overlay stay as D-031 set them. CyclOSM is hosted by OpenStreetMap France under a fair-use tile policy with no key (https://www.cyclosm.org); the D-031 usage rules carry over: attribution on the map, no bulk prefetch, no offline caching for the Field Station.
- **Sovereignty**: CyclOSM draws OpenStreetMap data, so its base labels over the archipelagos are the same as OpenStreetMap's. TC-24 was re-run on 2026-10-26 with the overlay present over both; the screenshots are in `capstone/Documents/evidence/map-sovereignty/` (`2026-10-26-cyclosm-*.png`). R11 keeps its D-031 standing: accepted within educational scope, no public deployment.
- **Rejected**: OpenTopoMap (it also draws terrain, but it is not the style the leader chose); Thunderforest Outdoors and Tracestrack Topo (need an API key held in the browser); keeping the plain OpenStreetMap style (no terrain).
- **Consequences**: treklink-web `scripts/specs/catalog.py`, `specs/platform/configuration-matrix.md`, `specs/monitoring/api-design/01-get-map-config.md` and migration `20261026170000_map_cyclosm_terrain` (treklink-web#83). An Admin can still change the three values through the parameters API.
- **Owner**: KhoaDD; LongNN (monitoring).

D-072: The live map offers switchable keyless basemaps, OpenTopoMap by default (supersedes D-071)

- **Status**: ✅ **Resolved by the leader** (2026-10-27).
- **Context**: CyclOSM (D-071) serves no tile above zoom 13 over Vietnam. On 2026-10-27 every subdomain answered HTTP 404 at zoom 14 to 17 over the default viewport (11.56°N 108.54°E), while the same zooms loaded over Paris; zooming in replaced the map with MSG33. The leader asked for several topographic maps instead of one.
- **Decision**:
  1. The live map offers four basemaps in a Leaflet layer control, none needing a key: Topographic (OpenTopoMap), the default; Terrain (Stadia Stamen Terrain); Topographic (Esri World Topo); OpenStreetMap.
  2. `monitoring.mapBasemaps` holds the list (id, name, tile URL, attribution, `maxZoom`, `maxNativeZoom`) and replaces `monitoring.mapTileUrl` and `monitoring.mapAttribution`; `monitoring.mapProvider` names the default entry. `GET /api/map/config` returns the list and still describes the default in `provider`, `tileUrl` and `attribution`.
  3. `maxNativeZoom` is the deepest zoom each provider drew over the default viewport on 2026-10-27: OpenTopoMap 17, Stadia 18, Esri 16, OpenStreetMap 19. Above it Leaflet enlarges the deepest tiles up to `maxZoom` (18; OpenStreetMap 19), so no zoom requests a tile that does not exist.

4. The sovereignty overlay is drawn on every basemap and is never in the layer control (D-031, BR-30).

- **Sovereignty**: TC-24 re-run on 2026-10-27 for all four basemaps over both archipelagos; the overlay is present on each. Three basemaps draw OpenStreetMap-derived data and carry its foreign labels beneath the overlay; Esri showed no foreign archipelago label at zoom 7, other zooms not checked. Evidence: `capstone/Documents/evidence/map-sovereignty/2026-10-27-*.png`. R11 keeps its D-031 standing: accepted within educational scope, no public deployment.
- **Usage terms (unverified in detail)**: OpenTopoMap and OpenStreetMap run volunteer servers under fair-use policies; Stadia accepts keyless requests from localhost, and a deployed domain needs a Stadia account; Esri's terms for World Topo Map were not reviewed. Re-check all four before any deployment beyond the course.
- **Rejected**: keeping CyclOSM (empty above zoom 13 here); CyclOSM enlarged past zoom 13 (blurry exactly where trekkers zoom); providers that need a key in the browser (Thunderforest, Tracestrack, MapTiler).
- **Consequences**: treklink-web#88: `scripts/specs/catalog.py`, the configuration matrix and parameter registry, migration `20261027090000_map_basemaps`, `LiveMapService`, `LiveMapWidget`, api-design 01, monitoring REQ-UBI-02, frontend REQ-UBI-06.
- **Owner**: KhoaDD; LongNN (monitoring and frontend lane).

D-073: Review 2 field-side rulings: device first, relays are rented nodes the organization places, no SIM master node, register Context from the approved slide (amends D-033 rule 8)

- **Status**: ✅ **Resolved by the leader** (2026-10-28).
- **Context**: Review 2 (2026-10-27), panel note `capstone/Documents/feedback/Note-review2.txt`. The panel approved the Context on slide 2 of the Canva deck "Treklink Review 2" (DAHZFEHnKsU) and asked that the registration form carry it unchanged. It asked the team to stop leaning on phones and the Meshtastic phone app, to say who pays for and who installs relays, and suggested a master node with a SIM card. The adjusted form (`topics/Phieu_FA26SE159_adjusted_2026-10.md` §3.2 a) still names three routes (Tà Năng–Phan Dũng, Tả Liên Sơn, Bạch Mộc Lương Tử), while the approved context covers every organization nationwide.
- **Decision**:
  1. **Register Context**: §3.2 a) of the adjusted form takes the slide 2 text word for word, grammar fixes only, and drops the route names.
  2. **Device first** (amends D-033 rule 8): a device holder works the device itself (SOS button, screen, preset messages) and needs no phone and no TrekLink account. The stock Meshtastic app is mentioned only as an optional backup, never as the holder interface.
  3. **Relays are ordinary rented nodes.** Any rented node can run in the Meshtastic relay role. The nodes have no solar supply, so a relay is a temporary checkpoint: the organization's staff place it on site for an operation and retrieve it. It is part of the same contract at the normal per-device price; TrekLink installs nothing on site. A node not returned at the end of the contract is a loss under D-033 rule 4.
  4. **No SIM master node.** Phones stay the backup uplink for the Field Station, since one LTE plan covers a whole team.
- **Rejected**: a separately priced relay kit (new billing rule and variant for no new capability); permanent relays installed by TrekLink (no solar, no maintenance model); a SIM master node (new device development, SIM allocation and SIM management do not fit the remaining term); keeping the stock app as the holder interface (contradicts the panel).
- **Files moved** (2026-10-28): the registered form `topics/Phieu_FA26SE159.md` and the pre-registration draft `topics/Phieu_dang_ky_de_tai_TrekLink_FA26_FINAL.md` with its two .docx files now live in `topics/.deprecated/`; older entries in this register cite their former paths. The style template `topics/docx/Phieu_FA26SE159.docx` stays in place.
- **Grammar fix confirmed** (2026-10-29): the slide's "with room of potential" reads "with room for growth" in the register, confirmed by the leader under rule 1. The Review 2 submission carries the register as .docx and .pdf, clean and highlighted, with BM03 appended to each PDF; `topics/pdf/` holds the register-only PDFs.
- **Consequences**: adjusted form §3.2 a) and BM03 Record of Changes; SRS context, constraints and the field-side narrative; the scope disclaimer on connectivity loss (still to be ruled). The 2026-10-02 field-test risk row ("plan a repeater node as optional equipment") now reads as rule 3.

- **Owner**: KhoaDD.

D-074: Organizations group their rented devices; the platform offers generic grouping, not trips (amends D-033 rule 3)

- **Status**: ✅ **Resolved by the leader** (2026-10-28).
- **Context**: Review 2 asked for tours or journeys so holder data can be attached, and gave a case: an organization rents 20 devices on one contract, sends 12 to one site and 8 to a distant site, each with its own group and chat channel, and a site may split into smaller groups. D-033 rule 3 excluded trips, and `schema.prisma` has no group model; devices hang only off contracts. Too specific a feature (tour trips) draws the panel's scope objection; too little leaves the gap it named.
- **Decision**:
  1. **Generic Group.** An organization creates groups with a name, an optional free-text label (for example "ranger patrol", "tour"), optional dates and an optional area note. TrekLink models no trip, tour, booking or customer; the label lets each organization fit groups to its own purpose.
  2. **One sub-level in business rules, unlimited in the data model.** A group may hold subgroups one level down. The two-level cap is a business rule held in configuration; the entity is self-referencing so a later term can lift the cap without a schema change.
  3. **Membership across contracts.** A group draws from every device the organization currently holds, across its contracts. A device sits in at most one group at a time and leaves it when it is returned.
  4. **Holder data**: per assignment, a holder display name and one free-text field. No holder accounts.
  5. **Platform grouping first.** Groups filter the live map, alerts and reports; every device still shares the organization's channel. Per-group mesh channels synced from the platform (through the Field Station over USB serial, or over the mesh) are a later stage, attempted only if time allows, and need firmware work (D-008). Since separate sites are out of radio range of each other, a shared channel is an accepted trade-off until then.
- **Rejected**: keeping D-033 rule 3 and only explaining it (the panel asked directly); full tour management (contradicts the device-rental scope and the title); groups bound to one contract (breaks the second-contract case); holder name plus emergency contact fields (the leader chose one free-text field).
- **Consequences**: new `Group` entity and assignment in the ERD and `schema.prisma`; Org Manager screens; SRS use cases; the live map and alert filters. Per-group channels, if attempted, touch D-021 key provisioning and the firmware.
- **Owner**: KhoaDD.

D-075: Review 2 scope rulings: connectivity disclaimer and operating envelope, Field Station at a fixed base point, a rented-device console for the Org Manager, plan prices and events in the register

- **Status**: ✅ **Resolved by the leader** (2026-10-28).
- **Context**: Review 2 panel note (`capstone/Documents/feedback/Note-review2.txt`): what happens when every link is cut, the three loss cases (out of range, dead battery, unheard SOS), what GPS is for, how the laptop is used, product management for the Org Manager, and a price table with rules and events per rental package.
- **Decision**:
  1. **Disclaimer up front.** The register scope opens with a short disclaimer: TrekLink is a supplementary safety and coordination tool that works within mesh range of a node, a relay or the Field Station; it is not a guaranteed rescue link.
  2. **Operating envelope in the SRS**, one table: (a) out of range: the device keeps beaconing and its on-device queue (D-018) delivers once a node or the Field Station hears it; (b) dead battery: the organization gets a stale-device alert with the last known position and the trail, and nothing after that; (c) unheard SOS: the device repeats until heard and the platform raises a suspected episode from the beacon cadence (REQ-EVT-06); plus the rain, ridge and indoor limits of the 2026-10-02 field test. Each row states what the device does and what it cannot.
  3. **GPS** fixes the position on the device and shares it over LoRa only. There is no satellite uplink.
  4. **Field Station at a fixed base point.** The laptop stays at a base point the organization picks (basecamp, vehicle, ranger station, trailhead) with one rented node on USB serial. It reaches groups through the mesh and relay

checkpoints (D-073 rule 3) and uploads over any internet it finds, site Wi-Fi or a phone hotspot; offline, it queues (D-068).

5. **Rented-device console for the Org Manager**: every device the organization holds across its contracts, with variant, asset tag, status, battery, last seen, group and holder (D-074). From it the Manager assigns devices to groups, reports a fault or a loss, and gives return notice. Devices still enter the fleet only through TrekLink Staff intake and reach an organization only at counter handover (D-033 rules 1 and 5).
6. **Register price table and plan events.** The register gains a compact table marked as configurable sample values, taken from the existing seed and parameter registry, not new figures: monthly price per variant (`seed-demo.ts` : v2 400,000, v3 450,000, v4 480,000 VND), day-plan rate as monthly divided by 30 times `billing.dayPremium` (1.5), day-plan lengths `rentals.dayPlanLengths` (3, 4, 7), `rentals.minOrderQuantity` (5), `billing.holdingFeeRatio` (0.5), `billing.lateFeePerDevicePerDayVnd` (50,000), `billing.damageApprovalThresholdVnd` (500,000), loss at remaining value. It also lists events per plan: monthly (open with holding fee, term close, renewal, notice, final close); day (payment at handover, due date, late, return).

- **Rejected**: the disclaimer in the SRS only (the panel asked for it up front); a laptop carried with the group (the case the panel mocked); a laptop placement left to the organization (weaker answer); an organization-owned product catalog (TrekLink is the only asset owner); rules without prices (the panel asked for prices).
- **Consequences**: adjusted form (scope disclaimer, price table, Field Station wording, BM03); SRS operating envelope, Org Manager use cases and screens; architecture and use case diagrams to be redrawn under D-069; the IoT hardware drawing (power, screen, ports, principle) is a separate figure still to be planned.
- **Owner**: KhoaDD.

D-076: Firmware variant identity and the treklink-firmware documentation layout

- **Status**: ✅ **Resolved by the leader** (2026-10-29).
- **Context**: `treklink-firmware` used "v3" and "v4" for two different things. Its code, `README.md` and variant specs mean the LilyGo T-Beam v1.2 and T-Beam Supreme (`variants/esp32/treklink_v3_tbeam/` , `variants/esp32s3/treklink_v4_supreme/`), while `.kiro/specs/roadmap.md` described v3 and v4 as custom pre-production PCBs and v5 as mass production. Its documentation was spread over `.kiro/specs/` , `.kiro/docs/` , `.kiro/guidelines/` , `.agents/rules/` , `_handoff/` , `docs/` and a 2615-line root `specifications.md` that is a drafting prompt plus a pasted methodology. `docs/commit-rules.md` allowed `dev/<username>-<feature>` branch names that chapter 07 does not, and `.agents/rules/save-your-tokens.md` imposed the compressed reply register that D-043 retired.
- **Decision**:
  1. **v3 is the LilyGo T-Beam v1.2 and v4 is the LilyGo T-Beam Supreme.** `treklink-firmware/docs/variants.md` is the single source for what each variant is. The custom-PCB tier roadmap is deprecated.
  2. **v1 is deprecated.** It still builds (`treklink`) and works as a mesh node; treklink-web does not cater for it, because its image compiles MQTT out (D-005). v1's requirements stay the base set the v2 to v4 specs carry forward.
  3. **Layout** (option A of the 2026-10-29 audit): one spec root, `specs/` (`variants/v1` to `v4` , `variants/shared` , and module folders `onboard-queue` , `sos` , `fall-detection`); `docs/` for the variant matrix, build and flash, coding conventions, hardware records, roadmap, dated hardware test runs, closed work records, and `docs/.deprecated/` with a reason per item. Rules: chapter 09 §1.1.
  4. **Nothing is deleted.** Every moved file goes through `git mv` ; superseded and wrong documents go to `docs/.deprecated/YYYY-MM-DD-<slug>/` .
- **Rejected**: the full `docs-scaffold` layout (`10-context` to `90-meta`), strongest drift detection but the only repository shaped that way; a minimal cleanup that keeps two spec roots; keeping the specs in `.kiro/specs/` for Kiro IDE, which the team no longer uses; renaming the LilyGo envs so v3 and v4 could stay roadmap tiers (touches env names and flash instructions for no gain).
- **Consequences**: `04-firmware-ground-truth.md` §5 marks v1 deprecated; chapter 09 §1.1 brings `treklink-firmware` into scope; the firmware restructure lands as one `docs/*` PR there. Hardware-verified status is now recorded per behaviour in `treklink-firmware/docs/test-runs/` .
- **Owner**: KhoaDD.

D-077: Firmware changes are classed, and safety-path changes merge only with a hardware run; the fork syncs to upstream 2.7.26 after the safety fixes

- **Status**: ✅ **Resolved by the leader** (2026-10-29 to 2026-10-30). **Rule 3 amended by D-086** (2026-10-31): the move to upstream `v2.7.26` comes before the class S fixes; rules 1 and 2 stand.
- **Context**: the 2026-10-29 v2 hardware run (`treklink-firmware/docs/test-runs/2026-10-29-v2-hardware-run.md`) found that any stock beep silences the SOS buzzer, that SOS vibration stops after three pulses, and that fall detection cannot reach its pre-alarm, in code whose variant specs were marked implemented. No step before merge ran the behaviour on a device. `treklink-firmware/docs/coding-conventions.md` (2026-02-04) predated the Meshtastic fork and prescribed FreeRTOS tasks per core, a `hal/ services/ ui/` tree and a `debugEnabled` console, none of which the code uses. The fork is one snapshot commit whose tree matches upstream `develop` at `538a5f0df` (2026-02-03, version 2.7.19); upstream's latest stable release is `v2.7.26` , and 2.8.x is an Alpha on Arduino-ESP32 3.x.
- **Decision**:
  1. **Location, split.** Process, gates, evidence rules for agents and the upstream policy are chapter 17 (`01-conventions/17-firmware-development.md`). Embedded C/C++ practice is `treklink-firmware/docs/coding-conventions.md` , rewritten for the code as it is; the 2026-02-04 version moves to `docs/.deprecated/` .
  2. **Tiered hardware gate.** Class S changes (anything that can change whether an SOS or fall alarm is raised, heard, felt, seen, sent or cancelled, or whether the device stays powered) merge only with a dated test-run file showing the flashed branch head, the fixed finding and the regression set on every affected variant. Class N changes need the build matrix and native tests; a hardware run is optional.
  3. **Upstream.** Fixes land in `treklink-firmware` `dev` first. Stock bugs still present at the latest stable release get an issue on `meshtastic/firmware` once the leader approves. Stock bugs already fixed upstream (the calibration screen exit, compass calibration persistence) are not fixed in the fork. After the class S fixes, one `chore/` branch replays the TrekLink delta onto `v2.7.26` by a 3-way merge from `538a5f0df` , with a full regression run. 2.8.x is not a target while it is Alpha.
- **Rejected**: a hardware run for every behaviour change (the leader holds the units and would gate every PR); advisory runs only (the SOS defects shipped that way); syncing to 2.7.26 before fixing (the SOS fixes would wait behind a 511-commit merge and a regression on v3 and v4, which have no baseline run); never syncing (the gap and the 2.8 toolchain jump only grow); targeting 2.8.1 (Alpha, two revoked builds, LEDC API port); keeping all firmware conventions in one repository (D-076 rule 3 keeps agent and process rules out of `treklink-firmware`).
- **Consequences**: every firmware PR states its class; class S PRs carry a test-run file; the fixing session opens one `fix/*` branch per finding; the upstream sync follows the fixes and records its new base in chapter 17 §6.
- **Owner**: KhoaDD.

D-078: Deadline takeover: until 2026-11-29 the leader's agent may implement a member's task directly

- **Status**: ✅ **Resolved by the leader** (2026-10-30). **Expires 2026-11-29**; after that date the normal ownership rules of chapter 10 apply again with no further edit.
- **Context**: on 2026-10-29 member PRs were waiting on fix rounds (treklink-web #92, #113, #116 still a draft, #117 changes requested) while D-066 and the supervisor meeting on Sunday 2026-11-01 need the full main flow running in a demo. The leader's machine runs an agent with enough capacity to build those tasks itself in the time left.
- **Decision**:
  1. **Window**: 2026-10-30 to 2026-11-29. The goal is the whole application built by 2026-11-29, and the full main flow demonstrable at the supervisor meeting on 2026-11-01.
  2. **Who picks**: the leader names each takeover, or decides it from a list the agent proposes. The agent does not take over a task on its own initiative.
  3. **An open PR**: the agent pushes its commits onto the member's PR branch, sealed with the leader's key and its own `TK_MODEL` (D-054), and the PR merges by rebase once CI is green. The PR stays the member's.
  4. **An untouched task**: the leader owns it. The Jira card moves to KhoaDD and the work goes on the leader's own branch and PR.
  5. Every other rule stands: specs first (§2.1 of AGENTS.md), CI green, rebase merge, no direct pushes.

- **Rejected**: waiting for each member's fix round (misses 2026-11-01 and puts 2026-11-29 at risk); closing a member's open PR and rebuilding it from scratch (throws away their work and their authorship on it); a takeover rule with no end date (it would replace the ownership model of chapter 10 for good).
- **Consequences**: chapter 10 §7.1b carries a note pointing here. Commits on a member's branch show two authors, so the individual-contribution risk (Project Tracking row of 2026-10-21) grows for members whose tasks are taken over; Project Tracking is regenerated from the commit record before each submission and shows who built what.
- **Owner**: KhoaDD.

D-079: An escalated incident alerts every active TrekLink Staff and Admin account, read from `auth`

- **Status**: ✅ **Resolved by the leader** (2026-10-30). Closes the open point of `incidents` tasks 2.2 (`NO_STAFF` in `routing.service.ts`). **Amended by the leader the same day** (treklink-web#120): the alert goes to every active Staff **and** Admin account, as `incidents` design §3 says, including an account whose invitation is not accepted yet; the read is `activeStaffAndAdminIds` .
- **Context**: the escalation tier of an incident (D-034) ends at TrekLink Staff, but `incidents` had no way to read Staff accounts: platform design Figure 3 has no `incidents` to `auth` edge, so the router sends Staff an empty list. The Sunday 2026-11-01 demo must show escalation reaching Staff.
- **Decision**: `auth` exports a read of the ids of active TrekLink Staff and Admin accounts. When an incident reaches `ESCALATED` , `incidents` calls it and writes one alert row per account, delivered like any other tier. The `incidents` to `auth` edge is added to platform design Figure 3.
- **Rejected**: an on-duty Staff list held as a platform parameter (someone must keep it current, and a stale list silently drops the last tier); a broadcast to the fleet room with no per-user alert rows (no delivery record, so a missed escalation cannot be proven or retried).
- **Consequences**: platform design Figure 3, `incidents` design and tasks 2.2 change with the code; the Staff incidents page (frontend 8.2) is built for the demo.
- **Owner**: KhoaDD.

D-080: Devices are docked over Web Serial at the counter, and the asset tag is the Meshtastic owner name

- **Status**: ✅ **Resolved by the leader** (2026-10-30). Writes the provisioning step D-021 left to `specs/devices/` .
- **Context**: D-021 requires a custom channel key on every rented unit, and the rentals design says Staff write it "with the provisioning tool", which was never specified. Intake typed the `nodeNum` by hand.
- **Decision**:
  1. **Docking**: at intake and before handover, Staff connect the unit by USB and a Chromium page of the Staff counter talks to it over Web Serial. Intake reads the unit's `nodeNum` into device registration. Handover checks that the docked unit's `nodeNum` matches the device record, writes the organization's channel key and the owner name, and records provisioning without retyping.
  2. **Asset tag**: the unit's Meshtastic long and short owner names carry the asset tag (`TL-0009`), so the mesh node list and MQTT packets show it. Configuration only, no firmware change.
  3. A Meshtastic client library used for Web Serial passes the third-party vetting workflow before it enters `package.json` .
- **Rejected**: a generated Meshtastic CLI command that Staff run by hand (no check that the right unit was written, and the key would pass through a terminal); a TrekLink serial command in the firmware (a class S firmware change with a hardware run under D-077, slowest path); a custom firmware field for the asset tag (firmware change for data the owner name already carries).
- **Consequences**: `specs/devices/` and `specs/rentals/` gain the docking step and screens; Web Serial is Chromium-only, so the counter states its browser requirement; how the counter obtains the channel key while the platform keeps only its version (D-021) is settled in the devices spec before code.
- **Amendment (2026-11-02, the leader's ruling on the open point of treklink-web#126)**: the counter obtains the channel key by option A of devices design §8.6: the key is derived per organization and key version from a master secret the server holds, and is issued once per docking under a permission check with an audit row. No per-device key is stored. D-021 and

REQ-UBI-03, which keep only the key's version, are reworded in the same change as the devices spec. The short owner name and the end of manual provisioning at handover follow the recommendations of #126 unless the leader rules otherwise: the last four characters of the asset tag, and manual provisioning removed once docking ships.

- **Owner**: KhoaDD.

D-081: A damage charge stores its contract and its inspector, so billing decides it without reading `devices` or `rentals`

- **Status**: ✅ **Resolved by the leader** (2026-10-30). Unblocks `billing` task 2.5 (UC-48, api-design 17), raised by LongLP in treklink-docs#114.
- **Context**: the Admin decision on a damage charge (UC-48) must refuse the Admin who recorded the inspection (403 `SEPARATION_OF_DUTY`, BR-24) and write the approved amount as a `DAMAGE` line on the contract's closing invoice. `DamageCharge` holds only `inspectionId` and `deviceId`. The inspector is `Inspection.inspectorId`, a `devices` model, and the contract is reached only through `ContractDevice`, a `rentals` model, so `billing` cannot read either under module isolation.
- **Decision**:
  1. `DamageCharge` gains `contractId` (relation to `RentalContract`, as `Invoice.contractId` already is) and `inspectorId` (relation to `User`), both required and indexed.
  2. `ChargesService.chargeDamage(contract, inspection, ...)` writes both from the values it already receives. `inspections` is append-only, so the stored inspector never drifts from the inspection.
  3. The migration fills existing rows from `inspections.inspector_id` and `contract_devices.contract_id` before it sets the columns `NOT NULL`.
  4. LongLP builds UC-48 on these columns in his own PR; it is not a D-078 takeover.
- **Rejected**: a `devices` read port for the inspector plus a `rentals` read port for the contract (two new cross-module dependencies for two values `billing` already holds when it creates the charge, and the owner of each port must build it first); a D-078 takeover (LongLP is active on the rest of MF-05, and the remaining work is his module).
- **Consequences**: `backend/prisma/schema.prisma` and one migration; `specs/billing/design.md` (data model and the UC-48 class view), `specs/billing/tasks.md` 2.5 and api-design 17 change with the code. Platform design Figure 3 gains no edge.
- **Owner**: LongLP (implementation), KhoaDD (ruling).

D-082: Docking rulings: the dock is the Staff device station, keys are derived on the server, Meshtastic packages are used as published

- **Status**: ✅ **Resolved by the leader** (2026-10-30). Settles the open points of D-080 listed in treklink-web#126 (`specs/devices/design.md` §8.6) and puts docking in scope for the Sunday 2026-11-01 demo as its own use case.
- **Context**: D-080 left five points open: how the counter obtains the channel key, which Web Serial client code to use, the four-character short name, whether manual provisioning survives, and v2 units that answer nothing over USB. The vetting record recommended re-authoring the client because `@meshtastic/core` and `@meshtastic/transport-web-serial` are GPL-3.0-only.
- **Decision**:
  1. **Scope**: the dock is the Staff device station, not only a key writer. Staff plug a unit in to register it at intake, read and record its state, adjust its configuration (owner names, channel), and provision it at handover. Each of those is a step of the existing device and handover flows, done through the docked unit instead of typed values.
  2. **Channel key, option A**: one master secret `CHANNEL_KEY_MASTER` in the deployment's secret store, never in the database or the seed. The key of an organization and version is HKDF-SHA256(master, salt = organization id, info = `treklink-channel-key/v{version}`), 32 bytes. A Staff-only endpoint returns it once per docking, only after the docked `nodeNum` matched a unit reserved to an `APPROVED` contract, with its own permission, an audit row that never holds the key, and `Cache-Control: no-store`. `REQ-UBI-03` is reworded to "returned once to the counter, never stored, displayed or logged".

3. **Client code**: use the published Meshtastic packages first. If they block an extension TrekLink needs, fork them into our own code at that point. The vetting record moves from pending to adopted with that condition.
4. **Short name**: the last four characters of the asset tag (`0009` for `TL-0009`); the long name carries the full tag.
5. **Manual provisioning** stays at handover as a fallback until after the 2026-11-01 demo, then the docked `nodeNum` becomes required. Intake keeps manual entry.
6. **v2 units** are set aside: the missing `-DARDUINO_USB_CDC_ON_BOOT=1` build flag is a class S firmware change that waits for a hardware run with the leader present (D-077). The demo docks v3 and v4 units.

- **Rejected**: options B (paste from escrow), C (encrypted keys at rest) and D (organization-held key) of design §8.6; re-authoring the client before any need is shown (slower, for a licence risk accepted below); removing manual provisioning before the demo (no fallback if the dock fails live).
- **Consequences**: D-021 is amended: the escrowed secret is the master, and per-organization keys are derived, never stored. `specs/devices/` (requirements, design §8, tasks Phase 7, vetting record), `specs/rentals/` api-design 03 and 09, and screens 4.2 and 5.4 change with the code. The web bundle ships GPL-3.0 code to the browser, so the source of that bundle must be offered to its users; this is recorded as a risk below. A leaked master secret exposes every organization's keys, past and future, so it gets the escrow D-021 asks for.
- **Amendment (2026-11-03, orchestrator, carrying out the D-080 amendment of 2026-11-02)**: rule 5's "after the 2026-11-01 demo" becomes "once every rented variant docks". v2 units cannot dock until the build flag of rule 6 lands, so the "Enter manually" fallback stays at handover until then and its records are audited as manual; the release that brings v2 docking makes the docked `nodeNum` required (treklink-web#126, devices design §8.6 decision 3). The channel-key endpoint is rentals api-design 21, because 19 and 20 were taken in the meantime. Rule 2's "once per docking" is the page's behaviour, not a server limit: HKDF is deterministic, so every call returns the key and every call is audited; the `nodeNum` match is a guard against the wrong unit, and the access limit is the device reserved to an `APPROVED` contract plus the `contract.issueChannelKey` permission. The owner and channel writes go in one edit transaction, because `set_owner` alone reboots the unit (firmware `dev` `a4aa98d` , `AdminModule.cpp:595-630`).
- **Owner**: KhoaDD.

D-083: A sequence diagram carries as many `alt` fragments as its meaning needs (withdrawn)

- **Status**: ❌ **Withdrawn by the leader** (2026-10-30, the same evening). The reworked `incidents` sequences (Figures 5 to 10) grew too big to read, so D-069 decision 3 and chapter 16 §6 rule 2 stand again: the main success path plus at most one `alt` . The record below is kept as the reasoning that was tried and rejected.
- **Context**: D-069 limited a sequence to the main success path plus at most one `alt` , with every other branch moved to the activity diagram. The handbook gate on `incidents` design Figure 10 (UC-35) showed that the code of one use case refuses in three ways the reader must see in the interaction: incident not found (404), not `ESCALATED` or `UNROUTED` (409 `INVALID_STATE_TRANSITION`), and a stale version (409 `STALE_VERSION`). With one `alt` , two of them vanish from the figure the SDD prints.
- **Decision**: a sequence diagram shows the main success path plus as many `alt` fragments as it takes to convey what the use case does, each split into labelled branches and each failure returning to the page. The handbook rule stands: every `alt` is split into its if and else lanes and labelled success or failure (Cẩm nang §2.5). A branch that adds nothing the reader needs still belongs in the activity diagram.
- **Rejected**: keeping one `alt` per sequence (drops the exception flows Cẩm nang §2.5 asks for); every possible exception as an `alt` (unreadable, the activity diagram already carries the full branching).
- **Consequences**: none remain. Chapter 16 §6 rule 2 and the `sequence.puml` skeleton comment are restored; the `incidents` figures were reworked to one `alt` each. Withdrawal reason: a sequence with three or four refusal branches doubles in height and stops being legible in the SDD; the activity diagram and the api-design files carry the other refusals.
- **Owner**: KhoaDD.

D-084: Every long page keeps its header and its actions on screen; only the content scrolls

- **Amended by D-096 for record pages.**
- **Status**: ✅ **Resolved by the leader** (2026-10-30, in-person dry run of MF-01, defect 6). Applies to every page of the web app.

- **Context**: on the counter handover and other long pages the whole page scrolled: the title, breadcrumbs and stepper left the screen, and Back and Next sat below the fold, so Staff lost their place in a multi-step flow and had to scroll to act.
- **Decision**: a page's title, breadcrumbs and stepper sit in a header that stays at the top and compacts once the content scrolls; the page's actions (Back, Next, the primary action) sit in a bar fixed to the bottom of the content area; only the content between them scrolls. It is built once in shared components and holds at 1280 px and 360 px, on both themes. Keyboard focus never lands under the fixed bar.
- **Rejected**: leaving each page to scroll as a whole (the dry run showed it fails a multi-step flow); repeating the actions at the top and bottom of every page (two sets of buttons to keep in step).
- **Consequences**: `specs/frontend/design.md` and `docs/design-system.md` in treklink-web state the rule; the counter handover, return counter, contract request, organization review and maintenance pages move onto it (treklink-web branch `fix/sticky-page-chrome`).
- **Owner**: KhoaDD.

D-085: The basemap labels over Hoàng Sa and Trường Sa are masked under the overlay, and Esri is the default basemap (amends D-031 and D-072)

- **Status**: ✅ **Resolved by the leader** (2026-10-30, dry run defect 11). Implemented by the leader's agent under D-078.
- **Context**: in the leader's dry run of 2026-10-30 the OpenStreetMap standard tiles printed "□□□" (Xisha) and "□□□" (Nansha) beside "Quần đảo Hoàng Sa (Việt Nam)" and "Quần đảo Trường Sa (Việt Nam)", and "□□□" (Sansha City). treklink-web#184 dropped that basemap, but the leader's check at 22:55 found OpenTopoMap, the default, printing the same district names; its tiles also name single reefs in Chinese ("□□□") from zoom 9. A Vietnamese panel reads that as the map naming the islands as PRC districts. Stadia and Esri showed no such label in that check. D-031 drew the overlay over the tiles but never hid what the tiles print under it, and D-072 records that three basemaps "carry its foreign labels beneath the overlay".
- **Decision**:
  1. Each label of the overlay constant `SOVEREIGNTY_OVERLAY` carries a `mask`, a polygon over its archipelago (Paracels 15.2 to 17.7 N, 110.6 to 113.6 E; Spratlys 7.0 to 12.3 N, 111.1 to 117.7 E, bent away from Palawan and Sabah). `GET /api/map/config` returns it with the label.
  2. The client fills each mask opaque in a pane above the tiles and below the markers and the labels, on every basemap and in both themes, so no basemap name for the archipelagos shows at any zoom. The islands' own shapes are hidden with the names; the label says whose they are.
  3. The default basemap is Topographic (Esri), by a forward migration that only changes a default still set to OpenTopoMap. OpenTopoMap and Stadia stay in the switcher. D-072 rule 1 ("OpenTopoMap, the default") is superseded on this point.
  4. The mask, like the labels, is a constant of the build and not a business parameter, so an Admin cannot edit it away (BR-30).
- **Sovereignty**: the polygons were checked over OpenTopoMap tiles at zoom 6 and 7 for both archipelagos on 2026-10-30, the zooms where the district names first appear (none at zoom 5); the PRC label anchors, Woody Island and Fiery Cross Reef, lie inside the masks. Evidence: `capstone/Documents/evidence/map-sovereignty/2026-10-30-*` (masked and unmasked). Not checked: zooms above 10, and the full app on the merged build.
- **Rejected**: dropping OpenTopoMap and Stadia as well (Esri's labels were checked at a few zooms only, so a mask is still needed, and the leader wants the topographic choice); a mask only at the label anchors, sized in pixels (the reef names spread over the whole archipelago from zoom 9); a semi-transparent mask (a tile label reads through it); tiles that need a key or a commercial account in the browser (D-072).
- **Consequences**: treklink-web#193: `sovereignty-overlay.ts`, `LiveMapService`, `LiveMapWidget`, migration `20261030234000_map_default_esri`, `catalog.py`, the configuration matrix, api-design 01, monitoring REQ-UBI-02 and design §5, ui-design 9-1, the demo script MF-04 step 3. R11 keeps its standing: accepted within educational scope, no public deployment.
- **Owner**: KhoaDD; LongNN (monitoring and frontend lane).

D-086: The firmware is a TrekLink overlay on stock Meshtastic, rebased on upstream history; the upstream sync comes before the fixes (amends D-077 rule 3)

- **Status**: ✅ **Resolved by the leader** (2026-10-31). Spec: `treklink-firmware/specs/architecture/`. **Parked by D-087** (2026-10-31, the same night): the overlay branch lost TrekLink behaviour, and `dev` took upstream `v2.7.26` by a merge instead. Rule 5 (sync before the class S fixes) is the part carried out.
- **Context**: the fork was one snapshot of Meshtastic 2.7.19 (`538a5f0df`) with TrekLink code mixed into 18 stock source files, several edits unguarded so stock boards built TrekLink code; two upstream submodules were deleted and about 60 stock files differed only in line endings or mode. Upstream moved 522 commits and 866 files to `v2.7.26.54e0d8d` , about 2500 changed lines in the stock files TrekLink had edited, so no pull could merge, and the variant specs no longer matched the code. The leader ruled that the code base is reorganised before any fix (D-077 had put the sync after the class S fixes).
- **Decision**:
  1. **History**: `treklink-firmware` is rebased on real upstream history. TrekLink is a short linear series of commits on top of the upstream release tag; each sync rebases the series onto the next stable tag. The old snapshot history is kept as tag `archive/pre-overlay` .
  2. **Overlay**: TrekLink code lives in `treklink/` (compiled only by TrekLink envs through `build_src_filter`), variants in `variants/<arch>/treklink_vN/` , tests in `test/treklink_*/` . Every stock path stays byte-identical to the upstream tag, except the TrekLink `AGENTS.md` and `README.md` .
  3. **Overrides**: TrekLink changes stock behaviour only from its side, with the stock code left in place: upstream hooks and defines, configuration defaults, objects created or observed at start-up, a linker wrap of a stock symbol. Each one is catalogued with the upstream line it depends on, and `treklink/tools/check_overlay.py` fails the build on any other stock change and flags every override whose stock code changed in a sync.
  4. **Capabilities**: variant files name the hardware; shared TrekLink code tests capabilities, never `TREKLINK_Vn` . Each variant has `specs/variants/vN/components.md` .
  5. **Order**: the move to `v2.7.26` comes first, then the class S fixes on the new base (reverses the order of D-077 rule 3; the hardware gate of D-077 rule 2 is unchanged).
  6. **Region**: "VN 433" is the label TrekLink uses for the `MY_433` region the variants lock at build time (`REGULATORY_LORA_REGIONCODE`); the fake `VN_433` entry in the stock menus is dropped. `MY_433` is not the Vietnamese allocation: its edges (433.0 to 435.0 MHz) sit outside 433.05 to 434.79 MHz and its 20 dBm default exceeds the 25 mW licence-free limit of Circular 08/2021/TT-BTTTT (firmware ground truth §5.1, the open gap stays as recorded there).
  7. **Tools**: a terminal tool, `treklink/tools/tk.py` , reads, builds and flashes units from a menu with no assistant; diagnostic images can press buttons over USB for unattended bench runs. It is the workshop tool for whoever builds and flashes firmware; the Staff counter path of D-080 and D-082 (Web Serial in the browser) is unchanged by it.
- **Rejected**: keeping the snapshot and replaying TrekLink by a 3-way merge per sync (git never knows upstream, and each sync repeats the conflict work); guarded edits inside stock files (today's state, conflicts on every sync); copying stock files into the overlay to change them (hides upstream fixes); fixing first on 2.7.19 (D-077's order: the fixes would be redone on the new base).
- **Consequences**: chapter 17 §1, §2 and §6 name the overlay paths and the new base, worded for the moment the D-086 branch lands as `dev` (until then `dev` is still the 2.7.19 snapshot); firmware ground truth paths move to `treklink/src/` when the branch lands; v1 is not ported (deprecated by D-076) and builds only on the archive tag; making the new history `dev` and `main` is a one-time force-push the leader does.
- **Owner**: KhoaDD.

D-087: The firmware takes upstream by a merge with TrekLink winning, and a sync lands as a fast-forward (parks D-086)

- **Status**: ✅ **Resolved by the leader** (2026-10-31): the rollback ruling, the go for the merge sync, and "auto merge" for the landing; the landing method was ruled by the orchestrator.
- **Context**: the D-086 overlay branch dropped the TrekLink boot title and broke the v2 LED heartbeat, so both bench v2s were rolled back to `dev` `f062a35` and the overlay was parked. Upstream `v2.7.26` (`54e0d8d`) was then merged into

`f062a35` on `chore/sync-upstream-2-7-26` with TrekLink winning every conflict (`de1ce2b` , 7 conflicts; the merge base came from a temporary graft of the snapshot commit `91134a2` onto `538a5f0` , removed afterwards), plus a build-flag fix (`db34bca`). Every TrekLink line in a stock file and all 164 TrekLink-only files survived; DMs, the SOS text and the physical SOS button were tested on v2, v3 and v4 pairs. The branch carries 11,777 upstream commits behind its merge commit.

- **Decision**:
  1. **D-086 is parked.** Its history, overlay, no-stock-edit and region rules do not apply until the leader revives them. TrekLink behaviour wins over stock: TrekLink may edit, tap or wrap stock files, keeping each edit small, marked and listed, so the next sync stays possible. No existing TrekLink behaviour is dropped in a sync or refactor.
  2. **Sync method.** A stable upstream release is merged into `dev` on a `chore/sync-upstream-<version>` branch, TrekLink winning every conflict, then a parity check (every TrekLink line in a stock file and every TrekLink-only file present on the merged tree), the build matrix, and the hardware regression on every variant with a unit.
  3. **Landing.** The sync PR lands by fast-forwarding `dev` to the tested head. This is the one exception to "no merge commits" (chapter 07 §5.7): the sync's own merge commit stays, because it is the upstream parent the next sync uses as its merge base, and no further merge commit is created. `checksum / verify` and `semgrep-diff` failures confined to upstream commits and upstream files are expected on a sync PR; every TrekLink commit stays sealed.
- **Rejected**: squash (drops the upstream parent, so the next sync needs the graft again); rebase merge (GitHub cannot rebase a merge commit, and a local rebase rewrites 11,777 upstream commits under new ids); a PR merge commit (disabled in the repository settings, and it adds a second merge commit); the D-086 overlay (lost TrekLink behaviour on the bench).
- **Consequences**: first use, treklink-firmware#22: `dev` fast-forwarded from `f062a35` to `db34bca` on 2026-10-31 at 15:47 UTC. `dev` now shares history with upstream from `v2.7.26` on. Chapter 17 §6 and chapter 07 §5.7 state the method. The overlay branches stay on origin, unmerged.
- **Owner**: KhoaDD.

D-088: Local demo operation: the landing page discovers the system at runtime, and an Admin demo control panel stages each flow

- **Status**: ✅ **Resolved by the leader** (2026-11-01): the landing page code must not change again when the system moves between the demo laptop and a hosted environment, and a local demo needs a panel that switches between the flows without manual setup; the mechanism was ruled by the orchestrator.
- **Context**: the operations system is not hosted (D-055 staging is due with the Deployment Package in W12), so demos run on the team laptop. The landing page baked its system URL in at build time (`site.config.ts` , a `.invalid` placeholder until 2026-11-01), so both public builds, GitHub Pages and Vercel, always showed the unavailable toast, and any URL change needed a landing release. Staging a demo flow meant running `seed:demo` , `demo:term-end` and resets by hand in the order of the demo script. Chrome 156 holds a request from a public HTTPS page to `localhost` on a local network access prompt until the visitor allows it (checked 2026-11-01).
- **Decision**:
  1. **Runtime discovery.** The landing page reads `deploy/system-endpoints.json` from `treklink-web` `main` through `raw.githubusercontent.com` (any origin allowed, five-minute cache) when a visitor activates "Open the system". The file lists candidates in priority order, each with the system URL, its health URL and a timeout; the page probes them in order and opens the first that answers, otherwise shows the toast. A hosted environment goes first and the demo laptop (`http://localhost:5173/` , `http://localhost:3000/api/health`) last, with a timeout long enough to answer Chrome's prompt. If the file cannot be read, the page falls back to one built-in candidate, the demo laptop. Moving the system changes that file through a `treklink-web` PR; the landing code does not change.
  2. **Health route open to any origin.** `GET /api/health` is public and answers without credentials, so it sends `Access-Control-Allow-Origin: *` ; every other route keeps the `CORS_ORIGINS` list.
  3. **Demo control panel.** An Admin-only page `/t/admin/demo` with a `demo` backend module stages each main flow from one button: reset the local database to the demo seed, apply the scenario's starting state, and show the first step to click. Scenarios: clean seed, organization registration (MF-01a), rental to handover (MF-01), field data sync (MF-02), SOS incident (MF-03), live map and monitoring (MF-04), term end and return (MF-05), asset management, and loss cases once treklink-web#228 lands. The panel also signs the presenter in as a seeded role in one click.

4. **Guards.** The module registers its routes only when `DEMO_CONTROLS_ENABLED=true`, and every action first refuses a database host that is not a loopback address, so Neon and any hosted database are out of reach whatever the flag says. Each action is audited. The flag defaults to false and is never set in a hosted environment.

- **Rejected**: a build-time URL per host (GitHub Pages and Vercel drift apart, and every move needs a landing release); a discovery file inside the landing repository (a landing code change on every move); probing `localhost` first on every visit (a permission prompt for every visitor); manual demo steps in the script only (the presenter has to remember resets mid-demo); a reset endpoint without the loopback guard (one wrong `DATABASE_URL` wipes the shared Neon database, which D-062 shares with every member).
- **Amendment (2026-11-01, the leader's go for a Vercel deployment for the supervisor demo)**: the frontend is built by Vercel from `dev` as project `treklink-web` at `https://treklink-web.vercel.app` (root `frontend`, `frontend/vercel.json` rewrites every path to `index.html`). The backend, the database and the MQTT broker stay on the demo laptop, because the backend holds MQTT, socket and scheduler connections that Vercel functions do not keep (the D-055 rejection stands); the frontend keeps its default `http://localhost:3000` API and socket base, the laptop's `CORS_ORIGINS` lists the Vercel origin, and `deploy/system-endpoints.json` lists the Vercel frontend before the laptop frontend. This is the course-scoped public deployment D-031 allows: the frontend still renders OpenStreetMap tiles with the sovereignty overlay, and a deployment beyond the course switches the provider back first. Rejected: the NestJS backend as a Vercel service (no broker, socket or scheduler, and only Neon would be reachable, which D-062 shares with every member).
- **Amendment (2026-11-01, the leader's instruction "ready to use accounts on the root page, with the credentials, for testing")**: while demo mode is on, the public root page and the sign-in page list every seeded test account with its email, role and password, and a button that fills the sign-in form. The backend serves the list from its `SEED_*_PASSWORD` settings through a public `GET /api/demo/accounts` that passes the same guards as the panel (flag on, not production, loopback database) and answers `Cache-Control: no-store`; the passwords are never written to a repository, a build or a Vercel variable. Anyone who reaches the demo backend can sign in as any role, Admin included, and stage a reset of the local demo database; that is accepted because the database holds only fictitious seed data, the backend is reachable only while the demo laptop runs it, and the flag is never set on a hosted environment. Rejected: passwords baked into the frontend build (they would outlive the demo in every deployed bundle); a list shown only to signed-in users (the point is to let a tester in).
- **Consequences**: `TrekLink-Team.github.io` changes once for discovery (`specs/landing` REQ-EVT-02 to REQ-EVT-04, Q1); `treklink-web` gains `deploy/system-endpoints.json`, the health CORS rule (`platform`), and the `demo` module spec suite before code (D-066). The panel lands after the 2026-11-01 supervisor demo, which runs on the current demo script.
- **Owner**: KhoaDD.

D-089: A Vercel production for testing: backend and frontend on Vercel, database on a new Neon branch

- **Status**: ⛔ **Superseded by D-091** (2026-11-01, production retired after the demo). Was: ✅ **Resolved by the leader** (2026-11-01): "deploy backend and frontend as full production", "do not connect my computer to production"; option chosen from the orchestrator's three (Vercel with a new Neon branch, AWS per D-055, or both in sequence).
- **Context**: D-055 puts staging and production on AWS, which is not provisioned, and the orchestrator has no AWS access and may not create hosting accounts. The frontend already builds on Vercel (D-088 amendment). Teammates and outside testers need a system that does not run on the leader's laptop. The standing rule that no agent migrates or seeds Neon protects the shared `dev` database of D-062.
- **Decision**:
  1. One Vercel project serves the frontend and the NestJS backend under one origin; `/api` and the live socket path go to the backend.
  2. The database is a **new Neon branch** `vercel-prod` (`br-flat-shadow-aonm9pmy`) with its own empty database `treklink_prod`; the project's default branch is named `production` but holds members' data and is not this branch (corrected 2026-11-01, D-090). The leader lifts the Neon rule for that branch only: the build may run `prisma migrate deploy` and the idempotent `seed:demo` against it. The shared `dev` branch keeps the rule: no agent migrates, seeds or resets it.

3. Secrets (the Neon connection strings, JWT secrets, SMTP, the seed passwords) are entered into Vercel by the leader; the orchestrator prepares the variable list in a git-ignored file and never types a secret into a form.
4. Known gaps on Vercel functions, stated to testers: no MQTT subscriber (MF-02 field data and the gateway do not reach it), no live socket push (screens refresh on reload), timed jobs run only while an instance is warm, and handover notes are written to temporary storage.
5. The demo control panel's reset stays loopback-only and never runs here; the test-account list may be enabled on this deployment by its own read-only flag.

- **Rejected**: the laptop behind a public tunnel (the leader: his computer must not serve production); AWS today (no access); seeding the shared Neon `dev` branch (members' data, D-062).
- **Consequences**: `treklink-web` gains a root `vercel.json` with the two services and a backend entry for Vercel functions; the full-feature host of D-055 stays open for the Deployment Package (W12).
- **Owner**: KhoaDD.

D-090: The Vercel production closes its gaps: jobs driven by requests, a field data simulator, a session that survives a reload, real mail

- **Status**: ✅ **Resolved by the orchestrator under D-078** (2026-11-01), on the leader's instruction to continue the deployment and fix what testers hit; amends D-060 rule 3 and D-089 rule 4.
- **Context**: the production of D-089 runs, but its smoke walk (2026-11-01, session vercel-prod) left four gaps that every tester meets. A page reload signs the user out, because tokens live in memory only (D-060 rule 3). Devices show "No position yet", because no MQTT subscriber runs on Vercel functions, so MF-02 to MF-04 have no field data. Timed jobs (`JobRunnerService`, every `@ScheduledJob`) fire only while an instance happens to be warm, so the stale sweep, the alert backstop and the term-end work of MF-05 run at random. Mail goes to the console, so the MF-01a invitation code reaches nobody.
- **Decision**:
  1. **Jobs driven by requests.** With `JOBS_TICK_ON_REQUEST=true` (default `false`, set only on Vercel), a backend request starts one job tick after its response is sent (Vercel `waitUntil`), at most once per instance per minute. The tick runs each scheduled job whose cron expression had a fire time since its last recorded run, through the existing runner and its advisory lock, so two instances never run one job twice. A daily Vercel Cron call to the same tick, behind `CRON_SECRET`, is a backstop if the plan allows it. The in-process timers stay as they are on every other host.
  2. **Field data simulator.** With `FIELD_SIMULATOR_ENABLED=true` (default `false`, set only on the Vercel production), a scheduled job ingests synthetic position envelopes for the demo seed's simulated devices through the normal `gateway-sync` ingestion path, at the interval of a parameter (D-015). An SOS episode at a second parameter's interval is off by default (0). The envelopes follow `mqtt-ingress-contract.md` and the gateway simulator, and testers are told the data is simulated. The demo control panel's guards (D-088 rule 4) are not relaxed: staging still truncates tables and never runs on a hosted database.
  3. **A session that survives a reload** (amends D-060 rule 3). The refresh token is kept in the tab's `sessionStorage`, cleared on sign-out, on a refused refresh and when the tab closes; the access token stays in memory. On load the client runs one silent refresh. Accepted risk: script injection in the page could read the refresh token; strict rotation with family revocation (D-060 rule 8) bounds a stolen token, and an httpOnly cookie is the follow-up for the D-055 host. Applies on every host, so local and Vercel behave alike.
  4. **Real mail.** The production sends mail through `MAIL_TRANSPORT=smtp` with `SMTP_URL`, a secret the leader enters in Vercel (D-089 rule 3). Until it is set, MF-01a is not testable end to end on the production and testers are told so.
- **Amendment (2026-11-01, treklink-web#261 follow-up)**: the signed handover note did not survive on Vercel: it was written to one function instance's `/tmp`, and the download ran on another, so the contract page showed "The stored note cannot be found". Ruled by the orchestrator: a note store setting `HANDOVER_NOTE_STORE` with `file` (default, unchanged on every local host) and `database`, set only on the Vercel production. `database` keeps the exact signed PDF bytes in a new table (one row per stored note name, one forward migration), so the SHA-256 integrity check reads the same bytes it signed. Rejected: re-rendering on download (the bytes would differ from the signed ones), and a blob store (needs an account and a token only the leader can create). D-089 rule 4's gap list loses the handover note line.

- **Rejected**: an MQTT broker host or a second always-on server (no account may be created by an agent, and D-089 rejected the laptop); a cron-only tick (Vercel Cron on the Hobby plan runs at most once a day; the team's plan is unverified); relaxing the demo panel's loopback guard (staging truncates every table, which would erase testers' work); `localStorage` for the refresh token (shared by every tab and kept after the browser closes).
- **Consequences**: `treklink-web` specs first (`platform` scheduler, `gateway-sync` simulator, `frontend` session and `auth` client notes), then code through PRs owned by the production session; one new forward migration if the job run record needs a table. D-089 rule 4's gap list shrinks to the live socket push (replaced by polling, treklink-web#253) and handover notes in temporary storage.
- **Owner**: KhoaDD.

D-091: The Vercel production is retired; work continues on the local stack

- **Status**: ✅ **Resolved by the leader** (2026-11-01, after the supervisor demo): "officially end the production ... ditch that or retire it. We will continue to work on the local thing." Supersedes D-089 and the production parts of D-090; the D-088 amendment that lists test accounts on public pages lapses with it.
- **Context**: the Vercel production of D-089 ran from 2026-11-01 about 11:30 to the end of the demo. Each gap closed (D-090) exposed the next one (function bundling, per-instance disk, no socket, no broker, no mail), and the leader judged that it did not work well enough to keep.
- **Decision**:
  1. The production deployment `treklink-web.vercel.app` is taken offline by the production session in the most reversible way the Vercel plan allows (pause or disable the project, or remove its production domain), after `DEMO_TEST_ACCOUNTS_ENABLED` is turned off so no public page lists passwords. The project, its settings and its history are kept.
  2. The landing page's discovery file `deploy/system-endpoints.json` on `treklink-web` `main` drops the Vercel candidate, so "Open the system" goes to the local stack again (D-088 rule 1; no landing code change).
  3. The Neon branch `vercel-prod` and its database `treklink_prod` are left as they are; deleting them destroys data and is the leader's own step. No agent migrates, seeds or writes to them from now on; the D-089 lift of the Neon rule for that branch ends.
  4. The Vercel-only code stays, dormant behind flags that default off on every other host: the root `vercel.json` services, `VITE_LIVE_MODE=poll` , `JOBS_TICK_ON_REQUEST` , `FIELD_SIMULATOR_ENABLED` , `HANDOVER_NOTE_STORE=database` . Removing it is churn with no gain; the full-feature host of D-055 remains the plan for the Deployment Package.
  5. The demo runs on the local stack (Docker Postgres, local broker, gateway simulator, the demo control panel of D-088).
- **Rejected**: keeping the production for testers (the leader's ruling); deleting the Vercel project and the Neon branch now (irreversible, and the leader may want the data or the settings later).
- **Amendment (2026-11-02, the leader's clarification)**: "retired" means **parked**, not abandoned. The production is not needed while the local stack is built properly; the paused Vercel project is revived for a test phase, when the leader needs to test live, and the next supervisor review runs on it as the production test. That run is driven by the admin demo control panel (D-093 rule 6), so a person can simulate an SOS or a trail without a device and without an agent. The orchestrator had read the decision as the end of every hosted environment and reported the BM04 commitment "runs on staging" as unmet; with this reading the revived Vercel project is the staging of BM04 §6 and NFR-PERF-01. The gaps of D-089 rule 4 still apply there (no MQTT subscriber, no live socket push, jobs only while an instance is warm), so the field data of a supervisor demo on Vercel comes from the simulator, which ingests inside the backend (D-090 rule 2).
- **Owner**: KhoaDD.

D-092: The supervisor's four flow fixes of 2026-11-01, and refunds as a designed follow-up

- **Status**: ✅ **Resolved by the orchestrator under D-078** (2026-11-01), on the leader's instruction to fix the issues the supervisor raised at the demo ("spin up agents to fix the issues"). Source: the meeting captions in `capstone/Documents/feedback/` , summarized for the team.
- **Context**: at the 2026-11-01 demo the supervisor named four errors in the main flows and asked for them to be fixed before the next review, and raised refunds as a fifth point the council may ask about.
- **Decision**:

1. **Availability at request (MF-01).** The request form shows, per variant, how many units are `AVAILABLE` now, read from a new organization-member endpoint, and refuses a quantity above it at request time (409 `INSUFFICIENT_DEVICES`, MSG11), not only at approval. A request reserves its units at once as a hold that expires after a parameter (D-015, for example `rentals.requestHoldHours`); the holding fee of the first invoice is the deposit, issued at request and recorded by Staff when paid; approval confirms the appointment and keeps the same units; an expired hold releases them. Two organizations racing for the last units are settled by the existing partial unique index (REQ-UBI-02), first come first served, so Staff no longer arbitrate. Amends rentals REQ-EVT-01, REQ-EVT-02 and REQ-ERR-01.
2. **Every contracted unit on the organization's map (MF-04).** The organization's live map and device list show every unit of its open contracts from the handover on, never only the ones that are reporting: live units as today; units heard during this contract but silent past the staleness threshold in a distinct offline colour with their last position and last-seen time; units never heard since the handover listed as "Not heard since handover" and pinned at the handover location with that label (a configured TrekLink counter location), because that is the last place the unit was known to be. No position from before the organization's custody interval is shown (D-040). Amends monitoring and frontend live map requirements.
3. **Return with a damaged or missing unit (MF-05).** A return never requires a replacement unit: Staff check in the units that came back, inspect each (a damaged one is charged per the damage rates through `billing`), and report a missing one lost (the loss case of treklink-web#228, charged per the contract's lost-unit price); the contract closes once every unit is checked in or settled lost and the balance is paid. The close action is visible to Staff whenever the contract can close, and the page says what still blocks it. Replacement stays a separate action for a running contract (rentals REQ-EVT-12). Lands after #228.
4. **Units available again after the end (MF-05).** A checked-in unit's path back to `AVAILABLE` (inspection, then intake) is shown as next actions on the returned units and on the device page; a unit that passes inspection and intake becomes `AVAILABLE` with no other step, and the contract page shows each unit's state after the return.
5. **Refunds.** A partial refund or credit for units that fail through no fault of the organization is specified in `billing` (a credit line against the next term or a refund record, with who may grant it and the evidence required) before it is built; it is not built in this round.

- **Amendment (2026-11-01 evening, build questions of W25 and W27, ruled by the orchestrator)**: (a) rule 1 uses the existing per-variant count `GET /api/devices/availability` (devices api-design 24, `device.availability.org`) instead of a new endpoint, its text no longer "advisory, enforced only at approval"; (b) an unpaid hold that expires cancels the contract (`CANCELLED`, reason `HOLD_EXPIRED`, unpaid first-invoice lines voided, the Manager requests again); (c) Staff may reject a `REQUESTED` contract whose deposit is paid: the unpaid lines are voided, the paid amount is returned in the answer and refunded outside TrekLink until the refund flow of rule 5 exists, and the page says so, because a deposit kept after TrekLink's own rejection would be unfair; (d) rule 4 keeps today's device machine: a `PASSED` inspection moves the unit straight to `AVAILABLE`; intake applies after a damaged or failed inspection and its maintenance, and the next actions shown follow that.
- **Rejected**: keeping reservation only at approval (the supervisor's case: the organization learns the next day that stock ran out); showing only reporting units (an organization cannot tell offline from never switched on); requiring a replacement to finish a return (blocks every return with a broken unit when no spare exists).
- **Consequences**: four spec-first build jobs in `treklink-web` (rentals, monitoring, devices, billing, frontend), each reviewed by another worker before merge; item 3 depends on #228. The demo script's MF-01, MF-04 and MF-05 sections change with them.
- **Owner**: KhoaDD.

D-093: No new stubs; the W10 checkpoint runs on real devices and real SePay sandbox payments

- **Status**: ✅ **Resolved by the leader** (2026-11-02): "from now on we don't stub; next week the actual milestone is real device checkpoint, payment, fix core flows, and stub any incomplete". The three open points were put to the leader as options the same day and he chose each recommendation. Amends D-091 rule 5 for the checkpoint run.
- **Context**: the supervisor demo of 2026-11-01 ran on the local stack with the field data simulator (D-090 rule 2) and the demo control panel (D-088). W10 (2026-11-09 to 15) is "All Main Flows demoable" on the roadmap. On 2026-11-02 the product still carries stand-ins: the field data simulator, the demo control panel and its time shifts, the console mail transport,

and the `API_EVENT` alert sender, which is not built and leaves those alerts `PENDING`. No run of a real node through a Field Station to the backend has been recorded (unverified).

- **Decision**:
  1. **No new stubs.** From 2026-11-02, a change in `treklink-web`, `treklink-firmware` or the gateway does not add a stand-in, a no-op provider or a simulated result to a product path. A part that cannot be finished is built as far as it goes and its remaining step is reported.
  2. **The W10 checkpoint** walks MF-01 to MF-05 with: real nodes on the TrekLink firmware, reaching the backend through a Field Station and the broker, with `FIELD_SIMULATOR_ENABLED` off; online payment through the SePay sandbox with its real webhook reaching the local stack through a tunnel, plus counter payment; real SMTP mail (`MAIL_TRANSPORT=smtp`); and the core flow fixes of D-092 in place.
  3. **Payment stays in the SePay sandbox** (REQ-UBI-04, BR-34, D-033 item 9). A sandbox payment is a real provider integration with test money, not a stub. The tunnel URL is registered in the SePay sandbox by the leader; no agent types a secret into a form.
  4. **Incomplete at the checkpoint**: a part still incomplete may run as a stand-in only behind an environment flag that defaults off, labelled "Simulated" wherever it shows, and listed here by name before the checkpoint. A stand-in that is not listed fails the checkpoint.
  5. **The existing demo aids stay** as development tools, off by default: the field data simulator, the demo control panel (D-088) and the console mail transport. They are off for the checkpoint run.
- **Rejected**: showing an incomplete step as "Not available yet" with no stand-in (a flow with one missing step cannot be walked end to end); payment with real money (reverses D-033 item 9 and BR-34 and needs a business account); counter payment only (leaves the online paths of MF-01 and MF-05 untested); deleting the demo aids before W10 (loses the local test and rehearsal tooling).
- **Consequences**: the firmware hardware gate of `treklink-firmware#23`, `#24` and `#25` comes before the real device run; a stand-in list is drawn up before 2026-11-09 and kept under this entry; the demo script and the W10 roadmap row follow this entry.
- **Amendment (2026-11-02, the leader's answers the same day)**:
  1. Rule 2 is narrowed to D-005 Stage A: real nodes publish over their own Wi-Fi to the broker. The Field Station's hardware serial reader is still a stub (`gateway/src/serial/serial-reader.ts`, gateway task 5.1); building it is a stretch goal for W10, and until it lands the Field Station runs in simulation mode as the one stand-in listed under this entry (flag `GATEWAY_SERIAL_SIMULATION`, labelled "Simulated" on the station's local page and its sync status).
  2. The units for the checkpoint are the four hardware variants v1 to v4.
  3. Required this week (W9, 2026-11-02 to 08), the supervisor demo by Friday 2026-11-06: a firmware flash tool; the device serial connector and configurator (D-080, treklink-web#126); the firmware settings the web relies on (the asset tag as the owner name, the Stage A MQTT settings, `ARDUINO_USB_CDC_ON_BOOT` on v2 so the dock and the flash tool reach it, the queue health payload and the v2 charge status); the admin demo control panel of simulated nodes and trails; and an incidents simulator.
  4. Rule 5 is extended: the admin demo control panel and the incidents simulator are demo tools, not product stand-ins. They exist so that a person, the leader included, can run every demo case from the browser without an agent and without the demo script: raise an SOS or a fall on a simulated node, move simulated nodes along trail paths with patterns, and walk the flows that follow. They stay behind their flags, label everything they create "Simulated", are off for the W10 real-device run, and are on for a supervisor demo, locally or on the revived Vercel project (D-091 amendment).
- **Owner**: KhoaDD.

D-094: The Vercel project is revived as an always-on staging, built from a `staging` branch that follows `dev`

- **Status**: ✅ **Resolved by the leader** (2026-11-02): "revive the vercel now and it always on, but not the latest ... I'll test both on local and prod at the same time, to see if prod breaks when dev ... Staging is required, so prod test while dev is acceptable, this even means I can test it while on the go with the phone. Do keep the ready to use credentials intact even

when demo." Amends D-091 (parked) and its amendment; renews the Neon lift of D-089 rule 2 for the branch `vercel-prod` only.

- **Context**: BM04 §6 commits every workflow to run on staging with seeded data, and NFR-PERF-01 is a load test on staging (D-091 amendment). The project was paused on 2026-11-01 with its Git link removed and automatic builds off. `main` of `treklink-web` carries only the landing page's endpoint file and is 778 commits behind `dev`, so it cannot be the deployed branch.
- **Decision**:
  1. The Vercel project `treklink-web` is unpaused and stays on: `https://treklink-web.vercel.app` is the staging of BM04 and the production test the leader uses from a laptop or a phone, side by side with the local stack.
  2. **Pinned, not the latest.** The production branch stays `dev`, but automatic builds stay off (Ignored Build Step). The orchestrator deploys a chosen `dev` commit on the leader's request or after a milestone, and records each promotion (commit, time, health result) in its session log. The local stack runs the newest `dev`; a difference between the two is how the leader sees whether new work breaks what was released.
  3. The quick-action test accounts box stays on (`DEMO_TEST_ACCOUNTS_ENABLED=true`), during demos included; its passwords are the seed's and the database is `treklink_prod` on the branch `vercel-prod` only.
  4. The request-driven jobs (`JOBS_TICK_ON_REQUEST=true`) and the field data simulator (`FIELD_SIMULATOR_ENABLED=true`) are on as before the pause, because Vercel has no broker subscriber and no timers (D-089 rule 4, D-090). The admin demo control panel of D-093 is the way a person drives the scenarios there.
  5. The build may run `prisma migrate deploy` and the idempotent `seed:demo` against `vercel-prod` only. The shared Neon branches `production` and `dev` keep the rule: no agent migrates, seeds or resets them.
  6. The landing page's endpoint file lists the Vercel frontend first again (D-088 rule 1), through a pull request to `main`.
- **How the pin works (2026-11-02, after the revival)**: Vercel's "Git deployments disabled" setting did not stop builds once the Git link was restored: the merge of treklink-web#296 built production automatically (`dev` 53c6b87, now the first pinned build). The project's Ignored Build Step is therefore `test "$VERCEL_ENV" != "production" || test "$VERCEL_GIT_COMMIT_SHA" != "$STAGING_PIN_SHA"`: preview builds are always skipped, and a production build runs only for the commit in the production variable `STAGING_PIN_SHA`. To promote, the orchestrator sets `STAGING_PIN_SHA` to the chosen `dev` commit and a build of that commit is started (the next push of exactly that commit, or a redeploy from the dashboard, which asks the leader for an email code). Preview builds never touch a database in any case: `backend/scripts/vercel-build.sh` migrates and seeds only when `VERCEL_ENV` is production and the database is `treklink_prod`.
- **Rejected**: deploying every `dev` merge (a break on `dev` would break the system the leader tests on the go, and the comparison with the local stack would be lost); a separate long-lived `staging` branch (not in the branch model of chapter 07); `main` as the production branch (778 commits behind).
- **Amendment (leader, 2026-11-04 10:50)**: "everyday is deploy to vercel latest team mades." Rule 2 changes from "on the leader's request or after a milestone" to **every day**: the orchestrator promotes the newest reviewed `dev` head to the staging daily (`STAGING_PIN_SHA` to that commit, then a production build of it) and names the live SHA in the morning report. The pin stays, so a break on an unreviewed commit still never reaches the staging. A production build started through the Vercel API needs the leader's email code, so on the same day he approved a deploy hook on `dev` (`staging-daily-promotion`), which builds without it; its URL is kept outside the repositories. Hobby plan builds are capped per day (the cap was hit on 2026-11-04 at about 05:00), so previews stay skipped.
- **Owner**: KhoaDD.
- **Amendment 2 (leader, 2026-11-05 11:30): a `staging` branch, always the latest reviewed `dev`, no previews.** "have a staging branch. it will use dev. staging is different than main. main is final & prod. staging is prod, but for dev ... i dont need previews. i want the updated latest on treklink-web.vercel.app." This reverses the rejection of a separate staging branch above, for a reason found on 2026-11-04 and 11-05: every push to a PR branch created a Vercel deployment that the Ignored Build Step then cancelled, and those records filled the Hobby plan's daily deployment limit ("more than 100", `api-deployments-free-per-day`), so the daily promotion failed twice (11-04 23:48, 11-05 11:20) and the staging fell behind `dev`.
  1. **`staging` branch** in `treklink-web`, created from `dev`. It is the production branch of the Vercel project; `https://treklink-web.vercel.app` builds every commit that lands on `staging`. `main` stays the final release and is not deployed by this project.

2. **Promotion moves the `staging` ref to a reviewed `dev` commit** (a fast forward through the GitHub API). Corrected 2026-11-05 13:25: the first promotion went through a pull request (treklink-web#394), and GitHub's rebase-merge rewrote the commits even though it was a fast forward (`staging` 3737679 for `dev` 40de81b, same tree), so `staging` would drift from `dev` by hash. The orchestrator moves the ref after each reviewed `dev` merge it wants live, at least daily at about 07:30, and names the live SHA in the morning report; a forced move is allowed only when `staging` holds the same tree as the last promoted `dev` commit. Nobody commits to `staging` directly; a fix goes to `dev` first.
3. **No other branch deploys.** `vercel.json` sets `git.deploymentEnabled` to `{"*": false, "staging": true}`, so pushes to `dev` and PR branches create no Vercel deployment at all and no preview. `STAGING_PIN_SHA` and the deploy hook retire once `staging` builds; the Ignored Build Step becomes unnecessary (kept until the first `staging` build is READY).
4. Rules 3 to 6 above are unchanged (test accounts box, request-driven jobs and simulator, `vercel-prod` database only, the landing endpoint file).
5. Chapter 07 §2 lists `staging` in the branch table, and AGENTS.md §3 in its branch row.

D-095: One owner for the RBAC framework

- **Status**: ✅ **Resolved by the leader** (2026-11-02): "Both to TanNB ... they all rely on a sole core RBAC framework all permission systems follow, regardless of hierarchy. Letting one person take charge will not drift the specs."
- **Context**: the leader found the roles and permissions screen below expectations and asked for a checkbox grid per role, for the TrekLink roles and for the organization roles. The roles page (frontend 7.2) was built by LongNN; the per-organization permissions belong to the organizations domain (TanNB). Splitting them by screen would give two people the same permission model to specify.
- **Decision**:
  1. TanNB owns the RBAC framework in `treklink-web`: the permission catalog (`scripts/specs/catalog.py`), roles and role permissions as data, the CASL ability factory's use of them, the Admin permission grid (frontend 7.2, moved from LongNN) and the per-organization permission grid. Every other permission surface follows this model.
  2. The Admin grid is built in W9; the per-organization grid is specified in W9 and built in W10 (treklink-web#304). Its change to D-057 is proposed in the spec and ruled by the leader before any code.
- **Rejected**: the Admin grid to LongNN, the screen's builder, and the per-organization grid to TanNB (the orchestrator's proposal): two owners of one permission model.
- **Owner**: KhoaDD.
- **Amendment** (2026-11-02, the orchestrator under D-078, on the per-organization grid spec treklink-web#310; amends D-057, closes the 2026-10-24 permission cache risk at the W10 build):
  1. **Ceiling and storage as proposed.** One global ceiling, the permissions `ORG_MANAGER` holds; an organization stores grants and revokes per role as a difference from the baseline, with a `version` and `expectedVersion` on the save (409 `STALE_VERSION`). Grants for `ORG_OPERATOR` only.
  2. **An Operator revoke never reaches the Manager** (OQ-01 of the spec). Inheritance (auth REQ-UBI-05) takes the inherited role's TrekLink baseline, not the organization's changes to it, so a Manager who unticks a permission for the Operator column keeps it in their own.
  3. **Protected permissions.** `organizationRole.manage.own` stays with every organization's Managers and is never grantable to the Operator (OQ-06). The highest role of each account type cannot lose its protected permission; screen 7.2 and the global save gain the same `MANAGER_LOCKOUT` check as a separate W10 task.
  4. **Out of this round:** organization API keys keep their own keys (OQ-02); no per-organization ceiling (OQ-03); no SRS or Report 3 edit now, the missing functional requirement (FR-AUTH-12) is listed for a resubmission (OQ-04, chapter 15 rule for graded reports); catalog keys and their migration land with the build (OQ-05). "Reset to TrekLink default" per role column is in.
  5. **Cache:** the W10 build adds a cache time-to-live as a parameter (`auth.permissionCacheTtlSeconds`, default 30) for TrekLink and organization entries alike, because the Vercel staging (D-094) can run several instances. The next-request guarantee holds within one process; across instances a change applies within the time-to-live.

D-096: Every list of records renders through one shared `CollectionView` module, and pages follow one layout rule set (amends D-084 for record pages)

- **Status**: ✅ **Resolved by the leader** (2026-11-03), standing instructions given while the contract-home prototype was designed on the TrekLink Web UI design system (canvas "Contract Home"); routing of each instruction ruled by the leader the same day.
- **Context**: list screens were being designed per page (fleet, maintenance, loss cases, accounts, sign-in events, audit log, telemetry history, reports; 10 of the 35 screen files under `treklink-web/specs/frontend/ui-design/` contain a table). Chapter 06 §4 Pattern A gave one sketch and §8.11 asked for reuse, but nothing fixed selection, bulk actions, views, tooltips or the keyboard model. A WCAG 2.2 review of chapter 06 on 2026-11-03 found gaps in status messages (4.1.3), target size (2.5.8), focus not obscured (2.4.11) and hover-only content (1.4.13) that each list would otherwise solve on its own. The prototype also showed that page chrome took most of the first screen.
- **Decision**:
  1. One module, `CollectionView` in `frontend/src/shared/ui/collection-view/`, renders every list of records (chapter 06 §9). It is a library component: pages supply data, fields and actions; it knows no module or endpoint.
  2. Six views behind one split View button; one compact command bar; selection by checkbox, Shift range and select-all; icon item actions with tooltips on hover and focus; state transitions through a Change status dropdown; one shared details pane.
  3. **Select-all selects the items on the current page only**, never the server's matches across pages (leader). **A search, filter or sort change clears the selection** (leader).
  4. Page layout rules for every working page, not only lists (chapter 06 §10): vertical space first, a dropdown instead of a second row, a chevron on every menu button, compact record pages, the 360 px phone layout, sideways scroll hints, target sizes, details pane placement.
  5. WCAG 2.2 AA is the target (chapter 06 §5 retitled from 2.1). 2.5.8 (AA) requires 24 by 24 CSS px for every target; the team's stricter rule, taken from 2.5.5 (AAA), sets 44 by 44 for primary controls (the page's main action, a dialog's confirm button and the SOS acknowledge). A new SOS alert is also rendered inside an open modal dialog, so a screen reader announces it; the banner's action is reachable once the dialog closes (leader). The handover signature pad stays drawing only, recorded as a known exception to 2.5.1 and 2.5.7 (leader).
  6. **Amends D-084 for record pages only** (orchestrator for the leader, 2026-11-03). A record page shows one entity with tabs and no step flow (contracts first); it keeps the record's actions in the sticky top row with its tabs (chapter 06 §10.4). Pages with a step flow (counter handover, return counter, contract request, organization review, maintenance) keep D-084's action bar fixed to the bottom. Both set scroll padding to their sticky bars' heights so focus is never obscured (2.4.11).
- **Rejected**: (a) each page builds its own table and cards, which repeats the same accessibility work per page and lets selection and bulk behaviour drift; (b) item actions revealed on hover or only in an overflow menu, which leaves them unreachable on touch and invisible to keyboard users until focus reaches them; (c) native `title` tooltips on icon buttons, which do not appear on keyboard focus or touch and cannot be dismissed; (d) select-all across every server match, which would need a filter-taking bulk endpoint per list.
- **Consequences**: chapter 06 gains §9 and §10 and edits §4, §5, §6.3, §7 and §8 in place. D-084 carries a pointer to this amendment; its step-flow pages keep the bottom action bar, and record pages follow chapter 06 §10.1 rule 3 and §10.4. `Menu` and `StateChangeMenu` in `shared/ui` draw the chevron themselves. The list screens under `specs/frontend/ui-design/` are re-checked against §9 when next edited, and the contract home (W9, before 2026-11-06) is the first page built on the module.
- **Owner**: KhoaDD.

D-097: A contract can be ended early, and the current term is billed pro rata to the end day

- **Status**: ✅ **Resolved by the leader** (2026-11-05, about 23:25): "pro-rata to today". Raised after the leader found that no contract can be ended before its term end, the point the review teachers criticised.
- **Context**: by the rentals specs a running monthly `ACTIVE` contract accepts no check-in (REQ-STA-01), an early return during `ACTIVE` or `ENDING` waits for the end-of-plan job (REQ-EVT-10), and a close needs `RETURNED` (REQ-ERR-05), so a contract runs to its term end whatever happens. D-092 rule 3 covered returns with damaged or missing units, not ending

early. On staging this also blocks WF-05 (treklink-web#400): RC-2026-0002 cannot reach its return before 2026-12-01, and the demo time shift of B-06 is refused there by design.

- **Decision**:
  1. **End now.** An `ACTIVE` or `ENDING` contract can be ended now with a reason, by TrekLink Staff, or requested by the organization's Manager. It moves to `RETURN_DUE` at once with `endsAt` and `returnDueAt` set to the end time; the existing return path finishes it (check-in, inspection, loss case, payment, close), and the grace and late rules of the return apply from that time.
  2. **Pro rata.** The current term's fee is billed pro rata to the end day: the unused whole days of the term are credited at the term's daily rate as one negative line on the contract's closing invoice (billing REQ-UBI-02), with its author and the end reason. Day plans are already billed per day and get no credit.
  3. **Money owed to the organization.** When the credit leaves the organization paid in advance, the difference counts as owed to it and is refunded outside TrekLink until the refund flow of D-092 rule 5 exists; the page says so.
  4. Spec first: rentals and billing requirements, design and api-design, then the frontend screens (contract home and the counter), with tests that fail without the change.
- **Rejected**: billing the full current term (the leader chose pro rata); keeping the term-end-only path and using the demo time shift on staging (it is not a product function and is refused on the shared database); ending a contract without the return path (units would leave custody unchecked).
- **Consequences**: treklink-web rentals, billing and frontend change spec first; treklink-web#400 is answered by this feature instead of a staging time shift; the demo script's WF-05 can end RC-2026-0002 on staging through the product.
- **[Amended 2026-11-06, leader]** A closing invoice whose total is below zero (the pro-rata credit exceeds what is owed) reads **Credit due to organization** with the amount TrekLink owes, never Paid. Staff closes it once the refund is made outside TrekLink (rule 3). Keeping the refund outside the system is the easier position to defend until the D-092 rule 5 refund flow exists. Found in the review of treklink-web#401.
- **Owner**: KhoaDD.

D-098: The field flow runs on an AWS host as the staging; the two-laptop local stack covers the panel until it is live

- **Status**: ✅ **Resolved by the orchestrator** (2026-11-06, about 00:05), on the leader's delegation of that night (he asked the orchestrator to decide; raised by him about 23:40 on 2026-11-05). Settled before the registration form locks at 18:00 on Monday 2026-11-09; the leader may overrule it.
- **Context**: main flow 2 runs device, LoRa mesh, base node on USB, Field Station, MQTT broker, backend subscriber (`gateway-sync`), database, web page. Vercel cannot host the broker or hold the subscriber's connection: it runs static files and short-lived functions, with no long-running process and no TCP listener (D-055, rejected list; D-094 rule 4). On the Vercel staging the field data simulator stands in, so a panel watching `treklink-web.vercel.app` sees no real device. Today the flow runs live only on the local stack (D-093). D-055 rule 4 puts staging and production on AWS, which is not provisioned (D-089, context). The Review 2 registration form commits to "MQTT (Mosquitto): QoS-based delivery between Field Station and backend" and to Docker Compose deployment, and names no hosting provider. The Field Station speaks MQTT only (`treklink-web` `gateway/src/mqtt/`), and the backend has no HTTP ingest endpoint (`POST /api/gateway-sync` serves read operations only).
- **Options**:
  - **A. Provision AWS now.** One always-on server runs Mosquitto with go-auth and a backend instance as the subscriber, writing to Neon. The Field Station uploads over the internet (site Wi-Fi or a phone hotspot) and the events show on the Vercel site, which polls the same database. No spec or form change; needs the leader's AWS account and a rehearsal. Report 4 Figure 3 is candidate C7: AWS is the staging and production, Vercel a test environment with simulated field data.
  - **B. Interim HTTPS uplink.** A backend ingest endpoint and an HTTPS transport in the Field Station, used where no broker is hosted; MQTT stays the design on AWS. Spec first in `gateway-sync` (requirements, design, api-design) and the Field Station, a registration form note before the lock, and Report 4 Figure 3 candidate C8.
  - **C. Neither.** The panel demo runs on two laptops over a phone hotspot, the Field Station on one and the local stack on the other. No change, and the weakest answer to "why is this not on the web".

- **Decision**:
  1. **Option A.** AWS is the staging and production for the field flow, as D-055 rule 4 and the registration form (MQTT between Field Station and backend, Docker Compose) already say: one always-on host runs Mosquitto with go-auth and a backend instance as the `gateway-sync` subscriber, writing to Neon; the Vercel site reads the same database. The leader provisions the host in his own account (the orchestrator has no AWS access and creates no hosting account); the orchestrator prepares the Compose deployment, the broker credentials layout, the subscriber's environment and a runbook, and rehearses it. Target: live before the W10 real-device checkpoint (D-093, 2026-11-15), earlier if the leader provisions it this weekend.
  2. **Until then, option C covers the panel.** The field flow is shown on the local stack over a phone hotspot (Field Station on one laptop, Compose stack on the other), said so out loud; the Vercel site shows the web flows with the field data simulator, labelled "Simulated".
  3. **Option B is rejected** (below).
  4. Once the AWS host is live, Vercel becomes the test environment with simulated field data, amending D-094 rule 1; until then it stays the staging for the web flows.
  5. Report 4 Figure 3 is candidate C7.
- **Rejected**: B, an interim HTTPS uplink (it adds a transport the registration form does not name, days before the lock, and is a stand-in of the kind D-093 stops adding; MQTT stays the only uplink); C alone (no answer to "why is this not on the web" for the council); hosting the broker on Vercel (impossible: no long-running process or TCP listener).
- **Consequences**: D-094 rule 1 is amended when the AWS host is live; Report 4 Figure 3 is C7 (C8 is dropped); the demo script says how the field flow is shown until then; an orchestrator task prepares the AWS deployment files and runbook.
- **[Amended 2026-11-06, leader]** The leader prefers a fallback to relying on MQTT alone: option B (an HTTPS ingest endpoint plus an HTTPS transport in the Field Station, used only where no broker is hosted) is wanted after all, and its rejection above is withdrawn **subject to the supervisor's acceptance**. It is asked at the weekend supervisor review as an addendum to the registration form; if accepted, the register and SRS get the note before the lock (Monday 2026-11-09 18:00) and the build follows, spec first in `gateway-sync`; if not, rule 3 stands. The AWS preparation of rule 1 starts after that review.
- **[Amended 2026-11-06 18:50, leader] The HTTPS fallback is dropped; the amendment above is withdrawn and option B stays rejected.** An HTTPS ingest at the Field Station covers only one of the uplink paths: nodes also publish through the Meshtastic phone app's MQTT client proxy (`proxy_to_client_enabled`, phones are the backup uplink), and with a Vercel-only backend that path would need a forked, signed Android app and an iOS app. A new transport would also change every graded document, each vetted by a member before reupload, days before the register lock (Monday 2026-11-09 18:00), for a supervisor addendum the leader rated 50/50, while every account is short of tokens. Option A, the AWS host running the MQTT broker, is the industry-standard answer and covers every path as registered; its preparation starts now instead of after the supervisor review. The supervisor is not asked about HTTPS. The draft spec (treklink-web#424) and the figure update (capstone#18) were closed unmerged.
- **Owner**: KhoaDD.

D-099: Releasing a unit from a running contract (gap G4)

- **Status**: ✅ **Resolved by the leader** (2026-11-06, about 09:40). The direction "allowed with a reason, audited, quantity recomputed" was set on 2026-11-03; the five open points were ruled today.
- **Context**: a contract's quantity never changes while it runs (rentals REQ-UBI-03, BR-05), a running monthly contract takes no check-in (REQ-STA-01), issued invoice lines never change (billing REQ-UBI-02), and a service credit exists only for a unit that failed through no fault (billing REQ-EVT-12). An organization that no longer needs one unit had no way to give it back before the term end. D-097 now ends a whole contract early with a pro-rata credit.
- **Decision**:
  1. **Money.** The released unit's unused whole days of the current term are credited at its daily rate as one negative line on the contract's next invoice, the same computation as D-097; the quantity drops from the release.
  2. **Minimum order quantity** binds only at the request: a release may take the contract below `rentals.minOrderQuantity`.
  3. **Last unit.** Releasing the last unit is refused; the dialog points to End contract now (D-097).

4. **Before handover** (REQUESTED or APPROVED), a release lowers the quantity and the unpaid deposit or first invoice is reissued for the new quantity.
5. **Who.** TrekLink Staff releases with a reason, TrekLink Admin approves the credit as for service credits; organization roles cannot release. Reports count the release time (treklink-docs#166).

- **Rejected**: a service credit for the current term (two credit paths for one event; D-097 already defines the pro-rata line); refusing a release below the minimum; ending the contract on the last release (End now exists); counter swap only before handover; Staff alone without approval.
- **Consequences**: amends rentals BR-05 and REQ-UBI-03 (spec first in `rentals` and `billing`); an SRS note for the next resubmission; build after the Friday finish unless the leader moves it.
- **Owner**: KhoaDD.

D-100: A unit provisioned before its organization's key was flagged exposed may still be handed over, with a warning

- **Status**: ✅ **Resolved by the leader** (2026-11-06, about 09:40); TASKBOARD item 1b from the review of treklink-web#358.
- **Context**: since treklink-web#358 the platform refuses to issue or write a channel key flagged exposed (devices REQ-ERR-20). A unit provisioned at that key version before the flag is set can still reach the handover step.
- **Decision**: the handover goes through. The handover screen warns that the unit carries a key flagged exposed and offers a direct action to the re-provision step for that unit, so Staff can clear it on the spot after the rotation.
- **Rejected**: refusing the handover with 409 CHANNEL_KEY_EXPOSED (blocks the counter for a key the organization can rotate in minutes).
- **Consequences**: rentals handover (api-design 10) returns the exposure on the unit; the counter shows the warning and the re-provision action.
- **Owner**: KhoaDD.

D-101: Money inputs group as you type and offer quick entry, with an optional on-screen numpad for payment amounts

- **Status**: ✅ **Resolved by the leader** (2026-11-06, about 09:40), after he found the price fields take plain numbers.
- **Context**: price, rate and amount fields accept a bare number with no grouping, which is slow to type and easy to misread by a factor of ten.
- **Decision**:
  1. Amounts show and type in the Vietnamese format, `1.000.000 ₫` (vi-VN: dot thousands, ₫ suffix), grouped as you type, tolerant of pasted text.
  2. Quick entry: a "000" button; shorthand `150k` for 150.000 ₫ and `1.5tr` for 1.500.000 ₫; preset chips with the field's common amounts.
  3. Payment amount fields offer a **secure keyboard** toggle, off by default: an on-screen numpad drawn by the page, so the amount is not typed through the device keyboard (keylogging). It is built for tablets and phones first and works on laptops: large keys, a clear structure that is easy to move through by keyboard and screen reader, T9-style letter hints on the keys, WCAG 2.2 AA (chapter 06 §11.10).
- **Rejected**: English-style commas (`1,000,000 VND`); step buttons.
- **Consequences**: one shared money input in `shared/ui` used by every price, rate and amount field; chapter 06 §11.10 carries the UI rule.
- **Owner**: KhoaDD.

D-103: The Review 2 v5.0 submission and register v4.0 are the source of truth; the specs are frozen

- **Status**: ✅ **Resolved by the leader** (2026-11-09, 16:10).
- **Context**: the leader submitted the Review 2 resubmission v5.0 (Reports 1 to 5 v1.3, forms BM01 to BM04 v5.0, Project Tracking v5.0) and the Commitment v5.0 on F-Caps; register v4.0 was submitted earlier and F-Caps shows it as version 3.

- **Decision**:
  1. The Review 2 v5.0 submission, the Commitment v5.0 included, is submitted and locked. Register v4.0 is submitted and locked (chapter 15 section 6).
  2. Together they are the single source of truth for scope, requirements, design and the committed tests: `capstone/Documents/submissions/review2/review2-v5.0/MANIFEST.md` and `capstone/Documents/submissions/register/register-v4.0/`.
  3. The module specs (`treklink-web/specs/`) and the requirements they carry no longer change. Code and tests follow the submission; a gap between the code and the submission is closed in the code.
- **Rejected**: keeping the specs editable and re-syncing the reports after each change.
- **Consequences**: no spec PR is opened or merged from 2026-11-09; a reviewer refuses a PR that edits `specs/`. The v5.0 package is recorded in `09-fcaps-review-record.md`.
- **Owner**: KhoaDD.

D-104: The AWS staging runs the whole system, and the demo accounts sign in from /demo

- **Status**: ✅ **Resolved by the leader** (2026-11-13): "AWS is back", "set up now, you do it", then "include the quick login panels for accounts ... don't place it on the / endpoint, have a dedicated endpoint ... /test or /demo". Amends D-089 rule 5 and, under D-103, the sign-in box of screens 2.1 and 7.5.
- **Context**: the team account 539883645281 was suspended on 2026-11-11 (fraud prevention). A new account, 566332862593 (ap-southeast-2), came up on 2026-11-13. The leader treats the AWS staging as equal to production: the sign-in page must stay clean, while the panel demo still needs one-click access to every seeded role.
- **Decision**:
  1. The AWS host of D-098, deployed by `deploy/aws/up.sh` (treklink-web#459), is the staging that runs the whole system: web app, API, broker and ingestion. It writes to the Neon `treklink_prod` database as `treklink_field`, the database the Vercel staging also uses. The SePay test webhook and `FIELD_STATION_BROKER_URL` point at it.
  2. The sandbox test accounts leave `/sign-in` and `/`. A dedicated page `/demo` lists them and signs in as the chosen account with one click (treklink-web#482). It reads the same `GET /api/demo/accounts`, so it exists only where `DEMO_TEST_ACCOUNTS_ENABLED` is true.
  3. On the AWS host `DEMO_TEST_ACCOUNTS_ENABLED` is read from its `.env` (off by default) and set true for the staging. The other demo switches stay fixed off by `compose.yml`.
- **Rejected**: keeping the box on `/sign-in` (the leader wants a clean sign-in on a production-like staging); `/test` as the path (`/demo` matches the existing demo module and its API prefix).
- **Consequences**: screens 2.1 and 7.5 read as amended by this entry; no spec file changes (D-103). The suspended account and its open cases no longer block the system. Only the leader holds the TrekLink devices, so every real-device step on the AWS staging runs with him.
- **Owner**: KhoaDD.

D-105: A public developer docs site for the organization API, built with Docusaurus from OpenAPI

- **Status**: ✅ **Resolved by the leader** (2026-11-13): "in org api keys, I have no way of knowing which endpoints an organization has. An API docs site is required, like any other site", then "Docusaurus + OpenAPI".
- **Context**: an organization Manager creates API keys on `/o/api-keys`, but nothing tells the organization what a key may call. The surface is two read-only routes, `GET /api/telemetry/devices` and `GET /api/telemetry/stream` (monitoring api-design 04 and 05), authenticated by `X-Api-Key`. The backend can emit OpenAPI (`@nestjs/swagger`), but `/api/docs` is off in production and no controller carries an OpenAPI annotation.
- **Decision**:
  1. A standalone Docusaurus 3 site in `treklink-web/developer-docs/`, served at `/developers/` on the AWS staging (D-104), with an OpenAPI plugin generating the reference.
  2. The reference comes from an OpenAPI file that holds only the organization API, exported from the annotated controller and kept current by a CI check. Internal endpoints are never published.

3. Hand-written pages cover authentication, the response envelope and errors, rate limits and reading the stream.
4. The API keys page links to the site.

- **Rejected**: LDINF (no endpoint page type, no OpenAPI input, and its proprietary licence would ship with a public site; the LDINF session's own advice); a single-file OpenAPI renderer (the leader chose the full site); turning on `/api/docs` in production (it would publish every internal route).
- **Consequences**: no spec file changes (D-103); the monitoring api-design 04 and 05 stay the contract and the OpenAPI annotations follow them. The AWS deploy gains a docs build step.
- **Owner**: KhoaDD.

D-106: TLS on the field hops: the AWS broker takes TLS only, docking turns it on, one hardware test per variant, no pinning yet

- **Status**: ✅ **Resolved by the leader** (2026-11-10, 00:20, quiz ruling (3)); recorded 2026-11-13 when the AWS host went live (D-104).
- **Context**: the design documents label the field hops "MQTT over TLS", but on 2026-11-09 no running stack used TLS. The firmware compiles TLS in, keeps it off by default and, when on, skips the certificate check (ground truth §4.3). The Field Station uses TLS when its broker URL starts with `mqtts://` and sets no option that turns off Node's default certificate check (`gateway/src/mqtt/mqtt-client.ts`). The AWS broker files publish only 8883 with a Let's Encrypt certificate, keep 1883 on the compose network and refuse anonymous logins (`deploy/aws/mosquitto/mosquitto.conf`).
- **Decision**:
  1. TLS on the field hops holds through the AWS go-live: nodes, the Field Station and phones reach the broker only on `mqtts://<host>:8883` . `FIELD_STATION_BROKER_URL` on AWS and Vercel is that URL (done 2026-11-13).
  2. The docking page's "Configure uplink" turns TLS on by default (treklink-web#486); it can be turned off only for a broker on the local network.
  3. One hardware TLS test each on v2, v3 and v4 before the field demo, recorded under `docs/test-runs/` : a docked unit connects to the AWS broker over TLS and its uplink reaches the live map. The mbedTLS handshake memory next to Bluetooth and Wi-Fi is the risk, highest on v3 (classic ESP32, no PSRAM).
  4. No certificate pinning now: the firmware keeps `setInsecure()` . Replacing it with `setCACert()` and the ISRG Root X1 certificate is the follow-up if the hardware tests leave room.
- **Rejected**: changing the firmware to check the certificate before the tests (memory risk unmeasured); leaving TLS claims true only on paper.
- **Consequences**: the TLS labels in the platform design and the reports are true once the docked units use TLS; the node hops keep the caveat that a node does not check the certificate. The hardware tests need the units, which only the leader holds (D-104). Phone-app TLS stays unverified (platform design).
- **Owner**: KhoaDD.

Risk register (carried from FA26SE159, kept live)

Risk	Likelihood	Impact	Mitigation	Status
GPL-3.0 Meshtastic packages in the web bundle (D-082 rule 3) oblige TrekLink to offer that bundle's source to its users	Medium	Medium	Keep the packages behind one adapter in `frontend/src/shared/lib`; fork into own code when an extension is blocked or before any commercial release	Open
Insufficient physical TrekLink devices	Medium	High	Simulate Gateway→Cloud load via MQTT scripts; simulation never substitutes for LoRa RF reliability claims. Since 2026-11-13 only the leader holds the devices: members rehearse device flows in simulation and the real run is his (D-104)	Open
Gateway sync latency exceeds 5s NFR	Medium	Medium	Tune MQTT QoS, reduce payload size, backpressure on queue flush	Open
RQ3 baseline not objectively measurable	High	Medium	Randomized simulation drills; independent observer triggers SOS, records timestamp; participants unaware of exact trigger time	Open
NestJS + MQTT + WebSocket integration underestimated	Medium	High	PoC gateway→backend integration in TP1 Week 2, not deferred to TP3	Open
Firmware message schema incompatible with new gateway	Low	High	Schema frozen & documented in TP1 before any gateway implementation	Open, tracked as TP1 exit gate
[Added 2026-10-18, D-048] The SEP490 syllabus sends the team to the second defence round if it completes less than 75% of the use case functions or screens submitted in Report 3 at the end of week 3, or fewer than 20 medium use cases (3 to 7 transactions). The SRS now lists 65 use cases, so 75% is 49. The week 3 draft committed on 2026-09-27 (`capstone` 4a7a135) lists 58 use cases under the pre-D-033 booking scope; which version the supervisor holds as the week 3 submission is unverified	High	Critical	Week 3 set mapped to today (D-051): the 44 `baseline` use cases deliver 51 of the 58 week 3 use cases; 44 of 58 is the floor. Task lists and the Coverage Matrix track the baseline flag	Open
[Added 2026-10-21, Project Tracking] Commit evidence from 2026-09-01: KhoaDD 203 commits; LongLP 6, HoangTK 3, LongNN 2, TanNB 0 across the five repositories. Review 2 part 5 and Defense 1.1	High	High	Every member commits their screen designs from 2026-10-21 and their story code from 2026-10-23 under their own GitHub account, sealed (D-054); Project Tracking is	Open

Risk	Likelihood	Impact	Mitigation	Status
verify each member against their own repository work; the study phase (D-052) explains part of the gap			regenerated before submission by `capstone/scripts/srs/build_tracking.py`	
[Added 2026-10-20, Review 2 guide] The course's Review 2 guide requires Iteration 1 code, tests and CI under the tag `review-2`, Project Tracking among the submissions, and the AI tools, models and stages declared in Report 4 (guide §3, §10). Software Package 1 is not built; D-050 dropped the Project Tracking workbook; D-049 removes AI attribution from commits. An undeclared or disguised AI marker would contradict guide §10, which also penalises concealment in the self-review	High	High	Code Iteration 1 from 2026-10-22; restore a Project Tracking deliverable; declare AI use in Report 4 §technology; the commit Checksum trailer (D-054) is documented in chapter 07 §3.6 and declared in Report 4	Open
[Added 2026-10-23, gateway-sync 1.2] The MQTT "golden" fixtures that drive the MF-02 replay are synthesized from `MeshPacketSerializer.cpp` and `TrekLinkSOSHelper.h`, not captured from real v2, v3 and v4 devices (treklink-web#55). A difference between the serializer source and what a flashed node actually publishes (a member name, the channel name in the topic, the telemetry variant) would pass every test and fail on hardware	Medium	High	Capture one publish of each fixture type from a real node on the local Mosquitto before Sprint 4 and replace the files, putting the captured node numbers on TL-0009 and TL-0010 of the demo seed in the same change; state at Review 2 that the Iteration 1 replay uses synthesized fixtures	Open
[Added 2026-10-24, treklink-web#61 review] The backend has no request throttling. The one-time-code race (D-063 rule 9) let 40 concurrent guesses through a limit of 5; the database fix closes that hole, but nothing limits request volume on `forgot`, `reset`, `set` or `login`, which OWASP's Forgot Password Cheat Sheet asks for	Medium	High	`platform` task for Sprint 4: global `@nestjs/throttler` with stricter limits on the `@Public` auth routes (D-063 rule 11); until then the per-account cooldown and the database-enforced attempt limit bound guessing per code	Open
[Added 2026-10-24, treklink-web#63 review] `PermissionCache` (`auth` 4.1) keeps permission rows until an in-process `policy.changed` event. Since D-062 several members run their own backend against the shared Neon `dev` database, and the staging plan of D-055 rule 4 may run more than one instance, so a permission change made through one backend leaves every other one on	Medium	Medium	Before Sprint 4 staging: a cache TTL as a parameter, or a version read from the database on each policy check, or a Postgres `LISTEN` / `NOTIFY` on `policy.changed`; until then, restart a local backend after changing role permissions on the shared database. **2026-11-02:** the time-to-live is chosen (D-095 amendment rule 5), built	Open

Risk	Likelihood	Impact	Mitigation	Status
stale rules until it restarts (AC-03 holds only on the instance that made the change)			in W10 with the per-organization grid	
Scope creep	High	Medium	Feature freeze after TP5 Week 10; anything else goes to post-capstone backlog	Open
~~ORM indecision stalls TP3 start~~	Medium	Medium	D-001 resolved (Prisma) ahead of the Week 4 target	**Mitigated**
[Added] Field connectivity may need phone-based bridging instead of a dedicated Gateway node (D-005)	Medium	High	Validate dedicated Gateway (Wi-Fi/cellular node, native Meshtastic MQTT module) in TP1 PoC before committing to it; mobile-app forking treated as out of scope given no macOS/Xcode access	**Mitigated**, D-005 resolved as a staged rollout (Stage A node-MQTT, Stage B basecamp bridge); app forking formally rejected
[Added] ~~NestJS is a skill only for Khoa~~, **corrected Session 6.** The enrolment framework codes show **LongLP and HoangTK are both** `BIT_SE_NJS_18D` **(Node.js)**; NestJS is a framework over Node and is treated as covered by that training. Backend capability is therefore **3 of 5**, not 1 of 5. Residual exposure is the two IC-track members (LongNN, TanNB) picking up backend stories solo	Low	Medium	Ramp LongNN and TanNB on `01-conventions/05-backend-conventions.md` module conventions during W2–W5, mentored by Khoa/LongLP. Lane assignment already routes core backend to the two NJS-track members. This is the substance of the Report 2 §2.3 Training Plan	**Downgraded** (Session 6)
[Added S3] SOS is announced by exactly one unacknowledged text packet. `TrekLinkSOSHelper::triggerSOS()` sends the `"SOS - …"` text once with `want_ack = false` (`TrekLinkSOSHelper.cpp:157–160`); `tickBeacon` then retransmits **position only**. If that single text frame is lost over RF, the episode is invisible to the backend, the beacons that follow look like routine position reports.	Medium	**Critical**	**Two layers, per D-008.** *Platform side (built now)*: cadence-anomaly detector, the beacon runs 5s for the first minute then 30s (`TrekLinkSOSHelper.cpp:181`), far denser than routine reporting, so ≥N positions in window W raises a *suspected* episode at lower confidence (REQ-EVT-06, `design.md` §2.4). *Firmware side (now available, preferred)*: retransmit the SOS discriminator with each beacon, and/or set `want_ack` , and/or introduce a real custom PortNum so SOS stops depending on a `printf` string. The platform mitigation is defence-in-depth and should be kept even after a firmware fix.	Open, **firmware fix candidate #1**

Risk	Likelihood	Impact	Mitigation	Status
[Added S3] Stage A (node MQTT, D-005) has no offline buffer, so charter §5's offline-recovery and priority-ordering NFRs and RQ1/RQ2 cannot be evaluated until Stage B lands	High	Medium	**Stage B is permanent scope** (D-005 closed, Session 6), it is the substance of supervisor-specified **MF-02** (D-016), so it cannot be traded away. Residual risk is now schedule, not scope: Stage B must land early enough for RQ1/RQ2 evaluation in W9–W12. Do not present Stage A as satisfying the offline NFR at any point. **Further reduced (Session 7, D-018)**: the buffer work is now split, and the *smaller* half, the on-device queue, is sequenced first and needs no basecamp hardware, so a usable offline buffer exists well before the basecamp gateway (now Stage C) is built.	Open, **schedule risk only**, scope question closed, exposure reduced by D-018
~~**[Added S3]** `treklink_v1_0` compiles MQTT out, so v1 units cannot act as the Stage A uplink node~~	Medium	High	v1 is **out of the demo set** (team lead, Session 3), Stage A targets v2/v3/v4, all of which leave MQTT compiled in and carry Wi-Fi silicon. Were v1 ever needed, removing `-D MESHTASTIC_EXCLUDE_MQTT=1` is a one-line build-flag change now that D-008 permits it.	**Closed**
[Added S3] Stage A's JSON MQTT path omits `MeshPacket.priority`, making the SOS position packet indistinguishable from a routine one (D-007)	High	Medium	Backend episode correlation with a backward grace window (`design.md` §2.4). Two upgrades now available: switch to the `/2/e/` protobuf topic to recover `priority`, or emit an explicit SOS marker firmware-side (D-008).	Open, accepted for Stage A
~~**[Added S3]** `04-architecture-conventions.md` §3 still publishes the old `deviceId:sessionId:sequenceNumber` formula~~	High	Medium	§3 rewritten to the D-006 split key, with the D-008 firmware-sequence option noted as a layered upgrade.	**Closed** (Session 3)
[Added S3] Sessions 1–3 reasoned under a false "firmware is frozen" premise (D-008); several conclusions were shaped by a constraint that does not exist	High	Medium	D-008 logs the correction and lists every decision it reopens. Re-derive the affected conclusions next session before they harden into implementation.	Open, **re-derivation pending**
~~**[Added S3]** Firmware changes may earn no graded credit (D-008 question 3)~~	Medium	Medium	Supervisor confirmed 2026-09-13 that **firmware commits do earn credit**, and that firmware enhancement is in scope rather	**Closed** (Session 6)

Risk	Likelihood	Impact	Mitigation	Status
			than the excluded "redesign". D-008 closed. Firmware work is planned, assigned and evidenced on the same footing as platform work.	
[Added S4] SOS beacon retransmits (all but the very first position packet of an episode) are sent at `BACKGROUND` mesh priority, not `MAX`, `PositionModule::sendOurPosition()` sets priority by device role, and a handheld unit isn't `TRACKER` / `TAK_TRACKER`. Under mesh congestion, an ongoing emergency's beacon trail is currently the least-protected traffic class on the network after its opening packet.	Medium	High	Firmware-fix candidate under D-008: set `priority = MAX` (or `RELIABLE`) explicitly on the beacon send path rather than delegating to the generic broadcast method. Platform-side, the episode-correlation logic in `gateway-sync` already doesn't rely on `MeshPacket.priority` at all, so this doesn't block TP1/TP2, it's a firmware-side robustness gap, not a backend defect.	Open, **firmware fix candidate**
[Added S6] Map tiles rendering foreign toponyms over Hoàng Sa / Trường Sa are unlawful to publish in Vietnam. `LiveMapWidget.tsx:18-19` ships the default OpenStreetMap tile server; the team lead verified every OSM base layer labels the archipelagos with Chinese names. Nghị định 174/2026/NĐ-CP Art. 93(3)(a), in force 1 Jul 2026, fines 30–40M VND and permits forced removal of the application	High	**Critical**	Migrate to **Goong Maps over MapLibre GL** (D-012), provider and style held in configuration so the layer is swappable. Referer-allowlist and rate-limit the browser-visible key. **Acceptance test before Review 1**: load the map over ~16.5°N 112.0°E and ~9.7°N 114.0°E, confirm Vietnamese toponyms, file screenshots as evidence	**Accepted, educational scope** (2026-09-29, D-031): the map reverts to OpenStreetMap under the supervisor's acceptance, with a Vietnamese overlay over both archipelagos. No public deployment on OpenStreetMap tiles beyond the course. 2026-10-26 (D-071): the CyclOSM style draws the same OpenStreetMap data; TC-24 re-run with the overlay present, evidence filed. 2026-10-27 (D-072): four switchable basemaps, TC-24 re-run on each. 2026-10-30 (D-085): OpenTopoMap found printing PRC district names beside the overlay; the basemap labels over both archipelagos are now masked under it and Esri is the default. Previously mitigated 2026-09-25 by Goong Maps, evidence in `capstone/Documents/evidence/map-sovereignty/`
[Added S6] The registered English title contains "Smart Device Rental Management" but the system has no AI/ML component. The faculty fault handbook devotes a whole section to projects whose name promises "AI / smart / thông minh" and whose demo reduces to CRUD, and states plainly that rule-based systems must be called rule-based	High	Medium	Prepare and rehearse the honest answer: the "smart" is **device-level autonomy**, IMU fall detection, autonomous SOS broadcast, multi-hop mesh routing, priority-ordered store-and-forward, not machine learning. Never use "AI" for the platform in any graded document or slide. Every	Open, **answer to be drafted and rehearsed before W12 Mock Council**

Risk	Likelihood	Impact	Mitigation	Status
			member must be able to give this answer; it is a near-certain council question	
[Added S6] Business parameters hardcoded as literals. Ranked #2 cause of failure in the faculty fault handbook, and the first entry in its most-asked-questions list is "can this number be changed? demo it now." Five instances already exist in a codebase with no business logic written yet	High	High	D-015: every business parameter in configuration, registered in the Configuration Matrix with a demo path. Fix the five existing instances now, before the pattern is copied into the modules that carry the real parameters (fees, deposits, thresholds, episode windows)	Open, **task queued this session**
[Added S6] Individual-contribution evidence. A member with few commits and thin meeting presence fails individually even when the group passes; Git organisation and the Progress Log are the named evidence. Implementation currently stands at zero across all modules, so no member has contribution evidence yet	Medium	High	D-014: Progress Log updated before every Group Meeting, per-member and tied to a named deliverable; `08_INDIVIDUAL_CONTRIBUTION_LOG` maintained from W1. Lane assignment gives every member an owned mainflow so commits distribute by construction	Open
[Added S7] The node's own MQTT queue discards an SOS before it discards telemetry. `mqttQueue` is 16 entries, RAM-only, strict FIFO, and evicts the **oldest** entry on overflow (`MQTT.h:27` , `MQTT.cpp:821–823`). An SOS beacon trail plus routine telemetry fills it in ~80 s of outage, and the single `"SOS - …"` text frame that identifies the episode is the oldest entry, so it goes first. A reboot loses the queue entirely. The eviction is a serial-console `LOG_WARN` , invisible to the platform, so the loss is also unmeasurable.	High	**Critical**	**D-018 Stage B**, an on-device priority-ordered, flash-backed, shed-aware queue, built additively per D-019 and following the `MessageStore` precedent (`04-firmware-ground-truth.md` §4.1). Publish per-tier drop counters so the loss becomes observable and RQ1 gets a device-side denominator.	Open, **this is the term's primary firmware deliverable**
[Added S7] v3 has no PSRAM, and a flash-sized queue bound must not be derived from PSRAM. `treklink-v3-tbeam` is ESP32 LX6 with ~4 MB flash shared with two OTA app slots; v2 (S3 N8R8) and v4 (Supreme S3) both carry 8 MB PSRAM. The existing `StoreForwardModule` already branches `ps_calloc` / `calloc` on PSRAM presence (`StoreForwardModule.cpp:80–85`), so a queue sized the same way would silently collapse to near-zero capacity on v3 while tests pass on v2.	Medium	High	Size the durable tier off **remaining LittleFS space**, per variant, with the bound as a `build_flags` override exactly as `MESSAGE_HISTORY_LIMIT` already is (`MessageStore.h:22–24`). Capacity is a Configuration Matrix entry per D-015. Test the bound on v3 hardware specifically, not only on v2.	Open, **v3 is in the demo set** (D-018)
[Added 2026-09-25] Correction to the S7 row "v3 has no PSRAM".	Medium	High	The S7 mitigation stands unchanged: size the durable	Open

Risk	Likelihood	Impact	Mitigation	Status
The build contradicts it: `treklink-v3-tbeam` inherits `-DBOARD_HAS_PSRAM -mfix-esp32-psram-cache-issue` from `env:tbeam` (`variants/esp32/tbeam/platformio.ini:19-20`), while `treklink-v2` enables no PSRAM (`treklink_v2_0/platformio.ini:19-24` , board `esp32-s3-devkitc-1` declares none). (unverified) physical PSRAM population on the v2 and v3 units. LittleFS is 1 MiB on v3 and 1.5 MiB on v2/v4 (`04-firmware-ground-truth.md` §5).			tier off remaining LittleFS space, never PSRAM. The per-variant PSRAM column in `onboard-queue/design.md` §4 is corrected in the firmware repo.	
[Added 2026-09-25] Correction to the S7 row "The node's own MQTT queue discards an SOS". Two facts in it were incomplete. (1) In direct Wi-Fi mode stock firmware drains **one** queued entry per successful reconnect and nothing while the link stays up (`MQTT.cpp:604-636` , `:699-709`), so the baseline is worse than drop-oldest alone. (2) The queue also holds **peer** packets the node hears (`Router.cpp:767-769`), so it fills faster than the "~80 s" estimate, which was never measured.	High	**Critical**	Same mitigation, D-018 Stage B. `onboard-queue` must add a drain on the connected branch of `MQTT::runOnce()` (`MQTT.cpp:624-632`), a third stock call site the design did not list.	Open
[Added 2026-09-25] A fall auto-SOS never beacons. `FallDetectionModule::triggerAutoSOS()` sends one `BACKGROUND` position and one text frame (`FallDetectionModule.cpp:144-145`) and never calls `tickBeacon()` , which only the button and gesture modules call (`TrekLinkButtonModule.cpp:312` , `TrekLinkSOSGesture.cpp:116`). A fall episode is two packets and then silence, so the cadence-anomaly detector (REQ-EVT-06) cannot fire for it, and losing the single text frame makes a fall invisible.	Medium	**Critical**	Firmware fix under D-008: have the fall path enter the same beacon loop as a button SOS and send its opening position at `MAX` . Sequence with `onboard-queue` Phase 9 so each change stays separately measurable.	Open, **firmware fix candidate**
[Added 2026-09-25] An SOS raised before the first GPS fix produces no beacons. `PositionModule::sendOurPosition()` returns without sending when there is no fixed position and no local position since boot (`PositionModule.cpp:352-355`). Only the trigger-time packets leave the node.	Medium	High	Firmware fix under D-008: the beacon path builds its own position packet (as `sendPositionPacket()` already does) instead of delegating to `sendOurPosition()` . The same change can carry `priority = MAX` (REQ-OPT-02).	Open, **firmware fix candidate**

Risk	Likelihood	Impact	Mitigation	Status
[Added 2026-09-25] The on-device queue-health report cannot be read on the JSON topic. `PRIVATE_APP` (256) has no case in `MeshPacketSerializer`, so it falls to `default` (`MeshPacketSerializer.cpp:403-404`) and the JSON message has no `payload` . `gateway-sync` Stage A ingests only `<root>/2/json/...` (REQ-EVT-01), so its REQ-EVT-12/13 are unreachable as specified.	High	Medium	Decide the transport before `onboard-queue` Phase 6: an additive `PRIVATE_APP` case in the serializer, or a `/2/e/` subscription for port 256 in the backend. Define the payload schema in both specs.	Open, **question raised by the firmware session**
[Added S7] The default LoRa channel PSK is Meshtastic's published key, so RF traffic is encrypted but not confidential, any stock client in radio range decrypts SOS positions (`Channels.cpp:128–134` , `:238`).	High	High	**D-021**, provision a custom per-fleet PSK during device provisioning in MF-01; treat it as a recovery-critical escrowed secret. Distinct from `mqtt.encryption_enabled` , which stays `false` per D-007 with the broker hop secured by TLS + per-gateway API key.	Open, **provisioning step not yet written into `specs/devices/`**
[Added S7] Stage C's browser form (D-020) relies on **Web Serial / Web Bluetooth, which are Chromium-only**, and on iOS no browser can reach the node at all, so an iPhone guide is served only by the stock Meshtastic app path. A backgrounded or closed tab also stalls forwarding, though IndexedDB means nothing is lost.	Medium	Medium	Document the supported-host matrix before Stage C kick-off; surface forwarding state in the UI; retain the native-desktop fallback (D-020 Option 2) for unsupported venues. State the tab dependency honestly at the council rather than presenting Stage C as an always-on service.	Open, **Stage C deferred; decision recorded so Stage B does not foreclose it**
[Added S4] No backlog user story exists for the cadence-inferred `SUSPECTED` SOS episode path (`gateway-sync/design.md` §1.3/ §2.4, REQ-EVT-06), the primary mitigation for the Critical single-unacknowledged-text-frame risk above has no corresponding Staff-facing workflow story yet	Medium	Medium	US-088 added (`03-backlog/02-user-stories.md`), assigned Khoa, Staff sees a Suspected episode visually distinct from Confirmed and can dismiss it with a lighter action than the full Resolved→Closed flow.	**Mitigated** (Session 4)
[Added 2026-09-25, web session] `Device.nodeNum Int?` overflows above 2147483647, and node numbers are unsigned 32-bit values from the MAC. Ingestion would fail for about half of all units.	High	High	Type `BigInt` (04-architecture-conventions §3, platform design §3.3); test with `4294967295` .	Mitigated in spec
[Added 2026-09-25, web session] `gateway-sync` queried the `Incident` table directly (a module-isolation breach) and ignored `RESOLVED` incidents in the episode lookup, which would create a second	High	Medium	Lookup moved behind `IncidentsService.correlateSos` ; a `RESOLVED` incident in the window reopens.	Mitigated in spec

Risk	Likelihood	Impact	Mitigation	Status
Incident where E03-6 requires a reopen.				
[Added 2026-09-25, web session] Stock firmware drains a queued backlog one entry per reconnect, so an arrival-time episode window could split one SOS into several Incidents.	Medium	High	Windows and ordering use the event timestamp when valid (`gateway-sync` REQ-UBI-02).	Mitigated in spec
[Added 2026-09-25, web session] A fall auto-SOS, or an SOS before the first GPS fix, sends no beacons, so losing its single text frame loses the episode and cadence detection cannot fire.	Medium	**Critical**	Firmware `onboard-queue` Phase 9 adds beacons.	Open
[Added 2026-09-25] New backend dependencies: `@nestjs/schedule` , `@nestjs/event-emitter` , `@nestjs/throttler` , `@casl/prisma` , `pdfkit` .	Medium	Low	Approved by the leader for Phase B (C-003 item 4); frontend test dependencies are approved when the frontend work starts. **2026-10-24**: `nodemailer` approved for the `smtp` transport of `auth` 1.3 (D-063 rule 3).	Resolved
[Added 2026-09-25, leader field report] Fall detection does not work on v1 (MPU6050) or v2 (ICM-20948), and some v2 units stay stuck in SOS. Root cause not established: IMU driver or HAL wiring, value scaling, thresholds, or a race between the fall, button and gesture SOS owners.	High	**Critical**	Reproduce on hardware with serial logs of raw IMU readings and SOS state transitions before designing a fix (`04-firmware-ground-truth.md` §2).	Open. **2026-10-29, logged v2 run at `ea37a06` **: v2 root cause established, see the 2026-10-29 rows below and ground truth §2; stuck-in-SOS not reproduced
[Added 2026-09-25, code-verified] On v3 and v4 the 3-second SOS hold shares `BUTTON_PIN` with the stock user button, which fires SELECT at 500 ms and SHUTDOWN on a longer hold (`InputBroker.cpp:290-306`). Button SOS on T-Beam boards is unreliable and can shut the unit down.	High	**Critical**	Move SOS to a dedicated input or disable the stock long press on TrekLink variants; decide before the demo.	Open

Risk	Likelihood	Impact	Mitigation	Status
[Added 2026-10-02, code-verified plus regulation] Transmit settings likely exceed Vietnamese licence-exempt limits. Every variant defaults to `MY_433` (433.0 to 435.0 MHz, 20 dBm conducted, `RadioInterface.cpp:158`, `:847-848`); Circular 08/2021/TT-BTTTT Article 5 licenses 433 MHz LPWAN above 25 mW ERP, so the exempt ceiling is 25 mW ERP in 433.05 to 434.79 MHz (inferred, appendix not read). With the 6 dBi antenna the radiated power is well above that. A reviewer asking "is this legal?" has no clean answer yet.	High	High	Confirm the appendix limit; add a TrekLink Vietnam region or a per-variant power cap so conducted power plus antenna gain stays within 25 mW ERP inside 433.05 to 434.79 MHz; re-measure range at the compliant power, because it will shorten. Firmware ground truth §5.1	Open
[Added 2026-10-02, leader field test] No link across a ridge without a relay on the crest, and range collapses in rain (below 100 m) and inside thick concrete. Typical trekking range is 1 to 3 km.	High	High	Accepted physical limit. Disclose to renters and users: the device is not a sole means of communication; move to high ground or place a repeater. Plan a repeater node as optional equipment. Second field test pending. Firmware ground truth §5.1	Accepted
[Added 2026-10-14, D-045] A lost renter device keeps the organization's channel key and can read that organization's mesh until the key is rotated, which happens only at the next counter visit.	Medium	High	Loss case flags the key as exposed and notifies the Manager; rotation and re-provisioning at the next counter visit; the limit is stated in the master contract and the documents.	Open, **accepted limit**
[Added 2026-10-14, D-046] The Field Station executable runs on the customer's laptop, so its code is in the customer's hands. (unverified) How easily the code can be extracted depends on the packager chosen in `gateway-sync` task 5.1.	Medium	Medium	NDA and software licence required at verification; compliance case for an IP violation with suspension and revocation; secrets never ship in the executable (credentials are per station, D-037).	Open
[Added 2026-10-14, D-047] The weekly scan takes units due for service out of `AVAILABLE` up to a week plus the lead days before their due date, so a contract approval can be refused for want of units that are not yet due.	Medium	Low	`devices.maintenanceLeadDays` is configurable; the weekly list lets Staff complete services early; approval reports the shortfall as today (`INSUFFICIENT_DEVICES`).	Open
[Added 2026-10-29, code-verified] The v3 and v4 specs promise "position broadcast + alarms" (REQ-V3-SOS-01.1, REQ-V4-SOS-01), but `TrekLinkSOSHelper::activateAlarms()` drives only the buzzer and vibrator pins a variant defines	High	High	Decide whether the requirement changes (screen and LED only) or the firmware adds feedback (screen flash, external buzzer on a free GPIO); record the ruling in the v3 and v4 specs.	Open

Risk	Likelihood	Impact	Mitigation	Status
(`TrekLinkSOSHelper.cpp:66-78`), and the T-Beam variants define neither. A v3 holder gets an LED blink and the screen banner (`TrekLinkSOSGesture.cpp:118-120`); a v4 holder gets only the banner, so a holder may not know the SOS fired.				
[Added 2026-10-29, leader field report] v2 SOS trigger works on hardware (leader, 2026-10-29), but cancel and the stuck-in-SOS case are unverified: a cancel transmits nothing (`TrekLinkSOSHelper.cpp:49-53`), so neither can be seen from the platform, and the flashed commit was not recorded. Does not close the 2026-09-25 field-report row above.	Medium	High	Next v2 run captures the serial log and the flashed commit, and exercises cancel and a repeated trigger; record it in `treklink-firmware/docs/test-runs/` .	Open. **2026-10-29, logged run**: trigger and cancel exercised with a serial log at `ea37a06` ; cancel transmits nothing, confirmed; flashed commit now recorded (`treklink-firmware/docs/test-runs/2026-10-29-v2-hardware-run.md`)
[Added 2026-10-29, hardware-verified on v2] Any stock beep silences the v1/v2 SOS buzzer. Arduino-ESP32 `tone()` uses LEDC channel 0 and detaches the pin after each note (`cores/esp32/Tone.cpp:33-47`); `BuzzerManager` attaches the buzzer to channel 0 once (`BuzzerManager.h:35-45`). One UP press before an SOS left the buzzer silent while `Activating alarms` was logged. Stock beeps on every button press and ringtones on incoming messages	High	**Critical**	Fixing session: give `BuzzerManager` its own LEDC channel and re-attach before each write, or route stock tones through it; hardware run with a beep before SOS as the acceptance test	Open
[Added 2026-10-29, hardware-verified on v2] Fall detection cannot reach the pre-alarm on any variant that runs it. The 10 s stillness check starts at impact and cancels on the first non-still sample (`FallDetectionModule.cpp:337-356`); a 1.5 m drop was detected and dismissed 100 ms later. On a cold-booted v2 the shared IMU also sleeps whenever the screen is off (`motion/ICM20948Sensor.cpp:50-56`), and the stored thresholds sit at the clamp floors (0.30 g, 0.050 rad/s)	High	**Critical**	Fixing session: a settling window after impact, a stillness test that tolerates small motion, an IMU the stock motion thread cannot sleep, a calibration in g; drop tests with the screen on and off as acceptance	Open
[Added 2026-10-29, code-verified] v4 fall detection probes its QMI8658 over I2C at 0x6B (`QMI8658FallSensor.cpp:25-33`); LilyGo documents the T-Beam Supreme IMU on SPI (CS GPIO 34). v4 fall detection is therefore expected	High	High	Fixing session: SPI adapter for v4, then a v4 hardware run; local feedback for the v4 pre-alarm	Open, not hardware-verified

Risk	Likelihood	Impact	Mitigation	Status
never to start, and its pre-alarm has no buzzer, vibrator or LED				
[Added 2026-10-29, code-verified] Holding MENU for 300 ms shuts a v1 or v2 down at once with no confirmation (`TrekLinkButtonInput.cpp:31` , `UpDownInterruptBase.h:7` , `SystemCommandsModule.cpp:115-116`). An accidental hold powers off the SOS device	High	High	Fixing session: no shutdown on a short hold; require a long hold with feedback, or remove the mapping	Open
[Added 2026-10-29, hardware-verified on v2] The v2 compass is unusable after every boot: the uncalibrated heading swings only about 45 degrees over a full turn, calibration is RAM-only, and the calibration screen cannot be left without a reboot (`graphics/Screen.cpp:862` , `:876-878`). After a warm reset the IMU is misread as an MPU6050 and the compass driver does not start at all	Medium	Medium	Fixing session: persist calibration in NVS, restore the frames after calibration, read `WHO_AM_I` from bank 0 explicitly; an upstream PR for the screen bug	Open
[Added 2026-10-29, measured] The v2 image has no serial console or client API on USB (`esp32-s3-devkitc-1` leaves `Serial` on UART0, `HardwareSerial.h:326-333`), so a v2 cannot be debugged or provisioned over USB as built	High	Medium	Add `-DARDUINO_USB_CDC_ON_BOOT=1` to the v2 env in the fixing session; test images use it through `PLATFORMIO_BUILD_FLAGS` until then	Open
[Added 2026-10-29, measured] Firmware builds take about 23 minutes on the leader's machine: the git SHA and the day are compiler flags on every file (`bin/platformio-custom.py:238-256`), the repository and `~/.platformio` sit on an NTFS partition read through FUSE, and `pio run -t nobuild -t upload` fails (`bin/platformio-custom.py:200`). Slow iteration discourages a hardware run per fix	High	Medium	Firmware tooling: flash-only script over esptool, version flags limited to the files that use them, build tree and toolchain on a native filesystem	Open
[Added 2026-11-01, CI-observed] The TK-143 alert dispatcher's after-commit wake may miss an alert: one CI run of `backend/test/incident-alert-socket.db-spec.ts:295` measured 2079 ms from commit to a connected client's alert (treklink-web#225 attempt 1, run 41222307522), about one 2 s cron period, so the cron backstop and not	Low	High	The test keeps its 2000 ms bound (NFR-PERF-04) and now prints the WEBSOCKET row's attempts and `sentAt` on failure, so the next occurrence shows which path delivered; then fix the wake	Open

Risk	Likelihood	Impact	Mitigation	Status
the wake delivered it; 10 local runs measured 5.8 to 8.3 ms				
[Added 2026-11-01, library-verified] v4 fall detection could never confirm a fall: SensorLib 0.3.4 `getAccelerometer` returns g (`SensorQMI8658.hpp:515, 910-923`), but `QMI8658FallSensor.cpp:68-70` divided it by 1000 as mg, so a resting unit read 0.001 g and stayed in FREEFALL_DETECTED. Separate from the I2C-versus-SPI probe risk above	High	High	treklink-firmware#25 converts g to m/s² with a native test (local build and 194 native tests pass); the v4 hardware gate is open	Mitigating
[Added 2026-11-10, treklink-web#455, code-verified on a local probe] An SOS from a device's current custodian is appended to the earlier custodian's open incident. After a custody change, a late in-grace SOS from organization A's station opens an A-routed incident (D-040); while it stays open, a new SOS from the device, now in organization B's custody, falls through to `append` in `incident-ingress.ts` `onSos` without comparing attribution, so B's emergency is linked to A's incident and B's responders are not alerted. It needs a late A flush and a B SOS within the same episode window (INFERRED: rare in the demo).	Low	**Critical**	Not fixed now: the fix changes D-040 and incidents design §4, and the specs are frozen (D-103); the leader left the choice open on 2026-11-10. Recommended fix after the freeze: when an SOS's attribution differs from the open episode's, close A's episode with its evidence kept and open a B-routed incident, which keeps one open incident per device. Until then the demo does not hand a device to a second organization while an earlier SOS incident is open. Leader ruling 2026-11-13: kept as a risk during the freeze; the demo mitigation stands (the requirements conflict: REQ-EVT-01 against REQ-EVT-03 and D-040 rule 2).	Open

Contributing to TrekLink

The 2-minute version. Full detail lives in `01-conventions/`, which is also the source of the Developer Handbook PDF.

1. Orient yourself

- What are we building: `00-project-context/01-project-charter.md` (`01-project-charter.md`)
- What week/sprint is it: `00-project-context/02-roadmap-and-milestones.md` (`02-roadmap-and-milestones.md`)
- Anything blocking you: `00-project-context/03-decisions-and-risk-register.md` (`03-decisions-and-risk-register.md`)

2. Where work lives

Jira is the single tracker (TK project). **GitHub Issues** hold daily reports and standalone bugs only. The **backlog** (`03-backlog/`) is read-only to members, it holds the EARS criteria you implement against. See `01-conventions/10-jira-tracking-and-workflow.md` (`10-jira-tracking-and-workflow.md`).

3. Before writing code

Every module goes through `specs/{module}/requirements.md` → `design.md` → `tasks.md` **before** implementation, see `01-conventions/02-spec-driven-development-workflow.md` (`02-spec-driven-development-workflow.md`). Blank templates in `02-templates/`.

4. Branch, commit, PR

```
git fetch origin && git checkout dev && git pull origin dev
git checkout -b feat/TK-45-device-registration        # Jira key in the branch name

# ... work, per 01-conventions/03-operational-workflows.md ...
git commit -m "feat(TK-45): add device FSM transition guard"

npm test                                              # must be green BEFORE the PR
git fetch origin && git rebase origin/dev
git push -u origin feat/TK-45-device-registration --force-with-lease
gh pr create --base dev --title "feat(TK-45): device registration" --label "module:devices"
```

Then **move the Jira card to `IN REVIEW`** and **ping your reviewer in Zalo**. Full convention: `01-conventions/07-github-workflow-git-conventions.md` (`07-github-workflow-git-conventions.md`).

No direct pushes to any branch, ever, including the leader's.

5. Merging

Rebase & merge (single commit) or Squash & merge (multiple). **Merge commits are prohibited.** Delete the source branch, except `dev` → `main`. **Announce every merge to `dev` in Zalo** so everyone pulls and rebases.

6. Backend response contract (non-negotiable)

Every endpoint returns `{ result, isSuccess, statusCode, message }`, see `01-conventions/05-backend-conventions.md` (`05-backend-conventions.md`) §3.

7. Language

English only, code, commits, PRs, specs, docs, Jira cards. You may prompt your AI agent in Vietnamese; what it writes to the repo is English regardless.

8. Using an AI coding agent

Read `01-conventions/11-ai-first-doctrine-and-toolchain.md` (`11-ai-first-doctrine-and-toolchain.md`) once, fully. Install `prompt-orchestrator` and the TrekLink skills, open the `capstone/` parent folder (not a single repo), and run `/treklink-session`. The agent reads the conventions itself, you should never have to tell it to.

9. Definition of Done, every PR

- [ ] EARS criteria in `requirements.md` satisfied
- [ ] **Unit tests written and passing**, before the PR is opened
- [ ] Module boundaries respected (no cross-module repository access)
- [ ] Lint/typecheck clean
- [ ] `api-design/*.md` updated in the same PR if any endpoint changed
- [ ] Rebased on `dev` ; Jira card linked and moved to `IN REVIEW`
- [ ] `Model used:` declared in the PR